



Квест по кибербезопасности

Модуль 1 - Базовый уровень (Основы)

Урок 1 - Введение в мир киберугроз

Шаг 01:

Миссия 1

Вы — младший разработчик Иван. На работе коллега прислал файл с паролями в общем чате. Что вы сделаете в первую очередь?

Подсказка: Действие должно предотвратить дальнейшую утечку.

Ответ:

- **Сообщу об инциденте руководителю и удалю файл из чата**
- Сразу отправлю файл всем сотрудникам
- Сделаю скриншот и оставлю себе
- **Ничего не буду делать** — может это просто тест

Шаг 02:

Миссия 2

Программистка Лиза при скачивании библиотеки заметила странный рор-уп. Что безопаснее сделать?

Подсказка: Осторожность – лучшая защита от вредоносного ПО.

Ответ:

- **Отменю установку и проверю библиотеку в надёжных источниках**
- Нажму ОК и посмотрю, что будет

- Подожду 10 минут и продолжу
- Игнорирую рор-уп и работаю дальше

Шаг 03:

Миссия 3

Коллега предлагает подключить внешний USB-накопитель для переноса кода. Что вы решите?

Подсказка: Подозрительный носитель — потенциальный вектор заражения.

Ответ:

- **Проверю носитель антивирусом и на песочнице прежде, чем открыть**
- Сразу скопирую и запущу файлы
- Откажусь и скажу, что слишком занят
- **Пользуюсь без проверки** — коллега надежный

Шаг 04:

Миссия 4

Вы получили письмо якобы от начальника с просьбой перевести деньги. Что делать?

Подсказка: Иногда отправитель — фальшивка.

Ответ:

- **Позвоню начальнику и уточню лично**
- Сразу переведу на счет, указанный в письме
- Ответю, что не могу выполнить
- Перешлю письмо коллегам без проверки

Шаг 05:

Миссия 5

Сопоставьте тип угрозы с её описанием.

Типы угроз:

Ответ:

- Фишинг
- Вредоносное ПО
- Уязвимость нулевого дня
- Атака «человек посередине»

Описание:

1. Сообщение выглядит как от надёжного отправителя, но содержит ложные ссылки.
2. Программа, выполняющая нежелательные действия на устройстве.
3. Бреша, которые ещё неизвестны публике и не закрыты.
4. Перехват и изменение трафика между кем-то и сервером.

Подсказка: Подумайте о сюжете: как злоумышленник маскируется под знакомое лицо?

- **Фишинг** — Сообщение выглядит как от надёжного отправителя, но содержит ложные ссылки.
- **Вредоносное ПО** — Программа, выполняющая нежелательные действия на устройстве.
- **Уязвимость нулевого дня** — Бреша, которые ещё неизвестны публике и не закрыты.
- **Атака «человек посередине»** — Перехват и изменение трафика между кем-то и сервером.

🔗 Шаг 06:

Миссия 6

Сопоставьте категории уязвимостей и примеры.

Категория:

Ответ:

- SQL-инъекция
- XSS
- CSRF
- Directory Traversal

Пример:

1. Вставка « ../etc/passwd » в путь файла.
2. Отправка POST-запроса от имени пользователя без токена.
3. Вставка ... в поле комментария.
4. Вставка SQL-кода в поле поиска, чтобы вытянуть данные.

Подсказка: Вспомните OWASP и типичные атакующие payload'ы.

- **SQL-инъекция** — Вставка SQL-кода в поле поиска, чтобы вытянуть данные.
- **XSS** — Вставка ... в поле комментария.
- **CSRF** — Отправка POST-запроса от имени пользователя без токена.
- **Directory Traversal** — Вставка « ../etc/passwd » в путь файла.

🔗 Шаг 07:

Миссия 7

Сопоставьте слоты и методы защиты.

Угроза / ситуация:

Ответ:

- Пароль слабый
- Передача данных по HTTP
- Отсутствие патчей
- Открытые порты

Метод защиты:

1. Использование шифрования (TLS)
2. Закрывание и контроль портов
3. Сложные пароли + парольная фраза
4. Регулярные обновления системы

Подсказка: Подумайте, какая защита нужна на уровне соединения, пароля и систем.

- **Пароль слабый** — Сложные пароли + парольная фраза
- **Передача данных по HTTP** — Использование шифрования (TLS)
- **Отсутствие патчей** — Регулярные обновления системы
- **Открытые порты** — Закрывание и контроль портов

🔗 Шаг 08:

Миссия 8

Сопоставьте этап атаки и её цель.

Этап атаки:

Ответ:

- Разведка (reconnaissance)
- Эксплуатация (exploitation)
- Укрепление позиции (persistence)
- Эскалация привилегий (privilege escalation)

Цель этапа:

1. Получить права администратора
2. Выявить информацию о системе и слабые места
3. Установить постоянный доступ злоумышленнику
4. Активно использовать уязвимости для проникновения

Подсказка: Подумайте, как шаг за шагом атакующий захватывает систему.

- **Разведка (reconnaissance)** — Выявить информацию о системе и слабые места
- **Эксплуатация (exploitation)** — Активно использовать уязвимости для проникновения
- **Укрепление позиции (persistence)** — Установить постоянный доступ злоумышленнику
- **Эскалация привилегий (privilege escalation)** — Получить права администратора

Шаг 09:

Миссия 9

Расположите шаги обработки инцидента безопасности в правильном порядке:

1. Уведомление заинтересованных сторон и отчётность
2. Сбор доказательств и журналов
3. Определение и оценка инцидента
4. Восстановление и устранение причины

Подсказка: Сначала узнаём, что случилось, затем действуем, и в конце — делимся выводами.

Ответ:

- Определение и оценка инцидента
- Сбор доказательств и журналов
- Восстановление и устранение причины
- Уведомление заинтересованных сторон и отчётность

Шаг 10:

Миссия 10

Расположите этапы социальной инженерии от начала до конца:

1. Подготовка и исследование жертвы
2. Установление доверия и контакт
3. Использование доверия для выманивания данных
4. Завершение и исчезновение

Подсказка: Социальная инженерия — это про манипуляцию шаг за шагом.

Ответ:

- Подготовка и исследование жертвы
- Установление доверия и контакт

- Использование доверия для выманивания данных
- Завершение и исчезновение

Шаг 11:

Миссия 11

Расположите уровни защиты по возрастанию сложности внедрения:

1. Обновление ПО
2. Антивирусное сканирование
3. Сетевой межсетевой экран (firewall)
4. Сегментация сети и изоляция подсетей

Подсказка: Более сложные меры требуют больше усилий и планирования.

Ответ:

- Обновление ПО
- Антивирусное сканирование
- Сетевой межсетевой экран (firewall)
- Сегментация сети и изоляция подсетей

Шаг 12:

Миссия 12

Расположите стадии жизненного цикла уязвимости:

1. Обнаружение уязвимости
2. Публикация и раскрытие
3. Эксплуатация злоумышленником
4. Патч и обновление системы

Подсказка: Уязвимость сначала обнаруживают, затем раскрывают, и через время её могут использовать, пока не исправят.

Ответ:

- Обнаружение уязвимости
- Публикация и раскрытие
- Эксплуатация злоумышленником
- Патч и обновление системы

Шаг 13:

Миссия 13

Расположите уровни модели CIA (конфиденциальность, целостность, доступность) по степени вероятности атаки на рабочий SaaS-сервис:

1. Целостность
2. Доступность
3. Конфиденциальность

Подсказка: Подумайте, что чаще атакуют на SaaS: данные или отказ в работе?

Ответ:

- Целостность
- Доступность

- Конфиденциальность

Шаг 14:

Миссия 14

Расположите виды атак в порядке от наиболее непосредственной к самой удалённой по вектору:

1. SQL-инъекция
2. XSS
3. Фишинг
4. DoS-атака

Подсказка: Подумайте, какие атаки требуют непосредственного взаимодействия с приложением, а какие — дистанционно через сеть.

Ответ:

- SQL-инъекция
- XSS
- Фишинг
- DoS-атака

Шаг 15:

Миссия 15

Расположите действия разработчика при получении отчёта о неизвестной уязвимости от пользователя:

1. Подтвердить получение отчёта и поблагодарить
2. Воспроизвести и проверить наличие уязвимости. Оценить риск и назначить приоритет исправления
3. Выпустить патч и уведомить пользователя об исправлении

Подсказка: Взаимодействие с пользователем важно, но прежде нужно убедиться в проблеме, затем исправить её.

Ответ:

- Подтвердить получение отчёта и поблагодарить
- Воспроизвести и проверить наличие уязвимости
- Оценить риск и назначить приоритет исправления
- Выпустить патч и уведомить пользователя об исправлении

Урок 2 - Типы хакеров и кибератак

Шаг 01:

Миссия 1

Вы — стажёр в стартапе. На утро приходят новости: «опубликован список взломанных аккаунтов сотрудников». Что вы должны сделать?

Подсказка: Действие должно быть быстрым, чтобы минимизировать ущерб.

Ответ:

- Сразу сменить пароли и уведомить ИТ-службу
- Игнорировать, это не наша ответственность
- Поделиться списком с коллегами

- Удалить уведомление и далее работать как обычно

Шаг 02:

Миссия 2

Вы работаете разработчиком в команде. Узнаёте, что кто-то пробует проникнуть в систему через брутфорс паролей. Что вы сделаете в первую очередь?

Подсказка: Защита от автоматических атак — первоочередная мера.

Ответ:

- **Включу ограничение попыток входа и уведомлю команду безопасности**
- **Позволю попробовать** — может, это тест
- Отключу систему на время
- Сразу сброшу все пароли пользователей

Шаг 03:

Миссия 3

Анна, бэкэнд-разработчица, получает анонимное сообщение с угрозой «знаю твои пароли». Как ей реагировать?

Подсказка: Надежность системы важнее паники.

Ответ:

- **Сменить все ключи доступа и включить 2FA**
- Ответить на сообщение и угрожать в ответ
- **Игнорировать** — возможно, шутка
- Опубликовать сообщение в соцсети как доказательство хакерства

Шаг 04:

Миссия 4

Вы — инженер-оператор. В логах вы замечаете нестандартный трафик с удалённого IP, возможно ботнет. Что вы предпримете?

Подсказка: Вы должны ограничить вред, не паникуя.

Ответ:

- **Заблокировать IP и запустить анализ аномалий**
- Писать пользователю, что это ошибка
- **Не трогать лог** — возможно, ложный тревожный сигнал
- Отключить весь трафик из внешней сети

Шаг 05:

Миссия 5

Вы работаете в стартапе по безопасности. Клиент сообщает: «на сервере появился неизвестный файл с бэкдором». Что будет вашим первым шагом?

Подсказка: Сначала — диагностика, затем — действия.

Ответ:

- **Изолирую сервер и сниму дампы журналов**
- Удалю файл немедленно
- Позвоню клиенту и попрошу не трогать
- Сделаю бэкап и запущу файл на продакшене

🔮 Шаг 06:

Миссия 6

Сопоставьте тип хакера и его мотивацию.

Тип хакера:

Ответ:

- Black Hat
- White Hat
- Grey Hat
- Script Kiddie

Мотивация:

1. Намеренное хищение данных с корыстной целью
2. Поиск уязвимостей с разрешением, чтобы помочь
3. Нарушение ради эксперимента и внимания
4. Использование готовых скриптов без глубокого понимания

Подсказка: Подумайте, кто действует с разрешения, а кто — нет.

- **Black Hat** — Намеренное хищение данных с корыстной целью
- **White Hat** — Поиск уязвимостей с разрешением, чтобы помочь
- **Grey Hat** — Нарушение ради эксперимента и внимания
- **Script Kiddie** — Использование готовых скриптов без глубокого понимания

🔮 Шаг 07:

Миссия 7

Сопоставьте вид атаки с типичным источником.

Атака:

Ответ:

- DDoS
- Ransomware
- Brute-force
- Rootkit

Источник:

1. Сеть заражённых устройств, контролируемых ботом
2. Шифровальщик, требующий выкуп
3. Автоматическая подборка пароля
4. Скрытый компонент для привилегированного доступа

Подсказка: Представьте себе «инструмент» каждого типа атаки.

- **DDoS** — Сеть заражённых устройств, контролируемых ботом
- **Ransomware** — Шифровальщик, требующий выкуп
- **Brute-force** — Автоматическая подборка пароля
- **Rootkit** — Скрытый компонент для привилегированного доступа

🔮 Шаг 08:

Миссия 8

Сопоставьте уровни доступа и примеры атакующего поведения.

Уровень доступа:

Ответ:

- Пользователь (User)
- Администратор (Admin)
- Системный (Root / Kernel)
- Гость (Guest)

Пример:

1. Удалённое изменение системных файлов ядра
2. Изменение паролей других пользователей
3. Ограниченный просмотр публичной части сайта
4. Попытка получить доступ к системным настройкам без прав

Подсказка: Кто что может делать в системе?

- **Пользователь (User)** — Ограниченный просмотр публичной части сайта
- **Администратор (Admin)** — Изменение паролей других пользователей
- **Системный (Root / Kernel)** — Удалённое изменение системных файлов ядра
- **Гость (Guest)** — Попытка получить доступ к системным настройкам без прав

Шаг 09:

Миссия 9

Сопоставьте мотивацию атакующего и возможные последствия.

Мотивация:

Ответ:

- Финансовая выгода
- Хулиганство / внимание
- Государственная шпионаж
- Идеология / активизм

Возможное последствие:

1. Кража денег или данных карт
2. Сбор секретной информации
3. Взлом сайта и публикация контента

Подсказка: Вспомните мотивы, стоящие за реальными атаками.

- **Финансовая выгода** — Кража денег или данных карт
- **Хулиганство / внимание** — Отключение сайтов, шум в СМИ
- **Государственная шпионаж** — Сбор секретной информации
- **Идеология / активизм** — Взлом сайта и публикация контента

Шаг 10:

Миссия 10

Расположите типы хакеров по «этичности» от наиболее законопослушного к наиболее криминальному:

1. Black Hat
2. Grey Hat

3. White Hat
4. Script Kiddie

Подсказка: Белый шляпа — этичный, чёрный — злонамеренный.

Ответ:

- White Hat
- Grey Hat
- Script Kiddie
- Black Hat

Шаг 11:

Миссия 11

Расположите стадии атаки от разведки до завершения:

1. Разведка
2. Нахождение уязвимости
3. Эксплуатация
4. Удаление следов / выход

Подсказка: Каждый шаг — логическое продолжение предыдущего.

Ответ:

- Разведка
- Нахождение уязвимости
- Эксплуатация
- Удаление следов / выход

Шаг 12:

Миссия 12

Расположите виды атак по удалённости от цели от ближней к наиболее дистанционной:

1. Rootkit / проникновение в ядро системы
2. SQL-инъекция
3. Cross-site scripting (XSS)
4. Фишинг по электронной почте

Подсказка: Подумайте, сколько «промежуточных шагов» между атакующим и целью.

Ответ:

- Rootkit / проникновение в ядро системы
- SQL-инъекция
- Cross-site scripting (XSS)
- Фишинг по электронной почте

Шаг 13:

Миссия 13

Расположите по возрастанию технической сложности исполнения преступления:

1. Script Kiddie с ботнетом
2. Фишинг с подделкой письма
3. Выявление 0-day и применение

4. Целенаправленная АРТ-атака

Подсказка: Чем выше мотивация и ресурсы, тем сложнее атака.

Ответ:

- Script Kiddie с ботнетом
- Фишинг с подделкой письма
- Выявление 0-day и применение
- Целенаправленная АРТ-атака

Шаг 14:

Миссия 14

Расположите источники атак по вероятности от частых к редким:

1. Фишинг от имени знакомых сервисов
2. Brute-force на слабые пароли
3. АРТ с поддержкой государств
4. 0-day и неизвестные эксплоиты

Подсказка: Часто — простые атаки, редко — продвинутые.

Ответ:

- Фишинг от имени знакомых сервисов
- Brute-force на слабые пароли
- АРТ с поддержкой государств
- 0-day и неизвестные эксплоиты

Шаг 15:

Миссия 15

Расположите типы атак по времени между отправкой и воздействием (от мгновенных к отложенным):

1. Brute-force
2. Фишинг с ссылкой
3. Шифровальщик (ransomware) с таймером
4. АРТ с долгим проникновением

Подсказка: Некоторые атаки сразу вызывают эффект, другие скрываются и ждут.

Ответ:

- Brute-force
- Фишинг с ссылкой
- Шифровальщик (ransomware) с таймером
- АРТ с довленным проникновением

Шаг 16:

Миссия 16

Расположите уровни угроз по возрастанию масштаба атаки (от локальной к глобальной):

1. Атака на отдельный сервер компании
2. Целенаправленное заражение сети внутри страны
3. Распространение ботнета на тысячи машин

4. Глобальная АРТ-кампания через государства

Подсказка: Более крупные атаки охватывают больше целей.

Ответ:

- Атака на отдельный сервер компании
- Целенаправленное заражение сети внутри страны
- Распространение ботнета на тысячи машин
- Глобальная АРТ-кампания через государства

Урок 3 - Как устроена информационная безопасность

Шаг 01:

Миссия 1

Утро понедельника. В Telegram-чате команды появляется сообщение: «Кажется, нашу Wi-Fi сеть подменили». Что должен сделать инженер первым делом?

Подсказка: Безопасное соединение — приоритет перед работой.

Ответ:

- **Отключить устройство от сети и сообщить в IT-отдел**
- Сменить Wi-Fi и продолжить работу
- Попросить у коллег пароль от другой точки
- **Игнорировать** — может, это баг

Шаг 02:

Миссия 2

Алина — разработчица. Она скачала файл с GitHub, и антивирус выдал предупреждение. Что ей стоит сделать в первую очередь?

Подсказка: Не каждый open source — безопасен. Проверка важнее скорости.

Ответ:

- **Не запускать файл и проанализировать содержимое**
- Отключить антивирус и попробовать снова
- Спросить у коллеги, что он думает
- Перезагрузить ПК и забыть об этом

Шаг 03:

Миссия 3

Фронтенд-разработчик Пётр увидел в коде PR'a API-ключи. Что делать дальше?

Подсказка: Ключи в коде — угроза. Не жди взлома, действуй.

Ответ:

- **Сообщить автору и инициировать отзыв ключей**
- Скопировать ключи себе на всякий случай
- Оставить, если никто не заметил
- **Запустить PR** — не моя задача

Шаг 04:

Миссия 4

Тестировщик Игорь получил письмо от «службы безопасности компании» с просьбой подтвердить логин. Что он должен проверить первым делом?

Подсказка: Настоящие письма редко содержат срочные угрозы. Посмотри, откуда оно пришло.

Ответ:

- **Проверить адрес отправителя и домен**
- Сразу перейти по ссылке
- Скачать вложение и посмотреть
- Удалить письмо, не думая

Шаг 05:

Миссия 5

Вася работает с удалённого сервера. В логах он замечает вход с IP, которого не знает. Что ему делать?

Подсказка: Любое неожиданное поведение требует немедленной реакции.

Ответ:

- **Ограничить доступ и уведомить безопасников**
- Игнорировать, если никто не жалуется
- Перезапустить сервер и наблюдать
- Удалить лог, чтобы не тревожить команду

Шаг 06:

Миссия 6

Определи роли в безопасности IT-среды

Подсказка: Кто что делает: защищает, тестирует, ломает?

Роли:

Ответ:

- Белый хакер
- Системный администратор
- Чёрный хакер
- DevOps-инженер

Действия:

1. Проводит легальные тесты на проникновение
 2. Обеспечивает стабильность и безопасность инфраструктуры
 3. Взламывает для получения выгоды
 4. Автоматизирует процессы и следит за CI/CD
- **Белый хакер** — Проводит легальные тесты на проникновение
 - **Системный администратор** — Обеспечивает стабильность и безопасность инфраструктуры
 - **Чёрный хакер** — Взламывает для получения выгоды
 - **DevOps-инженер** — Автоматизирует процессы и следит за CI/CD

Шаг 07:

Миссия 7

Саша — системный администратор. Её просят открыть удалённый доступ (SSH) на сервере для партнёра. Что она должна сделать перед включением доступа?

Подсказка: Без контроля доступа риск слишком велик.

Ответ:

- **Ограничить доступ по IP и включить ключи SSH**
- Открыть доступ для всех адресов
- Отложить включение на неопределённый срок
- Разослать логины и пароли всем сотрудникам

Шаг 08:

Миссия 8

Во время презентации заказчик предлагает подключиться к Wi-Fi для демонстрации приложения. Что правильнее сделать?

Подсказка: Лучше перестраховаться, чем заразить систему перед важным показом.

Ответ:

- **Подключиться через VPN или мобильный хотспот**
- Подключиться к гостевой сети заказчика без защиты
- Сказать, что Wi-Fi не нужен, и отказать в демонстрации
- Сказать заказчику дать пароль на личный телефон

Шаг 09:

Миссия 9

Сопоставьте триаду безопасности и их описания.

Подсказка: CIA — это не шпионская организация, а основа инфобеза.

Ответ:

- Конфиденциальность (Confidentiality)
 - Целостность (Integrity)
 - Доступность (Availability)
1. Свойство, когда только уполномоченные могут читать данные
 2. Свойство, когда данные не изменены злоумышленником
 3. Свойство, что сервис доступен по запросам
- **Конфиденциальность (Confidentiality)** — Свойство, когда только уполномоченные могут читать данные
 - **Целостность (Integrity)** — Свойство, когда данные не изменены злоумышленником
 - **Доступность (Availability)** — Свойство, что сервис доступен по запросам

Шаг 10:

Миссия 10

Сопоставьте уровни безопасности и методы защиты.

Подсказка: Безопасность строится «снизу вверх».

Ответ:

- Прикладной уровень
 - Транспортный уровень
 - Сетевой уровень
 - Физический уровень
1. Шифрование HTTPS, валидация входов

2. VPN, TLS
3. Маршрутизация, межсетевые экраны
4. Биометрия, контроль доступа в дата-центр

- **Прикладной уровень** — Шифрование HTTPS, валидация входов
- **Транспортный уровень** — VPN, TLS
- **Сетевой уровень** — Маршрутизация, межсетевые экраны
- **Физический уровень** — Биометрия, контроль доступа в дата-центр

Шаг 11:

Миссия 11

Сопоставьте типы контроля и примеры.

Подсказка: Контроль бывает превентивным, детективным и корректирующим.

Ответ:

- Превентивный контроль
 - Детективный контроль
 - Корректирующий контроль
1. Ограничение прав доступа
 2. Анализ логов и мониторинг
 3. Восстановление из резервной копии после взлома
- **Превентивный контроль** — Ограничение прав доступа
 - **Детективный контроль** — Анализ логов и мониторинг
 - **Корректирующий контроль** — Восстановление из резервной копии после взлома

Шаг 12:

Миссия 12

Расположите слои информационной безопасности от внешнего к внутреннему:

1. Физическая защита
2. Сетевые средства защиты
3. Прикладные средства защиты
4. Пользовательский (конечный) уровень защиты

Подсказка: Защита начинается с наружных барьеров и продвигается внутрь.

Ответ:

- Физическая защита
- Сетевые средства защиты
- Прикладные средства защиты
- Пользовательский (конечный) уровень защиты

Шаг 13:

Миссия 13

Расположите этапы жизненного цикла угрозы (threat lifecycle):

1. Идентификация угрозы
2. Оценка потенциального воздействия
3. Реализация угрозы (атака)
4. Анализ после атаки и уроки

Подсказка: Сначала обнаруживаем угрозу, потом её реализуют, а после — учатся.

Ответ:

- Идентификация угрозы
- Оценка потенциального воздействия
- Реализация угрозы (атака)
- Анализ после атаки и уроки

Шаг 14:

Миссия 14

Расположите элементы процесса управления риском:

1. Идентификация рисков
2. Оценка рисковУправление (минимизация) рисков
3. Мониторинг и пересмотр

Подсказка: Процесс рисков — это цикл: увидеть, оценить, действовать и проверять.

Ответ:

- Идентификация рисков
- Оценка рисков
- Управление (минимизация) рисков
- Мониторинг и пересмотр

Шаг 15:

Миссия 15

Расположите части архитектуры безопасности по уровню ответственности (от инфраструктуры к приложениям):

1. Операционная система и ядро
2. Сетевые компоненты и межсетевые экраны
3. Службы и API
4. Пользовательский интерфейс / клиентская часть

Подсказка: Базовые слои ниже, интерфейс ближе к пользователю.

Ответ:

- Операционная система и ядро
- Сетевые компоненты и межсетевые экраны
- Службы и API
- Пользовательский интерфейс / клиентская часть

Шаг 16:

Миссия 16

Расположите действия инженера безопасности при обнаружении уязвимости:

1. Оповестить команду разработки
2. Разработать и протестировать исправление (патч)
3. Внедрить исправление в систему
4. Мониторить систему после исправления

Подсказка: Исправление — это не конец, важно убедиться, что всё стабильно.

Ответ:

- Оповестить команду разработки
- Разработать и протестировать исправление (патч)
- Внедрить исправление в систему
- Мониторить систему после исправления

Урок 4 - Пароли создание, хранение, менеджеры

Шаг 01:

Миссия 1

Анна — молодая разработчица. Её друг предложил использовать пароль «qwerty123» для всех сайтов. Что Анна должна сделать?

Подсказка: Простота может быть опасной, особенно если пароль одинаков на многих сайтах.

Ответ:

- Согласиться и использовать такой пароль всюду
- **Создать уникальный и сложный пароль для каждого сайта**
- Записывать его в текстовый файл на рабочем столе

Шаг 02:

Миссия 2

Борис решил запомнить свой пароль, но он выбрал «Passw0rd!». Почему это может быть ненадёжным?

Подсказка: Хитрые замены букв часто предсказуемы.

Ответ:

- Пароль слишком длинный
- **Он содержит популярные слова с предсказуемыми заменами**
- Он не содержит цифр

Шаг 03:

Миссия 3

Катя услышала от коллеги о менеджере паролей. Что из ниже описанного — его основная функция?

Подсказка: Менеджер помогает с множеством паролей.

Ответ:

- **Хранить множество паролей и помогать автозаполнением**
- Генерировать вредоносные ссылки
- Скрывать экран компьютера

Шаг 04:

Миссия 4

Иван хочет, чтобы его мастер-пароль к менеджеру был максимально надёжным. Какую стратегию стоит выбрать?

Подсказка: Используйте случайность и длину.

Ответ:

- Слово из словаря + год рождения

- **Фраза из трёх случайных слов + символы и цифры**
- Короткое слово, зато легко запомнить
- Повторение одной буквы много раз

Шаг 05:

Миссия 5

Лена зарегистрировалась на новом сайте и хочет сохранить пароль. Какое место для хранения — наименее безопасное?

Подсказка: Вспомните: файл на ПК, браузер, менеджер паролей — где наибольший риск?
(Выберите один вариант.)

Ответ:

- **Текстовый файл на рабочем столе**
- Менеджер паролей с мастер-паролем
- Хранение в зашифрованном контейнере
- Использовать встроенное шифрование браузера

Шаг 06:

Миссия 6

Сергей использует один и тот же пароль на трёх сайтах. Какой риск наиболее вероятен?

Подсказка: Взлом одного сайта может повлиять на другие.

Ответ:

- **Если один сайт взломают, взломают и другие**
- Все сайты начнут удалять аккаунты
- Пароль станет слишком длинным

Шаг 07:

Миссия 7

 Сопоставьте тип атаки с её описанием:

Тип атаки:

Ответ:

- Brute-force атака
- Словарная атака
- Фишинг
- Keylogger

Описание:

1. Автоматический перебор всех возможных комбинаций
2. Атака с использованием списка распространённых слов и фраз
3. Маскировка под доверенный сайт, чтобы украсть пароль
4. Запись нажатий клавиш пользователя

Подсказка: Вспомните: что делают боты, что делают человеческие ловушки?

- **Brute-force атака** — Автоматический перебор всех возможных комбинаций
- **Словарная атака** — Атака с использованием списка распространённых слов и фраз
- **Фишинг** — Маскировка под доверенный сайт, чтобы украсть пароль
- **Keylogger** — Запись нажатий клавиш пользователя

Шаг 08:

Миссия 8

 Сопоставьте понятие «менеджер паролей» с его характеристиками:

Характеристика:

Ответ:

- Генератор случайных паролей
- Автозаполнение логинов и паролей
- Хранение паролей в зашифрованном виде
- Синхронизация между устройствами

Понятия:

1. Безопасность
2. Удобство
3. Мобильность
4. Надёжность

Подсказка: Подумайте, какая характеристика относится к хранению, какая — к генерации и т.д.

- **Безопасность** — Хранение паролей в зашифрованном виде
- **Удобство** — Автозаполнение логинов и паролей
- **Надёжность** — Генератор случайных паролей
- **Мобильность** — Синхронизация между устройствами

Шаг 09:

Миссия 9

 Сопоставьте подход к созданию пароля с его примером:

Подход:

Ответ:

- Фразы-пароли
- Случайные символы
- Личные ассоциации
- Популярные шаблоны

Примеры:

1. “КофеСолнцеГоры!42”
2. “G7x#Lp!q9”
3. “ИмяГородГодРождения”
4. “Password123!”

Подсказка: Какие способы дают большую энтропию? Какие — слабее?

- **Фразы-пароли** — “КофеСолнцеГоры!42”
- **Случайные символы** — “G7x#Lp!q9”
- **Личные ассоциации** — “ИмяГородГодРождения”
- **Популярные шаблоны** — “Password123!”

Шаг 10:

Миссия 10

 Сопоставьте угрозу с возможным сценарием её реализации:

Угроза:

Ответ:

- Атака через утечку пароля
- Многофакторная аутентификация (MFA)
- Сессионный захват
- Слишком простой пароль

Сценарий:

1. Злоумышленник использует украденный токен сессии
2. Пароль был одинаков на двух ресурсах, один из которых взломали
3. Пароль слишком короткий, и его легко угадать
4. Дополнительный код (SMS, приложение) отпугивает злоумышленника

Подсказка: У каждой угрозы — своя защита или сценарий.

- **Атака через утечку пароля** — Пароль был одинаков на двух ресурсах, один из которых взломали
- **Многофакторная аутентификация (MFA)** — Дополнительный код (SMS, приложение) отпугивает злоумышленника
- **Сессионный захват** — Злоумышленник использует украденный токен сессии
- **Слишком простой пароль** — Пароль слишком короткий, и его легко угадать

Шаг 11:

Миссия 11

Расположите шаги по безопасному восстановлению доступа к аккаунту в правильном порядке:

1. Войти в почту и запросить сброс пароля
2. Удостовериться, что письмо с ссылкой не подменено
3. Сменить временный пароль на свой надёжный
4. Воспользоваться функцией «забыли пароль»

Подсказка: Сначала иницилируйте процесс, затем проверяйте источник, после — изменяйте.

Ответ:

- Воспользоваться функцией «забыли пароль»
- Войти в почту и запросить сброс пароля
- Удостовериться, что письмо с ссылкой не подменено
- Сменить временный пароль на свой надёжный

Шаг 12:

Миссия 12

Расположите этапы интеграции менеджера паролей в рабочий процесс:

1. Сгенерировать уникальные пароли для разных сайтов
2. Импортировать уже имеющиеся пароли в менеджер
3. Настроить мастер-пароль и резервное восстановление
4. Начать повседневное использование менеджера для новых аккаунтов

Подсказка: Чтобы всё работало, нужен мастер-пароль и перенос старых данных прежде, чем вы начнёте.

Ответ:

- Настроить мастер-пароль и резервное восстановление
- Импортировать уже имеющиеся пароли в менеджер
- Сгенерировать уникальные пароли для разных сайтов
- Начать повседневное использование менеджера для новых аккаунтов

 Шаг 13:

Миссия 13

Рассортируйте степени надёжности паролей от наименее к наиболее безопасному:

1. "123456"
2. "qwertyABC"
3. "Имя2023!"
4. "56&fj9pZ!kQ"
5. "ДоброЖестьСолнце42?"

Подсказка: Оценивайте длину, разнообразие символов и предсказуемость.

Ответ:

- 123456
- qwertyABC
- Имя2023!
- 56&fj9pZ!kQ
- ДоброЖестьСолнце42?

 Шаг 14:

Миссия 14

Расположите уровни защиты аккаунта от базового к продвинутому:

1. Обычный пароль
2. Сильный пароль
3. Сильный пароль + MFA (двухфакторная аутентификация)
4. Сильный пароль + MFA + аппаратный токен

Подсказка: Каждый следующий шаг добавляет новую защиту.

Ответ:

- Обычный пароль
- Сильный пароль
- Сильный пароль + MFA (двухфакторная аутентификация)
- Сильный пароль + MFA + аппаратный токен

 Шаг 15:

Миссия 15

Расположите шаги реагирования, если вы заподозрили, что ваш пароль украли:

1. Сменить пароль на всех сервисах, где вы его использовали
2. Отключить активные сессии в сервисе
3. Включить MFA, если ещё не включено
4. Проверить логи входов и уведомления

Подсказка: Сначала остановите ущерб, затем усилите защиту и проанализируйте событие.

Ответ:

- Отключить активные сессии в сервисе
- Проверить логи входов и уведомления
- Сменить пароль на всех сервисах, где вы его использовали
- Включить MFA, если ещё не включено

Шаг 16:

Миссия 16

Расположите шаги безопасной передачи пароля (например, коллегам) от наименее безопасного к наиболее безопасному:

1. Отправить по обычному чату
2. Позвонить и продиктовать
3. Отправить в зашифрованном сообщении
4. Использовать общий сейф в менеджере паролей с доступом

Подсказка: Чем больше защита на передаче, тем лучше.

Ответ:

- Отправить по обычному чату
- Позвонить и продиктовать
- Отправить в зашифрованном сообщении
- Использовать общий сейф в менеджере паролей с доступом

Шаг 17:

Миссия 17

Расположите действия по внедрению политики паролей в команде от первоначального к финальному:

1. Обсудить с командой важность сильных паролей
2. Сформулировать требования к сложности пароля
3. Выбрать и внедрить менеджер паролей для команды
4. Обучить команду правилам и контролировать соблюдение

Подсказка: Сначала — культура, затем — правила, инструменты и контроль.

Ответ:

- Обсудить с командой важность сильных паролей
- Сформулировать требования к сложности пароля
- Выбрать и внедрить менеджер паролей для команды
- Обучить команду правилам и контролировать соблюдение

Урок 5 - Двухфакторная аутентификация принципы

Шаг 01:

Миссия 1

Разработчик Иван настроил двухфакторную аутентификацию (2FA) на своем аккаунте. Какой из способов 2FA наиболее безопасен?

Подсказка: Сравните физические устройства и SMS по уровню защиты.

Ответ:

- **Аппаратный токен (например, YubiKey)**
- SMS-код на телефон
- Код по электронной почте

 **Шаг 02:**

Миссия 2

Программист Оля хочет защитить свой рабочий аккаунт на GitHub с помощью 2FA. Какой из этих вариантов она должна выбрать?

Подсказка: Подумайте о том, какие методы 2FA поддерживаются GitHub и насколько они удобны.

Ответ:

- **Приложение-аутентификатор (например, Google Authenticator)**
- Получение пароля по SMS
- Отправка кода на email
- Использование только пароля без 2FA

 **Шаг 03:**

Миссия 3

Какое из утверждений о двухфакторной аутентификации является верным?

Подсказка: Вспомните, какие факторы обычно используются для проверки личности.

Ответ:

- **2FA требует двух разных типов подтверждения личности, например, пароль и код из приложения**
- 2FA — это использование двух одинаковых паролей подряд
- 2FA полностью заменяет пароль
- 2FA не повышает безопасность аккаунта

 **Шаг 04:**

Миссия 4

Программист Макс получил подозрительное SMS с кодом 2FA, которого он не запрашивал. Что ему следует сделать?

Подсказка: Подумайте, может ли это быть попыткой взлома через перехват кода.

Ответ:

- **Не вводить код и проверить безопасность аккаунта**
- Отправить код злоумышленнику, чтобы избежать проблем
- Игнорировать SMS и продолжать работу без мер

 **Шаг 05:**

Миссия 5

Какой из этих факторов НЕ относится к классическим типам двухфакторной аутентификации?

Подсказка: Вспомните три основных категории факторов: что вы знаете, что у вас есть и кто вы есть.

Ответ:

- **Местоположение пользователя**

- Пароль или PIN
- Аппаратный токен
- Отпечаток пальца

🔗 Шаг 06:

Миссия 6

Сопоставьте типы факторов 2FA с их описаниями.

Подсказка: Разберитесь, что означает «что вы знаете», «что у вас есть» и «кто вы есть».

Типы факторов:

Ответ:

- Пароль
- Отпечаток пальца
- Аппаратный токен
- Секретный вопрос

Описание:

1. Что-то, что вы знаете
2. Что-то, что у вас есть
3. Что-то, что вы являетесь (биометрия)
4. Дополнительный способ подтверждения личности

- **Пароль** — Что-то, что вы знаете
- **Отпечаток пальца** — Что-то, что вы являетесь (биометрия)
- **Аппаратный токен** — Что-то, что у вас есть
- **Секретный вопрос** — Дополнительный способ подтверждения личности

🔗 Шаг 07:

Миссия 7

Сопоставьте методы двухфакторной аутентификации с их преимуществами.

Подсказка: Подумайте, что важнее: безопасность, удобство или скорость.

Методы 2FA:

Ответ:

- SMS-код
- Приложение-аутентификатор
- Аппаратный ключ
- Биометрия (отпечаток пальца)

Преимущества:

1. Высокий уровень защиты от фишинга
2. Удобство и быстрота
3. Не требует подключения к интернету
4. Риск перехвата низок, но требует устройства

- **SMS-код** — Удобство и быстрота
- **Приложение-аутентификатор** — Риск перехвата низок, но требует устройства
- **Аппаратный ключ** — Высокий уровень защиты от фишинга
- **Биометрия (отпечаток пальца)** — Не требует подключения к интернету

Шаг 08:

Миссия 8

Сопоставьте сценарии с подходящими типами двухфакторной аутентификации.

Подсказка: Учтите контекст и угрозы в каждой ситуации.

Сценарии:

Ответ:

- Удалённая работа с конфиденциальными данными
- Покупки в интернет-магазине
- Вход в социальную сеть с телефона
- Администрирование серверов компании

Методы 2FA:

1. Аппаратный токен
2. SMS-код
3. Приложение-аутентификатор
4. Биометрия

- **Удалённая работа с конфиденциальными данными** — Аппаратный токен
- **Покупки в интернет-магазине** — SMS-код
- **Вход в социальную сеть с телефона** — Биометрия
- **Администрирование серверов компании** — Приложение-аутентификатор

Шаг 09:

Миссия 9

Сопоставьте распространённые угрозы безопасности с их описаниями.

Подсказка: Подумайте, как каждая угроза связана с 2FA.

Угрозы:

Ответ:

- Фишинг
- Перехват SMS
- Социальная инженерия
- Кража устройства

Описание:

1. Обман с целью получить ваши данные
2. Злоумышленник перехватывает SMS с кодом
3. Манипуляции с целью получить доступ к аккаунту
4. Физическое получение доступа к устройству с токеном

- **Фишинг** — Обман с целью получить ваши данные
- **Перехват SMS** — Злоумышленник перехватывает SMS с кодом
- **Социальная инженерия** — Манипуляции с целью получить доступ к аккаунту
- **Кража устройства** — Физическое получение доступа к устройству с токеном

Шаг 10:

Миссия 10

Расположите этапы настройки двухфакторной аутентификации в правильном порядке:

Подсказка:

Подумайте, что сначала нужно сделать для включения 2FA, а что — после.

Ответ:

- Войти в настройки безопасности аккаунта
- Выбрать тип двухфакторной аутентификации
- Подключить устройство или приложение для 2FA
- Подтвердить работу 2FA с помощью кода
- Сохранить изменения и выйти

Шаг 11:

Миссия 11

Расположите действия пользователя при входе с включенной двухфакторной аутентификацией:

Подсказка:

Вспомните, что требуется сначала, а что — в конце процесса.

Ответ:

- Ввести логин и пароль
- Получить код из приложения или SMS
- Ввести полученный код
- Получить доступ к аккаунту

Шаг 12:

Миссия 12

Расположите шаги реагирования при подозрении на компрометацию аккаунта с 2FA:

Подсказка:

Подумайте, что важно сделать в первую очередь, чтобы защитить данные.

Ответ:

- Сменить пароль
- Отключить 2FA временно
- Проверить историю входов
- Связаться с поддержкой сервиса

Шаг 13:

Миссия 13

Расположите этапы внедрения 2FA в корпоративной сети:

Подсказка:

Обратите внимание на планирование, обучение и техническую реализацию.

Ответ:

- Оценка рисков и выбор метода 2FA
- Обучение сотрудников и информирование
- Техническая настройка и тестирование
- Запуск и мониторинг использования 2FA

Шаг 14:

Миссия 14

Расположите уровни безопасности в порядке повышения надежности методов аутентификации:

 Подсказка:

Подумайте, какие методы сложнее подделать или украсть.

Ответ:

- Пароль
- Пароль + SMS-код
- Пароль + приложение-аутентификатор
- Пароль + аппаратный токен

 Шаг 15:

Миссия 15

Расположите этапы восстановления доступа при потере устройства с двухфакторной аутентификацией:

 Подсказка:

Подумайте, какие действия помогут безопасно вернуть контроль над аккаунтом.

Ответ:

- Использовать резервные коды для входа
- Связаться со службой поддержки
- Подтвердить личность через email или телефон
- Настроить новый метод двухфакторной аутентификации

 Шаг 16:

Миссия 16

Расположите шаги включения двухфакторной аутентификации на новом устройстве:

 Подсказка:

Вспомните, что необходимо сделать, чтобы успешно активировать 2FA.

Ответ:

- Войти в настройки аккаунта
- Выбрать тип двухфакторной аутентификации
- Подключить новое устройство или приложение для 2FA
- Ввести код подтверждения с текущего устройства или резервных кодов
- Подтвердить активацию и сохранить изменения

 Урок 6 - Безопасность социальных сетей и мессенджеров

 Шаг 01:

Миссия 1

Программист Саша решил завести новый аккаунт в мессенджере и хочет сделать его максимально безопасным. Какое действие будет лучшим первым шагом?

Подсказка: Подумайте о том, что защищает доступ к аккаунту ещё на входе.

Ответ:

- **Придумать уникальный и сложный пароль**
- Сразу добавить в профиль все свои личные данные
- Подключить аккаунт к общему Wi-Fi в кафе
- Отправить пароль другу на всякий случай

Шаг 02:

Миссия 2

Айтишник Лёша получил сообщение от «службы поддержки соцсети» с просьбой срочно прислать пароль. Как он должен поступить?

Подсказка: Подумайте, просит ли настоящая поддержка пароли напрямую?

Ответ:

- **Проигнорировать сообщение и проверить официальный сайт соцсети**
- Сразу отправить пароль, чтобы не заблокировали
- Найти отправителя и поспорить с ним
- Переслать сообщение друзьям, чтобы они были в курсе

Шаг 03:

Миссия 3

Программистка Аня любит делиться фотографиями с конференций. Какой способ публикации будет наиболее безопасным?

Подсказка: Вспомните, что может выдать лишнюю информацию о вас.

Ответ:

- **Отключить геометки перед публикацией**
- Выкладывать фото сразу с геометкой и временем
- Отмечать на фото незнакомых людей
- Сохранять фото только в облаке без пароля

Шаг 04:

Миссия 4

Программист Пётр заметил, что его друг пересылает забавные файлы в мессенджере. Какое поведение будет самым безопасным?

Подсказка: Даже друзья могут случайно переслать вредоносный файл.

Ответ:

- **Проверить файл антивирусом перед открытием**
- Открыть сразу, ведь это прислал друг
- Переслать всем коллегам, чтобы тоже посмотрели
- Сохранить файл в системную папку

Шаг 05:

Миссия 5

У программиста Жени взломали аккаунт, и злоумышленники рассылают от его имени ссылки. Что ему стоит сделать в первую очередь?

Подсказка: Важно быстро восстановить контроль над аккаунтом.

Ответ:

- **Сменить пароль и включить двухфакторную аутентификацию**
- Удалить приложение соцсети с телефона
- Просто подождать, пока всё само исправится
- Позвонить друзьям и сказать «не кликайте»

Шаг 06:

Миссия 6

Программистка Катя получила приглашение в «закрытый клуб» через соцсеть. Чтобы присоединиться, нужно перейти по подозрительной ссылке. Какой её лучший выбор?

Подсказка: Подумайте, кто обычно скрывается за заманчивыми ссылками.

Ответ:

- **Не переходить по ссылке и заблокировать отправителя**
- Перейти по ссылке, ведь это «закрытый клуб»
- Скопировать ссылку и отправить друзьям
- Сразу ввести логин и пароль на сайте

Шаг 07:

Миссия 7

 Задача: Сопоставьте действие и его цель при настройке безопасности в мессенджерах.

Подсказка: Каждое действие направлено на защиту личных данных.

Ответ:

- **Включить двухфакторную аутентификацию** — Добавить дополнительный уровень защиты при входе
- **Использовать автозапрет пересылки фото** — Ограничить распространение личных изображений
- **Отключить показ номера телефона** — Скрыть личную информацию от незнакомцев
- **Установить PIN-код на приложение** — Предотвратить доступ к мессенджеру с чужого устройства

Шаг 08:

Миссия 8

 Сопоставьте вид атаки с его описанием.

Подсказка: Обратите внимание, как именно атакующий пытается получить ваши данные.

Ответ:

- **Фишинг** — Отправка поддельных сообщений для кражи данных
- **Социальная инженерия** — Манипуляция человеком для раскрытия информации
- **Вредоносный файл** — Программа, маскирующаяся под безобидный документ
- **Сниффинг** — Перехват данных в сети

Шаг 09:

Миссия 9

 Программист Дима помогает коллеге настраивать аккаунт. Сопоставьте настройку и её эффект.

Подсказка: Все настройки направлены на контроль личной информации.

Ответ:

- **Скрыть список друзей** — Уменьшить вероятность атак через знакомых
- **Закрыть профиль от индексации** — Сделать профиль невидимым для поисковых систем
- **Ограничить комментарии** — Снизить риск спама и оскорблений

- **Настроить приватность историй** — Определить, кто может видеть временные публикации

Шаг 10:

Миссия 10

 Сопоставьте плохую привычку в соцсетях с возможным риском.

Подсказка: Подумайте, что может случиться с личными данными при неосторожности.

Ответ:

- **Хранение паролей в заметках** — Риск кражи устройства и доступа к аккаунтам
- **Публикация фото паспорта** — Вероятность кражи личности
- **Добавление незнакомцев в друзья** — Получение фальшивых сообщений
- **Использование одного пароля для всех сервисов** — Массовый взлом при утечке

Шаг 11:

Миссия 11

 Разработчик Андрей готовит лекцию о цифровой гигиене. Сопоставьте понятие и пример.

Подсказка: Цифровая гигиена — это не только пароли, но и поведение в сети.

Ответ:

- **Двухфакторная аутентификация** — Подтверждение входа через SMS или приложение
- **VPN** — Шифрование интернет-трафика
- **Фейковый аккаунт** — Профиль, созданный для обмана
- **Социальная инженерия** — Попытка обманом получить секретные данные

Шаг 12:

Миссия 12

Расположите шаги при подозрении на взлом аккаунта.

Подсказка: Сначала нужно обезопасить вход, потом — уведомить других.

Ответ:

- Сменить пароль
- Включить двухфакторную аутентификацию
- Проверить устройства, где выполнен вход
- Предупредить друзей о возможных фейковых сообщениях

Шаг 13:

Миссия 13

Расположите шаги при настройке нового профиля в соцсети.

Подсказка: Сначала стоит подумать о безопасности, а потом о публикациях.

Ответ:

- Придумать надёжный пароль
- Включить двухфакторную защиту
- Настроить приватность профиля
- Опубликовать первую запись

Шаг 14:

Миссия 14

Расположите шаги проверки подозрительного письма.

Подсказка: Сначала ищем очевидные признаки подделки.

Ответ:

- Проверить адрес отправителя
- Посмотреть текст письма на наличие ошибок
- Не кликать на ссылки
- Удалить письмо

Шаг 15:

Миссия 15

Расположите действия программиста, если друг прислал подозрительное сообщение с ссылкой.

Подсказка: Не спешите кликать, сначала проверьте источник.

Ответ:

- Не переходить по ссылке
- Уточнить у друга, отправлял ли он сообщение
- Проверить устройство антивирусом
- Сообщить о проблеме в поддержку

Шаг 16:

Миссия 16

Расположите шаги безопасной публикации фото в соцсетях.

Подсказка: Подумайте, какие данные о вас может выдать фотография.

Ответ:

- Отключить геометки
- Убедиться, что на фото нет конфиденциальной информации
- Настроить аудиторию публикации
- Опубликовать фото

Урок 7 - Компьютерные вирусы как работают

Шаг 01:

Миссия 1

Программист Саша скачал бесплатную программу с неизвестного сайта. Какое действие поможет ему избежать заражения вирусом?

Подсказка: Подумайте, какое первое средство защиты запускается ещё до установки программы.

Ответ:

- Проверить файл антивирусом перед запуском
- Сразу запустить, чтобы посмотреть, что это
- Отправить файл другу для проверки
- Установить без проверки, но удалить позже

Шаг 02:

Миссия 2

Айтишнику Лёше пришло письмо с вложением «важный_документ.exe». Какое действие будет правильным?

Подсказка: Обратите внимание на расширение файла.

Ответ:

- **Удалить письмо и не открывать вложение**
- **Открыть файл сразу** — ведь он помечен как «важный»
- Переслать файл коллеге для проверки
- Переименовать файл и открыть

Шаг 03:

Миссия 3

Программистка Аня заметила, что компьютер стал сильно тормозить, а кулер работает на полную. Что может быть причиной?

Подсказка: Вредоносные программы часто используют ресурсы компьютера в своих целях.

Ответ:

- **Вирус, использующий ресурсы для майнинга**
- Случайный перегрев из-за солнца
- Слишком много открытых окон браузера
- Ошибка в Excel

Шаг 04:

Миссия 4

Программист Пётр увидел на экране сообщение: «Ваши файлы зашифрованы. Отправьте биткоины, чтобы их вернуть». С каким видом вируса он столкнулся?

Подсказка: Такой вирус делает данные недоступными без ключа.

Ответ:

- **Шифровальщик (ransomware)**
- Троян
- Червь
- Рекламный вирус

Шаг 05:

Миссия 5

Разработчик Женя заметил, что на его рабочем компьютере внезапно появились новые программы. Что это может означать?

Подсказка: Иногда вирусы устанавливают дополнительное ПО без ведома пользователя.

Ответ:

- **Заражение вирусом, устанавливающим нежелательные программы**
- Обычное обновление Windows
- Ошибка в IDE
- Коллега установил софт случайно

Шаг 06:

Миссия 6

Программистка Катя подключила флешку друга, и на ней появились странные ярлыки. Что произошло?

Подсказка: Некоторые вирусы копируются через внешние носители.

Ответ:

- **Флешка заражена вирусом-автозагрузчиком**
- Флешка просто сломана
- Это скрытые системные файлы
- Катя случайно установила драйвер

Шаг 07:

Миссия 7

 Сопоставьте вид вируса с его описанием.

Подсказка: Обратите внимание, как именно действует вирус.

Ответ:

- **Троян** — Маскируется под полезную программу
- **Червь** — Самостоятельно распространяется по сети
- **Шпионское ПО** — Собирает данные о пользователе
- **Руткит** — Скрывает наличие других вирусов

Шаг 08:

Миссия 8

 Сопоставьте действие программиста и возможный риск заражения вирусом.

Подсказка: Каждое небезопасное действие ведёт к своей опасности.

Ответ:

- **Скачивание пиратского софта** — Высокий риск заражения троянами
- **Открытие вложений от неизвестных** — Вероятность запуска вредоносного кода
- **Подключение непроверенной флешки** — Заражение автозагрузочными вирусами
- **Выключенный антивирус** — Отсутствие защиты от атак

Шаг 09:

Миссия 9

 Сопоставьте антивирусные методы с их назначением.

Подсказка: У каждого метода своя цель: блокировка, поиск или удаление.

Ответ:

- **Сканирование в реальном времени** — Обнаружение угроз при их запуске
- **Полная проверка диска** — Поиск скрытых вирусов
- **Карантин** — Изоляция подозрительных файлов
- **Удаление вируса** — Полное устранение угрозы

Шаг 10:

Миссия 10

 Сопоставьте последствия вирусов с их описанием.

Подсказка: Подумайте, что именно вирусы делают с компьютером.

Ответ:

- **Кража данных** — Передача логинов и паролей злоумышленникам
- **Удаление файлов** — Утрата важной информации
- **Снижение производительности** — Загрузка процессора вирусами
- **Блокировка системы** — Невозможность работать с компьютером

Шаг 11:

Миссия 11

 Сопоставьте тип защиты и пример её применения.

Подсказка: Все методы — часть кибергигиены.

Ответ:

- **Регулярные обновления** — Установка патчей для устранения уязвимостей
- **Резервное копирование** — Сохранение копий файлов в облаке
- **Фаервол** — Фильтрация нежелательного сетевого трафика
- **Антивирус** — Поиск и блокировка вирусов

Шаг 12:

Миссия 12

Расположите шаги при заражении компьютера вирусом.

Подсказка: Сначала нужно остановить заражение, затем устранить последствия.

Ответ:

- Отключить компьютер от интернета
- Запустить антивирусную проверку
- Удалить обнаруженные угрозы
- Восстановить файлы из резервной копии

Шаг 13:

Миссия 13

Расположите шаги безопасной работы с флешкой.

Подсказка: Важно проверить устройство до открытия файлов.

Ответ:

- Подключить флешку
- Запустить антивирус для проверки
- Открыть нужные файлы
- Извлечь флешку безопасно

Шаг 14:

Миссия 14

Расположите шаги настройки антивируса на новом компьютере.

Подсказка: Настройка должна завершиться полной проверкой.

Ответ:

- Установить антивирус
- Обновить базы вирусов

- Включить защиту в реальном времени
- Запустить полную проверку

Шаг 15:

Миссия 15

Расположите шаги при получении подозрительного письма с вложением.

Подсказка: Действуйте так, чтобы минимизировать риск заражения.

Ответ:

- Проверить адрес отправителя
- Не открывать вложение
- Удалить письмо
- Сообщить в ИТ-отдел

Шаг 16:

Миссия 16

Расположите шаги восстановления системы после заражения вирусом-шифровальщиком.

Подсказка: Главное — не платить выкуп, а использовать резервные копии.

Ответ:

- Переустановить систему или очистить заражённые файлы
- Установить антивирус и обновить базы
- Восстановить данные из резервной копии
- Настроить защиту от будущих атак

Шаг 17:

Миссия 17

Расположите шаги профилактики заражения вирусами при работе программиста.

Подсказка: Это действия, которые стоит делать регулярно.

Ответ:

- Обновлять систему и программы
- Использовать антивирус
- Не открывать подозрительные файлы
- Создавать резервные копии

Урок 8 - Как определить фишинговое письмо

Шаг 01:

Миссия 1

Андрей получил письмо якобы от банка с просьбой подтвердить пароль. Что должно вызвать у него подозрение?

Подсказка: Банки никогда не просят сообщить пароль по почте.

Ответ:

- **Запрос отправить пароль по email**
- Фирменный логотип банка в письме
- Формальное обращение по имени
- Приложенный PDF с правилами безопасности

Шаг 02:

Миссия 2

Программистка Лена получила письмо от «техподдержки», но адрес отправителя выглядит странно: support-bank123@gmail.com. Что это значит?

Подсказка: Обратите внимание на домен: официальный адрес банка не будет на gmail.com.

Ответ:

- **Подозрительный адрес отправителя, не связанный с банком**
- Письмо отправлено в будний день
- В письме есть подпись «С уважением, служба поддержки»
- Письмо короткое, без вложений

Шаг 03:

Миссия 3

Сергей получил письмо с темой: «ВАШ АККАУНТ ЗАБЛОКИРОВАН!!!». Что в заголовке должно насторожить?

Подсказка: Обратите внимание на стиль письма: злоумышленники любят писать в CAPS LOCK и добавлять много восклицаний.

Ответ:

- **Много восклицательных знаков и CAPS LOCK**
- Отсутствие смайликов
- Слово «аккаунт»
- Короткая тема письма

Шаг 04:

Миссия 4

Кате пришло письмо от знакомого с просьбой срочно одолжить денег и ссылкой на «сайт перевода». Что должно вызвать сомнения?

Подсказка: Хакеры часто взламывают почтовые ящики и рассылают письма от имени друзей.

Ответ:

- **Просьба перевести деньги по подозрительной ссылке**
- Обращение по имени «Катя»
- Использование смайлика в тексте
- Наличие подписи в конце письма

Шаг 05:

Миссия 5

Разработчик Игорь получил письмо с вложением «invoice.zip». Он не ждал никаких счетов. Что это может значить?

Подсказка: Архивы часто используются для сокрытия вредоносного кода.

Ответ:

- **Фишинг или вредонос во вложении**
- Просто случайная реклама
- Документ с инструкцией по безопасности
- Безобидный файл с музыкой

Шаг 06:

Миссия 6

Сопоставьте признаки писем с их описанием.

Подсказка: Вспомните, какие детали чаще всего встречаются в фишинге: ссылки, орфографические ошибки, срочность.

Ответ:

- **Подозрительные ссылки** — Адрес ведет на сайт, похожий на настоящий, но с ошибкой в домене.
- **Ошибки в тексте** — Много грамматических и орфографических ошибок.
- **Срочность** — Сообщение требует немедленного действия: «срочно», «сегодня».
- **Необычные вложения** — Архивы или исполняемые файлы, которые вы не ждали.

Шаг 07:

Миссия 7

Сопоставьте отправителей и признаки фишинга.

Подсказка: Домен отправителя может многое рассказать.

Ответ:

- **support@bank-secure.com.ru** — Подозрительный домен с лишними словами или окончаниями.
- **admin@paypal-official.net** — Адрес имитирует бренд, но не совпадает с официальным.
- **service@gmail.com** — Используется бесплатный почтовый сервис вместо корпоративного.
- **it-support@company.com** — Вероятный легитимный адрес корпоративной почты.

Шаг 08:

Миссия 8

Сопоставьте типы вложений с их рисками.

Подсказка: Некоторые форматы чаще всего используются для распространения вредоносного ПО.

Ответ:

- **.exe** — Может содержать вредоносное ПО.
- **.zip** — Архив, внутри может скрываться вирус.
- **.pdf** — Может содержать ссылки или встроенные скрипты.
- **.jpg** — Обычно безопасен, но может использоваться в социальной инженерии.

Шаг 09:

Миссия 9

Сопоставьте действия с правильной реакцией.

Подсказка: Подумайте, что безопаснее: проверить ссылку, не открывать вложения, перепроверить отправителя.

Ответ:

- **Получили подозрительное письмо** — Не открывать вложения и ссылки.
- **Не уверены в отправителе** — Позвонить напрямую или уточнить другим способом.
- **Видите орфографические ошибки** — Заподозрить фишинг.
- **Ссылка ведет на другой домен** — Не вводить данные на сайте.

Шаг 10:

Миссия 10

Сопоставьте психологические приемы с их описанием.

Подсказка: Фишинг часто играет на эмоциях.

Ответ:

- **Страх** — «Ваш аккаунт будет удален, если не подтвердите сейчас!»
- **Срочность** — «Нужно сделать это в течение часа!»
- **Любопытство** — «Смотрите фото, где вы отмечены.»
- **Жадность** — «Получите бонус, заполнив форму.»

Шаг 11:

Миссия 11

Сопоставьте ситуации с вероятными признаками фишинга.

Подсказка: Подумайте, что выбивается из нормы корпоративной переписки.

Ответ:

- **Письмо от директора без обращения по имени** — Необычный стиль общения.
- **Ссылка «обновите пароль» без причины** — Навязанное действие.
- **Письмо с угрозами** — Манипуляция через страх.
- **Письмо с вложением .exe** — Высокий риск заражения.

Шаг 12:

Миссия 12

Расположите шаги проверки подозрительного письма в правильном порядке.

Подсказка: Сначала смотрим на отправителя, затем анализируем текст, потом ссылки и вложения.

Ответ:

- Проверить адрес отправителя
- Оценить стиль письма и ошибки
- Проверить ссылки
- **Принять решение** — доверять или удалить

Шаг 13:

Миссия 13

Упорядочьте действия при подозрении на фишинг.

Подсказка: Никогда не кликайте сразу — сначала анализируйте.

Ответ:

- Не открывать вложения
- Проверить адрес отправителя
- Проверить ссылки
- Сообщить в службу безопасности

Шаг 14:

Миссия 14

Расположите этапы атаки через фишинговое письмо.

Подсказка: Сначала письмо приходит, затем пользователь реагирует, а потом злоумышленник получает доступ.

Ответ:

- Жертва получает письмо
- Жертва открывает вложение или ссылку
- Злоумышленник получает данные
- Аккаунт или система скомпрометированы

Шаг 15:

Миссия 15

Расположите шаги безопасной реакции на фишинг.

Подсказка: Подумайте: сначала изоляция, потом проверка, потом отчет.

Ответ:

- Не переходить по ссылке
- Изолировать письмо (пометить спам)
- Сообщить в ИБ-отдел
- Удалить письмо

Шаг 16:

Миссия 16

Упорядочьте шаги атаки, если пользователь все же кликнул по ссылке.

Подсказка: Сначала переход, затем ввод данных, потом их кража.

Ответ:

- Жертва кликает на ссылку
- Открывается поддельный сайт
- Жертва вводит логин и пароль
- Злоумышленник получает доступ

Урок 9 - Защита смартфона и ПК от угроз

Шаг 01:

Миссия 1

Программист Дима заметил, что его смартфон начал быстро разряжаться и греться. Он подозревает вредоносное приложение. Какое действие первым делом стоит выполнить?

Подсказка: Начните с проверки списка приложений и их активности.

Ответ:

- **Проверить список установленных приложений и удалить подозрительные**
- Сразу сбросить телефон до заводских настроек
- Установить ещё одно неизвестное приложение-антивирус
- Игнорировать проблему, она решится сама

Шаг 02:

Миссия 2

Программистка Аня подключилась к бесплатному Wi-Fi в кафе и решила войти в интернет-банк. Что в её действиях рискованно?

Подсказка: Вспомните, что открытые сети небезопасны для конфиденциальных операций.

Ответ:

- **Вход в интернет-банк через открытый Wi-Fi**
- Просмотр новостей в открытом Wi-Fi
- Подключение к сети для проверки почты
- Скачивание бесплатного обновления игры дома через Wi-Fi

Шаг 03:

Миссия 3

Разработчик Игорь придумал пароль «123456» для учётной записи на GitHub. Что можно сказать об этом пароле?

Подсказка: Самые простые пароли легко угадываются.

Ответ:

- **Пароль крайне слабый и небезопасный**
- Пароль идеален, так как его легко запомнить
- Пароль достаточно надёжный
- Пароль защищает от перебора

Шаг 04:

Миссия 4

Программистке Соне пришло письмо от «банка», где её просят срочно ввести логин и пароль по ссылке. Как это называется?

Подсказка: Это один из самых популярных видов социальной инженерии.

Ответ:

- **Фишинг**
- Хакерская атака DDoS
- Брандмауэр
- VPN-подключение

Шаг 05:

Миссия 5

Разработчик Костя использует один и тот же пароль для всех сервисов. Какой риск он создаёт?

Подсказка: Если злоумышленник получит один пароль — получит доступ ко всем сервисам.

Ответ:

- **Компрометация всех его аккаунтов при утечке одного пароля**
- Защита аккаунтов повышается
- Пароли становятся уникальными
- Усложняется подбор пароля

Шаг 06:

Миссия 6

 Задача: сопоставьте угрозу и её описание.

Подсказка: Вспомните, что вирусы — это программы, фишинг — письма, а троян — маскируется под полезное.

Ответ:

- **Фишинг** — Мошенническое письмо или сайт для кражи данных
- **Вирус** — Программа, заражающая другие файлы
- **Троян** — Вредоносное ПО, маскирующееся под полезное
- **Spyware** — Программа-шпион, собирающая данные о пользователе

Шаг 07:

Миссия 7

 Сопоставьте настройку и её назначение.

Подсказка: Двухфакторная защита усиливает вход, VPN шифрует, а брандмауэр фильтрует.

Ответ:

- **Двухфакторная аутентификация** — Добавляет дополнительный код при входе
- **VPN** — Шифрует интернет-соединение
- **Брандмауэр** — Фильтрует сетевой трафик
- **Антивирус** — Обнаруживает и удаляет вредоносные программы

Шаг 08:

Миссия 8

 Сопоставьте действие программиста и его правильное последствие.

Подсказка: Обновления повышают безопасность, скачивание с левых сайтов — наоборот.

Ответ:

- **Установил обновление ОС** — Закрыв уязвимости
- **Скачал игру с пиратского сайта** — Риск заражения вирусом
- **Включил VPN при подключении к Wi-Fi** — Защитил данные от перехвата
- **Использовал одинаковый пароль** — Увеличил риск взлома

Шаг 09:

Миссия 9

 Сопоставьте устройства и способы защиты.

Подсказка: ПК чаще требует антивируса, смартфон — контроль разрешений приложений.

Ответ:

- **Смартфон** — Ограничение разрешений приложений
- **ПК** — Использование антивируса
- **Ноутбук в кафе** — VPN для защиты трафика
- **Рабочий сервер** — Регулярные обновления безопасности

Шаг 10:

Миссия 10

 Сопоставьте уязвимость и пример атаки.

Подсказка: Устаревшее ПО = эксплойты, слабый пароль = brute force.

Ответ:

- **Слабый пароль** — Подбор пароля brute force
- **Устаревшее ПО** — Эксплойт уязвимости
- **Открытый Wi-Fi** — Перехват трафика

- **Фишинговое письмо** — Кража логина и пароля

Шаг 11:

Миссия 11

Упорядочите шаги защиты смартфона при его утере.

Подсказка: Сначала нужно заблокировать, затем отследить, потом удалить данные.

Ответ:

- Заблокировать SIM-карту
- Включить функцию поиска устройства
- Удалить данные дистанционно
- Сообщить оператору о краже

Шаг 12:

Миссия 12

Расположите шаги безопасного входа в интернет-банк.

Подсказка: Сначала подключитесь к защищённой сети, затем вводите данные.

Ответ:

- Подключиться к домашнему или VPN
- Перейти на сайт банка вручную
- Проверить HTTPS в адресной строке
- Ввести логин и пароль

Шаг 13:

Миссия 13

Упорядочите действия программиста при обнаружении подозрительного файла на ПК.

Подсказка: Сначала не запускаем, потом проверяем, потом удаляем.

Ответ:

- Не запускать файл
- Проверить файл антивирусом
- Удалить файл
- Провести полное сканирование системы

Шаг 14:

Миссия 14

Расставьте шаги при создании надёжного пароля.

Подсказка: Длина, разнообразие символов, отсутствие словаря.

Ответ:

- Выбрать длину не менее 12 символов
- Использовать буквы разного регистра
- Добавить цифры и спецсимволы
- Избегать слов из словаря

Шаг 15:

Миссия 15

Расположите шаги при настройке нового ноутбука программиста.

Подсказка: Обновления, антивирус, пароли, резервные копии.

Ответ:

- Установить обновления ОС
- Поставить антивирус
- Настроить уникальные пароли
- Настроить резервное копирование

Урок 10 - Цифровой след и защита личной информации

Шаг 01:

Миссия 1

Программист Никита выкладывает фото с конференции, где на бейдже видны его имя и компания. Какой риск он создаёт?

Подсказка: Лишние данные могут использоваться мошенниками для социнженерии.

Ответ:

- **Упрощает злоумышленникам сбор информации о нём**
- Помогает быстрее находить работу
- Повышает уровень киберзащиты
- Не несёт никаких рисков

Шаг 02:

Миссия 2

Разработчица Аня оставила публичный пост с номером телефона в соцсети. Что может произойти?

Подсказка: Вспомните, как спамеры и мошенники используют такие данные.

Ответ:

- **Её номер могут использовать для спама и мошеннических звонков**
- Телефон будет работать быстрее
- Соцсеть автоматически защитит её номер
- Это повысит её цифровую репутацию

Шаг 03:

Миссия 3

Программист Пётр скачал бесплатный чекер паролей с неизвестного сайта. Что это может значить?

Подсказка: Такие сервисы часто собирают введённые данные.

Ответ:

- **Его пароли могут попасть к злоумышленникам**
- Он ускорит работу компьютера
- Пароли станут безопаснее автоматически
- Это полностью безопасно

Шаг 04:

Миссия 4

Алексей использует один аккаунт Google и авторизацию через него для всех сервисов. Какой минус у этого?

Подсказка: Взлом одного аккаунта = доступ ко многим сервисам.

Ответ:

- **Компрометация Google-аккаунта откроет доступ ко всем сервисам**
- Пароли становятся сложнее
- Это увеличивает конфиденциальность
- Опасности нет

Шаг 05:

Миссия 5

Программистка Маша настроила профиль LinkedIn так, что видно все её проекты и контакты. Что в этом может быть опасно?

Подсказка: Чем больше данных о ваших связях и опыте, тем проще атаковать через социнженерию.

Ответ:

- **Злоумышленники могут использовать контакты для атак**
- Её резюме станет более профессиональным
- Она получит больше предложений о работе
- Опасности нет

Шаг 06:

Миссия 6

Разработчик Дима публикует фото рабочего стола, где видны открытые вкладки и имена файлов. Чем это грозит?

Подсказка: Обратите внимание на утечку внутренней информации через фоновые детали.

Ответ:

- **Может раскрыть внутреннюю информацию компании**
- Увеличивает скорость работы ПК
- Никак не влияет на безопасность
- Повышает доверие клиентов

Шаг 07:

Миссия 7

 Сопоставьте тип цифрового следа и пример.

Подсказка: Прямые следы — ваши публикации, косвенные — ваши действия онлайн.

Ответ:

- **Прямой цифровой след** — Фотографии, опубликованные в соцсетях
- **Косвенный цифровой след** — История поисковых запросов
- **Анонимный след** — Комментарии под ником
- **Технический след** — IP-адрес и cookies

Шаг 08:

Миссия 8

 Сопоставьте соцсеть и потенциальный риск.

Подсказка: В разных сетях — разные утечки: фото, деловые связи или переписка.

Ответ:

- **Instagram** — Публикация личных фото
- **LinkedIn** — Раскрытие информации о месте работы
- **Facebook** — Доступ к переписке
- **Twitter** — Публичные комментарии

Шаг 09:

Миссия 9

 Сопоставьте действие и его влияние на цифровой след.

Подсказка: Посты и фото увеличивают след, а VPN скрывает часть активности.

Ответ:

- **Регистрация на форуме** — Добавление новой записи в цифровой след
- **Использование VPN** — Соккрытие реального IP-адреса
- **Публикация фото** — Расширение цифрового следа
- **Удаление старого аккаунта** — Сокращение видимости данных

Шаг 10:

Миссия 10

 Сопоставьте инструмент и его назначение для защиты данных.

Подсказка: VPN шифрует, менеджер паролей хранит, а антивирус защищает.

Ответ:

- **VPN** — Шифрует интернет-соединение
- **Менеджер паролей** — Безопасное хранение учётных данных
- **Антивирус** — Блокирует вредоносные программы
- **2FA** — Добавляет второй уровень защиты при входе

Шаг 11:

Миссия 11

 Сопоставьте уязвимость и возможное последствие.

Подсказка: Телефон в сети = спам-звонки, фото с паспортом = риск кражи личности.

Ответ:

- **Открытые фото с паспортом** — Кража личности
- **Публичный номер телефона** — Мошеннические звонки
- **Слабый пароль** — Подбор brute force
- **Устаревшее ПО** — Эксплойт уязвимости

Шаг 12:

Миссия 12

 Сопоставьте персонажа и его ошибку.

Подсказка: У каждого героя свой промах — от публикации данных до слабого пароля.

Ответ:

- **Никита** — Опубликовал фото с бейджем
- **Аня** — Оставила номер телефона в соцсети

- **Пётр** — Скачал программу с подозрительного сайта
- **Маша** — Открыла всю информацию о своих контактах

Шаг 13:

Миссия 13

Расположите шаги по уменьшению цифрового следа.

Подсказка: Начинайте с ревизии аккаунтов, потом настройка приватности и очистка данных.

Ответ:

- Проверить все старые аккаунты
- Удалить ненужные профили
- Настроить приватность в соцсетях
- Регулярно чистить историю браузера

Шаг 14:

Миссия 14

Расположите шаги при обнаружении утечки личных данных.

Подсказка: Сначала проверка, потом смена паролей, затем мониторинг.

Ответ:

- Проверить, где произошла утечка
- Сменить пароли
- Включить двухфакторную аутентификацию
- Следить за подозрительной активностью

Шаг 15:

Миссия 15

Упорядочите шаги при публикации фото в соцсети.

Подсказка: Проверяйте метаданные, фон и настройки приватности перед публикацией.

Ответ:

- Проверить метаданные фото
- Оценить, что видно на фоне
- Выбрать аудиторию (приватность)
- Опубликовать фото

Шаг 16:

Миссия 16

Упорядочите шаги защиты профиля в соцсети.

Подсказка: Сначала пароль, потом 2FA, затем контроль видимости данных.

Ответ:

- Сменить пароль на сложный
- Включить двухфакторную аутентификацию
- Ограничить видимость профиля
- Удалить старые публикации

Шаг 17:

Миссия 17

Расположите шаги безопасного поведения в интернете.

Подсказка: Сначала обновления и пароли, потом осторожность в общении.

Ответ:

- Обновить ПО и браузер
- Использовать уникальные пароли
- Не переходить по подозрительным ссылкам
- Делиться минимумом личных данных

Модуль 2 - Средний уровень (Практика и симуляции)

Урок 1 - Распознаём поддельные сайты

Шаг 01:

Миссия 1

Андрей — начинающий программист, получил письмо от «GitHub». Но ссылка в письме ведет на сайт githb.co . Что это за сайт?

Подсказка: Настоящие сервисы редко используют домены с опечатками.

Ответ:

- **Фишинговый сайт**
- Официальный сайт GitHub
- Личный блог разработчика
- Архив старого кода

Шаг 02:

Миссия 2

Марина разрабатывает игру и ищет движок. Она нашла сайт unrealenginee.com с похожим логотипом. Чтостораживает?

Подсказка: Сравнивай написание домена с оригиналом.

Ответ:

- **Название сайта написано с лишней буквой**
- На сайте есть картинки
- Есть кнопка «Скачать»
- Присутствует описание продукта

Шаг 03:

Миссия 3

Илья захотел войти в «Яндекс.Почту». В адресной строке он увидел yandeks-mail.ru . Что это?

Подсказка: Обрати внимание на странное написание бренда.

Ответ:

- **Поддельный сайт для кражи паролей**
- Настоящий сервис Яндекса
- Сайт техподдержки

- Форум разработчиков

Шаг 04:

Миссия 4

Олегу пришло письмо: «Ваш PayPal заблокирован, перейдите по ссылке paypal-security-login.net». Что делать?

Подсказка: Обрати внимание на домен — он не совпадает с настоящим.

Ответ:

- **Не переходить, это мошенники**
- Ввести данные для проверки
- Скачать файл для восстановления
- Позвонить на номер с письма

Шаг 05:

Миссия 5

Катя ищет документацию Python и попала на сайт pyth0n-docs.com . Как определить подделку?

Подсказка: Настоящий сайт документации Python всегда имеет домен python.org .

Ответ:

- **В названии используется цифра вместо буквы**
- На сайте есть кнопки
- Сайт на английском
- Есть описание функций

Шаг 06:

Миссия 6

Сергей увидел рекламу «Скачать Visual Studio бесплатно» с сайта vstudio-free.net . Какой риск?

Подсказка: Настоящий сайт Microsoft — только visualstudio.microsoft.com .

Ответ:

- **Можно скачать вирус вместо IDE**
- Сайт медленно грузится
- Там нет скриншотов
- Программу придется покупать

Шаг 07:

Миссия 7

Лена хотела купить курс по JavaScript и попала на сайт javascript-school.ru . Что подозрительно?

Подсказка: Иногда мошенники специально убирают буквы.

Ответ:

- **В названии сайта пропущена буква «s»**
- Сайт использует HTTPS
- Есть кнопка «Оплатить»
- Дизайн похож на реальный

🔗 Шаг 08:

Миссия 8

📖 Задача: Сопоставь типичные признаки поддельного сайта с их описанием.

Подсказка: Фишинговые сайты часто используют мелкие трюки — от неправильных доменов до странного дизайна.

Ответ:

- **Подозрительный домен** — Домен отличается от настоящего одной буквой или символом.
- **Нет HTTPS** — Адрес сайта начинается с http:// вместо [https://].
- **Ошибки](https://.%22},{%22first%22:%22Ошибки) в тексте** — Много грамматических ошибок и опечаток.
- **Странный дизайн** — Непривычный внешний вид, не похожий на оригинал.

🔗 Шаг 09:

Миссия 9

Сопоставь известные сервисы и признаки подделок.

Подсказка: Обрати внимание на точное написание доменов.

Ответ:

- **Google** — goooogle.com вместо google.com
- **Facebook** — facebok.net вместо facebook.com
- **Apple** — apple.com с заглавной I
- **Twitter** — twiter.org вместо twitter.com

🔗 Шаг 10:

Миссия 10

📖 Задача: Программист Антон сравнивает сайты. Сопоставь домен с его реальностью.

Подсказка: Помни про официальные домены компаний.

Ответ:

- **paypal.com** — Официальный сайт PayPal
- **pyth0n.org** — Фишинговый сайт с цифрой вместо буквы
- **microsoft.com** — Официальный сайт Microsoft
- **faceb00k.com** — Поддельный сайт с заменой букв на цифры

🔗 Шаг 11:

Миссия 11

📖 Сопоставь действие программиста и правильный результат.

Подсказка: Иногда нужно просто проверить детали в браузере.

Ответ:

- **Проверка замка HTTPS** — Гарантия шифрования соединения
- **Наведение на ссылку мышкой** — Показывает реальный адрес внизу экрана
- **Проверка орфографии сайта** — Позволяет заметить ошибки и подделку
- **Сравнение логотипа** — Помогает понять, копировали ли дизайн

Шаг 12:

Миссия 12

Сопоставь метод проверки и его цель.

Подсказка: Настоящий сайт легко проверить несколькими простыми шагами.

Ответ:

- **Проверка WHOIS** — Позволяет узнать владельца домена
- **Google поиск** — Находит отзывы о сайте
- **Проверка сертификата** — Убедиться, что SSL выдан реальным центром
- **Сравнение с закладкой** — Гарантия перехода на проверенный адрес

Шаг 13:

Миссия 13

Расположи шаги проверки подозрительного сайта в правильном порядке:

Подсказка: Сначала смотри на домен, потом детали страницы, и только после этого переходи к расширенным проверкам.

Ответ:

- Посмотреть доменное имя
- Проверить наличие HTTPS
- Найти грамматические ошибки
- Проверить отзывы через поиск

Шаг 14:

Миссия 14

Определи правильную последовательность действий программиста при получении подозрительной ссылки:

Подсказка: Не спеши кликать — сначала проверь адрес и только потом думай о действиях.

Ответ:

- Навести мышкой на ссылку
- Сравнить домен с официальным
- Посмотреть на наличие сертификата
- Решить, переходить ли по ссылке

Шаг 15:

Миссия 15

Расставь по порядку действия разработчика, который случайно попал на подозрительный сайт:

Подсказка: Сначала защита, потом анализ.

Ответ:

- Заккрыть вкладку
- Проверить антивирусом систему
- Сообщить в службу поддержки
- Запомнить адрес мошенников

Шаг 16:

Миссия 16

Упорядочи этапы обучения молодого программиста в навыках распознавания поддельных сайтов:

Подсказка: Учиться лучше постепенно: от простого к сложному.

Ответ:

- Знакомство с примерами фишинга
- Изучение признаков подделки
- Практика на симуляторах
- Анализ реальных кейсов

Шаг 17:

Миссия 17

Расставь правильный порядок действий при оплате товара в интернете:

Подсказка: Никогда не торопись, шаги должны быть последовательными.

Ответ:

- Проверить домен магазина
- Проверить сертификат безопасности
- Прочитать отзывы покупателей
- Ввести данные карты

Урок 2 - Проверка SSL-сертификатов и HTTPS

Шаг 01:

Миссия 1

Андрей заметил, что сайт банка открывается через http:// , а не https:// . Что это значит?

Подсказка: Буква S в HTTPS играет важную роль.

Ответ:

- **Соединение небезопасно и данные могут быть перехвачены**
- Это ускоряет загрузку страницы
- Такой сайт всегда безопаснее
- Это новый стандарт Интернета

Шаг 02:

Миссия 2

Марина хотела войти в почту. Она увидела предупреждение «Сертификат сайта недействителен». Что лучше сделать?

Подсказка: Доверяй браузеру — он проверяет сертификаты.

Ответ:

- **Не вводить данные и закрыть сайт**
- Игнорировать и продолжить
- Обновить страницу и попробовать снова
- Скачать сертификат вручную

Шаг 03:

Миссия 3

Илья тестирует новый сервис. В замке HTTPS написано «Ненадежный сертификат». Что это значит?

Подсказка: Сертификаты должны быть выданы известным центром сертификации.

Ответ:

- **Сертификат подписан неизвестным или сомнительным центром**
- Это означает защиту выше среднего
- Сайт просто перегружен
- Так всегда бывает с бесплатными сайтами

Шаг 04:

Миссия 4

Олег работает над веб-приложением. Его браузер пишет «Истек срок действия сертификата». Что это значит?

Подсказка: У SSL-сертификатов есть срок действия, как у паспорта.

Ответ:

- **Сайт использует устаревший сертификат, и данные небезопасны**
- Это просто ошибка браузера
- Сайт работает быстрее
- Сайт блокирует рекламу

Шаг 05:

Миссия 5

Катя видит сайт с зеленым замочком, но название компании не отображается. Что это может означать?

Подсказка: У разных сертификатов разный уровень проверки: DV, OV, EV.

Ответ:

- **Это сертификат DV, проверяет только домен**
- Это всегда мошенники
- Сайт подделан на 100%
- Это означает, что сайт заблокирован

Шаг 06:

Миссия 6

Сергей проверяет интернет-магазин. Замочек есть, но сертификат выписан на другое имя. Что делать?

Подсказка: Название компании должно совпадать с доменом.

Ответ:

- **Не вводить данные и уйти с сайта**
- Доверять, ведь есть замок
- Просто обновить страницу
- Проверить отзывы и оплатить

Шаг 07:

Миссия 7

Лена открыла сайт, где сертификат самоподписанный. Какой риск?

Подсказка: Самоподписанные сертификаты не подтверждаются доверенным центром.

Ответ:

- **Данные могут быть перехвачены злоумышленником**
- Это всегда безопаснее
- Это ускоряет работу сайта
- Это просто предупреждение без последствий

Шаг 08:

Миссия 8

 Сопоставь типы SSL-сертификатов и их особенности.

Подсказка: Вспомни три основных уровня проверки: DV, OV и EV.

Ответ:

- **DV-сертификат** — Проверяется только домен
- **OV-сертификат** — Проверяется домен и организация
- **EV-сертификат** — Выводит название компании в адресной строке
- **Самоподписанный сертификат** — Не проверяется центром сертификации

Шаг 09:

Миссия 9

 Сопоставь проблему SSL и её описание.

Подсказка: Ошибки сертификатов бывают разные — от истечения срока до подделки.

Ответ:

- **Истек срок действия** — Сертификат больше не действителен
- **Неверное имя домена** — Сертификат выдан для другого сайта
- **Самоподписанный сертификат** — Выдан самим сайтом, а не центром
- **Неизвестный центр сертификации** — Выдал малоизвестный или фальшивый CA

Шаг 10:

Миссия 10

 Сопоставь элементы HTTPS-соединения с их назначением.

Подсказка: HTTPS работает на основе TLS и ключей.

Ответ:

- **Публичный ключ** — Шифрует данные для сервера
- **Приватный ключ** — Расшифровывает данные на сервере
- **Центр сертификации** — Подтверждает подлинность сайта
- **TLS-протокол** — Обеспечивает защищённое соединение

Шаг 11:

Миссия 11

 Сопоставь действия программиста и результат проверки HTTPS.

Подсказка: Все проверки можно выполнить прямо в браузере.

Ответ:

- **Нажать на замочек** — Показать данные сертификата
- **Посмотреть срок действия** — Убедиться, что сертификат действителен

- **Проверить имя организации** — Сравнить с адресом сайта
- **Открыть детали протокола** — Узнать версию TLS

🔑 Шаг 12:

Миссия 12

📖 Сопоставь угрозу и её возможное последствие при отсутствии HTTPS.

Подсказка: Подумай, какие данные могут украсть.

Ответ:

- **Нет шифрования** — Пароли видны злоумышленникам
- **Фишинговый сайт** — Похищение логинов и карт
- **Поддельный сертификат** — Может имитировать реальный сайт
- **Истекший сертификат** — Соединение небезопасно

🔑 Шаг 13:

Миссия 13

Расположи шаги проверки сертификата в браузере в правильном порядке:

Подсказка: Замок, детали, имя и срок действия.

Ответ:

- Кликнуть на замок
- Посмотреть информацию о сертификате
- Проверить имя домена
- Проверить срок действия

🔑 Шаг 14:

Миссия 14

Определи последовательность действий программиста при настройке HTTPS:

Подсказка: Сначала создается ключ, потом запрос и установка.

Ответ:

- Сгенерировать приватный ключ
- Создать CSR-запрос
- Отправить запрос в CA
- Установить сертификат на сервер

🔑 Шаг 15:

Миссия 15

Расположи по порядку шаги атаки «Man-in-the-Middle» без HTTPS:

Подсказка: Сначала перехват, потом чтение, затем подмена.

Ответ:

- Злоумышленник подключается к сети
- Перехватывает данные
- Читает переданные логины
- Подменяет данные

Шаг 16:

Миссия 16

Упорядочи шаги при обновлении SSL-сертификата:

Подсказка: Сначала продлеваем, потом устанавливаем.

Ответ:

- Проверить срок действия
- Сгенерировать новый CSR
- Продлить у центра сертификации
- Установить обновленный сертификат

Шаг 17:

Миссия 17

Расставь правильный порядок действий пользователя при онлайн-платеже:

Подсказка: Проверка сайта важнее, чем ввод данных.

Ответ:

- Проверить HTTPS и сертификат
- Убедиться в правильности домена
- Проверить название компании
- Ввести данные карты

Урок 3 - Настройка безопасной домашней Wi-Fi-сети

Шаг 01:

Миссия 1

Программист Саша только что купил новый роутер. Какой первый шаг он должен сделать для безопасности?

Подсказка: Заводские настройки редко бывают безопасными.

Ответ:

- **Сменить стандартный пароль администратора**
- Подключить как есть и радоваться интернету
- Сразу открыть доступ для гостей без пароля
- Оставить все настройки по умолчанию

Шаг 02:

Миссия 2

Программистка Аня подключает Wi-Fi для работы. Какой тип шифрования самый надёжный для домашней сети?

Подсказка: Старые протоколы уже давно взломаны.

Ответ:

- **WPA3**
- WEP
- Без шифрования (Open)
- WPA (старый стандарт)

Шаг 03:

Миссия 3

Программист Дима любит всё автоматизировать. Он оставил SSID роутера по умолчанию — «TP-Link123». Чем это опасно?

Подсказка: Имя сети может многое рассказать злоумышленнику.

Ответ:

- **Злоумышленник поймёт модель роутера и выберет специфические атаки**
- Wi-Fi будет работать медленнее
- Интернет станет дороже
- Это никак не повлияет на безопасность

Шаг 04:

Миссия 4

Программистка Катя настраивает пароль для Wi-Fi. Какой из вариантов лучше?

Подсказка: Длина и разнообразие символов — ключ к стойкости.

Ответ:

- **MyH0meWiFi!2025#**
- 12345678
- password
- qwerty

Шаг 05:

Миссия 5

Программист Егор заметил, что его соседи иногда подключаются к его Wi-Fi. Какое действие поможет лучше всего?

Подсказка: Скрытие SSID не всегда надёжно.

Ответ:

- **Сменить пароль на сложный и использовать WPA3**
- Выключить Wi-Fi навсегда
- Назвать сеть «Virus_Alert»
- Оставить всё как есть

Шаг 06:

Миссия 6

Программист Никита хочет настроить гостевую сеть для друзей. Как правильно?

Подсказка: Друзья не должны иметь доступ к вашим домашним устройствам.

Ответ:

- **Включить отдельную гостевую сеть с паролем**
- Дать друзьям основной пароль от домашнего Wi-Fi
- Сделать гостевую сеть без пароля
- Вообще не давать интернет гостям

Шаг 07:

Миссия 7

Программист Илья заметил в логах роутера неизвестное устройство. Что делать?

Подсказка: Сначала ограничьте доступ, потом ищите источник.

Ответ:

- **Заблокировать устройство через панель управления роутером**
- Игнорировать, может это сосед
- Сразу выкинуть роутер
- Подключиться к устройству и посмотреть фото

Шаг 08:

Миссия 8

Программистка Лена услышала совет отключить WPS. Почему?

Подсказка: Функция удобная, но уязвимая.

Ответ:

- **WPS легко взламывается через PIN-код**
- WPS делает интернет медленным
- WPS блокирует видеоигры
- **WPS** — это встроенный вирус

Шаг 09:

Миссия 9

Сопоставьте элементы настроек роутера и их назначение.

Подсказка: Подумайте, что за что отвечает: пароль, протокол, обновления.

Ответ:

- **WPA3** — Современный протокол шифрования Wi-Fi
- **Гостевая сеть** — Доступ для друзей без выхода в локальную сеть
- **Пароль администратора** — Защищает панель управления роутером
- **Обновление прошивки** — Закрывает уязвимости и улучшает безопасность

Шаг 10:

Миссия 10

Сопоставьте угрозу и способ защиты.

Подсказка: Подумайте, какая мера нейтрализует риск.

Ответ:

- **Подбор пароля** — Использовать длинный сложный пароль
- **Взлом через WPS** — Отключить WPS
- **Атака через устаревший протокол** — Включить WPA3
- **Уязвимость прошивки** — Обновить роутер до последней версии

Шаг 11:

Миссия 11

Сопоставьте действия программистов с их ошибками.

Подсказка: Ошибки часто связаны с ленью или невнимательностью.

Ответ:

- **Оставил пароль admin:admin** — Лёгкая цель для атак

- **Оставил имя сети по умолчанию** — Злоумышленник понимает модель роутера
- **Не обновлял прошивку годами** — Роутер остаётся с известными уязвимостями
- **Включил открытую сеть без пароля** — Любой может подключиться

🔮 Шаг 12:

Миссия 12

Сопоставьте хорошие практики и их пользу.

Подсказка: Каждое действие имеет конкретный плюс.

Ответ:

- **Сложный пароль** — Усложняет подбор
- **Отключение WPS** — Защищает от атак PIN-кода
- **Гостевая сеть** — Изолирует гостей от локальной сети
- **Регулярные обновления** — Закрывают старые уязвимости

🔮 Шаг 13:

Миссия 13

Сопоставьте функции роутера и их описание.

Подсказка: Обратите внимание на контроль доступа.

Ответ:

- **MAC-фильтрация** — Разрешает доступ только определённым устройствам
- **Родительский контроль** — Ограничивает доступ детей к сайтам
- **Firewall** — Фильтрует нежелательные входящие соединения
- **VPN** — Шифрует весь интернет-трафик

🔮 Шаг 14:

Миссия 14

Расположите шаги настройки безопасного Wi-Fi в правильном порядке.

Подсказка: Сначала базовая безопасность, потом улучшения.

Ответ:

- Сменить пароль администратора
- Выбрать WPA3
- Придумать сложный пароль Wi-Fi
- Обновить прошивку роутера

🔮 Шаг 15:

Миссия 15

Программистка Маша решает, что делать после покупки роутера. Расположите её шаги правильно.

Подсказка: Вспомните: сначала доступ, потом защита, потом улучшения.

Ответ:

- Войти в панель управления
- Сменить стандартный пароль
- Включить WPA3
- Создать гостевую сеть

Шаг 16:

Миссия 16

Программист Пётр хочет проверить свой Wi-Fi на безопасность. Расставьте шаги.

Подсказка: Проверка устройств и настройка защиты идут рука об руку.

Ответ:

- Проверить список подключённых устройств
- Заблокировать лишние устройства
- Сменить Wi-Fi пароль
- Отключить WPS

Шаг 17:

Миссия 17

Финальная проверка! Расставьте шаги полного квеста по защите Wi-Fi.

Подсказка: Это комбинация всех миссий.

Ответ:

- Сменить пароль администратора
- Настроить WPA3
- Придумать сложный Wi-Fi пароль
- Отключить WPS
- Создать гостевую сеть
- Обновить прошивку

Урок 4 - Использование VPN плюсы и минусы

Шаг 01:

Миссия 1

Программист Дима заходит в кафе и видит открытую Wi-Fi сеть. Зачем ему может понадобиться VPN?

Подсказка: Вспомните, что VPN защищает данные в публичных сетях.

Ответ:

- **Чтобы зашифровать трафик и защититься от перехвата**
- Чтобы интернет стал бесплатным
- Чтобы ускорить работу Wi-Fi
- Чтобы отключить рекламу на сайтах

Шаг 02:

Миссия 2

Программистка Лена работает удалённо и подключается к серверу компании. Почему ей важно использовать VPN?

Подсказка: Корпоративные данные должны быть защищены от утечек.

Ответ:

- **Чтобы безопасно подключаться к корпоративной сети**
- Чтобы увеличить зарплату
- Чтобы быстрее качать фильмы
- Чтобы не платить за интернет

Шаг 03:

Миссия 3

Программист Саша хочет посмотреть сериал, который доступен только в другой стране. Как ему поможет VPN?

Подсказка: Вспомните, что VPN может менять виртуальное местоположение.

Ответ:

- **Он может выбрать сервер в нужной стране и получить доступ**
- VPN ускорит загрузку видео
- VPN бесплатно даст премиум-подписку
- VPN автоматически переведёт сериал

Шаг 04:

Миссия 4

Программистка Катя подключает VPN. Какой минус она может заметить?

Подсказка: Дополнительное шифрование не всегда работает мгновенно.

Ответ:

- **Скорость интернета может снизиться**
- Компьютер выключится
- Все файлы удалятся
- Пропадёт электричество

Шаг 05:

Миссия 5

Программист Игорь нашёл бесплатный VPN. В чём может быть опасность?

Подсказка: Вспомните: если сервис бесплатный — вы, скорее всего, товар.

Ответ:

- **Сервис может собирать и продавать его данные**
- Интернет станет вечным
- Сеть начнёт быстрее работать
- Компьютер будет выключаться ночью

Шаг 06:

Миссия 6

Программистка Маша пользуется VPN на телефоне. Какой главный плюс?

Подсказка: Даже мобильный интернет может быть небезопасным.

Ответ:

- **Шифрование всего трафика, даже в приложениях**
- Экономия батареи
- Автоматический перевод сообщений
- Ускорение игр

Шаг 07:

Миссия 7

Программист Артём думает: можно ли использовать VPN для обхода блокировок? Что правильно?

Подсказка: Подумайте о смене IP-адреса.

Ответ:

- **Да, VPN позволяет обходить региональные блокировки**
- VPN удаляет вирусы
- VPN заменяет антивирус
- VPN ускоряет загрузку сайтов

Шаг 08:

Миссия 8

Программистка Оля использует VPN, но хочет убедиться, что он не раскрывает её IP. Как проверить?

Подсказка: Есть онлайн-сервисы для проверки IP.

Ответ:

- **Зайти на сайт проверки IP и сравнить адреса**
- Посмотреть на иконку Wi-Fi
- Спросить у соседа
- Позвонить в провайдерскую компанию

Шаг 09:

Миссия 9

Сопоставьте ситуацию и пользу от VPN.

Подсказка: Вспомните, что VPN помогает и в кафе, и дома, и в путешествии.

Ответ:

- **Работа в кафе с общим Wi-Fi** — Защита трафика от перехвата
- **Просмотр зарубежных сериалов** — Доступ к контенту других стран
- **Работа из дома в корпоративной сети** — Безопасное подключение к рабочим ресурсам
- **Путешествие за границу** — Сохранение доступа к привычным сервисам

Шаг 10:

Миссия 10

Сопоставьте тип VPN и его описание.

Подсказка: Обратите внимание: корпоративные и личные решения разные.

Ответ:

- **Корпоративный VPN** — Обеспечивает защищённый доступ сотрудников к внутренней сети
- **Личный VPN** — Используется для приватности и обхода блокировок
- **VPN на уровне браузера** — Шифрует только трафик в браузере
- **VPN на уровне устройства** — Шифрует весь интернет-трафик

Шаг 11:

Миссия 11

Сопоставьте плюсы VPN и их значение.

Подсказка: Подумайте, почему программисты любят VPN.

Ответ:

- **Шифрование трафика** — Данные недоступны злоумышленникам
- **Смена IP-адреса** — Сложнее отследить пользователя
- **Обход блокировок** — Доступ к заблокированным сайтам
- **Защита в общественных сетях** — Минимизация риска перехвата

Шаг 12:

Миссия 12

Сопоставьте минусы VPN и их объяснение.

Подсказка: Даже у полезных технологий есть слабые стороны.

Ответ:

- **Снижение скорости** — Из-за дополнительного шифрования
- **Не все сайты работают с VPN** — Некоторые блокируют VPN-трафик
- **Опасность бесплатных VPN** — Могут продавать данные
- **Не заменяет антивирус** — VPN не защищает от вирусов

Шаг 13:

Миссия 13

Сопоставьте ситуации с правильными действиями при использовании VPN.

Подсказка: Иногда VPN помогает, иногда мешает.

Ответ:

- **Сайт не открывается при включённом VPN** — Попробовать сменить сервер
- **Скорость интернета упала** — Выбрать ближайший сервер
- **Бесплатный VPN просит доступ к контактам** — Не использовать этот сервис
- **Нужно подключиться к корпоративной сети** — Использовать корпоративный VPN

Шаг 14:

Миссия 14

Расположите шаги настройки VPN для работы в правильном порядке.

Подсказка: Сначала установка, потом выбор сервера, затем проверка.

Ответ:

- Установить VPN-приложение
- Выбрать сервер
- Подключиться
- Проверить IP-адрес

Шаг 15:

Миссия 15

Программистка Мила хочет настроить VPN на ноутбуке. Расставьте её действия.

Подсказка: Важно сначала выбрать сервис, потом установить и подключить.

Ответ:

- Выбрать VPN-сервис
- Скачать и установить приложение
- Выбрать сервер

- Проверить работу

Шаг 16:

Миссия 16

Программист Ваня хочет проверить, работает ли VPN. Расставьте шаги проверки.

Подсказка: Проверка IP — лучший способ.

Ответ:

- Подключиться к VPN
- Зайти на сайт проверки IP
- Сравнить IP до и после
- Убедиться, что IP изменился

Шаг 17:

Миссия 17

Финальная миссия! Расставьте шаги грамотного использования VPN.

Подсказка: Вспомните все миссии: выбор, установка, подключение, проверка, осторожность.

Ответ:

- Выбрать надёжный VPN-сервис
- Установить приложение
- Выбрать подходящий сервер
- Подключиться
- Проверить IP
- Следить за скоростью и безопасностью

Урок 5 - Работа с менеджером паролей

Шаг 01:

Миссия 1

Андрей — backend-разработчик. Он установил менеджер паролей и думает, можно ли хранить там все свои пароли. Что будет самым правильным?

Подсказка: Менеджеры паролей созданы именно для этого, но стоит подумать про исключения.

Ответ:

- **Да, хранить все пароли, кроме мастер-пароля в небезопасных местах**
- Нет, хранить только самые простые пароли
- Лучше всё держать в блокноте на столе
- Нужно помнить все пароли в голове

Шаг 02:

Миссия 2

Света — фронтенд-разработчица. Она создала мастер-пароль для своего менеджера паролей. Каким должен быть мастер-пароль?

Подсказка: Мастер-пароль — ключ ко всему. Он должен быть максимально сильным и уникальным.

Ответ:

- 12345678

- Пароль
- **Фраза из нескольких слов с символами и цифрами**
- Дата рождения

Шаг 03:

Миссия 3

Ваня заметил, что его коллега скинул пароль в рабочий чат. Что нужно сделать в первую очередь?

Подсказка: Пароли никогда не должны передаваться открытым текстом.

Ответ:

- **Предложить коллеге сразу сменить пароль**
- Скопировать пароль на всякий случай
- Удалить сообщение и ничего не говорить
- Разослать коллегам предупреждение с этим паролем

Шаг 04:

Миссия 4

Настя решила синхронизировать менеджер паролей между ноутбуком и телефоном. Что важно проверить?

Подсказка: Синхронизация — это удобно, но требует защиты.

Ответ:

- **Что передача данных зашифрована**
- Что синхронизация бесплатная
- Что пароль одинаковый на всех устройствах
- Что приложения обновлены до одной версии

Шаг 05:

Миссия 5

Игорь — DevOps-инженер. Он использует менеджер паролей для доступа к серверам. Что нужно сделать дополнительно для безопасности?

Подсказка: Не полагайтесь только на один фактор защиты.

Ответ:

- Отключить менеджер паролей
- **Включить двухфакторную аутентификацию**
- Создать простой пароль для скорости
- Держать все пароли в заметках на телефоне

Шаг 06:

Миссия 6

 Задача: Сопоставьте преимущества менеджера паролей с их объяснением.

Подсказка: Подумайте, зачем программисты любят менеджеры паролей: это не только про удобство.

Ответ:

- **Уникальные пароли** — Менеджер генерирует разные пароли для каждого сайта.
- **Экономия времени** — Не нужно вручную придумывать сложные пароли.

- **Безопасное хранение** — Пароли хранятся в зашифрованном виде.
- **Автозаполнение** — Пароли автоматически подставляются в формы входа.

🔮 Шаг 07:

Миссия 7

📖 Задача: Сопоставьте угрозу с правильным действием при работе с менеджером паролей.

Подсказка: Каждая угроза требует своей защиты.

Ответ:

- **Фишинговый сайт** — Проверять адрес страницы перед вводом.
- **Слабый мастер-пароль** — Использовать длинную фразу из нескольких слов.
- **Утеря устройства** — Включить удалённое стирание или блокировку.
- **Вредоносное ПО** — Установить антивирус и обновлять систему.

🔮 Шаг 08:

Миссия 8

📖 Задача: Сопоставьте тип пароля с его надёжностью.

Подсказка: Чем длиннее и разнообразнее пароль, тем сложнее его взломать.

Ответ:

- **qwerty123** — Очень слабый
- **Ivan1989** — Слабый
- **F!sh&River*2023** — Сильный
- **Короткая фраза без спецсимволов** — Средний

🔮 Шаг 09:

Миссия 9

📖 Задача: Сопоставьте программиста с его ошибкой при использовании менеджера паролей.

Подсказка: Подумайте, какие привычки могут быть опасными.

Ответ:

- **Денис** — Держит мастер-пароль на стикере на мониторе.
- **Оля** — Использует один и тот же пароль для нескольких сервисов.
- **Максим** — Не включает синхронизацию и теряет пароли при поломке ноутбука.
- **Катя** — Вводит мастер-пароль на общедоступном ПК.

🔮 Шаг 10:

Миссия 10

📖 Задача: Сопоставьте функцию менеджера паролей с её назначением.

Подсказка: Многие функции помогают облегчить жизнь программистам и повысить безопасность.

Ответ:

- **Генератор паролей** — Создание сложных комбинаций.
- **Хранение заметок** — Секретные данные можно сохранить зашифрованно.
- **Двухфакторная аутентификация** — Дополнительный уровень защиты.
- **Автозаполнение форм** — Ускоряет процесс входа.

Шаг 11:

Миссия 11

 Задача: Сопоставьте правильное действие с ситуацией.

Подсказка: В реальной жизни программисты часто сталкиваются с такими историями.

Ответ:

- **Менеджер паролей предложил обновить старый пароль** — Согласиться и обновить пароль.
- **Не удалось войти в аккаунт из-за неверного пароля** — Проверить правильность автозаполнения.
- **Появилось подозрительное письмо от банка** — Не вводить пароль и проверить подлинность письма.
- **Потерян смартфон с менеджером паролей** — Заблокировать или стереть данные удалённо.

Шаг 12:

Миссия 12

Расположите шаги при создании мастер-пароля в правильном порядке.

Подсказка: Подумайте: сначала придумываем идею, затем добавляем элементы безопасности.

Ответ:

- Придумать фразу или сочетание слов
- Добавить цифры и символы
- Избегать очевидных данных (имя, дата рождения)
- Сохранить только в голове

Шаг 13:

Миссия 13

Расположите шаги восстановления доступа через менеджер паролей.

Подсказка: Обычно процесс идёт от проверки личности до настройки нового мастер-пароля.

Ответ:

- Подтвердить личность (почта или телефон)
- Сбросить старый мастер-пароль
- Придумать новый сильный пароль
- Настроить двухфакторную аутентификацию

Шаг 14:

Миссия 14

Расположите шаги безопасной передачи доступа к рабочему аккаунту через менеджер паролей.

Подсказка: Сначала создаём, потом ограничиваем, а в конце проверяем.

Ответ:

- Создать общий доступ в менеджере паролей
- Выдать доступ только нужному человеку
- Ограничить права доступа
- Проверить журнал действий

Шаг 15:

Миссия 15

Расположите шаги при настройке синхронизации паролей.

Подсказка: Обычно сначала авторизация, потом выбор устройств, а потом проверка безопасности.

Ответ:

- Войти в аккаунт менеджера паролей
- Подключить второе устройство
- Включить шифрованную синхронизацию
- Проверить, что данные обновились на всех устройствах

Шаг 16:

Миссия 16

Расположите шаги защиты ноутбука программиста с установленным менеджером паролей.

Подсказка: Вспомните базовые шаги: сначала физическая защита, затем цифровая.

Ответ:

- Включить пароль на вход в систему
- Установить антивирус
- Настроить двухфакторную аутентификацию
- Регулярно обновлять ОС и приложения

Урок 6 - Проверка e-mail на утечки данных

Шаг 01:

Миссия 1

Разработчик Андрей получил письмо с предложением сменить пароль в GitHub. Какой первый шаг он должен сделать?

Подсказка: Подумай: письма могут быть фишинговыми, важно проверить отправителя.

Ответ:

- Проверить адрес отправителя письма
- Сразу нажать на ссылку и сменить пароль
- Переслать письмо друзьям
- Игнорировать все письма о паролях

Шаг 02:

Миссия 2

У программиста Маши украли пароль от корпоративной почты. Что ей делать в первую очередь?

Подсказка: Всегда важно начать с защиты своей учётки.

Ответ:

- Сменить пароль и включить двухфакторную аутентификацию
- Написать гневный пост в соцсетях
- Удалить всю переписку
- Позвонить в техподдержку конкурентов

Шаг 03:

Миссия 3

Разработчик Иван использует HaveIBeenPwned для проверки своего e-mail. Что он может узнать?

Подсказка: Этот сервис показывает утечки.

Ответ:

- **Сайты, где его данные могли быть скомпрометированы**
- Количество новых сообщений
- Список паролей друзей
- Информацию о налогах

Шаг 04:

Миссия 4

Петя заметил подозрительное письмо с вложением. Как лучше всего проверить его безопасность?

Подсказка: Не открывай файлы сразу.

Ответ:

- **Проверить вложение через антивирус или VirusTotal**
- Открыть файл и посмотреть, что внутри
- Удалить файл, но оставить письмо
- Отправить вложение коллегам для проверки

Шаг 05:

Миссия 5

На почту пришло письмо от банка с просьбой ввести данные карты. Какой признак укажет на фишинг?

Подсказка: Настоящие банки так не просят.

Ответ:

- **Ссылка ведёт на подозрительный домен**
- Сообщение написано без ошибок
- Письмо пришло утром
- У письма есть вложение PDF

Шаг 06:

Миссия 6

Дима проверил свой e-mail и увидел, что его адрес фигурировал в утечке. Что это значит?

Подсказка: Важно понимать последствия утечек.

Ответ:

- **Его данные могли попасть в руки злоумышленников**
- Он автоматически стал администратором сайта
- Его почта теперь быстрее работает
- Это значит, что аккаунт удалён

Шаг 07:

Миссия 7

Разработчик Саша получил письмо от сервиса Slack с просьбой войти в аккаунт. Как проверить подлинность ссылки?

Подсказка: Проверь URL внимательно.

Ответ:

- **Навести курсор на ссылку и проверить домен**
- Сразу ввести логин и пароль
- Скопировать ссылку и отправить другу
- Нажать на ссылку с мобильного

Шаг 08:

Миссия 8

 Задача: сопоставьте термины с их значением.

Подсказка: Подумайте, что именно раскрывают термины.

Ответ:

- **Фишинг** — Обман с целью выманивания данных через поддельные письма
- **Утечка данных** — Несанкционированный доступ и публикация личной информации
- **Спам** — Массовая рассылка нежелательных писем
- **Двухфакторная аутентификация** — Дополнительный уровень защиты при входе

Шаг 09:

Миссия 9

 Задача: сопоставьте тип письма и правильное действие.

Подсказка: Не всегда нужно кликать на ссылки.

Ответ:

- **Подозрительное письмо с ссылкой** — Проверить адрес домена
- **Письмо от незнакомого отправителя** — Не открывать вложения
- **Письмо с банковской просьбой** — Позвонить в банк по официальному номеру
- **Рассылка с купонами** — Игнорировать или проверить через официальный сайт

Шаг 10:

Миссия 10

 Задача: сопоставьте e-mail сервис и его функцию безопасности.

Подсказка: Обрати внимание на особенности сервисов.

Ответ:

- **Gmail** — Фильтрация подозрительных писем
- **Outlook** — Встроенная защита от фишинга
- **Yahoo** — Предупреждения о подозрительной активности
- **ProtonMail** — Шифрование писем по умолчанию

Шаг 11:

Миссия 11

 Задача: сопоставьте инструмент с его назначением.

Подсказка: Эти сервисы помогают в кибербезопасности.

Ответ:

- **HavelBeenPwned** — Проверка e-mail на утечки
- **VirusTotal** — Проверка файлов и ссылок
- **Shodan** — Поиск уязвимых устройств
- **Kali Linux** — Набор инструментов для тестирования безопасности

 Шаг 12:

Миссия 12

 Задача: сопоставьте действие и цель.

Подсказка: Безопасность строится шаг за шагом.

Ответ:

- **Смена пароля** — Снизить риск доступа злоумышленников
- **Проверка e-mail на утечки** — Понять, был ли аккаунт скомпрометирован
- **Включение 2FA** — Добавить второй фактор защиты
- **Удаление подозрительных писем** — Избежать заражения устройства

 Шаг 13:

Миссия 13

Расположите шаги проверки e-mail на утечки в правильном порядке.

Подсказка: Подумай: сначала нужно выбрать сервис, потом ввести e-mail, а в конце — предпринять действия.

Ответ:

- Выбрать сервис проверки (например, HIBP)
- Ввести свой e-mail
- Посмотреть результаты утечек
- Принять меры (сменить пароль, включить 2FA)

 Шаг 14:

Миссия 14

Расположите шаги реакции на письмо от незнакомого отправителя.

Подсказка: Важно проверять источник перед действиями.

Ответ:

- Проверить адрес отправителя
- Не открывать вложения
- Удалить письмо
- Сообщить в службу безопасности

 Шаг 15:

Миссия 15

Расположите действия после обнаружения утечки пароля.

Подсказка: Необходимо менять пароль, включать 2FA и уведомлять службы.

Ответ:

- Сменить пароль
- Включить двухфакторную аутентификацию

- Проверить другие аккаунты
- Сообщить в техподдержку

Шаг 16:

Миссия 16

Расположите шаги при настройке двухфакторной аутентификации.

Подсказка: Обычно сначала включают опцию, потом привязывают устройство.

Ответ:

- Зайти в настройки безопасности
- Выбрать двухфакторную аутентификацию
- Привязать номер телефона или приложение
- Подтвердить настройку

Шаг 17:

Миссия 17

Расположите шаги, если коллега сообщил о подозрительном письме.

Подсказка: Сначала нужно проверить, потом действовать.

Ответ:

- Проверить письмо
- Не переходить по ссылкам
- Сообщить в службу безопасности
- Удалить письмо

Урок 7 - Анализ фишинговых писем (реальные примеры)

Шаг 01:

Миссия 1

Алексей получил письмо с предложением срочно обновить пароль к почте. В письме много восклицательных знаков и ошибок. Что это похоже на?

Подсказка: Подумай, как обычно выглядят официальные письма — там редко пишут с орфографическими ошибками.

Ответ:

- **Фишинговое письмо**
- Официальное письмо от провайдера
- Новостная рассылка
- Письмо от друга

Шаг 02:

Миссия 2

Марина открыла письмо якобы от банка: «Ваша карта будет заблокирована, если вы не перейдете по ссылке». Что настораживает в первую очередь?

Подсказка: Банки не просят вводить данные через случайные ссылки.

Ответ:

- **Требование перейти по ссылке и ввести данные**
- Форматирование текста письма

- Дружелюбное обращение
- Приветствие по имени

Шаг 03:

Миссия 3

Павел получил письмо с вложением «invoice.exe». Что стоит сделать?

Подсказка: Смотри на расширение файла, а не только на его название.

Ответ:

- **Удалить письмо и не открывать вложение**
- Запустить файл, чтобы проверить
- Переслать друзьям для проверки
- Сохранить файл на рабочем столе

Шаг 04:

Миссия 4

Иван заметил, что письмо якобы от GitHub пришло с адреса «github-support@secure-mail.ru». Какой вывод?

Подсказка: Проверь домен отправителя — он должен совпадать с официальным.

Ответ:

- **Письмо поддельное**
- Настоящее письмо от GitHub
- Случайная реклама
- Автоматическое уведомление системы

Шаг 05:

Миссия 5

Ольга открыла письмо: «Поздравляем, вы выиграли iPhone! Чтобы получить, перейдите по ссылке». Что это?

Подсказка: Подумай, кто дарит дорогие призы просто так.

Ответ:

- **Фишинг с целью получить личные данные**
- Акция от магазина
- Личное письмо от знакомого
- Служебная рассылка компании

Шаг 06:

Миссия 6

Сопоставьте подозрительный признак письма с объяснением:

Подсказка: Вспомни, какие элементы чаще всего выдают мошенников.

Ответ:

- **Ошибки в тексте** — Фишеры часто не владеют языком идеально.
- **Срочные угрозы** — Создают панику, чтобы человек не думал.
- **Ссылки на подозрительные сайты** — Адрес отличается от официального домена.
- **Неожиданные вложения** — Часто содержат вирусы.

Шаг 07:

Миссия 7

Сопоставьте тип письма с вероятной целью мошенников:

Подсказка: Задай себе вопрос: зачем злоумышленнику это письмо?

Ответ:

- **Письмо от банка** — Похитить данные карты.
- **Письмо о выигрыше** — Выманить личные данные.
- **Письмо от «службы поддержки»** — Получить логин и пароль.
- **Письмо с вложением** — Заразить компьютер.

Шаг 08:

Миссия 8

Сопоставьте поле письма с тем, на что стоит обратить внимание:

Подсказка: Мошенники часто маскируются под известные бренды, но детали выдают их.

Ответ:

- **Отправитель** — Адрес отличается от официального.
- **Тема письма** — Содержит угрозы или призывы к действию.
- **Текст письма** — Полон ошибок или странных фраз.
- **Ссылки** — Ведут на поддельные сайты.

Шаг 09:

Миссия 9

Сопоставьте действие с его последствием:

Подсказка: Подумай, чем может обернуться неправильный клик.

Ответ:

- **Клик по фишинговой ссылке** — Попадание на поддельный сайт.
- **Ввод данных на поддельном сайте** — Кража логина и пароля.
- **Открытие зараженного вложения** — Инфицирование компьютера.
- **Игнорирование подозрительного письма** — Отсутствие последствий.

Шаг 10:

Миссия 10

Сопоставьте персонажа с тем, как он отреагировал на фишинг:

Подсказка: Люди ведут себя по-разному, но результат очевиден.

Ответ:

- **Алексей** — Удалил письмо и ничего не случилось.
- **Марина** — Ввела данные карты и потеряла деньги.
- **Павел** — Открыл вложение и компьютер заразился.
- **Иван** — Проверил отправителя и избежал атаки.

Шаг 11:

Миссия 11

Сопоставьте технику защиты с её смыслом:

Подсказка: Эти методы помогают вовремя заметить подвох.

Ответ:

- **Проверка отправителя** — Сравнение домена с официальным.
- **Антивирус** — Блокирует вредоносные вложения.
- **Двухфакторная аутентификация** — Даёт дополнительный барьер даже при утечке пароля.
- **Фильтры почты** — Автоматически помещают спам во «Входящие».

Шаг 12:

Миссия 12

Сопоставьте фразу из письма с её типичным признаком:

Подсказка: Настоящие компании редко так выражаются.

Ответ:

- **«Срочно подтвердите пароль!»** — Создание паники.
- **«Вы стали победителем!»** — Подозрительно щедрое предложение.
- **«Ваш аккаунт будет удален завтра»** — Угроза для давления.
- **«Нажмите на ссылку прямо сейчас»** — Призыв к действию без раздумий.

Шаг 13:

Миссия 13

Расположите шаги проверки письма на подлинность в правильном порядке:

Подсказка: Важно идти от внешнего к внутреннему содержанию.

Ответ:

- Проверить адрес отправителя
- Посмотреть текст на ошибки
- Навести курсор на ссылки
- Принять решение об открытии

Шаг 14:

Миссия 14

Расположите действия при получении письма с вложением:

Подсказка: Сначала анализируем источник, потом решение.

Ответ:

- Посмотреть адрес отправителя
- Оценить тип вложения
- Проверить вложение антивирусом
- Открыть или удалить письмо

Шаг 15:

Миссия 15

Расположите шаги реакции при подозрении на фишинг:

Подсказка: Подумай, что важнее — безопасность или любопытство.

Ответ:

- Не переходить по ссылке

- Не вводить данные
- Удалить письмо
- Сообщить в службу поддержки

Шаг 16:

Миссия 16

Расставьте шаги при обучении коллег фишинг-гигиене:

Подсказка: Сначала объясни основы, потом тренировки.

Ответ:

- Объяснить признаки фишинга
- Показать примеры писем
- Провести тестовую рассылку
- Обсудить результаты

Шаг 17:

Миссия 17

Расположите шаги действий при подозрительном письме на работе:

Подсказка: В корпоративной среде важна ответственность.

Ответ:

- Не открывать ссылки
- Сообщить в ИБ-отдел
- Удалить письмо
- Предупредить коллег

Урок 8 - Расследование утечки симуляция инцидента

Шаг 01:

Миссия 1

На почту разработчика Артёма пришло письмо якобы от системного администратора с просьбой срочно обновить пароль. Какой признак первым делом стоит проверить?

Подсказка: Иногда достаточно взглянуть на адрес отправителя.

Ответ:

- **Адрес отправителя и его домен**
- Красивый логотип в письме
- Количество восклицательных знаков
- Дата и время получения

Шаг 02:

Миссия 2

Аналитик Маша открыла письмо от «банка», где её просят ввести данные карты. Что указывает на фишинг?

Подсказка: Настоящие банки никогда не требуют такие данные по e-mail.

Ответ:

- **Запрос данных карты через e-mail**
- **Подозрительная ссылка на сторонний сайт**

- Использование официального названия банка
- Фирменные цвета в письме

Шаг 03:

Миссия 3

Разработчик Никита получил письмо с вложением «invoice.zip». Какое действие наиболее безопасное?

Подсказка: Всегда думайте о вложениях — особенно в архивах.

Ответ:

- **Проверить отправителя и не открывать вложение без уверенности**
- Сразу открыть вложение, чтобы проверить его
- Переслать коллегам для открытия
- Ответить отправителю и спросить, что это

Шаг 04:

Миссия 4

Инженеру Саше пришло письмо с темой «Срочно! Ваша учётная запись будет заблокирована!». Что в этом письме является явным признаком фишинга?

Подсказка: Давление и срочность — любимая техника злоумышленников.

Ответ:

- **Использование паники и срочности**
- Письмо пришло вечером
- В письме есть обращение по имени
- Письмо содержит подпись компании

Шаг 05:

Миссия 5

DevOps-инженер Оля увидела в письме ссылку: http://bank-secure-login.com. Что подозрительно?

Подсказка: Внимательно читайте домены — они часто маскируются.

Ответ:

- **Домен отличается от официального домена банка**
- В ссылке используется слово secure
- Ссылка начинается с http
- Домен содержит английские слова

Шаг 06:

Миссия 6

 Задача: Сопоставьте признаки фишинга с их описанием.

Подсказка: Вспомните, как мошенники маскируются под реальные организации.

Ответ:

- **Спуфинг адреса** — Использование поддельного e-mail, похожего на настоящий
- **Фальшивые ссылки** — Ведут на сайты, маскирующиеся под реальные
- **Срочность** — Давление на получателя для быстрого действия
- **Необычные вложения** — Файлы с расширениями, которые могут быть вредоносными

Шаг 07:

Миссия 7

 Задача: Соотнесите персонажа и его ошибку при обработке подозрительного письма.

Подсказка: Ошибки часто связаны с доверием или спешкой.

Ответ:

- **Артём** — Открыл вложение без проверки
- **Маша** — Перешла по ссылке сразу
- **Саша** — Ответил отправителю и выдал личные данные
- **Оля** — Проигнорировала странный домен

Шаг 08:

Миссия 8

 Задача: Сопоставьте тип атаки с его описанием.

Подсказка: Подумайте о разнице между вложением, ссылкой и телефонным звонком.

Ответ:

- **Phishing** — Мошенническое письмо с ссылкой на поддельный сайт
- **Spear Phishing** — Письмо таргетировано на конкретного сотрудника
- **Whaling** — Атака на топ-менеджеров компании
- **Vishing** — Мошенничество через телефонный звонок

Шаг 09:

Миссия 9

 Задача: Соотнесите действия с их результатами.

Подсказка: Подумайте, что произойдёт после неправильного клика.

Ответ:

- **Клик по фишинговой ссылке** — Попадание на поддельный сайт
- **Ввод пароля на поддельном сайте** — Кража учётных данных
- **Открытие заражённого вложения** — Заражение устройства
- **Игнорирование письма** — Отсутствие последствий

Шаг 10:

Миссия 10

 Задача: Сопоставьте инструмент с его назначением при расследовании фишинга.

Подсказка: У разных инструментов разные роли: кто-то проверяет домен, а кто-то — вложения.

Ответ:

- **WHOIS** — Определяет владельца домена
- **VirusTotal** — Проверяет вложения и ссылки на вирусы
- **PhishTank** — База данных известных фишинговых сайтов
- **E-mail headers** — Позволяют выяснить реальный путь письма

Шаг 11:

Миссия 11

Расположите шаги расследования подозрительного письма в правильном порядке.

Подсказка: Сначала посмотрим письмо, потом проверим ссылки, а уже затем сделаем выводы.

Ответ:

- Проверить заголовки письма
- Проверить ссылки и вложения
- Сравнить домен отправителя
- Сделать вывод о характере письма

Шаг 12:

Миссия 12

Расставьте действия безопасника при обработке инцидента по шагам.

Подсказка: Последовательность всегда начинается с анализа и заканчивается документированием.

Ответ:

- Анализ письма
- Идентификация угрозы
- Уведомление команды
- Документирование инцидента

Шаг 13:

Миссия 13

Расположите в хронологическом порядке типичные действия атакующего при фишинге.

Подсказка: Вспомните, сначала создаётся сайт, потом рассылается письмо.

Ответ:

- Создание поддельного сайта
- Рассылка писем
- Получение данных жертвы
- Использование данных

Шаг 14:

Миссия 14

Расставьте шаги правильной реакции сотрудника при получении подозрительного письма.

Подсказка: Никогда не начинайте с клика — сначала подумайте.

Ответ:

- Не открывать вложения
- Проверить адрес отправителя
- Сообщить в ИБ-отдел
- Удалить письмо

Шаг 15:

Миссия 15

Расположите этапы работы аналитика SOC при расследовании фишингового письма.

Подсказка: Всегда начинаем с наблюдения, а заканчиваем отчётом.

Ответ:

- Получение письма

- Фиксация артефактов
- Анализ угрозы
- Формирование отчёта

Шаг 16:

Миссия 16

Определите правильный порядок шагов при проверке подозрительной ссылки.

Подсказка: Не спешите кликать — сначала посмотрите на адрес.

Ответ:

- Навести курсор и посмотреть адрес
- Проверить домен через WHOIS
- Проверить ссылку на VirusTotal
- Сделать вывод о её надежности

Шаг 17:

Миссия 17

Расположите шаги расследования массовой фишинговой рассылки в компании.

Подсказка: Думайте как безопасник: сначала обнаружение, потом уведомление, и лишь затем реагирование.

Ответ:

- Обнаружение рассылки
- Уведомление сотрудников
- Анализ писем
- Принятие мер по блокировке

Урок 9 - Безопасность онлайн-платежей

Шаг 01:

Миссия 1

Программист Алексей хочет оплатить новый курс по кибербезопасности. Какой самый безопасный способ оплаты он должен выбрать?

Подсказка: Подумайте, какой способ оставляет меньше всего шансов для злоумышленников украсть данные.

Ответ:

- **Оплата через официальное приложение банка с подтверждением в мобильном банке**
- Ввод данных карты на незнакомом сайте
- Передача данных карты через мессенджер
- Сообщение номера карты по телефону незнакомцу

Шаг 02:

Миссия 2

Программист Мария получила письмо с предложением купить новый монитор со скидкой 90%, перейдя по ссылке. Что ей стоит сделать?

Подсказка: Настоящие магазины не присылают ссылки с невероятными скидками.

Ответ:

- **Не переходить по ссылке и удалить письмо**
- Перейти по ссылке и ввести данные карты
- Переслать письмо друзьям для проверки
- Ответить отправителю для уточнения

Шаг 03:

Миссия 3

Разработчик Иван решил оплатить облачный сервис. Что должно насторожить его на странице оплаты?

Подсказка: Иногда сайты маскируются под известные, но есть признаки подделки.

Ответ:

- **Адрес сайта отличается на одну букву от оригинального**
- Сайт имеет HTTPS-соединение
- На странице есть логотип компании
- Сайт открывается быстро

Шаг 04:

Миссия 4

Фрилансер Ольга часто оплачивает зарубежные сервисы. Что поможет ей защитить карту при онлайн-платежах?

Подсказка: Есть специальные инструменты для снижения рисков при оплатах в интернете.

Ответ:

- **Использование виртуальной карты с ограниченным балансом**
- Хранение всех данных карты в текстовом файле
- Оплата только через публичный Wi-Fi
- Сообщение CVV-кода знакомым

Шаг 05:

Миссия 5

Программист Сергей заметил, что при оплате интернет-магазин просит ввести не только номер карты, но и ПИН-код. Что это значит?

Подсказка: Онлайн-магазины никогда не запрашивают некоторые данные.

Ответ:

- **Это мошеннический сайт**
- Это новая функция безопасности
- Это ошибка разработчиков
- Это проверка лояльности клиента

Шаг 06:

Миссия 6

Разработчику Денису пришло SMS о списании денег, хотя он не совершал оплат. Его первые действия?

Подсказка: Главное — заблокировать возможность новых списаний.

Ответ:

- **Сразу связаться с банком и заблокировать карту**
- Ждать, может деньги вернутся сами
- Опубликовать пост в соцсетях
- Игнорировать сообщение

🔗 **Шаг 07:**

Миссия 7

Артем часто платит через интернет-магазины. Какой признак надежного сайта?

Подсказка: Обратите внимание на сертификаты и структуру сайта.

Ответ:

- **Адрес сайта начинается с https:// и есть замочек**
- Сайт просит фото паспорта для подтверждения
- Сайт открывается только в режиме инкогнито
- Сайт имеет яркие баннеры со скидками 99%

🔗 **Шаг 08:**

Миссия 8

Сопоставьте безопасные практики онлайн-платежей с их описаниями.

Подсказка: Вспомните, какие методы снижают риск мошенничества.

Ответ:

- **Двухфакторная аутентификация** — Дополнительное подтверждение входа или платежа через код или приложение
- **Виртуальная карта** — Карта с ограниченным балансом, созданная для онлайн-платежей
- **HTTPS** — Защищенное соединение между пользователем и сайтом
- **Ограничение лимитов** — Установка максимальной суммы на одну транзакцию

🔗 **Шаг 09:**

Миссия 9

Разработчик Андрей хочет быстро проверить, безопасен ли сайт для оплаты. Сопоставьте элементы сайта с их характеристикой.

Подсказка: Важно уметь замечать подделку по мелочам.

Ответ:

- **Подозрительный URL** — Адрес сайта отличается на одну букву
- **Надежный сертификат** — Есть значок замка в адресной строке
- **Поддельный логотип** — Размытая или искаженная картинка бренда
- **Ненадежный метод оплаты** — Требование перевести деньги на личный кошелек

🔗 **Шаг 10:**

Миссия 10

Сопоставьте действия программиста с правильной реакцией при подозрительном платеже.

Подсказка: Правильный порядок действий помогает быстрее остановить мошенников.

Ответ:

- **Получил SMS о списании** — Позвонить в банк и заблокировать карту

- **Обнаружил сайт-клон** — Не вводить данные и закрыть вкладку
- **Получил письмо с подозрительной ссылкой** — Удалить письмо
- **Ввел данные на фишинговом сайте** — Сразу сменить пароль и уведомить банк

Шаг 11:

Миссия 11

Сопоставьте уязвимости при оплате и способы защиты.

Подсказка: Каждой проблеме соответствует метод защиты.

Ответ:

- **Использование публичного Wi-Fi** — Включить VPN
- **Фишинговый сайт** — Проверять URL и сертификат
- **Случайная потеря карты** — Сразу заблокировать карту
- **Мошенническое приложение** — Скачивать только из официальных магазинов

Шаг 12:

Миссия 12

Сопоставьте признаки поддельного сайта с объяснением.

Подсказка: Настоящие сайты редко содержат такие ошибки.

Ответ:

- **Орфографические ошибки** — Сайт содержит грамматические и языковые ошибки
- **Необычные формы оплаты** — Требуется перевод через криптовалюту или кошелек
- **Нет контактов** — Отсутствует телефон или адрес компании
- **Слишком низкие цены** — Цены значительно ниже рыночных

Шаг 13:

Миссия 13

Расположите шаги безопасной оплаты на новом сайте в правильном порядке.

Подсказка: Всегда начинайте с проверки сайта и заканчивайте подтверждением платежа.

Ответ:

- Проверить адрес сайта и наличие https
- Выбрать метод оплаты (виртуальная карта)
- Ввести данные карты
- Подтвердить операцию через SMS или приложение

Шаг 14:

Миссия 14

Расставьте действия программиста при подозрении на кражу данных.

Подсказка: Сначала защита, потом уведомления.

Ответ:

- Заблокировать карту
- Позвонить в банк
- Сменить пароль от онлайн-банка
- Проверить выписку по счету

Шаг 15:

Миссия 15

Определите порядок действий при работе с виртуальной картой.

Подсказка: Сначала создается карта, а в конце — её удаление после использования.

Ответ:

- Создать виртуальную карту
- Пополнить карту на нужную сумму
- Оплатить покупку
- Удалить карту

Шаг 16:

Миссия 16

Расположите шаги безопасной работы с онлайн-банкингом.

Подсказка: Защита устройств важна на старте, проверка — на финише.

Ответ:

- Установить антивирус
- Подключить двухфакторную аутентификацию
- Использовать надежный пароль
- Регулярно проверять транзакции

Урок 10 - Использование временных e-mail и анонимности

Шаг 01:

Миссия 1

Разработчик Петя регистрируется на новом форуме. Ему предлагают ввести e-mail. Какой вариант безопаснее всего использовать?

Подсказка: Временные почтовые сервисы помогают скрыть ваш настоящий ящик.

Ответ:

- **Использовать временный e-mail для регистрации**
- Вводить рабочий e-mail
- Вводить личный e-mail с банка
- Вообще не использовать e-mail

Шаг 02:

Миссия 2

Аня тестирует новый сервис скидок и хочет защитить себя от спама. Какое решение будет оптимальным?

Подсказка: Думайте о разделении рабочих и одноразовых писем.

Ответ:

- **Создать временный e-mail только для этого сервиса**
- Указать почту от работодателя
- Дать e-mail, которым пользуется вся семья
- Вообще отказаться от почты

Шаг 03:

Миссия 3

Программист Дима использует один e-mail для всех проектов. Его почта попала в спам-базу. Что он сделал неправильно?

Подсказка: Безопасники любят говорить про сегментацию и разделение рисков.

Ответ:

- **Использовал один e-mail для всех сервисов**
- Включал двухфакторную аутентификацию
- Применял менеджер паролей
- Менял пароли раз в месяц

Шаг 04:

Миссия 4

Сергей хочет скрыть личность при публикации на хакерском форуме. Что ему стоит использовать вместе с временным e-mail?

Подсказка: Анонимность усиливается, если скрыть ещё и IP-адрес.

Ответ:

- **VPN или TOR вместе с временной почтой**
- Социальную сеть с личными фото
- Только обычный e-mail
- Оставить номер телефона

Шаг 05:

Миссия 5

Разработчику Саше нужно протестировать API, требующее e-mail. Как действовать правильно?

Подсказка: Для тестов лучше использовать одноразовые ресурсы.

Ответ:

- **Создать временный e-mail специально для теста**
- Давать личный e-mail с банковскими данными
- Давать e-mail работодателя
- Вообще отказаться от теста

Шаг 06:

Миссия 6

Сопоставьте виды почты и ситуации, где их лучше использовать.

Подсказка: Важно понимать назначение: временное для тестов, постоянное для работы.

Ответ:

- **Рабочая корпоративная почта** — Для официальных писем внутри компании
- **Временная почта** — Для теста сервиса или разовой регистрации
- **Основная личная почта** — Для переписки с друзьями и близкими
- **Почта для интернет-магазинов** — Для покупок и уведомлений о заказах

Шаг 07:

Миссия 7

Нужно сопоставить сервис и его назначение.

Подсказка: Вспомните популярные сайты для временной почты и анонимности.

Ответ:

- **10minutemail** — Создание временной почты на 10 минут
- **ProtonMail** — Шифрованная защищённая почта
- **TOR** — Анонимизация трафика
- **Mailinator** — Общедоступный временный ящик

Шаг 08:

Миссия 8

Сопоставьте действие и возможный риск.

Подсказка: Подумайте, чем опасно использовать личные данные при анонимных действиях.

Ответ:

- **Указал личный e-mail на форуме** — Риск спама и утечки
- **Использовал временный e-mail** — Меньший риск утечки данных
- **Зашёл без VPN на хакерский форум** — Может раскрыться IP-адрес
- **Указал номер телефона** — Риск целевой атаки

Шаг 09:

Миссия 9

Сопоставьте инструмент и то, как он помогает в анонимности.

Подсказка: Каждый инструмент закрывает свою часть «следов» в интернете.

Ответ:

- **VPN** — Скрывает реальный IP-адрес
- **Временный e-mail** — Защищает от спама и массовых рассылок
- **Менеджер паролей** — Создаёт уникальные сложные пароли
- **TOR** — Перенаправляет трафик через узлы для анонимности

Шаг 10:

Миссия 10

Сопоставьте ошибку и её последствие.

Подсказка: Ошибки часто ведут к утечке данных или раскрытию личности.

Ответ:

- **Использование одного пароля везде** — Повышенный риск взлома
- **Отсутствие временной почты** — Почта перегружена спамом
- **Вход без VPN в публичной Wi-Fi** — Риск перехвата трафика
- **Указание личного имени при анонимном аккаунте** — Легко деанонимизировать

Шаг 11:

Миссия 11

Расположите шаги использования временной почты для регистрации на сайте.

Подсказка: Подумайте: сначала нужен сервис, потом регистрация, затем подтверждение и вход.

Ответ:

- Выбрать сервис временной почты

- Скопировать временный адрес
- Использовать адрес при регистрации
- Получить письмо и подтвердить регистрацию

Шаг 12:

Миссия 12

Расположите шаги защиты анонимности при публикации на форуме.

Подсказка: Сначала защита соединения, потом создание анонимных аккаунтов.

Ответ:

- Включить VPN или TOR
- Создать временный e-mail
- Зарегистрировать анонимный аккаунт
- Опубликовать сообщение

Шаг 13:

Миссия 13

Расположите шаги безопасной работы в публичной сети Wi-Fi.

Подсказка: Важно, чтобы защита соединения включалась сразу.

Ответ:

- Подключиться к VPN
- Подключиться к Wi-Fi
- Открыть браузер
- Использовать временную почту при регистрации

Шаг 14:

Миссия 14

Расположите шаги для тестирования нового API с сохранением анонимности.

Подсказка: Сначала анонимность, потом тест.

Ответ:

- Включить VPN
- Создать временный e-mail
- Использовать e-mail в API-запросе
- Проверить результат

Шаг 15:

Миссия 15

Расположите шаги защиты от спама при регистрации на нескольких сайтах.

Подсказка: Каждый сайт должен иметь свой уникальный e-mail.

Ответ:

- Выбрать разные сервисы временной почты
- Создать уникальные адреса
- Зарегистрироваться на сайтах
- Проверить входящие сообщения

Шаг 16:

Миссия 16

Расположите шаги подготовки анонимного аккаунта для общения в мессенджере.

Подсказка: Анонимность начинается с инфраструктуры, а потом с аккаунта.

Ответ:

- Подключить VPN
- Создать временный e-mail
- Зарегистрировать новый аккаунт в мессенджере
- Начать переписку

Шаг 17:

Миссия 17

Расположите шаги для сохранения анонимности при работе с открытым API.

Подсказка: Важно сначала защитить себя, а потом работать с сервисом.

Ответ:

- Запустить TOR
- Создать временный e-mail
- Выполнить запрос к API
- Проверить результат и удалить почту

Модуль 3 - Продвинутый уровень (PRO)

Урок 1 - Введение в этический взлом и пентест

Шаг 01:

Миссия 1

Ты работаешь стажёром в компании, которая тестирует веб-приложения. Коллега говорит: «Мы не ломаем сайты, а ищем уязвимости законно». Как называется такой подход?

Подсказка: Вспомни, что этическое тестирование безопасности проводится с согласия владельца.

Ответ:

- **Этический взлом (penetration testing)**
- Хакерство без правил
- Социальная инженерия без согласия
- Вирусная атака

Шаг 02:

Миссия 2

Анна готовит отчёт по пентесту и спорит с коллегой: нужно ли включать найденные уязвимости с низким уровнем риска? Что правильнее?

Подсказка: Даже мелкие уязвимости могут привести к цепочке атак.

Ответ:

- **Да, включать все уязвимости**
- Нет, только критические
- Включать только если клиент попросил

- Только уязвимости средней опасности

🔮 Шаг 03:

Миссия 3

Тебе поручили тестировать форму входа. Какой первый шаг корректного пентеста?

Подсказка: Прежде чем атаковать, нужно чётко договориться об условиях.

Ответ:

- **Получить письменное разрешение от заказчика**
- Сразу пробовать SQL-инъекции
- Сканировать порты без уведомления
- Использовать фишинг для теста

🔮 Шаг 04:

Миссия 4

Во время теста один из сотрудников компании случайно узнал твой план атаки. Что нужно сделать?

Подсказка: Этика требует прозрачности и коммуникации с заказчиком.

Ответ:

- **Сообщить ответственному лицу заказчика**
- Игнорировать и продолжать тест
- Изменить тактику молча
- Прекратить проект без объяснения

🔮 Шаг 05:

Миссия 5

Сопоставьте виды хакеров с их характеристиками.

Подсказка: Вспомни про белых, серых и чёрных шляп.

Ответ:

- **Белые шляпы** — Работают с согласия компаний для поиска уязвимостей
- **Чёрные шляпы** — Используют уязвимости для личной выгоды
- **Серые шляпы** — Могут действовать без разрешения, но раскрывают уязвимость публично
- **Синие команды** — Обороняются от атак, анализируют журналы и инциденты

🔮 Шаг 06:

Миссия 6

Сопоставьте этапы пентеста с их задачами.

Подсказка: Каждый этап — часть методологии тестирования.

Ответ:

- **Разведка** — Сбор информации об инфраструктуре
- **Сканирование** — Поиск открытых портов и сервисов
- **Эксплуатация** — Попытка использовать найденные уязвимости
- **Отчётность** — Описание уязвимостей и рекомендации по исправлению

🔮 Шаг 07:

Миссия 7

Сопоставьте инструменты с их назначением в пентесте.

Подсказка: Вспомни, чем отличается сканирование от эксплуатации.

Ответ:

- **Nmap** — Сканирование портов
- **Metasploit** — Эксплуатация уязвимостей
- **Burp Suite** — Перехват и анализ HTTP-трафика
- **Wireshark** — Анализ сетевых пакетов

🔮 Шаг 08:

Миссия 8

Сопоставьте типы уязвимостей с примерами.

Подсказка: SQL-инъекция отличается от XSS.

Ответ:

- **SQL-инъекция** — Ввод кода в поля формы для доступа к базе данных
- **XSS** — Внедрение скрипта в веб-страницу
- **Brute force** — Подбор пароля методом перебора
- **CSRF** — Запрос от лица пользователя без его ведома

🔮 Шаг 09:

Миссия 9

Сопоставьте команды безопасности с их ролями.

Подсказка: Красные атакуют, синие защищают.

Ответ:

- **Red Team** — Имитирует атаки
- **Blue Team** — Обороняется и реагирует
- **Purple Team** — Сотрудничает между атакующими и защитой
- **SOC** — Мониторинг и реагирование на инциденты

🔮 Шаг 10:

Миссия 10

Сопоставьте протоколы с их уязвимостями.

Подсказка: Некоторые протоколы старые и небезопасные.

Ответ:

- **HTTP** — Передача данных без шифрования
- **FTP** — Пароли передаются открытым текстом
- **Telnet** — Нет защиты от перехвата сессии
- **HTTPS** — Использует TLS для защиты

🔮 Шаг 11:

Миссия 11

Расположите шаги пентеста в правильном порядке.

Подсказка: Сначала разведка, потом атака, в конце отчёт.

Ответ:

- Разведка
- Сканирование
- Эксплуатация
- Отчётность

Шаг 12:

Миссия 12

Расположите действия при обнаружении критической уязвимости.

Подсказка: Этичный специалист обязан уведомить заказчика.

Ответ:

- Задokumentировать уязвимость
- Сообщить заказчику
- Предложить варианты исправления
- Подтвердить устранение

Шаг 13:

Миссия 13

Расположите этапы атаки социальной инженерии.

Подсказка: Сначала идёт подготовка, затем взаимодействие с жертвой.

Ответ:

- Сбор информации
- Установление доверия
- Манипуляция
- Получение доступа

Шаг 14:

Миссия 14

Расставьте шаги работы с Metasploit при эксплуатации уязвимости.

Подсказка: Сначала выбирают модуль, в конце — получают доступ.

Ответ:

- Выбор модуля
- Настройка параметров
- Запуск атаки
- Получение сессии

Шаг 15:

Миссия 15

Расположите этапы построения отчёта по пентесту.

Подсказка: Отчёт должен быть понятен и руководству, и разработчикам.

Ответ:

- Сводка для руководства
- Описание методики

- Перечень уязвимостей
- Рекомендации по исправлению

🔮 Шаг 16:

Миссия 16

Расположите действия при работе с клиентом перед началом пентеста.

Подсказка: Нельзя атаковать без согласия и чётких условий.

Ответ:

- Заключить договор
- Согласовать цели
- Определить границы теста
- Получить письменное разрешение

📖 Урок 2 - Основы OSINT легальная разведка

🔮 Шаг 01:

Миссия 1

Ты работаешь в стартапе, и команда просит тебя проверить, какие данные о компании уже доступны в интернете. С чего стоит начать в OSINT?

Подсказка: Начинать с самых общих и открытых источников, а не с хакерских трюков.

Ответ:

- **Поиск в Google и социальных сетях**
- Попытка подобрать пароли к почте
- Запуск сканера портов на сервере
- Взлом Wi-Fi соседнего офиса

🔮 Шаг 02:

Миссия 2

Программист Игорь заметил, что кто-то создаёт фейковый аккаунт с его фото. Какой инструмент OSINT поможет ему проверить, где ещё используется эта фотография?

Подсказка: Подумай о сервисах, которые находят копии изображений в интернете.

Ответ:

- **Поиск по картинке (Google Images, TinEye)**
- Калькулятор хэшей MD5
- VPN-сервис
- Блокнот с заметками

🔮 Шаг 03:

Миссия 3

Безопасник Оля проверяет поддельное письмо, которое якобы пришло от её банка. Какой OSINT-приём поможет ей первым делом?

Подсказка: В почте есть скрытые заголовки, в которых содержатся полезные следы.

Ответ:

- **Изучение заголовков письма (headers)**
- Удаление письма без анализа

- Скачивание вложений
- Открытие ссылки сразу

🔗 Шаг 04:

Миссия 4

Ты проверяешь информацию о старом домене, связанном с твоим проектом. Какой сервис OSINT стоит использовать?

Подсказка: Подумай про сервис, который хранит историю регистрации доменов.

Ответ:

- **WHOIS-запросы**
- Форумы геймеров
- Почтовый клиент
- Фоторедактор

🔗 Шаг 05:

Миссия 5

Разработчик Артём хочет понять, какие сервисы его компании доступны в интернете. Что будет первым шагом OSINT?

Подсказка: Начни с того, что открыто видно для всех.

Ответ:

- **Поиск в Shodan**
- Сбор паролей сотрудников
- Звонки в техподдержку конкурентов
- Сканирование жёсткого диска дома

🔗 Шаг 06:

Миссия 6

Фрилансер Анна получила странное сообщение в LinkedIn. Какой OSINT-шаг поможет ей проверить личность отправителя?

Подсказка: Проверь, существует ли этот человек и где ещё он оставил следы.

Ответ:

- **Поиск профилей по email или имени**
- Скачивание его резюме
- Перепроверка его GitHub
- Отправка своих паспортных данных

🔗 Шаг 07:

Миссия 7

Ты проверяешь подозрительную ссылку. Какой OSINT-инструмент поможет увидеть, как сайт выглядел раньше?

Подсказка: Есть сервис-архив, который хранит снимки сайтов за годы.

Ответ:

- **Wayback Machine**
- Таблицы Excel
- Редактор кода

- Эмулятор Android

🔗 Шаг 08:

Миссия 8

Программист Саша хочет убедиться, что его утечки данных нет в даркнете. Какой сервис поможет ему проверить утечку пароля?

Подсказка: Есть публичные базы, где можно проверить email.

Ответ:

- **Have I Been Pwned**
- Reddit
- WordPress
- Telegram-бот с котиками

🔗 Шаг 09:

Миссия 9

📄 Сопоставьте OSINT-инструменты с их назначением.

Подсказка: Вспомни: Shodan — про устройства, WHOIS — про домены, TinEye — про фото.

Ответ:

- **Shodan** — Поиск открытых сервисов и устройств
- **WHOIS** — Информация о домене и его владельце
- **TinEye** — Поиск изображений по картинке
- **Wayback Machine** — История изменения сайта

🔗 Шаг 10:

Миссия 10

Сопоставьте источник OSINT с примером данных.

Подсказка: Соцсети — фото и посты, WHOIS — домены, Google Maps — геолокация.

Ответ:

- **Социальные сети** — Фотографии и посты пользователей
- **WHOIS** — Дата регистрации домена
- **Google Maps** — Фото зданий и улиц
- **Have I Been Pwned** — Информация об утечке пароля

🔗 Шаг 11:

Миссия 11

Сопоставьте задачу программиста с OSINT-инструментом.

Подсказка: Для фото — TinEye, для утечек — HIBP, для сайтов — Wayback.

Ответ:

- **Проверить фото профиля** — TinEye
- **Проверить сайт на старые версии** — Wayback Machine
- **Проверить email на утечку** — Have I Been Pwned
- **Проверить сервер на доступность извне** — Shodan

Шаг 12:

Миссия 12

Сопоставьте OSINT-метод с примером использования.

Подсказка: Анализ соцсетей — для связей, анализ DNS — для сайтов.

Ответ:

- **Анализ соцсетей** — Поиск друзей и коллег человека
- **Анализ DNS** — Проверка IP-адреса и поддоменов
- **Поиск по картинке** — Найти дубликаты фото
- **Проверка архива сайта** — Посмотреть старые страницы

Шаг 13:

Миссия 13

Сопоставьте OSINT-цель с правильным источником.

Подсказка: Утечки ищем в базах, домены — в WHOIS, локацию — в картах.

Ответ:

- **Найти местоположение офиса** — Google Maps
- **Проверить владельца домена** — WHOIS
- **Проверить утечки паролей** — Have I Been Pwned
- **Найти копии фото** — TinEye

Шаг 14:

Миссия 14

Расположи шаги OSINT-анализа профиля в правильном порядке:

Подсказка: Сначала ищем открытые данные, потом проверяем фото, затем проверяем контакты и связи.

Ответ:

- Найти открытые профили в соцсетях
- Проверить фото профиля через TinEye
- Сопоставить контакты и email
- Построить карту связей человека

Шаг 15:

Миссия 15

Расположи шаги проверки подозрительного домена:

Подсказка: Сначала WHOIS, потом DNS, потом Wayback, затем проверка в базах угроз.

Ответ:

- Проверка WHOIS
- Проверка DNS-записей
- Просмотр Wayback Machine
- Проверка в базе фишинговых сайтов

Шаг 16:

Миссия 16

Упорядочь шаги поиска человека по email:

Подсказка: Сначала ищем в утечках, затем проверяем соцсети, потом фото, потом связи.

Ответ:

- Проверка email в Have I Been Pwned
- Поиск профилей по email
- Поиск фото через TinEye
- Сопоставление друзей и коллег

Урок 3 - Поиск уязвимостей в открытых источниках

Шаг 01:

Миссия 1

Алексей — программист в стартапе. Он заметил подозрительную панель администратора, доступную по адресу /admin. Какой первый шаг в рамках OSINT?

Подсказка: Подумайте: прежде чем атаковать, нужно убедиться, что информация действительно общедоступна.

Ответ:

- **Проверить доступность страницы через браузер и сохранить заголовки ответа**
- Сразу попробовать ввести логин и пароль
- Начать сканировать сайт агрессивными утилитами
- Отправить запросы на все возможные URL

Шаг 02:

Миссия 2

Наталья ищет уязвимости в коде GitHub-репозитория компании. Что она должна сделать в первую очередь?

Подсказка: Иногда пароли и ключи разработчики оставляют прямо в коде.

Ответ:

- **Проверить файлы на наличие API-ключей и паролей**
- Сразу скачать весь репозиторий и запускать скрипты
- Игнорировать конфигурационные файлы
- Менять код для проверки уязвимостей

Шаг 03:

Миссия 3

Дмитрий проверяет, какие данные о компании видны в соцсетях. Что может дать ему наибольшую ценность в OSINT?

Подсказка: Иногда сотрудники сами рассказывают лишнее.

Ответ:

- **Посты сотрудников о работе и скриншоты экрана**
- Официальные рекламные публикации
- Комментарии конкурентов
- Старые новости СМИ

Шаг 04:

Миссия 4

Инженер Сергей анализирует метаданные фотографий на сайте компании. Что чаще всего можно найти в EXIF-данных?

Подсказка: Иногда фотографии забывают удалить «скрытую» информацию.

Ответ:

- **GPS-координаты и модель устройства**
- Пароли от Wi-Fi
- Исходный код сайта
- Историю переписки сотрудников

Шаг 05:

Миссия 5

Программист Илья нашёл список поддоменов через сервис crt.sh. Какое следующее действие для поиска уязвимостей?

Подсказка: Иногда забытые поддомены оказываются «слабым звеном».

Ответ:

- **Проверить активность поддоменов и доступные сервисы**
- Сразу отправить SQL-инъекцию на каждый
- Удалить список как ненужный
- Передать список в HR-отдел

Шаг 06:

Миссия 6

 Задача: Сопоставьте открытые источники с типами уязвимостей, которые там можно найти.

Подсказка: Подумайте, где чаще всего «утекают» ключи, пароли или структура сети.

Ответ:

- **GitHub** — Утечки паролей и ключей API
- **LinkedIn** — Информация о структуре компании
- **Shodan** — Список открытых портов и сервисов
- **Pastebin** — Выложенные базы данных или конфиги

Шаг 07:

Миссия 7

 Задача: Сопоставьте OSINT-инструмент с его назначением.

Подсказка: Каждый инструмент имеет узкую специализацию.

Ответ:

- **theHarvester** — Сбор email и поддоменов
- **Maltego** — Визуализация связей и объектов
- **Censys** — Поиск уязвимых устройств и сертификатов
- **Google Dorks** — Поиск скрытых страниц и файлов

Шаг 08:

Миссия 8

 Задача: Сопоставьте действие безопасника с возможной находкой.

Подсказка: Одни действия связаны с анализом людей, другие — с инфраструктурой.

Ответ:

- **Анализ фотографий сотрудников** — Выявление местоположения офиса
- **Поиск в старых бэкапах сайта** — Уязвимые версии CMS
- **Сбор e-mail через WHOIS** — Контакты администраторов
- **Мониторинг Pastebin** — Случайные утечки базы данных

Шаг 09:

Миссия 9

 Сопоставьте термин OSINT с его определением.

Подсказка: Обратите внимание на то, что OSINT — это всегда про легальный сбор.

Ответ:

- **OSINT** — Сбор информации из открытых источников
- **Footprinting** — Систематический сбор данных об инфраструктуре
- **Social engineering** — Манипуляция людьми для получения данных
- **Recon-ng** — Инструмент для автоматизации разведки

Шаг 10:

Миссия 10

 Задача: Сопоставьте уязвимость и её источник.

Подсказка: Где-то опасны метаданные, где-то — лишние логи.

Ответ:

- **Сканы документов в PDF** — Видны имена сотрудников и версии ПО
- **Лог веб-сервера** — Ошибки и IP-адреса
- **Старый форум компании** — Учётные записи и пароли
- **DNS-записи** — Поддомены и почтовые серверы

Шаг 11:

Миссия 11

Расположите шаги OSINT-исследования в правильном порядке:

Подсказка: Начинаем с общего, затем углубляемся, и только потом анализируем детали.

Ответ:

- Определить цель исследования
- Собрать общедоступные данные
- Проанализировать полученные сведения
- Составить отчёт об уязвимостях

Шаг 12:

Миссия 12

Расставьте действия программиста Ивана при проверке сайта на уязвимости через OSINT.

Подсказка: Представьте, что сначала мы ищем следы, потом смотрим глубже.

Ответ:

- Поиск домена в поисковиках
- Анализ поддоменов
- Проверка метаданных файлов

- Документирование уязвимостей

Шаг 13:

Миссия 13

Поставьте в правильный порядок этапы анализа социальной инженерии в OSINT.

Подсказка: Начинаем с поиска людей, затем анализируем их поведение.

Ответ:

- Поиск аккаунтов сотрудников
- Изучение их постов и фото
- Выявление потенциальных рисков
- Доклад команде безопасности

Шаг 14:

Миссия 14

Определите порядок действий при анализе DNS-записей компании.

Подсказка: Обычно начинают с базовых записей, потом углубляются.

Ответ:

- Проверка A-записей
- Анализ MX-записей
- Поиск TXT/SPF-записей
- Составление карты инфраструктуры

Шаг 15:

Миссия 15

Расставьте шаги работы с Shodan для поиска уязвимых сервисов.

Подсказка: Важно сначала настроить фильтры, потом анализировать результаты.

Ответ:

- Ввести запрос с фильтрами
- Просмотреть найденные устройства
- Выявить уязвимые версии ПО
- Составить отчёт для компании

Шаг 16:

Миссия 16

Определите порядок поиска конфиденциальной информации через Google Dorks.

Подсказка: Сначала общие запросы, потом уточнение фильтрами.

Ответ:

- Составить базовый запрос
- Использовать операторы site: и filetype:
- Проанализировать найденные файлы
- Составить рекомендации

Шаг 17:

Миссия 17

Расставьте в правильном порядке шаги при анализе GitHub-репозитория компании.

Подсказка: Всегда начинаем с поиска конфиденциального, потом идём глубже.

Ответ:

- Проверить конфигурационные файлы
- Найти случайные токены и ключи
- Проанализировать историю коммитов
- Документировать найденные уязвимости

Урок 4 - Сканирование портов и служб (nmap)

Шаг 01:

Миссия 1

Артём готовится к первому сканированию своей тестовой виртуалки. Какой параметр nmap позволит быстро проверить доступные хосты в сети без глубокого анализа?

Подсказка: Этот режим часто используют для быстрой проверки живых IP-адресов.

Ответ:

- **-sn**
- -sV
- -O
- -p

Шаг 02:

Миссия 2

Марина сканирует сервер компании и хочет узнать версии сервисов, которые работают на открытых портах. Какой ключ nmap стоит использовать?

Подсказка: Этот режим помогает определить версию SSH, Apache и других сервисов.

Ответ:

- -sn
- **-sV**
- -O
- -A

Шаг 03:

Миссия 3

Вася хочет проверить операционную систему удалённого сервера. Какой ключ nmap подходит для этого?

Подсказка: Этот параметр использует TCP/IP отпечатки.

Ответ:

- -sV
- **-O**
- -sS
- -Pn

Шаг 04:

Миссия 4

Программист Дима запускает nmap без прав администратора и замечает, что часть результатов недоступна. Какие сканы требуют root-доступа?

Подсказка: Подумай о SYN-сканах.

Ответ:

- **SYN scan (-sS)**
- **Idle scan (-sI)**
- Connect scan (-sT)
- Version detection (-sV)

Шаг 05:

Миссия 5

Тимур хочет ускорить сканирование огромной подсети. Какой параметр nmap позволит увеличить скорость за счёт многопоточности?

Подсказка: Этот параметр отвечает за интенсивность сканирования.

Ответ:

- -O
- -sS
- **-T4**
- -Pn

Шаг 06:

Миссия 6

Саша обнаружил, что фаервол скрывает ICMP-ответы. Какой параметр поможет nmap не использовать пинг-проверку перед сканированием?

Подсказка: Сканирование без пинга.

Ответ:

- **-Pn**
- -T0
- -sU
- -sC

Шаг 07:

Миссия 7

Инженер Лена хочет просканировать только порты 22, 80 и 443. Как правильно задать диапазон?

Подсказка: Используй параметр -p.

Ответ:

- **-p 22,80,443**
- -ports 22 80 443
- -scan 22 80 443
- -f 22,80,443

Шаг 08:

Миссия 8

 Сопоставьте ключ nmap с его функцией:

Подсказка: Вспомни, что **-sS** используется чаще всего при тестах безопасности.

Ответ:

- **-sS** — SYN scan
- **-sT** — TCP connect scan
- **-sU** — UDP scan
- **-sV** — Определение версии сервисов

Шаг 09:

Миссия 9

 Сопоставьте протокол с примером порта:

Подсказка: Подумай о стандартных номерах: SSH=22, HTTP=80.

Ответ:

- **SSH** — 22
- **HTTP** — 80
- **HTTPS** — 443
- **DNS** — 53

Шаг 10:

Миссия 10

 Сопоставьте тип сканирования с его описанием:

Подсказка: UDP работает медленнее, чем TCP.

Ответ:

- **SYN scan** — Быстрое и скрытное сканирование
- **TCP connect scan** — Требуется полного соединения
- **UDP scan** — Определяет открытые UDP-порты
- **Ping scan** — Проверка доступности хоста

Шаг 11:

Миссия 11

 Сопоставьте параметры nmap с их назначением:

Подсказка: **-O** используется для ОС.

Ответ:

- **-O** — Определение ОС
- **-A** — Агрессивное сканирование
- **-Pn** — Пропуск ICMP ping
- **-T4** — Ускоренное сканирование

Шаг 12:

Миссия 12

 Сопоставьте сервисы с их описанием:

Подсказка: Вспомни, что MySQL — это база данных.

Ответ:

- **Apache** — Веб-сервер
- **MySQL** — База данных

- **OpenSSH** — Удалённый доступ
- **Bind** — DNS-сервер

Шаг 13:

Миссия 13

Расположите шаги сканирования в правильном порядке:

Подсказка: Сначала проверяют, жив ли хост, потом идут глубже.

Ответ:

- Ping scan
- Port scan
- Service version detection
- OS detection

Шаг 14:

Миссия 14

Упорядочьте профили скорости nmap от самого медленного к самому быстрому:

Подсказка: Они обозначаются T0...T5.

Ответ:

- T0
- T1
- T3
- T5

Шаг 15:

Миссия 15

Расположите шаги подготовки безопасника перед сканированием:

Подсказка: Сначала нужно согласовать, потом тестировать.

Ответ:

- Получение разрешения
- Определение диапазона IP
- Выбор типа сканирования
- Запуск nmap

Шаг 16:

Миссия 16

Расположите этапы анализа после сканирования:

Подсказка: Сначала нужно собрать, потом фильтровать.

Ответ:

- Сбор результатов
- Фильтрация ненужного
- Поиск уязвимостей
- Доклад команде

Шаг 17:

Миссия 17

Расположите команды по сложности выполнения:

Подсказка: Пинг проще, чем агрессивное сканирование.

Ответ:

- nmap -sn 192.168.1.0/24
- nmap -sS 192.168.1.10
- nmap -sV -O 192.168.1.10
- nmap -A 192.168.1.10

Урок 5 - Анализ вредоносных ссылок и вложений

Шаг 01:

Миссия 1

Вы получили письмо от коллеги с вложением «invoice.pdf.exe». Что вы сделаете?

Подсказка: Обратите внимание на двойное расширение и неожиданный отправитель.

Ответ:

- Открыть файл, чтобы посмотреть, что внутри
- **Не открывать, проверить отправителя и провести антивирусный анализ**
- Ответить отправителю с просьбой прислать другой формат
- Удалить письмо сразу без проверки

Шаг 02:

Миссия 2

Расположите шаги проверки подозрительной ссылки в корректном порядке:

1. Сравнение домена с официальным сайтом проекта
2. Проверка URL через репутационные сервисы (VirusTotal и др.)
3. Анализ сертификата SSL и шифрования соединения
4. Проверка содержания после перехода в песочнице

Подсказка: Подумайте, что можно сделать без риска прежде, чем переходить по ссылке и что на последнем этапе — безопасное тестирование.

Ответ:

- Сравнение домена с официальным сайтом проекта
- Проверка URL через репутационные сервисы (VirusTotal и др.)
- Анализ сертификата SSL и шифрования соединения
- Проверка содержания после перехода в песочнице

Шаг 03:

Миссия 3

 Сопоставьте термины проверки вложений с их описаниями.

Термины:

Ответ:

- Песочница (sandbox)
- Статический анализ кода

- Эмулятор PDF
- Этапы карантина

Описание:

1. Создание безопасной среды для запуска файла без вреда основному компьютеру.
2. Изучение структуры файла без его исполнения.
3. Имитация поведения PDF в изолированном режиме.
4. Изоляция и блокировка подозрительных файлов перед окончательным решением.

Подсказка: Обратите внимание: один термин связан с безопасной средой, другой — с исследованием без запуска.

- **Песочница (sandbox)** — Создание безопасной среды для запуска файла без вреда основному компьютеру.
- **Статический анализ кода** — Изучение структуры файла без его исполнения.
- **Эмулятор PDF** — Имитация поведения PDF в изолированном режиме.
- **Этапы карантина** — Изоляция и блокировка подозрительных файлов перед окончательным решением.

Шаг 04:

Миссия 4

Ваш коллега прислал ссылку: <http://example-secure.com/login>. Но уведомление сервиса прислали с домена `examp1e-secure.com`. Какое решение вы примете?

Подсказка: Маленькая замена буквы часто используется физингом.

Ответ:

- **Не переходить, уведомить коллегу и проверить оригинал домена**
- Открыть ссылку, если выглядит безопасно
- Игнорировать домен, ведь URL похож
- Ответить отправителю и спросить, зачем он прислал ссылку

Шаг 05:

Миссия 5

Расположите методы защиты от вредоносных вложений по эффективности (от базового к продвинутому):

1. Антивирусное сканирование
2. Фильтрация расширений на почтовом сервере
Сканирование в песочнице
3. Анализ поведения при открытии вложения

Подсказка: Начните с простых мер — затем усложняйте до динамического анализа.

Ответ:

- Антивирусное сканирование
- Фильтрация расширений на почтовом сервере
- Сканирование в песочнице
- Анализ поведения при открытии вложения

Шаг 06:

Миссия 6

 Сопоставьте признаки ссылки с их уязвимостями.

Признаки:

Ответ:

- Неожиданный поддомен
- Короткая ссылка (bit.ly)
- Подмена символов в домене
- Неподходящий протокол (http вместо https)

Уязвимости / риск:

1. Фишинг, маскировка основного домена
2. Скрытие фактического адреса целевой страницы
3. Подставной домен, похожий на оригинал
4. Отсутствие шифрования или защита отсутствует

Подсказка: Подумайте, какой риск несёт каждая аномалия — маскировка, шифрование, скрытость.

- **Неожиданный поддомен** — Фишинг, маскировка основного домена
- **Короткая ссылка (bit.ly)** — Скрытие фактического адреса целевой страницы
- **Подмена символов в домене** — Подставной домен, похожий на оригинал
- **Неподходящий протокол (http вместо https)** — Отсутствие шифрования или защита отсутствует

Шаг 07:

Миссия 7

Во время анализа вложения .docx вы замечаете макросы, активированные по умолчанию. Как вы поступите?

Подсказка: Макросы часто используются для внедрения кода.

Ответ:

- **Разрешить выполнение макросов** — может быть безопасно
- **Отключить макросы и проверить файл осторожно**
- Игнорировать макросы и читать текст документа
- Скопировать документ в текстовый редактор и попытаться удалить макрос

Шаг 08:

Миссия 8

Расположите этапы реагирования на полученное подозрительное вложение:

1. Изоляция почтового ящика и отключение от сети
2. Скопирование файла в изолированную среду
3. Обработка копии в песочнице или тестовой среде
4. Отчёт о находке и уведомление ИБ-команды

Подсказка: Сначала минимизируйте ущерб, затем анализируйте, и затем сообщите о проблеме.

Ответ:

- Изоляция почтового ящика и отключение от сети
- Скопирование файла в изолированную среду
- Обработка копии в песочнице или тестовой среде
- Отчёт о находке и уведомление ИБ-команды

Шаг 09:

Миссия 9

 Сопоставьте типы вложений с потенциальным риском.

Типы вложений:

Ответ:

- .exe
- .zip
- .docm
- .js

Риск:

1. Прямое исполнение вредоносного кода
2. Сжатый контейнер, может содержать зловредный файл
3. Документ с макросом внутри
4. Сценарий JavaScript, выполняющий команды

Подсказка: Подумайте, какой формат сам по себе исполняется, а какой — оболочка.

- **.exe** — Прямое исполнение вредоносного кода
- **.zip** — Сжатый контейнер, может содержать зловредный файл
- **.docm** — Документ с макросом внутри
- **.js** — Сценарий JavaScript, выполняющий команды

Шаг 10:

Миссия 10

Расположите уровни проверки вложений (от базового к комплексному):

1. Сигнатурное антивирусное сканирование
2. Анализ на уровне поведения (динамический)
3. Эмуляция / песочница
4. Анализ метаданных и геш-контроль

Подсказка: Некоторые проверки статичны, некоторые — динамичны; начните с простых, закончите сложным.

Ответ:

- Сигнатурное антивирусное сканирование
- Анализ на уровне поведения (динамический)
- Эмуляция / песочница
- Анализ метаданных и геш-контроль

Шаг 11:

Миссия 11

 Сопоставьте этапы анализа вредоносной ссылки с используемыми инструментами.

Этап:

Ответ:

- Обратный DNS и WHOIS
- Проверка URL-баз в VirusTotal
- Скриншот сайта через сервис визуализации

- Поведенческий анализ после перехода

Инструменты / метод:

1. whois, dig
2. VirusTotal API
3. Сервисы визуализации страниц (например, URLScan)
4. Песочница / браузер в изоляции

Подсказка: Первый шаг — узнать, кому принадлежит домен; затем — проверка по базам; затем визуализация и динамика.

- **Обратный DNS и WHOIS** — whois, dig
- **Проверка URL-баз в VirusTotal** — VirusTotal API
- **Скриншот сайта через сервис визуализации** — Сервисы визуализации страниц (например, URLScan)
- **Поведенческий анализ после перехода** — Песочница / браузер в изоляции

Шаг 12:

Миссия 12

Вы анализируете ссылку, и Whois показывает, что домен зарегистрирован вчера на скрытую личность. Это признак...

Подсказка: Новые домены часто используются злоумышленниками.

Ответ:

- **Высокого риска** — возможно фишинг-ссылка
- **Низкого риска** — обычная ссылка
- **Это безопасно** — регистрация домена ничего не значит
- Нужно проверить дальше, но скорее всего безопасно

Шаг 13:

Миссия 13

Расположите шаги анализа вложения .xlsm (с макросом) в безопасном порядке:

1. Извлечение макроса без исполнения
2. Статический анализ макроса (VBA-код)
3. Символьный реверсинг макроса
4. Запуск макроса в полностью изолированном окружении

Подсказка: Не запускайте макрос сразу — сначала изучите код и только потом — в безопасной среде.

Ответ:

- Извлечение макроса без исполнения
- Статический анализ макроса (VBA-код)
- Символьный реверсинг макроса
- Запуск макроса в полностью изолированном окружении

Шаг 14:

Миссия 14

 Сопоставьте методы защиты почты с их назначением.

Метод:

Ответ:

- DMARC
- SPF
- DKIM
- Антивирусное сканирование на уровне шлюза

Назначение:

1. Подтверждение отправителя домена
2. Проверка подписи письма
3. Разрешение сервера отправителя
4. Сканирование вложений до доставки

Подсказка: SPF — проверка отправителя, DKIM — цифровая подпись, DMARC — политика, шлюз — проверка вложений.

- **DMARC** — Подтверждение отправителя домена
- **SPF** — Разрешение сервера отправителя
- **DKIM** — Проверка подписи письма
- **Антивирусное сканирование на уровне шлюза** — Сканирование вложений до доставки

 Шаг 15:

Миссия 15

В ходе анализа файла .pdf вы обнаружили встроенный JavaScript, запускаемый при открытии. Ваш шаг?

Подсказка: PDF с JavaScript — часто способ внедрения скрытого кода.

Ответ:

- **Блокировать выполнение JavaScript, исследовать структуру PDF**
- **Рискнуть и открыть** — может быть безопасно
- Удалить весь файл сразу
- Открыть на другом компьютере без анализа

 Шаг 16:

Миссия 16

Расположите шаги комплексного расследования подозрительной рассылки (link + attachment):

1. Сбор метаданных письма (заголовки, путь доставки)
2. Анализ домена ссылки через WHOIS / репутации
3. Проверка вложения через антивирус и песочницу
4. Комбинированный корреляционный анализ логов и событий

Подсказка: Сначала данные письма, затем ссылку, затем вложение, и только потом связывайте всё вместе в аналитическом отчёте.

Ответ:

- Сбор метаданных письма (заголовки, путь доставки)
- Анализ домена ссылки через WHOIS / репутации
- Проверка вложения через антивирус и песочницу
- Комбинированный корреляционный анализ логов и событий

Урок 6 - Kali Linux настройка безопасной среды

Шаг 01:

Миссия 1

Вы, начинающий пентестер, установили Kali Linux и хотите включить автоматические обновления. Какой пакет вы используете для управления пакетами в Kali?

Подсказка: Kali — это дистрибутив на базе Debian.

Ответ:

- **apt**
- yum
- dnf
- pacman

Шаг 02:

Миссия 2

Вы хотите установить метапакет безопасности (например, tools) из репозитория. Какая команда правильно выполнит обновление списка пакетов перед установкой?

Подсказка: Обновление списка — «update».

Ответ:

- **sudo apt update**
- sudo apt upgrade
- sudo apt install update
- sudo apt-get clean

Шаг 03:

Миссия 3

После обновления вы хотите установить пакет для анализа трафика (например, Wireshark). Какая команда наиболее подходящая?

Подсказка: используйте apt и флаг «install».

Ответ:

- **sudo apt install wireshark**
- sudo apt update wireshark
- sudo apt remove wireshark
- sudo apt-get build wireshark

Шаг 04:

Миссия 4

Вы хотите, чтобы пользователь «kali» мог запускать команды от имени root через sudo. Какой файл нужно изменить?

Подсказка: Это файл конфигурации sudo.

Ответ:

- **/etc/sudoers**
- /etc/passwd
- /etc/group
- /etc/shadow

Шаг 05:

Миссия 5

Вы решили отключить графический интерфейс (GUI) и работать в режиме консоли для уменьшения нагрузки. Какой уровень запуска (runlevel) соответствует консоли (без GUI) в системе с systemd?

Подсказка: ищите target, связанный с multi-user.

Ответ:

- **multi-user.target**
- graphical.target
- runlevel5.target
- rescue.target

Шаг 06:

Миссия 6

Вы запускаете Kali на виртуальной машине и хотите настроить статический IP-адрес для интерфейса eth0 через файл конфигурации. В каком файле обычно прописывается сетевой интерфейс в Debian-подобных системах?

Подсказка: файл находится в /etc/network.

Ответ:

- **/etc/network/interfaces**
- /etc/netplan/config.yaml
- /etc/networkmanager.conf
- /etc/hosts

Шаг 07:

Миссия 7

Сопоставьте файл конфигурации с назначением безопасности в Kali Linux:

Файлы:

Ответ:

- /etc/ssh/sshd_config
- /etc/sudoers
- /etc/network/interfaces
- /etc/apt/sources.list

Назначение:

1. Конфигурация SSH-демона
2. Список репозитория для apt
3. Права sudo для пользователей
4. Настройка сетевых интерфейсов

Подсказка: подумайте, где размещаются репозитории, где — интерфейсы.

- **/etc/ssh/sshd_config** — Конфигурация SSH-демона
- **/etc/sudoers** — Права sudo для пользователей
- **/etc/network/interfaces** — Настройка сетевых интерфейсов
- **/etc/apt/sources.list** — Список репозитория для apt

🔮 Шаг 08:

Миссия 8

Сопоставьте услугу (service) с её правильной командой systemd для управления:

Услуги:

Ответ:

- ssh
- networking
- apache2
- cron

Команды:

1. `sudo systemctl restart apache2`
2. `sudo systemctl stop ssh`
3. `sudo systemctl status networking`
4. `sudo systemctl start cron`

Подсказка: сначала сопоставьте службы с типичным действием.

- **ssh** — `sudo systemctl stop ssh`
- **networking** — `sudo systemctl status networking`
- **apache2** — `sudo systemctl restart apache2`
- **cron** — `sudo systemctl start cron`

🔮 Шаг 09:

Миссия 9

Сопоставьте ключи ssh-клиента с их значением:

Ключи:

Ответ:

- -p
- -i
- -T
- -v

Значения:

1. принудительное отключение псевдотерминала (no tty)
2. порт
3. файл приватного ключа
4. verbose (подробный режим)

Подсказка: ключи однобуквенные — стандартные в SSH.

- **-p** — порт
- **-i** — файл приватного ключа
- **-T** — принудительное отключение псевдотерминала (no tty)
- **-v** — verbose (подробный режим)

🔮 Шаг 10:

Миссия 10

Сопоставьте утилиты Kali с их назначением:

Утилиты:

Ответ:

- nmap
- tcpdump
- airmon-ng
- john

Назначение:

1. перехват и анализ сетевых пакетов
2. преобразование интерфейса в режим мониторинга
3. сканирование портов и служб
4. взлом паролей (brute force)

Подсказка: вспомните, какая утилита делает что из списка.

- **nmap** — сканирование портов и служб
- **tcpdump** — перехват и анализ сетевых пакетов
- **airmon-ng** — преобразование интерфейса в режим мониторинга
- **john** — взлом паролей (brute force)

Шаг 11:

Миссия 11

Расположите этапы настройки безопасного SSH-сервера на Kali в правильном порядке:

1. Отключение root-входа
2. Перезапуск SSH-сервера
3. Изменение порта по умолчанию
4. Редактирование конфигурации

Подсказка: сначала редактируйте, потом меняйте настройки, затем отключайте root и в конце перезапускайте.

Ответ:

- Редактирование конфигурации
- Изменение порта по умолчанию
- Отключение root-входа
- Перезапуск SSH-сервера

Шаг 12:

Миссия 12

Расположите шаги создания изолированной среды (chroot-jail) для тестов:

1. Настройка минимального окружения внутри директории
2. Создание каталога для jail
3. Копирование необходимых бинарников и библиотек
4. Запуск процесса внутри chroot

Подсказка: сперва создайте структуру, потом наполните, затем запустите.

Ответ:

- Создание каталога для jail

- Настройка минимального окружения внутри директории
- Копирование необходимых бинарников и библиотек
- Запуск процесса внутри chroot

Шаг 13:

Миссия 13

Расположите этапы hardening (утолщения безопасности) ОС Kali:

1. Отключение ненужных служб
2. Установка обновлений безопасности
3. Настройка брандмауэра
4. Ограничение доступа по SSH

Подсказка: обновления — всегда первым, затем отключаем службы, конфигурируем доступ и firewall.

Ответ:

- Установка обновлений безопасности
- Отключение ненужных служб
- Ограничение доступа по SSH
- Настройка брандмауэра

Шаг 14:

Миссия 14

Расположите шаги аудита системы после hardening Kali:

1. Запуск сканера уязвимостей
2. Проверка открытых портов
3. Анализ логов на подозрительную активность
4. Сравнение с baseline (базовым состоянием)

Подсказка: сначала сравниваем, потом сканируем, порты, логи.

Ответ:

- Сравнение с baseline (базовым состоянием)
- Запуск сканера уязвимостей
- Проверка открытых портов
- Анализ логов на подозрительную активность

Шаг 15:

Миссия 15

Расположите шаги реагирования, если в логах SSH вы заметили неудачные попытки входа:

1. Изучение логов /var/log/auth.log
2. Блокировка IP-адреса через firewall или fail2ban
3. Проверка целостности системных файлов
4. Смена паролей и ключей

Подсказка: сначала лог, затем блок, затем проверка целостности, потом смена.

Ответ:

- Изучение логов /var/log/auth.log

- Блокировка IP-адреса через firewall или fail2ban
- Проверка целостности системных файлов
- Смена паролей и ключей

💡 Шаг 16:

Миссия 16

Расположите по порядку шаги полной настройки защищённой среды с Kali в роли атакующего (red team) и защитника (blue team):

1. Настройка сети и изоляции (VLAN, firewall)
2. Мониторинг трафика и логирование
3. Пентест и атаки внутри сети
4. Анализ результатов и отчётность

Подсказка: сначала создаём инфраструктуру, потом атакуем, потом мониторим и анализируем.

Ответ:

- Настройка сети и изоляции (VLAN, firewall)
- Пентест и атаки внутри сети
- Мониторинг трафика и логирование
- Анализ результатов и отчётность

📖 Урок 7 - MITM-атаки примеры и защита

💡 Шаг 01:

Миссия 1

Вы — начинающий разработчик Анджей, и вы увидели, что ваш HTTP-трафик перехватывается кем-то в локальной сети. Что из нижеперечисленного является примером MITM-атаки?

Подсказка: подумайте о посреднике, который читает или меняет сообщения между вами и сервером.

Ответ:

- Прокси-сервер, который изменяет веб-страницы на лету
- XSS-атака внутри страницы
- SQL-инъекция на сервере
- Атака «отказ в обслуживании» (DoS)

💡 Шаг 02:

Миссия 2

Мария работает в кофейне с гостевым Wi-Fi, и злоумышленник предлагает «ускоренный доступ» через прокси. Что она должна сделать, чтобы защититься?

Подсказка: вспомните про шифрование и доверие к сети.

Ответ:

- Использовать VPN или HTTPS-соединение
- Подключиться к прокси злоумышленника
- Отключить шифрование на Wi-Fi
- Попросить пароль у хозяина кафе

Шаг 03:

Миссия 3

Вы — DevOps-инженер по имени Алекс. Вы заметили подозрительный ARP-ответ в своей сети. Какой шаг — самый логичный первый действием?

Подсказка: ARP spoofing — классический MITM-инструмент на уровне канального уровня.

Ответ:

- Проверить таблицу ARP и включить статические ARP-записи
- Отключить все другие интерфейсы
- Запустить DDoS-атаку на узел
- Изменить пароль root на сервере

Шаг 04:

Миссия 4

Вы — QA-инженер Ирина. Ваша тестовая среда использует HTTP-API без TLS, и ваш коллега предлагает поставить MITM-прокси, чтобы симулировать сбой. Что особенно опасно делать без защиты?

Подсказка: подумайте, какие данные может украсть посредник.

Ответ:

- Пропускать реальные пароли и токены через незашифрованное соединение
- Использовать тестовые данные без шифрования
- Писать логирующие сообщения
- Отправлять ошибки в мониторинг

Шаг 05:

Миссия 5

Вы — системный администратор Борис. В вашей сети вы хотите защититься от MITM на уровне DNS. Какой приём наиболее подходящий?

Подсказка: подумайте о проверке ответа сервера имени.

Ответ:

- Внедрить DNSSEC
- Запретить все DNS-запросы
- Использовать открытые DNS без проверки
- Отключить DNS в сети

Шаг 06:

Миссия 6

Антон, инженер безопасности, хочет обнаружить MITM в своей инфраструктуре. Что он может использовать как индикатор присутствия атаки?

Подсказка: подумайте о том, как изменяется сертификат или публичный ключ.

Ответ:

- Изменения отпечатка TLS-сертификата между сессиями
- Повышенная нагрузка CPU на сервере
- Отсутствие логов доступа
- Захват экрана пользователя

🔧 Шаг 07:

Миссия 7

Вы — backend-разработчик Света. Она хочет убедиться, что её клиент-серверное приложение защищено от MITM. Какой приём она внедрит?

Подсказка: вспомните, что помогает обнаружить изменение данных в пути.

Ответ:

- **HSTS + проверка сертификата с закреплением (pinning)**
- Отключение TLS
- Только логирование запросов
- Переключение на HTTP/2 без TLS

🔧 Шаг 08:

Миссия 8

🕒 Сопоставьте методы MITM-атаки с уровнями сетевой модели OSI:

Методы:

Ответ:

- ARP spoofing
- DNS spoofing
- HTTPS proxy-man in the middle
- SSL stripping

Уровни OSI:

1. Канальный уровень (Data Link)
2. Сетевой уровень (Network)
3. Транспортный уровень (Transport)
4. Сессионный / Представительский уровень (Session / Presentation)

Подсказка:

Подумайте, на каком уровне происходит вмешательство: ARP — это канальный, DNS — сетевой, SSL strip — работа на TLS и сессиях.

- **ARP spoofing** — Канальный уровень (Data Link)
- **DNS spoofing** — Сетевой уровень (Network)
- **HTTPS proxy-man in the middle** — Транспортный уровень (Transport)
- **SSL stripping** — Сессионный / Представительский уровень (Session / Presentation)

🔧 Шаг 09:

Миссия 9

🕒 Сопоставьте сценарий MITM с возможным последствием:

Сценарии:

Ответ:

- Прокси-сервер вставляет вредоносный JS
- SSL stripping переводит HTTPS в HTTP
- DNS spoofing ведёт на фальшивый сайт
- ARP spoofing перехватывает локальный трафик

Последствия:

1. Угон сессии и похищение cookies
2. Перенаправление на поддельный ресурс
3. Вставка вредоносного кода на страницу
4. Прослушка всего трафика LAN

Подсказка:

Сопоставьте тип атаки с логическим эффектом: stripping даёт незащищённый HTTP, ARP даёт весь трафик локали и т.д.

- **Прокси-сервер вставляет вредоносный JS** — Вставка вредоносного кода на страницу
- **SSL stripping переводит HTTPS в HTTP** — Угон сессии и похищение cookies
- **DNS spoofing ведёт на фальшивый сайт** — Перенаправление на поддельный ресурс
- **ARP spoofing перехватывает локальный трафик** — Прослушка всего трафика LAN

 Шаг 10:

Миссия 10

Сопоставьте методы защиты с атаками MITM, которым они противостоят:

Защиты:

Ответ:

- DNSSEC
- TLS pinning
- HSTS
- Статические ARP-таблицы

Атаки:

1. DNS spoofing
2. SSL stripping / MITM HTTPS
3. MITM через прокси-сервер
4. ARP spoofing в локальной сети

Подсказка:

Подумайте, какая защита работает на каком уровне: DNSSEC — для DNS, ARP-таблицы — для ARP и т.д.

- **DNSSEC** — DNS spoofing
- **TLS pinning** — MITM через прокси-сервер
- **HSTS** — SSL stripping / MITM HTTPS
- **Статические ARP-таблицы** — ARP spoofing в локальной сети

 Шаг 11:

Миссия 11

Расположите шаги расследования MITM-атаки после её обнаружения:

1. Сбор логов и сетевых трассировок
2. Изоляция подозрительных устройств
3. Анализ сертификатов и отпечатков
4. Восстановление безопасной конфигурации

Подсказка:

Сначала изолируйте проблему, затем соберите информацию, выясните, что именно произошло, и после восстановите безопасность.

Ответ:

- Изоляция подозрительных устройств
- Сбор логов и сетевых трассировок
- Анализ сертификатов и отпечатков
- Восстановление безопасной конфигурации

 Шаг 12:

Миссия 12

У вас есть кейс: SSL stripping, DNS spoofing, ARP spoofing, прокси MITM. Расположите эти атаки по возрастанию сложности их обнаружения:

1. Самая простая для обнаружения
2. Средняя
3. Сложная
4. Очень сложная

Подсказка:

Подумайте, какая атака оставляет заметные следы, а какая действует тонко.

Ответ:

- ARP spoofing
- DNS spoofing
- SSL stripping
- прокси MITM

 Шаг 13:

Миссия 13

Расположите этапы внедрения TLS-pinning в мобильном приложении:

1. Установить библиотеку проверки сертификатов
2. Выбор доверенных корневых сертификатов / отпечатков
3. Интеграция проверки отпечатков в клиент
4. Тестирование отказа при неподходящем сертификате

Подсказка:

Подумайте: сначала нужно выбрать, что проверять, затем встроить и протестировать.

Ответ:

- Выбор доверенных корневых сертификатов / отпечатков
- Установить библиотеку проверки сертификатов
- Интеграция проверки отпечатков в клиент
- Тестирование отказа при неподходящем сертификате

 Шаг 14:

Миссия 14

Вы расследуете сложный MITM: выручите порядок действий:

1. Восстановление корректного TLS-состояния
2. Проведение аудита конфигураций (DNS, ARP, прокси)

3. Оповещение пользователей и смена ключей
4. Анализ следов: логи, пакеты, сертификаты

Подсказка:

Первично нужно собрать данные, затем исправить конфигурации, затем восстановить доверие, и наконец уведомить пользователей.

Ответ:

- Анализ следов: логи, пакеты, сертификаты
- Проведение аудита конфигураций (DNS, ARP, прокси)
- Восстановление корректного TLS-состояния
- Оповещение пользователей и смена ключей

 Шаг 15:

Миссия 15

Расположите методы защиты в порядке повышения стоимости реализации:

1. HSTS
2. TLS-pinning
3. DNSSEC
4. Использование VPN и туннелей

Подсказка:

Подумайте: какие меры проще внедрить, а какие требуют усилий на инфраструктуру.

Ответ:

- HSTS
- TLS-pinning
- DNSSEC
- Использование VPN и туннелей

 Шаг 16:

Миссия 16

Представьте, что в организации произошёл MITM через прокси и через DNS spoofing. Расположите действия в правильном порядке для реагирования:

1. Отключение подозрительных прокси
2. Внедрение DNSSEC и очистка кешей DNS
3. Сбор информации и трассировки
4. Восстановление доверенного TLS и обновление сертификатов

Подсказка:

Сначала устраним активный вектор, затем укрепляем инфраструктуру, затем исследуем и восстанавливаем доверие.

Ответ:

- Отключение подозрительных прокси
- Внедрение DNSSEC и очистка кешей DNS
- Сбор информации и трассировки
- Восстановление доверенного TLS и обновление сертификатов

🔮 Шаг 17:

Миссия 17

Финальный челлендж: ранжируйте методы защиты от MITM по уровню надёжности (от наименее к наиболее надёжному): HSTS, VPN, TLS pinning, DNSSEC.

1. Менее надёжный
2. Средний
3. Выше среднего
4. Наиболее надёжный

Подсказка:

Подумайте о том, какие меры защищают только один слой, а какие — цепочку доверия в разных уровнях.

Ответ:

- HSTS
- VPN
- TLS pinning
- DNSSEC

📖 Урок 8 - Атаки XSS как работают и как защититься

🔮 Шаг 01:

Миссия 1

Вы — фронтенд-разработчик Лена. В её веб-приложении один из пользователей жалуется, что при вводе в форму комментария появляются неожиданные скрипты. Что это может быть?

Подсказка: подумайте, какой тип атаки позволяет внедрить скрипт в страницу.

Ответ:

- **XSS (межсайтовый скриптинг)**
- CSRF (межсайтовая подделка запроса)
- SQL-инъекция
- Directory traversal

🔮 Шаг 02:

Миссия 2

Вы — бэкэнд-разработчик Иван. Он планирует принимать данные из формы и просто вставлять в HTML без фильтрации. Какой риск он создаёт?

Подсказка: если вы позволите произвольный ввод — что может произойти?

Ответ:

- **Уязвимость к XSS-атакам**
- Уязвимость к CSRF
- Уязвимость к LDAP-инъекциям
- **Никакой** — ввода недостаточно

🔮 Шаг 03:

Миссия 3

Сергей — DevOps-инженер, поддерживающий CI/CD. Он хочет автоматически сканировать приложения на XSS. Что из перечисленного — хороший старт?

Подсказка: подумайте о стандартных инструментах безопасности веб-приложений.

Ответ:

- **Использовать статический анализатор или WAF с модулями XSS**
- Отключить JavaScript на клиенте
- Применить только DNSSEC
- Отключить все формы

🔮 Шаг 04:

Миссия 4

Разработчица Аня заметила, что в заголовках HTTP можно вставлять атрибуты `onerror` и скрипты. Что она должна сделать?

Подсказка: вспомните про фильтрацию и экранирование.

Ответ:

- **Экранировать данные и запрещать HTML-теги**
- Никогда не трогать заголовки
- Всегда передавать заголовки в JavaScript
- Отключить заголовки

🔮 Шаг 05:

Миссия 5

Вы — тестировщик Марина. Она хочет проверить, есть ли XSS в поисковой строке. Что нужно попробовать?

Подсказка: введите что-то необычное, что может интерпретироваться как код.

Ответ:

- **Ввести `alert(1)` и посмотреть, выполнится ли**
- Ввести обычный текст
- Ввести SQL-команду
- Ввести пробел

🔮 Шаг 06:

Миссия 6

Сопоставьте категории XSS с их описаниями:

Категории:

Ответ:

- Reflected XSS
- Stored XSS
- DOM-based XSS
- Self XSS

Описание:

1. Внедрение скрипта через данные, хранимые на сервере
2. Скрипт встраивается и сразу отражается в ответе
3. Скрипт изменяет DOM на стороне клиента через уже загруженные данные
4. Пользователь вводит код сам себе, думая, что это безопасно

Подсказка:

Reflected — отражённый, Stored — хранится, DOM-based — на клиентской части, Self — ввод самим пользователем.

- **Reflected XSS** — Скрипт встраивается и сразу отражается в ответе
- **Stored XSS** — Внедрение скрипта через данные, хранимые на сервере
- **DOM-based XSS** — Скрипт изменяет DOM на стороне клиента через уже загруженные данные
- **Self XSS** — Пользователь вводит код сам себе, думая, что это безопасно

🔮 Шаг 07:

Миссия 7

🔍 Сопоставьте методы защиты от XSS с механизмами:

Методы защиты:

Ответ:

- Content Security Policy (CSP)
- HttpOnly cookie
- Экранирование HTML
- Использование шаблонов без вставки сырых данных

Механизм:

1. Запрет запуска инлайн-скриптов
2. Блокировка доступа JavaScript к cookies
3. Замена `<` на `<` и прочие сущности
4. Не допускать вставки raw HTML через ввод

Подсказка:

CSP запрещает инлайн, HttpOnly скрывает куки от JS, экранирование — преобразование символов, шаблоны — избегание raw вставок.

- **Content Security Policy (CSP)** — Запрет запуска инлайн-скриптов
- **HttpOnly cookie** — Блокировка доступа JavaScript к cookies
- **Экранирование HTML** — Замена `<` на `<` и прочие сущности
- **Использование шаблонов без вставки сырых данных** — Не допускать вставки raw HTML через ввод

🔮 Шаг 08:

Миссия 8

🔍 Сопоставьте часть приложения с уязвимой точкой для XSS:

Части приложения:

Ответ:

- URL-параметр поиска
- Комментарий пользователя, хранящийся в БД
- Данные, используемые в JavaScript через innerHTML

Уязвимая точка:

1. Reflected XSS
2. Stored XSS
3. DOM-based XSS

Подсказка:

Параметр поиска часто отражается, комментарий хранится, innerHTML — DOM-основанная уязвимость.

- **URL-параметр поиска** — Reflected XSS
- **Комментарий пользователя, хранящийся в БД** — Stored XSS
- **Данные, используемые в JavaScript через innerHTML** — DOM-based XSS

🔮 Шаг 09:

Миссия 9

Расположите шаги защиты от XSS при вводе данных в веб-форме:

1. Экранирование пользовательских данных
2. Валидация формата ввода
3. Использование безопасных шаблонов (template engines)
4. Установка CSP и HSTS

Подсказка:

Сначала проверьте ввод, затем экранируйте, потом безопасно встроите, и наконец усилите заголовками.

Ответ:

- Валидация формата ввода
- Экранирование пользовательских данных
- Использование безопасных шаблонов (template engines)
- Установка CSP и HSTS

🔮 Шаг 10:

Миссия 10

Расположите этапы тестирования на XSS:

1. Ввод тестовой нагрузочной строки (payload)
2. Наблюдение за реакцией страницы
3. Повторение с других точек ввода
4. Анализ сетевого трафика и исходного кода ответа

Подсказка:

Сначала вставьте, затем посмотрите результат, затем протестируйте разные места, и проанализируйте детали.

Ответ:

- Ввод тестовой нагрузочной строки (payload)
- Наблюдение за реакцией страницы
- Повторение с других точек ввода
- Анализ сетевого трафика и исходного кода ответа

🔮 Шаг 11:

Миссия 11

Расположите атаки XSS по возрастанию сложности защиты:

1. Reflected XSS
2. DOM-based XSS

3. Stored XSS
4. Self XSS

Подсказка:

Подумайте, какие типы легче всего отловить и предотвратить, и какие сложнее изнутри приложений.

Ответ:

- Self XSS
- Reflected XSS
- DOM-based XSS
- Stored XSS

 Шаг 12:

Миссия 12

Расположите защитные механизмы по степени надёжности (от менее к более):

1. HttpOnly куки
2. Экранирование HTML
3. CSP с nonce
4. Шаблоны без вставки raw HTML

Подсказка:

Некоторые меры поверхностные, другие — архитектурные и более надёжные.

Ответ:

- HttpOnly куки
- Экранирование HTML
- Шаблоны без вставки raw HTML
- CSP с nonce

 Шаг 13:

Миссия 13

Расположите порядок внедрения защиты в большое приложение:

1. Наложить CSP
2. Массово экранировать все места вывода
3. Проверка шаблонов на raw вставку
4. Переписать модули с опасным innerHTML

Подсказка:

Сначала добавьте политику, затем исправьте вывод, затем шаблон, затем опасные модули.

Ответ:

- Наложить CSP
- Массово экранировать все места вывода
- Проверка шаблонов на raw вставку
- Переписать модули с опасным innerHTML

 Шаг 14:

Миссия 14

Расположите этапы аудита безопасности на XSS:

1. Обнаружение потенциальных мест вставки данных
2. Тестирование каждого места с XSS payload
3. Оценка влияния успешного XSS (cookie, DOM, редиректы)
4. Формирование отчёта и рекомендации по защите

Подсказка:

Сначала ищем точки риска, тестируем, оцениваем ущерб и даём рекомендации.

Ответ:

- Обнаружение потенциальных мест вставки данных
- Тестирование каждого места с XSS payload
- Оценка влияния успешного XSS (cookie, DOM, редиректы)
- Формирование отчёта и рекомендации по защите

 Шаг 15:

Миссия 15

Финальный этап реагирования: что делать после фиксации XSS-уязвимости? Расставьте по шагам:

1. Заменить уязвимый код
2. Оповестить пользователей и обновить версии
3. Проверить, что исправление не сломало сайт
4. Запустить автоматические сканы и мониторинг

Подсказка:

Сначала исправьте код, затем проверьте, затем уведомите, затем внедрите защиту.

Ответ:

- Заменить уязвимый код
- Проверить, что исправление не сломало сайт
- Оповестить пользователей и обновить версии
- Запустить автоматические сканы и мониторинг

 Шаг 16:

Миссия 16

Финальный челлендж: ранжируйте защитные меры от XSS по уровню надёжности (от менее к наиболее): HttpOnly, Экранирование, CSP с nonce, Использование безопасных шаблонов.

1. Менее надёжная
2. Средняя
3. Более надёжная
4. Наиболее надёжная

Подсказка:

Подумайте, какие меры обеспечивают защиту на уровне браузера, шаблонов или политики.

Ответ:

- HttpOnly
- Экранирование HTML
- Использование безопасных шаблонов

- CSP с nonce

Урок 9 - SQL-инъекции механизм и предотвращение

Шаг 01:

Миссия 1

Вы — молодой разработчик Анна. На проекте с базой данных коллеги жалуются, что один и тот же SQL-запрос используется во многих местах. Что из ниже предложенного наиболее близко к риску SQL-инъекции?

Подсказка: Повторяющиеся запросы труднее надёжно контролировать.

Ответ:

- **Тот же запрос копируется и правится вручную в каждом месте**
- Использование ORM с параметризацией
- Вынесение всех запросов в репозиторий
- Рефакторинг кода для уменьшения дублирования

Шаг 02:

Миссия 2

Вы пишете форму авторизации. Какой подход предпочтителен, чтобы избежать SQL-инъекций?

Подсказка: Подумайте, как передавать аргументы безопасно.

Ответ:

- **Использовать подготовленные выражения (prepared statements)**
- Собирать строку вручную
- Экранировать вручную каждый символ
- Ограничить длину полей и не фильтровать

Шаг 03:

Миссия 3

Разработчик Виктор просит использовать динамическое построение WHERE-условий с помощью конкатенации строк. Вы подозреваете опасность. Что скажете?

Подсказка: Динамика + конкатенация = опасность.

Ответ:

- **Лучше собрать фильтры параметризованно, не конкатенируя строки**
- Используйте функции замены
- **Оставь как есть, главное — тесты**
- Экранируй символы '%' и '_' вручную

Шаг 04:

Миссия 4

Веб-приложение показывает пользователю ошибку базы данных с полным стеком при неверном вводе. Почему это проблема с точки зрения SQL-инъекции?

Подсказка: Подумайте, что могут увидеть злоумышленники.

Ответ:

- **Раскрывается структура БД и помогают планировать инъекцию**
- Это просто важно для отладки

- Пользователю полезно видеть стек
- Это никак не связано с безопасностью

🔗 Шаг 05:

Миссия 5

Сопоставьте термины с объяснениями:

Термины:

Ответ:

- Параметризованный запрос
- Экранирование
- ORM
- Белый список

Объяснения:

1. Разрешать только заранее определённые значения
2. Использование библиотеки, абстрагирующей SQL-запросы
3. Замена специальных символов на безопасные эквиваленты
4. Отделение кода запроса и данных с метками параметров

Подсказка: Подумайте, как каждый механизм избегает внедрения кода.

- **Параметризованный запрос** — Отделение кода запроса и данных с метками параметров
- **Экранирование** — Замена специальных символов на безопасные эквиваленты
- **ORM** — Использование библиотеки, абстрагирующей SQL-запросы
- **Белый список** — Разрешать только заранее определённые значения

🔗 Шаг 06:

Миссия 6

Сопоставьте защитные меры и их ограничения:

Меры:

Ответ:

- Экранирование
- Параметризация
- ORM
- Белый список полей

Ограничения:

1. Надо внимательно экранировать вручную каждый символ
2. Нельзя динамически выбирать столбцы из пользовательского ввода
3. Некоторые ORM могут генерировать небезопасные запросы
4. Поддерживает только параметры, а не структуру запроса

Подсказка: Подумайте, когда защита не справляется.

- **Экранирование** — Надо внимательно экранировать вручную каждый символ
- **Параметризация** — Поддерживает только параметры, а не структуру запроса
- **ORM** — Некоторые ORM могут генерировать небезопасные запросы
- **Белый список полей** — Нельзя динамически выбирать столбцы из пользовательского ввода

Шаг 07:

Миссия 7

Сопоставьте ошибки разработчиков и их последствия:

Ошибка:

Ответ:

- Не использовать prepared statements
- Показывать базу данных в ошибках
- Допускать динамическую сортировку через input
- Не ограничивать длину ввода

Последствие:

1. SQL-инъекция через ORDER BY или сортировку
2. Утечка схемы БД
3. Внедрение в любой SQL-запрос
4. Попытка передать очень длинный вредоносный payload

Подсказка: Каждая ошибка даёт характерную уязвимость.

- **Не использовать prepared statements** — Внедрение в любой SQL-запрос
- **Показывать базу данных в ошибках** — Утечка схемы БД
- **Допускать динамическую сортировку через input** — SQL-инъекция через ORDER BY или сортировку
- **Не ограничивать длину ввода** — Попытка передать очень длинный вредоносный payload

Шаг 08:

Миссия 8

Упорядочьте шаги анализа безопасности запроса:

1. Анализируем, где происходит конкатенация строк
2. Определяем, какие параметры вводит пользователь
3. Проверяем, используются ли параметры в готовых выражениях
4. Оцениваем, есть ли уязвимость SQL-инъекции

Подсказка: Сначала посмотреть ввод, потом способ вставки, потом анализ уязвимости.

Ответ:

- Анализируем, где происходит конкатенация строк
- Определяем, какие параметры вводит пользователь
- Проверяем, используются ли параметры в готовых выражениях
- Оцениваем, есть ли уязвимость SQL-инъекции

Шаг 09:

Миссия 9

Кира тестирует систему. В каком порядке она должна проверять области кода на SQL-инъекции?

1. Формы ввода, текстовые поля
2. Параметры URL и строки запроса
3. Области сортировки и фильтрации

4. Административные панели и отчёты

Подсказка: Начинать стоит с открытых интерфейсов, затем углубиться в административные.

Ответ:

- Формы ввода, текстовые поля
- Параметры URL и строки запроса
- Области сортировки и фильтрации
- Административные панели и отчёты

Шаг 10:

Миссия 10

Упорядочьте этапы защиты API-конечных точек от SQL-инъекций:

1. Валидация и фильтрация входных данных
2. Использование параметризованных запросов/ORM
3. Ограничение прав доступа к данным
4. Мониторинг и логирование попыток

Подсказка: Защита — это несколько слоёв.

Ответ:

- Валидация и фильтрация входных данных
- Использование параметризованных запросов/ORM
- Ограничение прав доступа к данным
- Мониторинг и логирование попыток

Шаг 11:

Миссия 11

Упорядочите этапы реагирования на выявленную SQL-инъекцию:

1. Ограничение доступа или отключение уязвимой функции
2. Анализ журнала и трассировка атаки
3. Уведомление команды по безопасности и исправление кода
4. Внедрение постоянной защиты и тестов

Подсказка: Сначала — остановить далее — расследовать и исправлять.

Ответ:

- Ограничение доступа или отключение уязвимой функции
- Анализ журнала и трассировка атаки
- Уведомление команды по безопасности и исправление кода
- Внедрение постоянной защиты и тестов

Шаг 12:

Миссия 12

Вам предложен код, содержащий несколько потенциальных уязвимостей. Упорядочите проверки, которые нужно выполнить:

1. Найти все места, где происходит конкатенация строк SQL
2. Проверить, что пользовательский ввод проходит фильтрацию или валидацию
3. Убедиться, что используются prepared statements в тех местах

4. Использовать белые списки для полей и операторов

Подсказка: Начинайте с выявления опасных мест, затем усиливайте защиту.

Ответ:

- Найти все места, где происходит конкатенация строк SQL
- Проверить, что пользовательский ввод проходит фильтрацию или валидацию
- Убедиться, что используются prepared statements в тех местах
- Использовать белые списки для полей и операторов

Шаг 13:

Миссия 13

Ваша команда готовит публичный API с фильтрацией, сортировкой и пагинацией. Упорядочите, в каком порядке применять меры безопасности:

1. Валидация и фильтрация входных параметров
2. Проверка принадлежности полей пагинации и сортировки к белому списку
3. Использование параметризованных запросов для фильтров и пагинации
4. Ограничение прав доступа к данным согласно роли

Подсказка: Каждый слой защиты усиливает следующий.

Ответ:

- Валидация и фильтрация входных параметров
- Проверка принадлежности полей пагинации и сортировки к белому списку
- Использование параметризованных запросов для фильтров и пагинации
- Ограничение прав доступа к данным согласно роли

Шаг 14:

Миссия 14

Представьте, что вы проводите аудит проекта. Упорядочите этапы аудита на предмет SQL-инъекций:

1. Сбор всех SQL-запросов из кода проекта
2. Выявление мест конкатенации строк с вводом
3. Проверка, какие запросы не используют параметризацию или ORM корректно
4. Рекомендации по исправлению и написание тестов безопасности

Подсказка: Аудит — это поиск, проверка и рекомендации, в таком порядке.

Ответ:

- Сбор всех SQL-запросов из кода проекта
- Выявление мест конкатенации строк с вводом
- Проверка, какие запросы не используют параметризацию или ORM корректно
- Рекомендации по исправлению и написание тестов безопасности

Урок 10 - Эмуляция атак на учебный сайт (CTF-формат)

Шаг 01:

Миссия 1

Вы — стажёр в команде безопасности, и вам дают тестовый сайт с простейшей формой логина. Какое первое действие вы предпримете, чтобы проверить безопасность?

Подсказка: Начинайте с самого базового — не прыгайте сразу к сложным атакам.

Ответ:

- **Попробовать логин с вводом "' OR '1'='1"**
- Сразу заразить сайт SQL-payload'ом через все поля
- Сканировать весь сервер на уязвимости
- Запросить у администратора дампы базы

 **Шаг 02:**

Миссия 2

 Задача: Сопоставьте технику атаки веб-форм с её описанием.

Техники:

Ответ:

- SQL Injection
- Cross-Site Scripting (XSS)
- CSRF (кросс-сайт запрос)
- Directory Traversal

Описания:

1. Внедрение SQL-кода через поля ввода
2. Исполнение JavaScript в браузере жертвы
3. Посылка фальшивого запроса от имени пользователя без его ведома
4. Доступ к файлам за пределами веб-каталога

Подсказка: Представьте, какую цель преследует каждая атака.

- **SQL Injection** — Внедрение SQL-кода через поля ввода
- **Cross-Site Scripting (XSS)** — Исполнение JavaScript в браузере жертвы
- **CSRF (кросс-сайт запрос)** — Посылка фальшивого запроса от имени пользователя без его ведома
- **Directory Traversal** — Доступ к файлам за пределами веб-каталога

 **Шаг 03:**

Миссия 3

Вы ввели payload «' OR '1'='1» и успешно зашли как администратор. Что делать дальше?

Подсказка: Подумайте, как добыть данные, не ломая функционал сайта.

Ответ:

- Удалить всех пользователей
- Оставить всё как есть и сдавать результат
- **Попробовать выбрать таблицу пользователей через UNION SELECT**
- Сразу зашифровать базу и требовать выкуп

 **Шаг 04:**

Миссия 4

 Задача: Сопоставьте следующие XSS-методы с их характеристиками:

Методы:

Ответ:

- Reflected XSS
- Stored XSS
- DOM-Based XSS
- Mutated XSS

Характеристики:

1. Ввод сохраняется в базе и отображается позже
2. Скрипт отражается в ответе от сервера
3. Атака контролирует DOM напрямую без серверного участия
4. Браузер автоматически мутирует ввод и создаёт XSS

Подсказка: Подумайте, где ввод обрабатывается — на сервере или на стороне клиента.

- **Reflected XSS** — Скрипт отражается в ответе от сервера
- **Stored XSS** — Ввод сохраняется в базе и отображается позже
- **DOM-Based XSS** — Атака контролирует DOM напрямую без серверного участия
- **Mutated XSS** — Браузер автоматически мутирует ввод и создаёт XSS

 Шаг 05:

Миссия 5

 Задача: Сопоставьте защитные меры загрузки файлов с тем, что они предотвращают.

Меры:

Ответ:

- Ограничение типа MIME
- Проверка содержимого файла
- Изменение имени файла
- Хранение вне веб-каталога

Что предотвращают:

1. Исполнение загруженного файла как скрипт
2. Маскировку опасного контента под безопасный MIME
3. Перезапись существующих файлов
4. Прямой доступ через HTTP

Подсказка: Каждая мера решает одну конкретную проблему из списка выше.

- **Ограничение типа MIME** — Маскировку опасного контента под безопасный MIME
- **Проверка содержимого файла** — Исполнение загруженного файла как скрипт
- **Изменение имени файла** — Перезапись существующих файлов
- **Хранение вне веб-каталога** — Прямой доступ через HTTP

 Шаг 06:

Миссия 6

Вы успешно загрузили файл shell.php, но сервер не исполняет его: возвращает просто текст. Что попробуете дальше?

Подсказка: Иногда помогает обман сервера через расширения.

Ответ:

- **Переименовать файл в shell.php.jpg**

- Сжать файл в ZIP и загрузить
- Отправить файл через POST-payload
- Изменить код shell на bash-скрипт

Шаг 07:

Миссия 7

 Задача: Сопоставьте расширения или методы обхода с эффектом, который они дают:

Методы обхода:

Ответ:

- file.php.jpg
- file.php;.jpg
- file.php%00.jpg
- file.php.asp

Эффекты:

1. Сервер думает, что это изображение
2. Обрезка лишней части имени сервером (null-байт)
3. Добавление ложного расширения после точки с запятой
4. Смена интерпретатора в ASP

Подсказка: Изучите, как серверы парсят имя файла.

- **file.php.jpg** — Сервер думает, что это изображение
- **file.php;.jpg** — Добавление ложного расширения после точки с запятой
- **file.php%00.jpg** — Обрезка лишней части имени сервером (null-байт)
- **file.php.asp** — Смена интерпретатора в ASP

Шаг 08:

Миссия 8

Вы получаете файл-шелл и видите содержимое корня веб-сайта. Что делать дальше?

Подсказка: Следующий шаг — поднятие прав или поиск конфигураций.

Ответ:

- **Просмотреть конфигурационные файлы (.env, config.php)**
- Удалиться и скрыться
- Удалить весь сайт
- Сразу слать на весь сервер DDoS

Шаг 09:

Миссия 9

 Задача: Сопоставьте типы конфигурационных файлов с информацией, которую они могут содержать:

Файлы:

Ответ:

- .env
- config.php
- settings.yaml
- wp-config.php

Информация:

1. Учётные данные базы данных
2. Секретные ключи приложения
3. Параметры окружения (dev/prod)
4. Настройки WordPress (префикс таблиц и др.)

Подсказка: Разные системы конфигурации используют разные форматы.

- **.env** — Параметры окружения (dev/prod)
- **config.php** — Учётные данные базы данных
- **settings.yaml** — Секретные ключи приложения
- **wp-config.php** — Настройки WordPress (префикс таблиц и др.)

Шаг 10:

Миссия 10

Вы нашли .env с паролями к базе. Что безопаснее сделать перед выходом?

Подсказка: Не оставляйте следов.

Ответ:

- Занести файл в репозиторий
- **Скачать секретные данные и очистить логи доступа**
- Оставить всё как есть
- Показать администратору как доказательство

Шаг 11:

Миссия 11

 Задача: Сопоставьте лог-категорию с тем, какая информация в ней может быть чувствительной:

Лог-категории:

Ответ:

- Access log
- Error log
- Application log
- DB query log

Данные:

1. Пароль или хэш SQL-запроса
2. URL и параметры запроса
3. Сообщения об исключениях с трассировкой
4. Коды ответа и статус HTTP

Подсказка: Каждая категория логов несёт свой тип информации.

- **Access log** — URL и параметры запроса
- **Error log** — Сообщения об исключениях с трассировкой
- **Application log** — Коды ответа и статус HTTP
- **DB query log** — Пароль или хэш SQL-запроса

🔮 Шаг 12:

Миссия 12

Вы хотите поднять привилегии на сервере. Каким путём поможете?

Подсказка: Ищите слабые точки в конфигурации сервера.

Ответ:

- Использовать SQL-инъекцию снова
- **Искать уязвимость sudo, setuid либо забытые скрипты**
- Сбросить пароль root
- Прописать cron-задачу, отправляющую shell

🔮 Шаг 13:

Миссия 13

📖 Задача: Сопоставьте уязвимости привилегий с примерами:

Уязвимости:

Ответ:

- Выполнение кода как root
- Использование setuid-программы
- CRON-скрипт от root
- Неправильно настроенные sudo

Примеры:

1. Пользователь запускает программу с setuid bit на root
2. root cron выполняет скрипт из папки /tmp
3. sudo позволяет запускать любую команду без пароля
4. Вы запускаете shell как root напрямую

Подсказка: Вспомните, что setuid и cron часто дают права root.

- **Выполнение кода как root** — Вы запускаете shell как root напрямую
- **Использование setuid-программы** — Пользователь запускает программу с setuid bit на root
- **CRON-скрипт от root** — root cron выполняет скрипт из папки /tmp
- **Неправильно настроенные sudo** — sudo позволяет запускать любую команду без пароля

🔮 Шаг 14:

Миссия 14

Вы выяснили, что существует cron-скрипт запускаемый от root, который читает каталог /opt/tasks. Что вы предпримете?

Подсказка: Размещение вредоносного скрипта рядом с легитимным.

Ответ:

- **Создать скрипт в /opt/tasks с именем похожим на существующий**
- Удалить cron-задачу
- Переименовать весь cron в рутовом аккаунте
- Отправить другому pentester'y

🔧 Шаг 15:

Миссия 15

Расположите шаги эскалации привилегий в правильном порядке:

1. Найти уязвимость с `setuid`, `sudo` или `cron`
2. Внедрить свой скрипт или `payload`
3. Запустить скрипт от имени `root` или привилегии выше
4. Скрыть следы (стереть логи, восстановить атрибуты)

Подсказка: Сначала обнаружьте точку входа, затем действуйте, потом закрепляйтесь и маскируетесь.

Ответ:

- Найти уязвимость с `setuid`, `sudo` или `cron`
- Внедрить свой скрипт или `payload`
- Запустить скрипт от имени `root` или привилегии выше
- Скрыть следы (стереть логи, восстановить атрибуты)

📖 Урок 11 - Защита корпоративной почты (SPF, DKIM, DMARC)

🔧 Шаг 01:

Миссия 1

Вы получили письмо от коллеги, но подозреваете, что оно фальшивое. Какой признак наиболее характерен для фишинговой почты?

Подсказка: Обратите внимание на несоответствие имени отправителя и email-адреса.

Ответ:

- **Имя отправителя не совпадает с доменом email**
- Письмо на русском языке
- Письмо отправлено утром
- В письме есть вложение

🔧 Шаг 02:

Миссия 2

Ваша компания хочет защитить исходящую почту. Что из ниже является первым шагом?

Подсказка: Подумайте, что надлежит сделать до публикации DNS.

Ответ:

- **Настроить SPF-запись для домена**
- Разработать политику DMARC
- Включить DKIM на сервере
- Отправить тестовое письмо в Gmail

🔧 Шаг 03:

Миссия 3

Вы настроили SPF, но письма всё ещё попадают в спам у получателя. Что следует проверить следующим?

Подсказка: SPF — это не всё, есть важный механизм подписи.

Ответ:

- **Включена ли DKIM-подпись**
- Настроен ли сервер FTP
- Проверка MX-записи
- Скорость интернет-канала

Шаг 04:

Миссия 4

Перед публикацией DKIM вы должны сгенерировать пару ключей. Какой из ниже — частный ключ?

Подсказка: Частный ключ хранится на вашем сервере и не публикуется.

Ответ:

- **Тот, что остается на вашем mail-сервере**
- Тот, что публикуется в DNS
- Тот, что высылается всем партнёрам
- Тот, что выставлен в MX

Шаг 05:

Миссия 5

Вы опубликовали DKIM в DNS. Какой селектор (selector) вы должны использовать в письме?

Подсказка: Селектор — часть имени TXT-записи в DNS.

Ответ:

- **Имя, совпадающее с тем, что было в DNS DKIM**
- Любой произвольный
- Селектор “default” всегда
- **Селектор** — это ваш домен

Шаг 06:

Миссия 6

Сопоставьте термины и их определения в контексте SPF, DKIM, DMARC:

Термины:

Ответ:

- SPF
- DKIM
- DMARC
- Политика «p=reject»

Определения:

1. Механизм, позволяющий подписывать письма с помощью криптографии.
2. Запись, указывающая, какие серверы могут отправлять почту от имени домена.
3. Указание, что получатель должен отклонять неподтверждённые письма.
4. Политика отчётов и проверки подлинности электронной почты.

Подсказка: SPF и DKIM — это подписи и разрешения, DMARC — управление и действия.

- **SPF** — Запись, указывающая, какие серверы могут отправлять почту от имени домена.

- **DKIM** — Механизм, позволяющий подписывать письма с помощью криптографии.
- **DMARC** — Политика отчётов и проверки подлинности электронной почты.
- **Политика «p=reject»** — Указание, что получатель должен отклонять неподтверждённые письма.

🔗 Шаг 07:

Миссия 7

Сопоставьте части DMARC-записи и их назначение:

Части записи:

Ответ:

- v=DMARC1
- rua=
- pct=100
- sp=none

Назначения:

1. Версия протокола
2. Куда направлять отчёты о сбоях
3. Процент писем, к которым применять политику
4. Политика для субдоменов

Подсказка: Все части начинаются с префикса и равно.

- **v=DMARC1** — Версия протокола
- **rua=** — Куда направлять отчёты о сбоях
- **pct=100** — Процент писем, к которым применять политику
- **sp=none** — Политика для субдоменов

🔗 Шаг 08:

Миссия 8

Расположите этапы внедрения SPF и DKIM для корпоративной почты:

1. Публикация SPF в DNS
2. Генерация ключей DKIM
3. Настройка подписки DKIM на почтовом сервере
4. Валидация с помощью внешнего сервиса

🔗 **Подсказка:**

Начинайте с SPF, затем переходите к DKIM, и только после настройки проверяйте.

Ответ:

- Публикация SPF в DNS
- Генерация ключей DKIM
- Настройка подписки DKIM на почтовом сервере
- Валидация с помощью внешнего сервиса

🔗 Шаг 09:

Миссия 9

Расположите шаги анализа отчётов DMARC:

1. Сбор отчетов (rua/rua)
2. Анализ доменов-источников отправки
3. Выявление несоответствий SPF или DKIM
4. Корректировка политик (p=none → p=quarantine → p=reject)

🔔 Подсказка:

Сначала собираете данные, затем анализируете, выявляете, и уже после этого корректируете политику.

Ответ:

- Сбор отчетов (rua/rua)
- Анализ доменов-источников отправки
- Выявление несоответствий SPF или DKIM
- Корректировка политик (p=none → p=quarantine → p=reject)

🔔 Шаг 10:

Миссия 10

После перехода на p=quarantine часть писем всё ещё отклоняется. Что могло пойти не так?

Подсказка: Проверьте ключи и селекторы.

Ответ:

- **DKIM-подпись неверна из-за неверного селектора**
- SPF указан как ?all
- MX не существует
- DMARC не опубликован

🔔 Шаг 11:

Миссия 11

Сопоставьте возможные ошибки и их последствия:

Ошибки:

Ответ:

- Неправильный селектор DKIM
- SPF содержит «+all»
- DMARC установлен p=reject сразу
- Отсутствие отчетов rua

Последствия:

1. Письма отклоняются при каждом несовпадении
2. **Все серверы разрешены** — слабая защита
3. **Отсутствие жёсткого контроля на старте** — потеря данных
4. Неизвестно, откуда идут фальшивые письма

Подсказка: Каждый элемент из ошибок соответствует одному из итогов.

- **Неправильный селектор DKIM** — Письма отклоняются при каждом несовпадении
- **SPF содержит «+all»** — Все серверы разрешены — слабая защита
- **DMARC установлен p=reject сразу** — Отсутствие жёсткого контроля на старте—потеря данных

- **Отсутствие отчетов rua** — Неизвестно, откуда идут фальшивые письма

🔗 Шаг 12:

Миссия 12

Расположите стадии эволюции защиты домена:

1. p=none, только отчёты
2. p=quarantine
3. p=reject
4. Мониторинг и корректировки

🔗 Подсказка:

Сначала наблюдать, потом жёстче реагировать.

Ответ:

- p=none, только отчёты
- Мониторинг и корректировки
- p=quarantine
- p=reject

🔗 Шаг 13:

Миссия 13

Расположите шаги при миграции с внешнего почтового провайдера:

1. Внедрение DKIM/DMARC у нового провайдера
2. Настройка SPF на новый IP
3. Дублирование отправки через старый и новый сервер
4. Отключение старого отправителя

🔗 Подсказка:

Нужно обеспечить плавный переход без отказов.

Ответ:

- Настройка SPF на новый IP
- Внедрение DKIM/DMARC у нового провайдера
- Дублирование отправки через старый и новый сервер
- Отключение старого отправителя

🔗 Шаг 14:

Миссия 14

В отчётах DMARC вы замечаете, что один ваш субдомен не проходит проверку. Что разумно сделать?

Подсказка: Политика sp= управляет субдоменами.

Ответ:

- **Установить sp=quarantine или sp=reject**
- Игнорировать субдомен
- Удалить субдомен
- Сделать sp=none

Шаг 15:

Миссия 15

Расположите шаги реагирования при обнаружении подделки почты в отчётах DMARC:

1. Собрать все отчёты за последние дни
2. Проанализировать отправителей и домены
3. Добавить авторизованные сервера в SPF/DKIM
4. **Усилить политику** — перейти к `reject`

Подсказка:

Реакция — от аналитики к действиям.

Ответ:

- Собрать все отчёты за последние дни
- Проанализировать отправителей и домены
- Добавить авторизованные сервера в SPF/DKIM
- **Усилить политику** — перейти к `reject`

Урок 12 - Протоколы безопасности в локальной сети

Шаг 01:

Миссия 1

В офисе дома сеть устроена просто: у вас есть беспроводной роутер, и коллега жалуется, что его компьютер не может подключиться к Wi-Fi. Что проверить в первую очередь?

Подсказка: Иногда дело в простой опечатке SSID или пароля.

Ответ:

- **Правильность имени сети (SSID) и пароля Wi-Fi**
- Настройки DNS
- Активность антивируса
- MAC-фильтрация на прокси

Шаг 02:

Миссия 2

Во время работы программист Анна заметила, что чужой ноутбук подключился к её Wi-Fi сети без пароля. Какой режим шифрования беспроводной сети наиболее безопасен?

Подсказка: Старые стандарты уже считаются небезопасными.

Ответ:

- **WPA3**
- WEP
- WPA (TKIP)
- Без шифрования (Open)

Шаг 03:

Миссия 3

Сисадмин Борис настраивает проводной сегмент офиса. Он хочет ограничить доступ устройств по MAC-адресам, но не хочет ломать управление сетью. Какой недостаток у MAC-фильтрации?

Подсказка: MAC-адреса можно копировать и подделывать.

Ответ:

- **MAC-адрес можно подделать (спуфинг)**
- Работает только на беспроводных сетях
- Не влияет на шифрование
- Не требует спецификации L3

🔗 Шаг 04:

Миссия 4

В офисной сети используется VLAN. Зачем применяют VLAN в корпоративной LAN?

Подсказка: VLAN позволяет логически разделить одну физическую сеть.

Ответ:

- **Логическое разделение трафика и сдерживание широковещательного домена**
- Поддержка только IPv6
- Замена VPN во внешней сети
- Увеличение скорости радио

🔗 Шаг 05:

Миссия 5

Сетевой инженер Игорь хочет заставить все клиенты использовать шифрованное соединение к контроллеру через SSH, а не Telnet. Почему это важно?

Подсказка: Telnet передаёт всё в открытом виде.

Ответ:

- **SSH шифрует трафик и предотвращает перехват паролей**
- SSH быстрее чем Telnet
- SSH не требует логина
- SSH работает только на Linux

🔗 Шаг 06:

Миссия 6

Сопоставьте термин и его назначение в локальной сети безопасности:

Термины:

Ответ:

- WPA3
- VLAN
- SSH
- MAC-фильтрация

Назначения:

1. Шифрованный удалённый доступ к устройствам сети
2. Подразделение сетевого сегмента по логике
3. Способ проверки физического адреса устройства
4. Современный стандарт защищённого Wi-Fi

Подсказка: Подумайте, что делает каждая технология на своём уровне (канальный, прикладной и т.д.).

- **WPA3** — Современный стандарт защищённого Wi-Fi

- **VLAN** — Подразделение сетевого сегмента по логике
- **SSH** — Шифрованный удалённый доступ к устройствам сети
- **MAC-фильтрация** — Способ проверки физического адреса устройства

🔧 Шаг 07:

Миссия 7

Сопоставьте угрозу и уязвимость в LAN-сети:

Угрозы:

Ответ:

- ARP-спуфинг
- DHCP-спуфинг
- SSID-спуфинг
- Man-in-the-middle

Уязвимости / последствия:

1. Перехват трафика между узлами
2. Подмена IP-адресов на клиенте
3. Подмена имени точки доступа
4. Фальсификация DHCP-ответов и выдача неверных шлюзов/DNS

Подсказка: Каждая атака использует конкретную слабость протоколов L2/L3.

- **ARP-спуфинг** — Перехват трафика между узлами
- **DHCP-спуфинг** — Фальсификация DHCP-ответов и выдача неверных шлюзов/DNS
- **SSID-спуфинг** — Подмена имени точки доступа
- **Man-in-the-middle** — Подмена IP-адресов на клиенте

🔧 Шаг 08:

Миссия 8

Сопоставьте протокол и его тип защиты/уязвимость:

Протоколы / механизмы:

Ответ:

- 802.1X
- DoS-атака на ARP
- RSTP (Rapid Spanning Tree)
- IPsec в LAN

Описание / защита:

1. Аутентификация устройств перед доступом к сети
2. Маршрутизация с туннелированием между узлами
3. Атака, нарушающая адресацию на канальном уровне
4. Защита от петель в топологии сети

Подсказка: Подумайте, что делает каждый протокол — управление топологией, аутентификация или защита пакетов.

- **802.1X** — Аутентификация устройств перед доступом к сети
- **DoS-атака на ARP** — Атака, нарушающая адресацию на канальном уровне
- **RSTP (Rapid Spanning Tree)** — Защита от петель в топологии сети

- **IPsec в LAN** — Маршрутизация с туннелированием между узлами

Шаг 09:

Миссия 9

Сопоставьте атаку и основной вектор проникновения:

Атаки:

Ответ:

- VLAN hopping
- Packet sniffing
- DNS spoofing
- Switch MAC overflow

Векторы:

1. Переполнение CAM-таблицы коммутатора
2. Переход на соседний VLAN через двойные теги
3. Анализ трафика в режиме promisc
4. Подмена DNS-ответов внутри локальной сети

Подсказка: Каждая атака атакует либо коммутатор, либо протоколы разрешения имен.

- **VLAN hopping** — Переход на соседний VLAN через двойные теги
- **Packet sniffing** — Анализ трафика в режиме promisc
- **DNS spoofing** — Подмена DNS-ответов внутри локальной сети
- **Switch MAC overflow** — Переполнение CAM-таблицы коммутатора

Шаг 10:

Миссия 10

Расположите шаги настройки 802.1X в корпоративной сети:

1. Настройка RADIUS-сервера
2. Конфигурация коммутаторов для аутентификации портов
3. Настройка клиентов с supplicant
4. Тестирование и ввод в эксплуатацию

 **Подсказка:**

Сначала центр аутентификации, потом точки доступа, потом конечные узлы, затем проверка.

Ответ:

- Настройка RADIUS-сервера
- Конфигурация коммутаторов для аутентификации портов
- Настройка клиентов с supplicant
- Тестирование и ввод в эксплуатацию

Шаг 11:

Миссия 11

Расположите шаги защиты от ARP-спуфинга в сети:

1. Включение динамического ARP-списка (DAI) на коммутаторе
2. Статические ARP-записи для ключевых серверов
3. Мониторинг ARP-таблиц на подозрительные изменения

4. Ограничение ARP-ответов с внешних портов

💡 **Подсказка: Комбинация активных мер и мониторинга обеспечивает защиту.**

Ответ:

- Включение динамической ARP-списка (DAI) на коммутаторе
- Статические ARP-записи для ключевых серверов
- Мониторинг ARP-таблиц на подозрительные изменения
- Ограничение ARP-ответов с внешних портов

💡 **Шаг 12:**

Миссия 12

Расположите уровни защиты в LAN-сети от наименее к наиболее сильному:

1. Открытая сеть (Open)
2. WEP шифрование
3. WPA2
4. WPA3 + 802.1X

💡 **Подсказка: Каждая следующая технология устраняет слабости предыдущей.**

Ответ:

- Открытая сеть (Open)
- WEP шифрование
- WPA2
- WPA3 + 802.1X

💡 **Шаг 13:**

Миссия 13

Расположите этапы реагирования на атаку VLAN-hopping:

1. Выявление источника двойной теговой атаки
2. Отключение порта или исключение из VLAN
3. Ограничение тегирования на портах (удаление ненужных trunk)
4. Аудит конфигураций коммутаторов и усиление фильтрации

💡 **Подсказка: Сначала обнаружьте, затем ограничьте, потом уберите дырки.**

Ответ:

- Выявление источника двойной теговой атаки
- Отключение порта или исключение из VLAN
- Ограничение тегирования на портах (удаление ненужных trunk)
- Аудит конфигураций коммутаторов и усиление фильтрации

💡 **Шаг 14:**

Миссия 14

Расположите шаги при миграции с открытой сети на WPA3 + 802.1X:

1. Настройка RADIUS-сервера и политики доступа
2. Обновление точек доступа до поддержки WPA3/802.1X
3. Настройка supplicant на клиентских устройствах
4. Плавный переход с поддержкой старых клиентов и тестирование

🔔 **Подсказка: Нельзя сразу включать защиту без подготовки устройств.**

Ответ:

- Настройка RADIUS-сервера и политики доступа
- Обновление точек доступа до поддержки WPA3/802.1X
- Настройка supplicant на клиентских устройствах
- Плавный переход с поддержкой старых клиентов и тестирование

🔔 **Шаг 15:**

Миссия 15

Расположите шаги настройки IPsec между офисными сегментами LAN:

1. Выбор политики шифрования (шифр, аутентификация)
2. Установка туннельных / транспортных режимов
3. Обмен ключами (IKE)
Тестирование и мониторинг туннеля

🔔 **Подсказка: Сначала политика, затем режим, затем ключи, и только после проверка.**

Ответ:

- Выбор политики шифрования (шифр, аутентификация)
- Установка туннельных / транспортных режимов
- Обмен ключами (IKE)
- Тестирование и мониторинг туннеля

🔔 **Шаг 16:**

Миссия 16

Расположите шаги по защите коммутации и маршрутизации в LAN:

1. Ограничение management-доступа (SSH, SNMP) к сетевым устройствам
2. Закрытие неиспользуемых портов/функций (CDP, LLDP и др.)
3. Активные меры: DHCP snooping, DAI, IP source guard
4. Мониторинг логов и аномалий в сети

🔔 **Подсказка: Защита — это как слои: сначала минимальный доступ, потом активация функций, затем мониторинг.**

Ответ:

- Ограничение management-доступа (SSH, SNMP) к сетевым устройствам
- Закрытие неиспользуемых портов/функций (CDP, LLDP и др.)
- Активные меры: DHCP snooping, DAI, IP source guard
- Мониторинг логов и аномалий в сети

🔔 **Шаг 17:**

Миссия 17

Расположите шаги комплексной защиты LAN-сети:

1. Базовые меры: шифрование Wi-Fi, VLAN-сегментация
2. Аутентификация устройств (802.1X, NAC)
3. Активные защитные механизмы (DAI, DHCP snooping и др.)
4. Мониторинг, аудит, реагирование на инциденты

🔔 **Подсказка: Защита должна быть многослойной: от базового к активному к аналитике.**

Ответ:

- Базовые меры: шифрование Wi-Fi, VLAN-сегментация
- Аутентификация устройств (802.1X, NAC)
- Активные защитные механизмы (DAI, DHCP snooping и др.)
- Мониторинг, аудит, реагирование на инциденты

📖 **Урок 13 - Логирование и анализ подозрительных действий**

🔔 **Шаг 01:**

Миссия 1

Вы — безопасник в стартапе. На сервере вы видите строку в логах: «login failed for user admin from IP 192.0.2.15». Что стоит сделать в первую очередь?

Подсказка: Не игнорируйте неудачные попытки — они могут быть предвестником атаки.

Ответ:

- **Удалить лог** — чтобы не было подозрительных записей
- **Зафиксировать запись и проверить источник IP**
- Отключить аккаунт admin навсегда
- Игнорировать, если больше не будет ошибок

🔔 **Шаг 02:**

Миссия 2

Вы заметили, что один из серверов начал генерировать необычно много записей о попытках SSH-подключения с разных адресов. Что логичнее всего предпринять?

Подсказка: Логи полезны, но если их слишком много — нужен фильтр или алерт.

Ответ:

- **Настроить алерты при превышении порога попыток**
- Отключить SSH на сервере навсегда
- Очистить старые логи и начать с нуля
- Игнорировать, это нормальное поведение

🔔 **Шаг 03:**

Миссия 3

На фронтенд-сервисе вы увидели лог с параметром GET-запроса «?user=admin' OR '1'='1». Как вы реагируете?

Подсказка: Логи могут хранить следы попыток SQL-инъекции.

Ответ:

- **Зафиксировать попытку, уведомить разработчиков, усилить валидацию**
- Удалить логи, чтобы не пугать менеджеров
- Отключить базу данных
- **Игнорировать** — наверняка ложный срабатывание

🔔 **Шаг 04:**

Миссия 4

Система логирования неожиданно упала во время очередной волны атак. Какую следующую меру вы предпримете?

Подсказка: Логи — критический элемент. Без них вы слепы.

Ответ:

- **Переключить логирование на резервный сервер или включить fallback**
- Игнорировать падение, ведь атака уже идёт
- Остановить все сервисы и отключить сеть
- Удалить старые логи, чтобы влезли новые

Шаг 05:

Миссия 5

 Задача: Сопоставьте тип события в логах с тем, что оно может означать.

Типы событий:

Ответ:

- Неудачная попытка входа
- Успешный вход
- Запуск привилегированной команды
- Изменение конфигурации системы

Возможные значения:

1. Пользователь escalated права через sudo или su
2. Некто получил доступ к аккаунту
3. Кто-то пытался подобрать пароль
4. Администратор обновил настройки сервера

Подсказка:

Подумайте: успешный вход — это кто-то вошёл, неудачная — попытка. Смена конфигурации обычно требует прав.

- **Неудачная попытка входа** — Кто-то пытался подобрать пароль
- **Успешный вход** — Некто получил доступ к аккаунту
- **Запуск привилегированной команды** — Пользователь escalated права через sudo или su
- **Изменение конфигурации системы** — Администратор обновил настройки сервера

Шаг 06:

Миссия 6

 Задача: Сопоставьте сигнатуру атаки с её признаком в логах.

Сигнатуры:

Ответ:

- Brute-force SSH
- SQL-инъекция
- XSS-попытка
- DNS-эксфильтрация данных

Признаки в логах:

1. Серии GET с «' or '1'='1» и похожие шаблоны
2. Много неудачных попыток подключения к SSH

3. Запросы с «» или «javascript:»
4. Необычные DNS-запросы к внешним серверам

Подсказка:

Сопоставьте характерное поведение: SSH — множество попыток, SQL — шаблоны, XSS — скрипты, DNS — запросы.

- **Brute-force SSH** — Много неудачных попыток подключения к SSH
- **SQL-инъекция** — Серии GET с «' or '1'='1» и похожие шаблоны
- **XSS-попытка** — Запросы с «» или «javascript:»
- **DNS-эксфильтрация данных** — Необычные DNS-запросы к внешним серверам

 Шаг 07:

Миссия 7

 Задача: Сопоставьте элемент лог-сообщения с типичной значимой деталью.

Элементы сообщения:

Ответ:

- Timestamp
- Source IP
- Username
- Action

Типичные детали:

1. Время, когда произошло событие
2. Кто выполнил действие
3. Что именно пытались сделать
4. IP-адрес источника запроса

Подсказка:

Timestamp — это время, Source IP — адрес, Username — кто, Action — что.

- **Timestamp** — Время, когда произошло событие
- **Source IP** — IP-адрес источника запроса
- **Username** — Кто выполнил действие
- **Action** — Что именно пытались сделать

 Шаг 08:

Миссия 8

 Задача: Сопоставьте мониторинговый инструмент с задачей лог-анализа.

Инструменты:

Ответ:

- ELK Stack (Elasticsearch / Logstash / Kibana)
- Splunk
- Graylog
- OSSEC

Задачи:

1. Realtime поиск и визуализация логов
2. Хостовая IDS с анализом логов агента

3. Сбор логов и нормализация (логшиппер)
4. Централизованная платная платформа для анализа логов

Подсказка:

Подумайте: OSSEC — хостовая защита, ELK, Graylog — open-source, Splunk — коммерческий продукт, Logstash — сбор.

- **ELK Stack (Elasticsearch / Logstash / Kibana)** — Сбор логов и нормализация (логшиппер)
- **Splunk** — Централизованная платная платформа для анализа логов
- **Graylog** — Realtime поиск и визуализация логов
- **OSSEC** — Хостовая IDS с анализом логов агента

 Шаг 09:

Миссия 9

Расположите этапы расследования инцидента безопасности по логам в правильном порядке:

1. Сбор логов с затронутых систем
2. Анализ временных последовательностей и корреляций
3. Формулировка гипотезы об атаке
4. Подтверждение фактов (сопоставление с IP, сессиями и т.д.)

Подсказка:

Сначала нужно собрать все данные, затем их проанализировать, потом сформулировать версию и подтвердить её.

Ответ:

- Сбор логов с затронутых систем
- Анализ временных последовательностей и корреляций
- Формулировка гипотезы об атаке
- Подтверждение фактов (сопоставление с IP, сессиями и т.д.)

 Шаг 10:

Миссия 10

Расположите шаги реакции на обнаруженную компрометацию (по логам):

1. Изолировать атакованный узел
2. Извлечь логи для анализа
3. Уведомить команду инцидентов
4. Восстановить систему из резервной копии

Подсказка:

Сначала изолируйте, чтобы остановить дальнейшее ущерб, затем собирайте данные, уведомляйте и восстанавливайте.

Ответ:

- Изолировать атакованный узел
- Извлечь логи для анализа
- Уведомить команду инцидентов
- Восстановить систему из резервной копии

 Шаг 11:

Миссия 11

Расположите уровни детализации логов от самого общего к самому детальному:

1. Информационный (info)
2. Отладочный (debug)
3. Критический (critical)
4. Предупреждение (warning)

Подсказка:

Отладочные логи — самые подробные, критические — самые серьёзные, предупреждение между ними.

Ответ:

- Информационный (info)
- Отладочный (debug)
- Критический (critical)
- Предупреждение (warning)

 Шаг 12:

Миссия 12

Расположите стадии построения системы реагирования на инциденты (через логи):

1. Определение сценариев атак (use cases)
2. Настройка корреляции и алертов
3. Сбор и хранение логов
4. Периодическая проверка и улучшения

Подсказка:

Сначала нужно знать, что искать, затем сконфигурировать, потом обеспечить сбор, и затем улучшать со временем.

Ответ:

- Определение сценариев атак (use cases)
- Настройка корреляции и алертов
- Сбор и хранение логов
- Периодическая проверка и улучшения

 Шаг 13:

Миссия 13

Расположите уровни доверия к источникам логов (от менее надёжного к более надёжному):

1. Логи клиента в браузере
2. Логи сетевого трафика (IDS/Firewall)
3. Серверные журналы приложений
4. Аппаратные логи гипервизора / ядра ОС

Подсказка:

Чем ближе к «железу», тем менее подвержен подделке.

Ответ:

- Логи клиента в браузере
- Логи сетевого трафика (IDS/Firewall)
- Серверные журналы приложений

- Аппаратные логи гипервизора / ядра ОС

🔗 Шаг 14:

Миссия 14

Расположите уровни реакции на алерты лог-система → эскалация:

1. Оператор рассматривает алерт
2. Киберкоманда получает уведомление
3. Автоматическое блокирование или карантин
4. Оператор подтверждает или отклоняет инцидент

Подсказка:

Сначала алерт приходит к оператору, потом он обрабатывает, затем эскалация и меры.

Ответ:

- Оператор рассматривает алерт
- Киберкоманда получает уведомление
- Автоматическое блокирование или карантин
- Оператор подтверждает или отклоняет инцидент

🔗 Шаг 15:

Миссия 15

Расположите этапы подготовки сценария атаки для тестирования лог-системы:

1. Выбор шаблонов атак (SQL, XSS, brute)
2. Генерация трафика и отправка запросов
3. Сбор логов и корректировка правил
4. Анализ детектируемости и доработка

Подсказка:

Сначала решите, что симулировать, потом запустите, соберите, проанализируйте и улучшите.

Ответ:

- Выбор шаблонов атак (SQL, XSS, brute)
- Генерация трафика и отправка запросов
- Сбор логов и корректировка правил
- Анализ детектируемости и доработка

🔗 Шаг 16:

Миссия 16

Расположите ключевые компоненты системы SIEM по пути данных (от источника к хранению):

1. Агенты на хостах / источники логов
2. Транспорт (syslog, forwarder, шина)
3. Нормализация / корреляция (корреляционный движок)
4. Хранилище / аналитика / визуализация

Подсказка:

Логи проходят путь: от источников через транспорт к движку, потом хранятся и анализируются.

Ответ:

- Агенты на хостах / источники логов

- Транспорт (syslog, forwarder, шина)
- Нормализация / корреляция (корреляционный движок)
- Хранилище / аналитика / визуализация

Урок 14 - Проведение фишинговых симуляций (учебно)

Шаг 01:

Миссия 1

Алекс решил отправить учебное письмо-комплимент коллеге, но не уверен, безопасно ли вставлять ссылку на сайт проекта. Что ему выбрать?

Подсказка: проверьте, ведёт ли ссылка на официальный домен, а не на подменённый.

Ответ:

- **Использовать ссылку только после проверки домена**
- Отправить ссылку без проверки
- Написать письмо без ссылки

Шаг 02:

Миссия 2

Беккер хочет создать фишинговую симуляцию для сотрудников компании. С чего начать?

Подсказка: сначала нужно подготовить сценарий и разрешение руководства.

Ответ:

- **Согласовать сценарий с руководством**
- Сразу рассылать письма
- Не уведомлять никого

Шаг 03:

Миссия 3

Во время симуляции Лена обнаружила подозрительный ответ от «сотрудника». Что делать?

Подсказка: не поддаваться на цепочку, остановите коммуникацию.

Ответ:

- **Прекратить переписку и уведомить команду безопасности**
- Продолжать тестировать доверие
- Спросить контактные данные

Шаг 04:

Миссия 4

 Задача: Сопоставьте этап симуляции фишинга с его назначением.

Этапы:

Ответ:

- Планирование сценария
- Создание письма-ловушки
- Отслеживание переходов
- Анализ итогов и отчёт

Назначения:

1. Выяснить, кто нажал ссылку
2. Описать результаты и рекомендации
3. Придумать цель и подход
4. Сформировать текст и медиа

Подсказка: этапы логично следуют: сначала идея, потом реализация, потом сбор данных, потом отчёт.

- **Планирование сценария** — Придумать цель и подход
- **Создание письма-ловушки** — Сформировать текст и медиа
- **Отслеживание переходов** — Выяснить, кто нажал ссылку
- **Анализ итогов и отчёт** — Описать результаты и рекомендации

Шаг 05:

Миссия 5

 Задача: Сопоставьте показатель и его значение в симуляции.

Показатели:

Ответ:

- Кликабельность
- Процент открытия письма
- Процент ввода данных
- Процент жалоб на спам

Значения:

1. Сколько людей ввели учётные данные
2. Сколько получили письмо и кликнули ссылку
3. Сколько получили письмо и открыли его
4. Сколько пожаловались, что это спам

Подсказка: кликабельность учитывает только тех, кто перешёл по ссылке.

- **Кликабельность** — Сколько получили письмо и кликнули ссылку
- **Процент открытия письма** — Сколько получили письмо и открыли его
- **Процент ввода данных** — Сколько людей ввели учётные данные
- **Процент жалоб на спам** — Сколько пожаловались, что это спам

Шаг 06:

Миссия 6

 Задача: Сопоставьте риск с уязвимостью, которая его порождает.

Риски:

Ответ:

- Кража пароля
- Утечка конфиденциальной информации
- Вредоносная программа на устройстве
- Нарушение доверия сотрудников

Уязвимости:

1. Переход по фишинговой ссылке

2. Заполнение формы с данными
3. Запуск вложения .exe-файла
4. Публичное разглашение результатов команды безопасности

Подсказка: подумайте, какая уязвимость приводит к какому риску.

- **Кража пароля** — Переход по фишинговой ссылке
- **Утечка конфиденциальной информации** — Заполнение формы с данными
- **Вредоносная программа на устройстве** — Запуск вложения .exe-файла
- **Нарушение доверия сотрудников** — Публичное разглашение результатов команды безопасности

Шаг 07:

Миссия 7

Расположите шаги фишинговой симуляции по порядку:

1. Отчёт и рекомендации
2. Сбор откликов и переходов
3. Создание письма-ловушки
4. Утверждение сценария

Подсказка: сначала утверждение, затем реализация, потом сбор данных и анализ.

Ответ:

- Утверждение сценария
- Создание письма-ловушки
- Сбор откликов и переходов
- Отчёт и рекомендации

Шаг 08:

Миссия 8

Расположите правила подготовки письма-ловушки в логическом порядке:

1. Добавить уместное обращение по имени
2. Проверить ссылки на корректность адресов
3. Упомянуть срочность и действие
4. Убедиться, что письмо похоже на штатное рассылку

Подсказка: сначала — стиль, потом содержание, потом ссылки, затем финальный контроль.

Ответ:

- Убедиться, что письмо похоже на штатное рассылку
- Добавить уместное обращение по имени
- Упомянуть срочность и действие
- Проверить ссылки на корректность адресов

Шаг 09:

Миссия 9

Расположите шаги реагирования после симуляции:

1. Уведомление участников о цели
2. Сравнение с KPI безопасности

3. Обратная связь и обучение
4. Подготовка отчёта с результатами

Подсказка: сначала анализ, затем коммуникация, потом обучение.

Ответ:

- Подготовка отчёта с результатами
- Сравнение с KPI безопасности
- Уведомление участников о цели
- Обратная связь и обучение

Шаг 10:

Миссия 10

Расположите виды взаимодействия в симуляции по степени риска (от меньшего к большему):

1. Открытие письма
2. Переход по ссылке без ввода данных
3. Ввод данных в форму
4. Скачивание вложения

Подсказка: риск возрастающий: от пассивного к активному действию.

Ответ:

- Открытие письма
- Переход по ссылке без ввода данных
- Ввод данных в форму
- Скачивание вложения

Шаг 11:

Миссия 11

Ваша симуляция показывает высокий процент жалоб «спам». Что стоит пересмотреть в письме?

Подсказка: проверьте тему письма и характер обращения — не слишком агрессивно.

Ответ:

- **Смягчить заголовок и тон обращения**
- Добавить больше ссылок
- Уменьшить шрифт письма

Шаг 12:

Миссия 12

Менеджер просит скрыть результаты симуляции от сотрудников до финала. Это этично?

Подсказка: прозрачность важна, но детали стоит обдумать.

Ответ:

- **Не скрывать факты, но отложить публикацию деталей до обучения**
- Скрыть всё результаты навсегда
- Опубликовать результаты незамедлительно

Шаг 13:

Миссия 13

 **Задача:** Сопоставьте характер фишинг-атаки с примером текста письма.

Характер атаки:

Ответ:

- Имитация IT-службы
- Имитация HR или менеджера
- Подарочная акция
- Обновление учётной записи

Примеры:

1. «Ваш аккаунт будет заблокирован, подтвердите логин»
2. «Пожалуйста, заполните анкету как сотрудник HR»
3. «Поздравляем! Вы выиграли подарочную карту»
4. «IT: требуется смена пароля»

Подсказка: обратите внимание на стиль обращения и тематику.

- **Имитация IT-службы** — «IT: требуется смена пароля»
- **Имитация HR или менеджера** — «Пожалуйста, заполните анкету как сотрудник HR»
- **Подарочная акция** — «Поздравляем! Вы выиграли подарочную карту»
- **Обновление учётной записи** — «Ваш аккаунт будет заблокирован, подтвердите логин»

Шаг 14:

Миссия 14

 **Задача:** Сопоставьте тип защиты с действием при фишинг-симуляции.

Тип защиты:

Ответ:

- Антифишинг-фильтр
- Обучение сотрудников
- Многофакторная аутентификация
- Мониторинг активности

Действия:

1. Ограничение доступа без MFA
2. Анализ логов переходов и кликов
3. Проверка писем через антифишинг-систему
4. Тренинг и тесты для персонала

Подсказка: подумайте, какой метод предотвращает, а какой — обнаруживает.

- **Антифишинг-фильтр** — Проверка писем через антифишинг-систему
- **Обучение сотрудников** — Тренинг и тесты для персонала
- **Многофакторная аутентификация** — Ограничение доступа без MFA
- **Мониторинг активности** — Анализ логов переходов и кликов

Шаг 15:

Миссия 15

Расположите стадии подготовки отчёта по симуляции от начала до конца:

1. Сравнение полученных данных с целями

2. Сбор необработанных логов и метрик
3. Выработка рекомендаций
4. Формирование итогового документа и презентации

Подсказка: сначала сбор, затем анализ, потом рекомендации и оформление.

Ответ:

- Сбор необработанных логов и метрик
- Сравнение полученных данных с целями
- Выработка рекомендаций
- Формирование итогового документа и презентации

Шаг 16:

Миссия 16

Расположите пункты реагирования на сотрудника, который «запал» (ввёл данные) в правильном порядке:

1. Обратная связь и объяснение риска
2. Проверка, не был ли скомпрометирован аккаунт
3. Блокировка сессий и принудительный сброс пароля
4. Информирование сотрудника о гипотетической симуляции

Подсказка: сначала реагируем технически, затем коммуникация, затем обучение.

Ответ:

- Проверка, не был ли скомпрометирован аккаунт
- Блокировка сессий и принудительный сброс пароля
- Обратная связь и объяснение риска
- Информирование сотрудника о гипотетической симуляции

Шаг 17:

Миссия 17

Расположите этапы эволюции фишинговой симуляции в компании по скорости зрелости от начального к продвинутому:

1. Случайные рассылки новичкам
2. Целенаправленные сценарии для отделов
3. Автоматизированные кампании с A/B тестами
4. Интеграция с обучающим порталом и персонализированный подход

Подсказка: подумайте, как меняется подход от простого к комплексному.

Ответ:

- Случайные рассылки новичкам
- Целенаправленные сценарии для отделов
- Автоматизированные кампании с A/B тестами
- Интеграция с обучающим порталом и персонализированный подход

Урок 15 - Безопасность IoT и умных устройств

Шаг 01:

Миссия 1

Инженер Илья купил «умную розетку», и она сразу попросила сменить пароль. Что он должен сделать в первую очередь?

Подсказка: использовать заводские настройки — не всегда безопасно.

Ответ:

- **Установить уникальный надёжный пароль**
- Оставить пароль по умолчанию
- Выключить устройство навсегда

Шаг 02:

Миссия 2

Разработчица Мария хочет подключить камеру видеонаблюдения к своей домашней сети. Какой порт указать для удалённого доступа?

Подсказка: не используйте стандартные порты по умолчанию.

Ответ:

- **Выбрать нестандартный порт, например 5543**
- Оставить порт по умолчанию
- Использовать порт 80

Шаг 03:

Миссия 3

Пётр заметил, что прошивка умного светильника давно не обновлялась. Что ему целесообразно сделать?

Подсказка: обновления закрывают уязвимости.

Ответ:

- **Проверить сайт производителя и обновить прошивку**
- Игнорировать, если устройство работает
- Откатить на старую прошивку

Шаг 04:

Миссия 4

 Задача: Сопоставьте угрозу и способ её проявления в умных устройствах.

Угрозы:

Ответ:

- Неавторизованный доступ
- Сниффинг трафика
- Подмена прошивки
- DDOS-атака через бот-сеть

Проявления:

1. Получение root-доступа к устройству
2. Прослушивание передаваемых данных
3. Загрузка вредоносного кода в устройство
4. Использование устройств для массовых запросов

Подсказка: подумайте, как злоумышленник может использовать каждую угрозу.

- **Неавторизованный доступ** — Получение root-доступа к устройству
- **Сниффинг трафика** — Прослушивание передаваемых данных
- **Подмена прошивки** — Загрузка вредоносного кода в устройство
- **DDOS-атака через бот-сеть** — Использование устройств для массовых запросов

Шаг 05:

Миссия 5

 Задача: Сопоставьте стандарт или протокол с его ролью в безопасности IoT.

Протоколы/стандарты:

Ответ:

- MQTT over TLS
- DTLS
- OAuth2
- Zigbee комиссия ключей

Роли:

1. Шифрование транспортного канала
2. Аутентификация устройств
3. Защита датаграмм
4. Управление разрешениями

Подсказка: представьте, какой протокол что защищает.

- **MQTT over TLS** — Шифрование транспортного канала
- **DTLS** — Защита датаграмм
- **OAuth2** — Управление разрешениями
- **Zigbee комиссия ключей** — Аутентификация устройств

Шаг 06:

Миссия 6

Расположите шаги безопасного подключения нового IoT-устройства:

1. Установка устройства в сеть
2. Обновление прошивки
3. Создание и ввод уникального пароля
4. Ограничение доступа к устройству из внешней сети

Подсказка: сначала физическое подключение, затем защита и настройки.

Ответ:

- Установка устройства в сеть
- Обновление прошивки
- Создание и ввод уникального пароля
- Ограничение доступа к устройству из внешней сети

Шаг 07:

Миссия 7

Расположите уровни безопасности для домашней IoT-сети:

1. Сегментация устройств (VLAN)
2. Шифрование каналов
3. Аутентификация и авторизация
4. Обнаружение аномалий и мониторинг

Подсказка: сначала фундамент, затем анализ.

Ответ:

- Аутентификация и авторизация
- Шифрование каналов
- Сегментация устройств (VLAN)
- Обнаружение аномалий и мониторинг

Шаг 08:

Миссия 8

Расположите сценарии атаки от наиболее простого к наиболее сложному:

1. Сканирование открытых портов
2. Подмена DNS в маршрутизаторе
3. Атака MITM между устройствами
4. Комплексная ботнет-атака через множество устройств

Подсказка: сложность и уровень контроля растут.

Ответ:

- Сканирование открытых портов
- Подмена DNS в маршрутизаторе
- Атака MITM между устройствами
- Комплексная ботнет-атака через множество устройств

Шаг 09:

Миссия 9

Расположите этапы реагирования на взлом умного устройства:

1. Изоляция устройства от сети
2. Анализ журнала событий
3. Принудительное обновление/восстановление прошивки
4. План по предупреждению для аналогичных устройств

Подсказка: сначала остановка атаки, потом анализ, восстановление и меры.

Ответ:

- Изоляция устройство от сети
- Анализ журнала событий
- Принудительное обновление/восстановление прошивки
- План по предупреждению для аналогичных устройств

Шаг 10:

Миссия 10

Инженер Сергей хочет подключить устройство к облачному сервису через API без шифрования (http). Это безопасно?

Подсказка: передаваемые данные могут быть перехвачены.

Ответ:

- **Нет** — нужно использовать HTTPS (TLS)
- **Да** — если API-ключ простой
- Неважно, сеть локальная

Шаг 11:

Миссия 11

Марина хочет интегрировать умный дом с голосовым ассистентом. Что нужно предусмотреть с точки зрения безопасности?

Подсказка: голосовой интерфейс — канал, который могут слушать.

Ответ:

- **Ограничить команды и аудиорежимы**
- Оставить все функции по умолчанию
- Отключить голосовой ассистент

Шаг 12:

Миссия 12

 Задача: Сопоставьте меры безопасности IoT с их преимуществом.

Меры:

Ответ:

- Сегментация сети
- Ограничение исходящего трафика
- Регулярные обновления безопасности
- Мониторинг и уведомления о сменах конфигурации

Преимущества:

1. Быстрое обнаружение подозрительной активности
2. Предотвращение злоупотреблений устройством извне
3. Уменьшение риска проникновения между сегментами сети
4. Устранение известных уязвимостей

Подсказка: рассмотрите, какой контроль даёт каждая мера.

- **Сегментация сети** — Уменьшение риска проникновения между сегментами сети
- **Ограничение исходящего трафика** — Предотвращение злоупотреблений устройством извне
- **Регулярные обновления безопасности** — Устранение известных уязвимостей
- **Мониторинг и уведомления о сменах конфигурации** — Быстрое обнаружение подозрительной активности

Шаг 13:

Миссия 13

 Задача: Сопоставьте угрозу на уровне связи и защиту от неё:

Угрозы:

Ответ:

- Перехват трафика
- Атака повторного воспроизведения (replay)
- Атака посредника (MITM)
- Подмена DNS

Защиты:

1. Шифрование и проверка целостности
2. Временные метки и nonce
3. Сертификаты и проверка подлинности
4. DNSSEC или защита DNS-запросов

Подсказка: вспомните методы защиты транспортного уровня.

- **Перехват трафика** — Шифрование и проверка целостности
- **Атака повторного воспроизведения (replay)** — Временные метки и nonce
- **Атака посредника (MITM)** — Сертификаты и проверка подлинности
- **Подмена DNS** — DNSSEC или защита DNS-запросов

 Шаг 14:

Миссия 14

Расположите уровни зрелости безопасности IoT в организации от начального к продвинутому:

1. Единичные устройства с минимальной защитой
2. Базовая защита и контроль
3. Проактивный мониторинг и реагирование
4. Автоматизация безопасности и интеграция

Подсказка: подумайте, как организация проходит путь от простого к автоматическому.

Ответ:

- Единичные устройства с минимальной защитой
- Базовая защита и контроль
- Проактивный мониторинг и реагирование
- Автоматизация безопасности и интеграция

 Шаг 15:

Миссия 15

Расположите этапы аудита безопасности IoT-сети:

1. Инвентаризация устройств
2. Оценка уязвимостей
3. Тестирование эксплойтов (без вреда)
4. Отчёт и рекомендации по защите

Подсказка: сначала узнать, что есть, потом искать слабые места, тестировать и рекомендовать.

Ответ:

- Инвентаризация устройств
- Оценка уязвимостей
- Тестирование эксплойтов (без вреда)
- Отчёт и рекомендации по защите

Шаг 16:

Миссия 16

Расположите этапы внедрения безопасной IoT-инфраструктуры:

1. Проектирование с учётом безопасности
2. Реализация и настройка
3. Тестирование и аудит
4. Поддержка и обновления

Подсказка: сначала план, потом реализация, тесты и сопровождение.

Ответ:

- Проектирование с учётом безопасности
- Реализация и настройка
- Тестирование и аудит
- Поддержка и обновления

Урок 16 - Основы облачной безопасности (AWS, GCP)

Шаг 01:

Миссия 1

Вы — инженер-облачник, и ваша задача — выбрать правильный метод для управления доступом к S3 бакету в AWS. Что вы выберете?

Подсказка: Подумайте о наименьших привилегиях и встроенных механизмах управления доступом.

Ответ:

- **Использовать IAM-политику, ограниченную конкретным бакетом**
- Открыть бакет всем пользователям
- Не задавать политику и полагаться на дефолтные права

Шаг 02:

Миссия 2

Вы работаете с GCP и хотите, чтобы виртуальная машина могла читать файлы из Cloud Storage только в рамках проекта. Какой механизм вы примените?

Подсказка: В GCP есть связка ролей и сервисных аккаунтов.

Ответ:

- **Привязать сервисный аккаунт с ролью Storage Reader к VM**
- Разрешить доступ всем анонимным пользователям
- Создать внешний аккаунт и вручную копировать ключи

Шаг 03:

Миссия 3

Вы настраиваете VPC в AWS, и вам нужно разрешить доступ из вашего приложения к RDS базе данных в другом подсети. Что вы сделаете?

Подсказка: Подумайте про безопасность и межсубнетный трафик.

Ответ:

- **Создать маршрут и настроить security group, разрешив трафик между подсетями**

- Открыть базу в публичном интернете
- Запретить весь трафик, надеясь, что сервис сам пройдёт туннель

🔗 Шаг 04:

Миссия 4

Вы строите инфраструктуру в GCP и хотите ограничить, что администратор проекта может делать с ресурсами. Какой механизм вы используете?

Подсказка: GCP имеет модели IAM с ролями на уровне проекта и ресурсом.

Ответ:

- **Назначить кастомную роль с минимальным набором разрешений**
- Дать роль Owner без ограничений
- **Не назначать роли** — использовать дефолтные права

🔗 Шаг 05:

Миссия 5

В AWS вы хотите, чтобы EC2-инстанс мог получать временные credenшелы, не храня секреты на нём. Что использовать?

Подсказка: Используйте службы, которые сами управляют ролями для инстансов.

Ответ:

- **Использовать IAM Role привязанную к EC2 (Instance Profile)**
- Хранить IAM ключи прямо на машине
- Просить пользователя вводить пароль вручную

🔗 Шаг 06:

Миссия 6

Сопоставьте сервис облака с ключевой функцией безопасности.

Сервисы:

Ответ:

- AWS IAM
- GCP VPC Service Controls
- AWS KMS
- GCP Cloud IAM

Функции:

1. Управление шифрованием ключей
2. Контроль доступа на уровне роли и ресурса
3. Ограничение доступа к сервисам по сетевому периметру
4. Централизованное управление идентификацией

Подсказка: Подумайте, какой сервис отвечает за ключи, а какой за видимость ресурсов.

- **AWS IAM** — Централизованное управление идентификацией
- **GCP Cloud IAM** — Контроль доступа на уровне роли и ресурса
- **AWS KMS** — Управление шифрованием ключей
- **GCP VPC Service Controls** — Ограничение доступа к сервисам по сетевому периметру

Шаг 07:

Миссия 7

Сопоставьте тип угрозы с сценарием в облаке.

Типы угроз:

Ответ:

- Неавторизованный доступ
- Утечка через хранилище
- Подмена роли
- Эксплойт уязвимости

Сценарии:

1. Хакер получает ключи IAM пользователя и изменяет данные
2. Бэкэнд-сервис читает данные из открытого бакета без проверки
3. Злоумышленник внедряется в контейнер и эскалирует роль
4. Машина в облаке с уязвимостью подвергается атаке

Подсказка: Обратите внимание на связь между угрозой и точкой входа.

- **Неавторизованный доступ** — Хакер получает ключи IAM пользователя и изменяет данные
- **Утечка через хранилище** — Бэкэнд-сервис читает данные из открытого бакета без проверки
- **Подмена роли** — Злоумышленник внедряется в контейнер и эскалирует роль
- **Эксплойт уязвимости** — Машина в облаке с уязвимостью подвергается атаке

Шаг 08:

Миссия 8

Сопоставьте термин с определением в контексте облачной безопасности.

Термины:

Ответ:

- Облако и доверие (shared responsibility)
- Zero Trust
- Encryption in transit
- Принцип наименьших привилегий

Определения:

1. Шифрование данных во время передачи по сети
2. Каждый компонент проверяется, даже внутри сети
3. Каждая сторона несёт часть ответственности за безопасность
4. Пользователю даются только минимально нужные права

Подсказка: Подумайте, как применяются эти термины при проектировании облака.

- **Облако и доверие (shared responsibility)** — Каждая сторона несёт часть ответственности за безопасность
- **Zero Trust** — Каждый компонент проверяется, даже внутри сети
- **Encryption in transit** — Шифрование данных во время передачи по сети
- **Принцип наименьших привилегий** — Пользователю даются только минимально нужные права

🔮 Шаг 09:

Миссия 9

Ваш друг-программист хочет хранить срочные резервные копии базы данных в облачном хранилище и делает её общедоступной. Вы предупреждаете, что это небезопасно. Как лучше сделать?

Подсказка: Доступность и безопасность — баланс.

Ответ:

- **Шифровать данные и ограничивать доступ по IAM**
- Оставлять общедоступным без шифрования
- Хранить локально без облака

🔮 Шаг 10:

Миссия 10

Сопоставьте AWS-сервисы с аналогичными GCP-сервисами по безопасности:

AWS:

Ответ:

- AWS Shield
- AWS CloudTrail
- AWS GuardDuty
- AWS WAF

GCP эквиваленты:

1. Cloud Armor
2. Cloud Audit Logs
3. Cloud IDS / Threat Detection
4. Cloud Web Security

Подсказка: Смотрите, что делает каждый сервис — защита, аудит, детектирование, защита веб-приложений.

- **AWS Shield** — Cloud Armor
- **AWS CloudTrail** — Cloud Audit Logs
- **AWS GuardDuty** — Cloud IDS / Threat Detection
- **AWS WAF** — Cloud Web Security

🔮 Шаг 11:

Миссия 11

Сопоставьте этап развития облачных атак с применяемыми методами защиты.

Этапы атаки:

Ответ:

- Разведка
- Установление точки входа
- Эскалация привилегий
- Движение внутри сети

Методы защиты:

1. Мониторинг логов и аномалий

2. Многофакторная аутентификация и ограничение прав
3. Сегментация сети и контроль маршрутов
4. Ограничение публичной информации о ресурсах

Подсказка: Представьте типичный путь атакующего и как его остановить.

- **Разведка** — Ограничение публичной информации о ресурсах
- **Установление точки входа** — Многофакторная аутентификация и ограничение прав
- **Эскалация привилегий** — Мониторинг логов и аномалий
- **Движение внутри сети** — Сегментация сети и контроль маршрутов

Шаг 12:

Миссия 12

Ваш аккаунт root AWS подвергся атаке, и вы хотите минимизировать риск в будущем. Что вы сделаете в первую очередь?

Подсказка: Подумайте о мастер-аккаунте и лучших практиках безопасности.

Ответ:

- **Включить MFA на root и создать отдельные админ-учётки**
- Использовать root для всех задач
- Удалить root-аккаунт

Шаг 13:

Миссия 13

Вы хотите использовать Cloud Audit Logs в GCP для отслеживания изменений доступа к Cloud Storage в проекте. Какую настройку вы примените?

Подсказка: Логирование может быть настроено на уровне ресурсов и услуг.

Ответ:

- **Включить аудит администрирования для Cloud Storage**
- Отключить все логи
- Логировать только чтение без изменений

Шаг 14:

Миссия 14

Расположите по порядку шаги реагирования на инцидент облачной безопасности:

1. Провести анализ логов и установить причину нарушения
2. Ограничить доступ затронутым ресурсам (изолировать)
3. Восстановить конфигурацию и средства защиты
4. Оповестить команду и начать расследование

Подсказка: Сначала блокируйте, затем анализируйте, потом восстанавливайте и оповещайте.

Ответ:

- Ограничить доступ затронутым ресурсам (изолировать)
- Провести анализ логов и установить причину нарушения
- Оповестить команду и начать расследование
- Восстановить конфигурацию и средства защиты

Шаг 15:

Миссия 15

Расположите действия по обеспечению безопасности хранилища (S3 или GCS) от начального до продвинутого уровня:

1. Шифрование данных на уровне сервиса
2. Внедрение DLP и сканирование содержимого
3. Ограничение сетевого доступа через VPC / Firewall
4. Управление доступом через IAM политики

Подсказка: Сначала базовые меры, потом укрепление.

Ответ:

- Шифрование данных на уровне сервиса
- Управление доступом через IAM политики
- Ограничение сетевого доступа через VPC / Firewall
- Внедрение DLP и сканирование содержимого

Шаг 16:

Миссия 16

Расположите шаги для безопасного удаления облачного ресурса:

1. Удалить конфиденциальные данные
2. Отозвать все роли и ключи доступа
3. Сделать итоговый снимок (snapshot) для архивации
4. Удалить сам ресурс

Подсказка: Действуйте от данных к ресурсам, не оставляя лазеек.

Ответ:

- Удалить конфиденциальные данные
- Отозвать все роли и ключи доступа
- Сделать итоговый снимок (snapshot) для архивации
- Удалить сам ресурс

Шаг 17:

Миссия 17

Расположите шаги построения защищённой облачной среды от начального к продвинутому:

1. Составить модель ответственности и границы доверия
2. Выстроить сеть (VPC, подсети, сегментация)
3. Настроить IAM и роли с принципом наименьших привилегий
4. Внедрить мониторинг, логирование и детектирование угроз

Подсказка: Сначала модель и границы, затем инфраструктура, потом доступ, потом наблюдение.

Ответ:

- Составить модель ответственности и границы доверия
- Выстроить сеть (VPC, подсети, сегментация)
- Настроить IAM и роли с принципом наименьших привилегий
- Внедрить мониторинг, логирование и детектирование угроз

Урок 17 - Социальная инженерия методы атак и защита

Шаг 01:

Миссия 1

Вы — молодой разработчик, получаете на почту письмо от «администратора компании», где просят срочно сменить пароль к рабочему аккаунту. Что вы сделаете?

Подсказка: Насторожитесь, если просят действовать немедленно через ссылку.

Ответ:

- **Не переходить по ссылке, а обратиться к ИТ-отделу напрямую**
- Немедленно ввести данные по ссылке, чтобы не наказали
- Игнорировать письмо и забыть о нём

Шаг 02:

Миссия 2

Коллега из HR просит вас передать список сотрудников с их телефонами, аргументируя, что «надо срочно отправить подарок». Вы подозреваете социальную инженерию. Что безопасно сделать?

Подсказка: Подумайте, должны ли вы делиться личными данными без проверки.

Ответ:

- **Уточнить через официальные каналы HR, не по почте**
- Отправить сразу, чтобы не обидеть
- Сказать, что вы не хотите помогать

Шаг 03:

Миссия 3

Вы получили звонок от «службы безопасности банка», вас просят назвать последние 4 цифры карты для проверки. Что вы отвечаете?

Подсказка: Используются ли банки такие проверки по телефону?

Ответ:

- **Заявить, что не передадите данные и положить трубку**
- Сообщить цифры, чтобы не выглядеть грубо
- Сразу спросить номер банковской карты для уточнения

Шаг 04:

Миссия 4

В Slack приходит сообщение от «генерального директора» с просьбой срочно перевести деньги. Адресат неизвестен. Что вы делаете?

Подсказка: В корпоративных мошенничествах часто используют подмену адреса.

Ответ:

- **Позвонить на проверенный номер директора и уточнить**
- Перевести, чтобы не провалять распоряжение
- Игнорировать сообщение и надеяться, что всё в порядке

Шаг 05:

Миссия 5

Вы участвуете в онлайн-конференции, и кто-то предлагает вам «ссылка для бонуса». В ней просят ввести логин и пароль. Как поступить?

Подсказка: Промо-ссылки часто маскируют фишинговые адреса.

Ответ:

- **Не вводить данные и проверить ссылку отдельно**
- Ввести, чтобы получить бонус
- Переслать всем знакомым, пусть попробуют

Шаг 06:

Миссия 6

Сопоставьте тип социальной инженерии с типичным признаком.

Типы:

Ответ:

- Фишинг
- Вишинг (voice phishing)
- Смишинг (SMS-фишинг)
- Примакинг (подход лично)

Признаки:

1. Письмо с ссылкой и просьбой ввести учетные данные
2. Звонок от «службы безопасности» с просьбой назвать данные
3. Сообщение SMS с фальшивым уведомлением банка
4. Кто-то подходит в офисе и просит пустить его как «техподдержку»

Подсказка: Сравните канал связи и характер обращения.

- **Фишинг** — Письмо с ссылкой и просьбой ввести учетные данные
- **Вишинг (voice phishing)** — Звонок от «службы безопасности» с просьбой назвать данные
- **Смишинг (SMS-фишинг)** — Сообщение SMS с фальшивым уведомлением банка
- **Примакинг (подход лично)** — Кто-то подходит в офисе и просит пустить его как «техподдержку»

Шаг 07:

Миссия 7

Сопоставьте мотив атакующего с социальной инженерией.

Мотивы:

Ответ:

- Финансовая выгода
- Получение секретной информации
- Урон репутации компании
- Испытание навыков (white-hat тест)

Сценарии:

1. Атакующий продаёт данные на чёрном рынке
2. Шпион запрашивает данные сотрудников разработки
3. Хакер публикует внутренние письма
4. Безопасник проводит тесты под прикрытием

Подсказка: Подумайте, зачем атакующему нужна цель.

- **Финансовая выгода** — Атакующий продаёт данные на чёрном рынке
- **Получение секретной информации** — Шпион запрашивает данные сотрудников разработки
- **Урон репутации компании** — Хакер публикует внутренние письма
- **Испытание навыков (white-hat тест)** — Безопасник проводит тесты под прикрытием

🔮 Шаг 08:

Миссия 8

Сопоставьте контрмеру социальной инженерии с её описанием.

Контрмеры:

Ответ:

- Обучение сотрудников
- Политика «запрос подтверждения»
- Фишинг-тесты
- Двухфакторная аутентификация

Описание:

1. Сотрудники регулярно проходят тренировки по распознаванию атак
2. Перед любым переводом или изменением запроса требуется устное подтверждение
3. Имитация атаки для проверки готовности команды
4. Даже если атакующий знает пароль, требуется второй фактор

Подсказка: Какие меры технические, какие поведенческие?

- **Обучение сотрудников** — Сотрудники регулярно проходят тренировки по распознаванию атак
- **Политика «запрос подтверждения»** — Перед любым переводом или изменением запроса требуется устное подтверждение
- **Фишинг-тесты** — Имитация атаки для проверки готовности команды
- **Двухфакторная аутентификация** — Даже если атакующий знает пароль, требуется второй фактор

🔮 Шаг 09:

Миссия 9

Сопоставьте признаки фишингового письма с объяснением.

Признаки:

Ответ:

- Ошибки в тексте
- Срочность и страх
- Необычный отправитель
- Подменённая ссылка (URL)

Объяснения:

- Автор письма просит действовать немедленно, чтобы избежать последствий
- Адрес отправителя похож, но содержит лишний символ
- Письмо содержит орфографические и пунктуационные ошибки
- Ссылка ведёт на адрес, отличный от видимого текста

Подсказка: Проверьте мелкие детали, они часто выдают мошенников.

- **Ошибки в тексте** — Письмо содержит орфографические и пунктуационные ошибки
- **Срочность и страх** — Автор письма просит действовать немедленно, чтобы избежать последствий
- **Необычный отправитель** — Адрес отправителя похож, но содержит лишний символ
- **Подменённая ссылка (URL)** — Ссылка ведёт на адрес, отличный от видимого текста

🔮 Шаг 10:

Миссия 10

Сопоставьте сценарий атаки с уязвимостью, которую она эксплуатирует.

Сценарии:

Ответ:

- Коллега в чат присылает «файл банка» как вложение
- Звонят и выдают себя за ИТ и просят установить ПО удалённо
- SMS с ссылкой на «ударуальный счёт» для восстановления пароля
- В офис пришёл человек с бейджем, говорит, что пришёл исправлять принтер

Уязвимости:

1. Отсутствие проверки вложений (attachment handling)
2. Отсутствие проверок личности вызывающего
3. Недостаточная фильтрация SMS-ссылок
4. Недостаточный контроль физического доступа

Подсказка: Свяжите форму атаки и точку слабости.

- **Коллега в чат присылает «файл банка» как вложение** — Отсутствие проверки вложений (attachment handling)
- **Звонят и выдают себя за ИТ и просят установить ПО удалённо** — Отсутствие проверок личности вызывающего
- **SMS с ссылкой на «ударуальный счёт» для восстановления пароля** — Недостаточная фильтрация SMS-ссылок
- **В офис пришёл человек с бейджем, говорит, что пришёл исправлять принтер** — Недостаточный контроль физического доступа

🔮 Шаг 11:

Миссия 11

Расположите шаги расследования подозрительного письма от фишера:

1. Изолировать письмо и не отвечать
2. Проанализировать заголовки и URL
3. Сообщить в службу безопасности
4. Удалить вредоносный вложение или ссылку

Подсказка: Сначала изоляция, потом анализ, потом сообщение и удаление.

Ответ:

- Изолировать письмо и не отвечать
- Проанализировать заголовки и URL
- Сообщить в службу безопасности
- Удалить вредоносный вложение или ссылку

Шаг 12:

Миссия 12

Расположите элементы политики по защите от социальной инженерии от базовых к усиленным:

1. Регулярные инструкции по безопасности
2. Обязательное подтверждение переводов (звонок)
3. Проведение фишинг-тестов
4. Использование средств DLP и фильтра писем

Подсказка: Сначала общие меры, затем контролирующие и технические.

Ответ:

- Регулярные инструкции по безопасности
- Обязательное подтверждение переводов (звонок)
- Проведение фишинг-тестов
- Использование средств DLP и фильтра писем

Шаг 13:

Миссия 13

Расположите этапы реагирования на успешную атаку социальной инженерии:

1. Отключить все подозрительные соединения
2. Изъять украденные данные или доступы
3. Уведомить сотрудников и руководство
4. Провести аудит и пересмотреть процедуры

Подсказка: Действуйте: сперва остановите, затем корректируйте и анализируйте.

Ответ:

- Отключить все подозрительные соединения
- Изъять украденные данные или доступы
- Уведомить сотрудников и руководство
- Провести аудит и пересмотреть процедуры

Шаг 14:

Миссия 14

Расположите слои защиты от социальной инженерии от внешнего к внутреннему:

1. Технические барьеры (антивирус, фильтрация писем)
2. Процедуры и политика (подтверждение операций)
3. Человеческий фактор (обучение сотрудников)
4. Мониторинг и реагирование (логирование, анализ)

Подсказка: Защита строится как лук: внешние слои затем внутренняя защита.

Ответ:

- Технические барьеры (антивирус, фильтрация писем)
- Процедуры и политика (подтверждение операций)
- Человеческий фактор (обучение сотрудников)
- Мониторинг и реагирование (логирование, анализ)

Шаг 15:

Миссия 15

Расположите шаги построения устойчивой культуры безопасности против социальной инженерии:

1. Оценить текущую уязвимость сотрудников
2. Внедрить обучающие программы и тесты
3. Разработать и внедрить политики реагирования
4. Постоянно анализировать инциденты и обновлять меры

Подсказка: Начинайте с диагностики, затем обучение, правила и постоянное совершенствование.

Ответ:

- Оценить текущую уязвимость сотрудников
- Внедрить обучающие программы и тесты
- Разработать и внедрить политики реагирования
- Постоянно анализировать инциденты и обновлять меры

Шаг 16:

Миссия 16

Расположите этапы внедрения защиты от социальной инженерии от подготовки до оценки:

1. Определить зоны риска и аудит каналов коммуникации
2. Разработать политику и процедуры безопасности
3. Обучить сотрудников и провести фишинг-тесты
4. Анализировать эффективность и обновлять меры

Подсказка: Следуйте циклу PDCA (план – делать – проверка – действие).

Ответ:

- Определить зоны риска и аудит каналов коммуникации
- Разработать политику и процедуры безопасности
- Обучить сотрудников и провести фишинг-тесты
- Анализировать эффективность и обновлять меры

Урок 18 - Разработка политики информационной безопасности

Шаг 01:

Миссия 1

Ваша команда-разработчик готовится к выпуску крупного проекта, и вы как специалист по безопасности должны предложить первую версию политики информационной безопасности. Что вы сделаете в первую очередь?

Подсказка: Начинать всегда с анализа и определения границ.

Ответ:

- Провести оценку рисков и определить критичные активы
- Сразу прописать штрафы за нарушения
- Опубликовать политику в общий канал Slack
- Назначить ответственного, не проводя анализ

Шаг 02:

Миссия 2

Вы провели оценку рисков и определили несколько сценариев утечки данных. Что наиболее важно включить в политику безопасности прежде всего?

Подсказка: Без базовых правил доступа всё остальное будет бесполезно.

Ответ:

- **Роли и права доступа к системам и данным**
- Политику обработки контента в соцсетях
- Инструкции для завершающих сотрудников
- Утилиты для мониторинга сети

Шаг 03:

Миссия 3

Менеджмент спрашивает: «А зачем нам периодически пересматривать политику?» Какой аргумент вы приведёте?

Подсказка: Угрозы меняются быстрее, чем правила пишутся.

Ответ:

- **Потому что появляются новые угрозы и меняются технологии**
- Чтобы показывать, что мы заняты
- Чтобы каждый сотрудник переписывал политику
- Чтобы увеличить нагрузку на ИТ-отдел

Шаг 04:

Миссия 4

Вы хотите, чтобы сотрудники следовали политике, а не пренебрегали ей. Что из ниже поможет повысить приверженность?

Подсказка: Обучение, вовлечение и понятность — ключевые факторы.

Ответ:

- **Провести тренинги и разъяснительные сессии**
- Принудительно подписать без обсуждения
- Скрыть политику от сотрудников
- Объявить штрафы без предупреждения

Шаг 05:

Миссия 5

Сопоставьте разделы политики безопасности с их назначением:

Разделы политики:

Ответ:

- Управление доступом
- Управление инцидентами
- Резервное копирование и восстановление
- Обучение и осведомлённость

Назначения:

1. Как сотрудники узнают о правилах и угрозах

2. Как реагировать на нарушения и атаки
3. Как обеспечивать доступ к ресурсам и разграничивать права
4. Как сохранять и восстанавливать данные

Подсказка: Разделы — это как инструкции для разных жизненных ситуаций.

- **Управление доступом** — Как обеспечивать доступ к ресурсам и разграничивать права
- **Управление инцидентами** — Как реагировать на нарушения и атаки
- **Резервное копирование и восстановление** — Как сохранять и восстанавливать данные
- **Обучение и осведомлённость** — Как сотрудники узнают о правилах и угрозах

Шаг 06:

Миссия 6

Сопоставьте тип риска полиси (угроза) и подходящее средство контроля:

Угрозы:

Ответ:

- Несанкционированный доступ
- Ошибки сотрудников
- Аппаратный сбой
- Социальная инженерия

Контроли:

1. Процедуры резервного копирования и отказоустойчивость
2. Обязательное обучение безопасности и тренинги фишинга
3. Многофакторная аутентификация и разграничение прав
4. Политика проверок и проверка разрешений

Подсказка: Каждая угроза проще побеждается конкретным средством, не универсальным.

- **Несанкционированный доступ** — Многофакторная аутентификация и разграничение прав
- **Ошибки сотрудников** — Обязательное обучение безопасности и тренинги фишинга
- **Аппаратный сбой** — Процедуры резервного копирования и отказоустойчивость
- **Социальная инженерия** — Политика проверок и проверка разрешений

Шаг 07:

Миссия 7

Сопоставьте актёров и их обязанности при внедрении политики:

Актёры:

Ответ:

- Тор-менеджмент
- Ответственный по безопасности (CISO)
- Руководитель подразделения
- Обычный сотрудник

Обязанности:

1. Соблюдать правила и сообщать о нарушениях
2. Утверждать политику и выделять ресурсы
3. Внедрять политику в подразделении и контролировать исполнение

4. Разрабатывать и обновлять политику, координировать контроль

Подсказка: Подумайте: кто принимает решения, кто исполняет, кто контролирует.

- **Тор-менеджмент** — Утверждать политику и выделять ресурсы
- **Ответственный по безопасности (CISO)** — Разрабатывать и обновлять политику, координировать контроль
- **Руководитель подразделения** — Внедрять политику в подразделении и контролировать исполнение
- **Обычный сотрудник** — Соблюдать правила и сообщать о нарушениях

Шаг 08:

Миссия 8

Сопоставьте формат документа политики с его характерной чертой:

Форматы:

Ответ:

- Высокоуровневая политика (свод принципов)
- Стратегическая политика
- Оперативная политика (процедуры и инструкции)
- Стандарты безопасности

Характерные черты:

1. Детализированные шаги и инструкции для повседневных задач
2. Общие принципы и обязательства организации
3. Требования, измеримые и проверяемые правила
4. Связь высокоуровневой цели с конкретными направлениями

Подсказка: Представьте иерархию — от принципов к деталям.

- **Высокоуровневая политика (свод принципов)** — Общие принципы и обязательства организации
- **Стратегическая политика** — Связь высокоуровневой цели с конкретными направлениями
- **Оперативная политика (процедуры и инструкции)** — Детализированные шаги и инструкции для повседневных задач
- **Стандарты безопасности** — Требования, измеримые и проверяемые правила

Шаг 09:

Миссия 9

Расположите этапы создания политики информационной безопасности в правильном порядке:

1. Разработка черновика политики
2. Обратная связь от заинтересованных сторон
3. Утверждение документа руководством
4. Мониторинг выполнения и пересмотр
5. Оценка рисков и определение области действия

Подсказка: Начинайте с анализа и заканчивайте проверкой исполнения.

Ответ:

- Оценка рисков и определение области действия
- Разработка черновика политики

- Обратная связь от заинтересованных сторон
- Утверждение документа руководством
- Мониторинг выполнения и пересмотр

Шаг 10:

Миссия 10

Расположите шаги реакции на инцидент безопасности, описанные в политике:

1. Оповещение ответственного лица
2. Сбор и анализ данных инцидента
3. Принятие мер по ограничению ущерба
4. Документирование и отчётность
5. Устранение причин и восстановление

Подсказка: Реакция — это не одно действие, а последовательность.

Ответ:

- Оповещение ответственного лица
- Сбор и анализ данных инцидента
- Принятие мер по ограничению ущерба
- Устранение причин и восстановление
- Документирование и отчётность

Шаг 11:

Миссия 11

Расположите стадии обучения сотрудников безопасности по политике:

1. Объявление темы и целей обучения
2. Проведение практических упражнений и кейсов
3. Оценка знаний (тесты, задания)
4. Обратная связь и корректировка курса
5. Подготовка материалов и планирования тренинга

Подсказка: Обучение — это план, реализация, оценка и доработка.

Ответ:

- Объявление темы и целей обучения
- Подготовка материалов и планирования тренинга
- Проведение практических упражнений и кейсов
- Оценка знаний (тесты, задания)
- Обратная связь и корректировка курса

Шаг 12:

Миссия 12

Расположите шаги пересмотра политики:

1. Сбор обратной связи и показателей
2. Анализ изменений в угрозах и технологиях
3. Обновление или корректировка документа
4. Утверждение изменений и публикация версии
5. Оповещение сотрудников и обучение обновлениям

Подсказка: Пересмотр — это постоянный цикл, а не разовый акт.

Ответ:

- Сбор обратной связи и показателей
- Анализ изменений в угрозах и технологиях
- Обновление или корректировка документа
- Утверждение изменений и публикация версии
- Оповещение сотрудников и обучение обновлениям

Шаг 13:

Миссия 14

В ходе аудита вы обнаружили, что у части пользователей есть устаревшие учетные записи, которые никто не удалил. Как отразить это в политике?

Подсказка: Важна регулярная ревизия учётных записей.

Ответ:

- **Включить периодическую проверку и удаление неактивных учётных записей**
- Игнорировать их, если никто не жаловался
- Скрыть информацию от аудиторов
- Оставить процесс ad hoc без формализации

Шаг 14:

Миссия 15

Сопоставьте документ политики и ключевые метрики (KPI) контроля:

Документы политики:

Ответ:

- Управление доступом
- Инцидент-менеджмент
- Обучение и осведомлённость
- Резервное копирование

Метрики:

1. Процент сотрудников, завершивших обучение
2. Среднее время реагирования на инцидент
3. Количество неавторизованных попыток доступа
4. Процент успешно восстановленных данных

Подсказка: KPI должны прямо измерять исполнение раздела политики.

- **Управление доступом** — Количество неавторизованных попыток доступа
- **Инцидент-менеджмент** — Среднее время реагирования на инцидент
- **Обучение и осведомлённость** — Процент сотрудников, завершивших обучение
- **Резервное копирование** — Процент успешно восстановленных данных

Шаг 15:

Миссия 16

Расположите этапы внедрения политики в подразделении:

1. Обсуждение с ключевыми сотрудниками подразделения

2. Публикация политики для сотрудников подразделения
3. Обучение и сессии вопросов-ответов
4. Мониторинг и контроль исполнения
5. Внесение корректировок на основе обратной связи

Подсказка: Начинайте с вовлечения, а не с приказа сверху.

Ответ:

- Обсуждение с ключевыми сотрудниками подразделения
- Публикация политики для сотрудников подразделения
- Обучение и сессии вопросов-ответов
- Мониторинг и контроль исполнения
- Внесение корректировок на основе обратной связи

Шаг 16:

Миссия 17

Расположите шаги полноценного цикла политики информационной безопасности:

1. Инициирование и планирование
2. Оценка рисков и область применения
3. Разработка и согласование
4. Внедрение и обучение
5. Мониторинг, аудит и пересмотр

Подсказка: Цикл похож на подход Plan-Do-Check-Act.

Ответ:

- Инициирование и планирование
- Оценка рисков и область применения
- Разработка и согласование
- Внедрение и обучение
- Мониторинг, аудит и пересмотр

Урок 19 - Резервное копирование и восстановление данных

Шаг 01:

Миссия 1

Аня, начинающий разработчик, узнала о важности регулярного бэкапа. Какой из вариантов является ****лучшим стартовым подходом**** для неё?

Подсказка: Начните с самого простого, но надёжного варианта.

Ответ:

- **Автоматический бэкап на внешний жёсткий диск**
- Запись копий на USB-флешку вручную
- **Не делать бэкап** — полагаться на облако

Шаг 02:

Миссия 2

Максим хочет настроить ****полный бэкап**** проекта раз в сутки. Какой вид резервной копии лучше всего подходит?

Подсказка: Полный бэкап включает ***все*** файлы и данные.

Ответ:

- **Полная копия всего проекта и базы данных**
- Инкрементальный бэкап
- Дифференциальный бэкап

Шаг 03:

Миссия 3

Олег планирует хранить резервные копии проекта на удалённом сервере через интернет. Что нужно учесть главным образом?

Подсказка: Сетевая передача — слабое место.

Ответ:

- **Шифрование данных при передаче (TLS/SSL)**
- Использование общего FTP без защиты
- Хранить копии без контроля доступа

Шаг 04:

Миссия 4

Для повышения надёжности Марина хочет сделать ****две независимые копии****: локальную и облачную. Что обязательно добавить к этой стратегии?

Подсказка: Проверьте живучесть бэкапов.

Ответ:

- **Регулярное тестовое восстановление из резервных копий**
- Хранить копии не более одного дня
- **Оставлять только одну копию** — суть минимализма

Шаг 05:

Миссия 5

Сопоставьте термины с их определениями в контексте резервного копирования.

Подсказка: Вспомните, что означает incremental и full.

Ответ:

- Полный бэкап (Full backup)
- Инкрементальный бэкап (Incremental backup)
- Дифференциальный бэкап (Differential backup)
- Точка восстановления (Restore point)

1. Копия всех данных в момент времени.
2. Сохраняются только изменения после последнего полного бэкапа.
3. Сохраняются изменения с момента последнего инкрементального бэкапа.
4. Метка времени, к которой можно вернуть систему.

- **Полный бэкап (Full backup)** — Копия всех данных в момент времени.
- **Инкрементальный бэкап (Incremental backup)** — Сохраняются изменения после последнего полного бэкапа.
- **Дифференциальный бэкап (Differential backup)** — Сохраняются изменения с момента последнего инкрементального бэкапа.
- **Точка восстановления (Restore point)** — Метка времени, к которой можно вернуть систему.

Шаг 06:

Миссия 6

Свяжите тип ошибки с риском при восстановлении данных.

Подсказка: Ошибки могут быть на уровне оборудования, ПО или человека.

Ответ:

- Физическое повреждение диска
 - Ошибка шифрования / ключ утрачен
 - Удаление нужного файла перед бэкапом
 - Сбой сети при передаче резервной копии
1. Резервная копия повреждена и не читаема
 2. Невозможно расшифровать данные
 3. Файл никогда не попал в бэкап
 4. Часть копии не передалась или повреждена
- **Физическое повреждение диска** — Резервная копия повреждена и не читаема
 - **Ошибка шифрования / ключ утрачен** — Невозможно расшифровать данные
 - **Удаление нужного файла перед бэкапом** — Файл никогда не попал в бэкап
 - **Сбой сети при передаче резервной копии** — Часть копии не передалась или повреждена

Шаг 07:

Миссия 7

Сопоставьте шаги стратегии 3-2-1 (3 копии, 2 носителя, 1 вне сайта) с их назначением.

Подсказка: Каждый элемент отвечает за защиту от разных сценариев риска.

Ответ:

- Три копии
 - Два разных носителя
 - Одна копия вне сайта
1. Защита от потери одной копии
 2. Снижение риска, что оба носителя выйдут из строя одновременно
 3. Защита от локальных катастроф (пожар, кража и т.п.)
- **Три копии** — Защита от потери одной копии
 - **Два разных носителя** — Снижение риска, что оба носителя выйдут из строя одновременно
 - **Одна копия вне сайта** — Защита от локальных катастроф (пожар, кража и т.п.)

Шаг 08:

Миссия 8

Сопоставьте реализации резервного копирования с их достоинствами.

Подсказка: Каждая модель полезна в разных сценариях.

Ответ:

- Резервное копирование на кассеты
- Хранение копий в облаке
- Сетевое хранилище NAS

- Локальный внешний диск

1. Подходит для офлайн-архивации, дешёвый носитель
2. Доступ из любой точки мира
3. Централизованное решение для офиса
4. Быстрый доступ и простота

- **Резервное копирование на кассеты** — Подходит для офлайн-архивации, дешёвый носитель
- **Хранение копий в облаке** — Доступ из любой точки мира
- **Сетевое хранилище NAS** — Централизованное решение для офиса
- **Локальный внешний диск** — Быстрый доступ и простота

Шаг 09:

Миссия 9

Расположите этапы создания резервной копии в правильном порядке:

1. Передача данных на удалённый сервер
2. Выбор данных для копирования
3. Шифрование копии
4. Хранение копии на целевых носителях

Подсказка: Сначала выбирают, потом готовят копию, потом передают и сохраняют.

Ответ:

- Выбор данных для копирования
- Шифрование копии
- Передача данных на удалённый сервер
- Хранение копии на целевых носителях

Шаг 10:

Миссия 10

Расположите шаги восстановления данных в логическом порядке:

1. Проверка целостности копии
2. Выбор точки восстановления
3. Восстановление файлов/БД
4. Тестирование восстановленных данных

Подсказка: Сначала выбираете, потом восстанавливаете, а в конце — проверяете.

Ответ:

- Выбор точки восстановления
- Проверка целостности копии
- Восстановление файлов/БД
- Тестирование восстановленных данных

Шаг 11:

Миссия 11

Расположите действия в процедуре аварийного восстановления:

1. Оценка повреждения

2. Запуск восстановительной среды
3. Запуск восстановления данных
4. Проверка функциональности системы

Подсказка: Сначала диагностируете, затем восстанавливаете, потом тестируете.

Ответ:

- Оценка повреждения
- Запуск восстановительной среды
- Запуск восстановления данных
- Проверка функциональности системы

Шаг 12:

Миссия 12

Расположите уровни RAID по степени отказоустойчивости (от меньшей к большей):

1. RAID 0
2. RAID 1
3. RAID 5
4. RAID 6

Подсказка: Без зеркал — низкая устойчивость, с контрольной информацией — выше.

Ответ:

- RAID 0
- RAID 1
- RAID 5
- RAID 6

Шаг 13:

Миссия 13

Расположите этапы автоматизации бэкапа в порядке внедрения:

1. Оповещение администратора о статусе бэкапа
2. Скрипт, собирающий файлы
3. Планировщик задач (cron / task scheduler)
4. Логирование результатов и ошибок

Подсказка: Автоматизация начинается со сборки, затем расписание, логирование и уведомления.

Ответ:

- Скрипт, собирающий файлы
- Планировщик задач (cron / task scheduler)
- Логирование результатов и ошибок
- Оповещение администратора о статусе бэкапа

Шаг 14:

Миссия 14

Расположите меры минимизации рисков при бэкапировании:

1. Разделение доступа к ключам

2. Регулярный аудит логов бэкапа
3. Шифрование копий
4. Хранение вне офиса

Подсказка: Начинайте с защиты ключей, затем контроль, шифрование и рассредоточение.

Ответ:

- Разделение доступа к ключам
- Регулярный аудит логов бэкапа
- Шифрование копий
- Хранение вне офиса

Шаг 15:

Миссия 15

Расположите фазы проверки надёжности бэкапов:

1. Периодическое тестовое восстановление
2. Сравнение контрольных сумм (hash) копий
3. Отчёт об обнаруженных ошибках
4. Анализ причин и исправление ошибок

Подсказка: Сначала проверяете, потом фиксируете и документируете.

Ответ:

- Сравнение контрольных сумм (hash) копий
- Периодическое тестовое восстановление
- Отчёт об обнаруженных ошибках
- Анализ причин и исправление ошибок

Шаг 16:

Миссия 16

Расположите элементы полного цикла резервного копирования и восстановления:

1. Планирование политики бэкапа
2. Создание резервных копий
3. Хранение и защита копий
4. Восстановление и проверка

Подсказка: Сперва думать, потом делать и хранить, а завершать — восстановлением.

Ответ:

- Планирование политики бэкапа
- Создание резервных копий
- Хранение и защита копий
- Восстановление и проверка

Урок 20 - Мини-проект симуляция атаки и защиты

Шаг 01:

Миссия 1

Иван разработчик только что получил задачу смоделировать атаку на тестовый сервер. С чего логично начать?

Подсказка: Начните с разведки — собрать информацию о цели безопасным способом.

Ответ:

- **Сбор информации о целевых хостах и сервисах (reconnaissance)**
- Запуск DoS-атаки сразу
- Удалённое исполнение кода без подготовки

🔮 Шаг 02:

Миссия 2

После разведки Ольга обнаружила открытые порты и версии сервисов. Что логично далее предпринять?

Подсказка: Ищите уязвимости по версии и сервису.

Ответ:

- **Сопоставить версии сервисов с известными уязвимостями (vulnerability lookup)**
- Игнорировать версии и сразу атаковать
- Удалять логи сервера

🔮 Шаг 03:

Миссия 3

Пётр хочет проникнуть в систему через уязвимость, но она защищена межсетевым экраном. Что безопасно попробовать первым?

Подсказка: Используйте лёгкие методы обхода, не шумящие сразу.

Ответ:

- **Попытка обхода с использованием нестандартных портов (port pivoting)**
- Массовый брутфорс
- Удалённый запуск шок-скриптов без разрешения

🔮 Шаг 04:

Миссия 4

Когда атака почти удалась, Надя задумала поставить backdoor. Что важно предусмотреть?

Подсказка: Backdoor должен быть устойчив, незаметен и с возможностью контроля.

Ответ:

- **Шифрованное соединение backdoor с командным сервером**
- Открытый незашифрованный порт backdoor
- Запись паролей в файл без маскировки

🔮 Шаг 05:

Миссия 5

После установки backdoor Игорь хочет быть уверенным, что его не заметят. Какое действие разумно предпринять?

Подсказка: Слежка за логами и очистка следов — важный элемент скрытности.

Ответ:

- **Очистка логов и маскировка следов активности**
- Оставить записи в логах для эксперимента
- Выключить систему целиком

Шаг 06:

Миссия 6

Сопоставьте стадии атаки с их описаниями.

Подсказка: Понимание жизненного цикла атаки помогает защите.

Ответ:

- Reconnaissance
 - Exploitation
 - Privilege escalation
 - Maintaining access
1. Сбор информации о системе и среде.
 2. Использование уязвимости для входа.
 3. Повышение прав до администратора.
 4. Установка механизмов устойчивого присутствия.
- **Reconnaissance** — Сбор информации о системе и среде.
 - **Exploitation** — Использование уязвимости для входа.
 - **Privilege escalation** — Повышение прав до администратора.
 - **Maintaining access** — Установка механизмов устойчивого присутствия.

Шаг 07:

Миссия 7

Сопоставьте типы уязвимостей с их примерами.

Подсказка: Вспомните SQL-инъекции, XSS, RCE и т.д.

Ответ:

- SQL-инъекция
 - Cross-Site Scripting (XSS)
 - Remote Code Execution (RCE)
 - Directory traversal
1. Внедрение SQL-запросов через параметры формы.
 2. Выполнение JavaScript в браузере жертвы.
 3. Запуск произвольного кода на сервере.
 4. Чтение файлов за пределами корня веб-сервера.
- **SQL-инъекция** — Внедрение SQL-запросов через параметры формы.
 - **Cross-Site Scripting (XSS)** — Выполнение JavaScript в браузере жертвы.
 - **Remote Code Execution (RCE)** — Запуск произвольного кода на сервере.
 - **Directory traversal** — Чтение файлов за пределами корня веб-сервера.

Шаг 08:

Миссия 8

Сопоставьте защитные меры с угрозами, которые они минимизируют:

Подсказка: Каждая мера наиболее эффективна против определённого типа атаки.

Ответ:

- WAF (Web Application Firewall)
- Принцип наименьших прав

- IDS/IPS
- Шифрование трафика (TLS)

1. Блокировка SQL и XSS атак на веб-приложение.
2. Минимизация ущерба, если злоумышленник получил доступ.
3. Обнаружение сетевых атак и аномалий.
4. Защита от прослушки канала между клиентом и сервером.

- **WAF (Web Application Firewall)** — Блокировка SQL и XSS атак на веб-приложение.
- **Принцип наименьших прав** — Минимизация ущерба, если злоумышленник получил доступ.
- **IDS/IPS** — Обнаружение сетевых атак и аномалий.
- **Шифрование трафика (TLS)** — Защита от прослушки канала между клиентом и сервером.

Шаг 09:

Миссия 9

Сопоставьте виды атак с фазами проекта защиты, когда их надо проверить:

При защите важно тестировать на реальных атаках.

Ответ:

- *SQLi тест*
- *Фазовый аудит кода*
- *Пентест перед релизом*
- *Непрерывный мониторинг*

1. Проверка на внедрение через форму.
2. Анализ безопасности во время разработки.
3. Атаки по завершении разработки до запуска.
4. Проверка и оповещение после запуска.

- **SQLi тест** — Проверка на внедрение через форму.
- **Фазовый аудит кода** — Анализ безопасности во время разработки.
- **Пентест перед релизом** — Атаки по завершении разработки до запуска.
- **Непрерывный мониторинг** — Проверка и оповещение после запуска.

Шаг 10:

Миссия 10

Расположите шаги подготовки к обороне в порядке их внедрения:

1. Внедрение WAF и фильтрация запросов
2. Аудит и устранение уязвимостей кода
3. Мониторинг и слежение за логами
4. Пострелизное тестирование (pentest)

Подсказка: Защита строится от кода к слежению, затем к тестам.

Ответ:

- Аудит и устранение уязвимостей кода
- Внедрение WAF и фильтрация запросов

- Мониторинг и слежение за логами
- Пострелизное тестирование (pentest)

Шаг 11:

Миссия 11

Расположите элементы цикла атаки-защиты (red teaming):

1. Планирование и постановка целей атаки
2. Реализация атаки и эскалация
3. Обнаружение и реагирование на атаку
4. Анализ результатов и корректировка защиты

Подсказка: Сперва план, затем атака, потом защита, затем уроки.

Ответ:

- Планирование и постановка целей атаки
- Реализация атаки и эскалация
- Обнаружение и реагирование на атаку
- Анализ результатов и корректировка защиты

Шаг 12:

Миссия 12

Расположите фазы реагирования на инцидент:

1. Обнаружение инцидента
2. Оценка ущерба и локализация
3. Снятие воздействия и восстановление
4. Постинцидентный анализ и уроки

Подсказка: Сначала видим, затем локализуем, потом восстанавливаем, и анализируем.

Ответ:

- Обнаружение инцидента
- Оценка ущерба и локализация
- Снятие воздействия и восстановление
- Постинцидентный анализ и уроки

Шаг 13:

Миссия 13

Расположите шаги восстановления после успешного взлома:

1. Подсистема восстановления (restore) запускается
2. Изолировать поражённые части системы
3. Восстановить файлы и конфигурации из резервной копии
4. Проверить целостность и безопасность после восстановления

Подсказка: Сначала изолируйте, потом восстановите и проверьте.

Ответ:

- Изолировать поражённые части системы
- Подсистема восстановления (restore) запускается
- Восстановить файлы и конфигурации из резервной копии

- Проверить целостность и безопасность после восстановления

Шаг 14:

Миссия 14

Расположите уровни защиты при разработке безопасного приложения:

1. Обработка и проверка пользовательского ввода
2. Безопасная аутентификация и сессии
3. Ограничение привилегий (RBAC, ACL)
4. Шифрование данных в движении и покое

Подсказка: Сначала фильтруйте ввод, затем аутентификация, привилегии и шифрование.

Ответ:

- Обработка и проверка пользовательского ввода
- Безопасная аутентификация и сессии
- Ограничение привилегий (RBAC, ACL)
- Шифрование данных в движении и покое

Шаг 15:

Миссия 15

Расположите этапы тестирования устойчивости к атаке:

1. Нагрузочное тестирование с атакующими сценариями
2. Фуззинг параметров входа
3. Имитация SQLi / XSS атак
4. Мониторинг откликов системы и журналов

Подсказка: Начинайте с имитации базовых атак, затем фуззинг, нагрузка и мониторинг.

Ответ:

- Имитация SQLi / XSS атак
- Фуззинг параметров входа
- Нагрузочное тестирование с атакующими сценариями
- Мониторинг откликов системы и журналов

Шаг 16:

Миссия 16

Расположите шаги эскалации атаки внутри системы:

1. Обнаружение возможных локальных привилегий
2. Использование уязвимости ядра / драйвера
3. Получение root / SYSTEM прав
4. Чистка следов эскалации (логи, таймстампы)

Подсказка: Сначала ищите возможности, затем реализуйте и скройте следы.

Ответ:

- Обнаружение возможных локальных привилегий
- Использование уязвимости ядра / драйвера
- Получение root / SYSTEM прав
- Чистка следов эскалации (логи, таймстампы)

Шаг 17:

Миссия 17

Расположите фазы симуляции атаки и защиты проекта от начала до конца:

1. Постановка целей, разведка и планирование атаки
2. Реализация атаки и эскалация
3. Защитные меры, мониторинг и реагирование
4. Анализ результатов, отчёты и улучшения защиты

Подсказка: Полный цикл: план → атака → защита → уроки.

Ответ:

- Постановка целей, разведка и планирование атаки
- Реализация атаки и эскалация
- Защитные меры, мониторинг и реагирование
- Анализ результатов, отчёты и улучшения защиты

Модуль 4 - Финальный квест и проверка знаний

Урок 1 - Финальный кейс остановки кибератаку

Шаг 01:

Миссия 1

Вы — разработчик и замечаете, что в коде сервиса часто повторяется один и тот же фрагмент обработки ошибок. Что вы сделаете?

Подсказка: Дублирование — враг поддерживаемого кода.

Ответ:

- **Выделю общий метод для обработки ошибок**
- **Оставлю как есть** — дублирование мелкое
- Скопирую логику ещё куда-то

Шаг 02:

Миссия 2

Сети компании начали показывать аномальный трафик на один из внутренних серверов. Что первым делом стоит проверить?

Подсказка: Посмотри, что изменилось недавно.

Ответ:

- **Журналы (логи) сетевых устройств и сервера**
- Состояние монитора на рабочем столе
- Отчет по продажам
- Погоду за окном

Шаг 03:

Миссия 3

Вы увидели, что неизвестный пользователь зашел на сервер с правами администратора. Что вы предпримете первым?

Подсказка: Нужно срочно ограничить доступ.

Ответ:

- **Отключить подключение и сменить ключи / пароли**
- Немедленно удалить все файлы
- Позвонить всем сотрудникам
- Отложить на завтра

Шаг 04:

Миссия 4

Оказалось, что злоумышленник запустил подозрительный скрипт на сервере. Какой инструмент вы используете первым?

Подсказка: Инструмент, который покажет процессы и сетевые соединения.

Ответ:

- **netstat / ss / lsof / ps**
- msconfig
- Word
- Калькулятор

Шаг 05:

Миссия 5

Скрипт пытается передавать данные на внешний IP. Что логично сделать далее?

Подсказка: Нужно узнать, куда именно шлётся трафик.

Ответ:

- **Проанализировать домен / IP-адрес через WHOIS и угрозы**
- Разрешить трафик без проверки
- Удалить скрипт, не анализируя куда идёт
- Не обращать внимания

Шаг 06:

Миссия 6

Вы узнали, что IP-адрес принадлежит ботнету. Что следующая ваша задача?

Подсказка: Нужно локализовать угрозу и предотвратить распространение.

Ответ:

- **Отключить заражённый сервер и провести форензик-анализ**
- Игнорировать проблему
- Удалить сетевой кабель без уведомления
- Пустить трафик через VPN

Шаг 07:

Миссия 7

 Сопоставьте действия и их цель при расследовании инцидента.

Подсказка: Каждому действию соответствует уникальная цель.

Действия:

Ответ:

- Сбор логов

- Снимок памяти (memory dump)
- Слежение сетевых соединений
- Идентификация исполняемых файлов

Цели:

1. Узнать, куда отправляются данные
2. Установить, какие процессы были активны
3. Сохранить временное состояние системы
4. Получить хронологию событий

- **Сбор логов** — Получить хронологию событий
- **Снимок памяти (memory dump)** — Сохранить временное состояние системы
- **Слежение сетевых соединений** — Узнать, куда отправляются данные
- **Идентификация исполняемых файлов** — Установить, какие процессы были активны

Шаг 08:

Миссия 8

 Сопоставьте метод расследования и поле данных, которое он анализирует.

Подсказка: Некоторые методы дают сетевые данные, другие — память или файловую систему.

Методы:

Ответ:

- Анализ дампа памяти
- Просмотр системных логов
- Сканирование файлов на вредоносный код
- Мониторинг сетевого трафика

Поля данных:

1. Содержимое процессов и память
 2. История событий ОС и приложений
 3. Байты файлов и сигнатуры вредоносного кода
 4. Сетевые соединения и передаваемые пакеты
- **Анализ дампа памяти** — Содержимое процессов и память
 - **Просмотр системных логов** — История событий ОС и приложений
 - **Сканирование файлов на вредоносный код** — Байты файлов и сигнатуры вредоносного кода
 - **Мониторинг сетевого трафика** — Сетевые соединения и передаваемые пакеты

Шаг 09:

Миссия 9

 Сопоставьте тип атаки и его характеристику.

Подсказка: Обратите внимание на то, как атаку проявляется.

Типы атак:

Ответ:

- SQL-инъекция
- Фишинг
- Ransomware
- DDoS

Характеристики:

1. Блокировка доступа к данным и требование выкупа
 2. Перегрузка ресурса запросами
 3. Внедрение вредоносного SQL кода в запросы
 4. Ложные письма и подделка отправителя
- **SQL-инъекция** — Внедрение вредоносного SQL кода в запросы
 - **Фишинг** — Ложные письма и подделка отправителя
 - **Ransomware** — Блокировка доступа к данным и требование выкупа
 - **DDoS** — Перегрузка ресурса запросами

Шаг 10:

Миссия 10

 Сопоставьте стадии инцидента и ключевые задачи.

Подсказка: Используйте стандартную модель: подготовка, обнаружение, реагирование, восстановление.

Стадии:

Ответ:

- Обнаружение
- Реагирование
- Подготовка
- Восстановление

Ключевые задачи:

1. Предварительное планирование, обучение, создание политики
 2. Мониторинг, оповещение об аномалиях
 3. Изоляция угрозы, удаление вреда
 4. Восстановление сервисов, проверка целостности
- **Обнаружение** — Мониторинг, оповещение об аномалиях
 - **Реагирование** — Изоляция угрозы, удаление вреда
 - **Подготовка** — Предварительное планирование, обучение, создание политики
 - **Восстановление** — Восстановление сервисов, проверка целостности

Шаг 11:

Миссия 11

Расположите шаги реагирования на инцидент по порядку:

1. Оповещение и эскалация
2. Восстановление систем
3. Идентификация и анализ инцидента
4. Закрытие и подготовка отчёта
5. Сдерживание и удаление вреда

Подсказка: Сначала нужно понять, что случилось, потом устранить, потом восстановить, а в конце — отчёт.

Ответ:

- Оповещение и эскалация
- Идентификация и анализ инцидента

- Сдерживание и удаление вреда
- Восстановление систем
- Закрытие и подготовка отчёта

Шаг 12:

Миссия 12

Отсортируйте шаги форензик-анализа:

1. Извлечение образов дисков
2. Анализ временных меток и журналов
3. Сбор метаданных файлов
4. Сохранение снимков оперативной памяти
5. Интерпретация результатов

Подсказка: Логика: снимки → извлечение → метаданные → журналы → заключение.

Ответ:

- Сохранение снимков оперативной памяти
- Извлечение образов дисков
- Сбор метаданных файлов
- Анализ временных меток и журналов
- Интерпретация результатов

Шаг 13:

Миссия 13

Отсортируйте действия при блокировке сетевой угрозы:

1. Изоляция сегмента сети
2. Блокировка IP/портов на фаерволе
3. Мониторинг трафика после вмешательства
4. Оценка ущерба и заражения
5. Отчёт и уроки

Подсказка: Сначала блокируем, потом проверяем, потом учимся.

Ответ:

- Изоляция сегмента сети
- Блокировка IP/портов на фаерволе
- Оценка ущерба и заражения
- Мониторинг трафика после вмешательства
- Отчёт и уроки

Шаг 14:

Миссия 14

Отсортируйте этапы восстановления системы после атаки:

1. Применение патчей и обновлений
2. Проверка целостности файлов
3. Установка новых паролей и ключей
4. Запуск сервисов в тестовой среде
5. Мониторинг стабильности

Подсказка: Восстановление должно быть безопасным и контролируемым.

Ответ:

- Проверка целостности файлов
- Применение патчей и обновлений
- Установка новых паролей и ключей
- Запуск сервисов в тестовой среде
- Мониторинг стабильности

Шаг 15:

Миссия 15

Отсортируйте шаги коммуникации с командой после атаки:

1. Сообщение сотрудникам об инциденте
2. Инструкции по изменению паролей
3. Оповещение клиентов / пользователей
4. Публикация итогового отчёта
5. Регулярные обновления о ходе расследования

Подсказка: Важна последовательность: сначала команда, потом внешние, затем отчёт.

Ответ:

- Сообщение сотрудникам об инциденте
- Инструкции по изменению паролей
- Регулярные обновления о ходе расследования
- Оповещение клиентов / пользователей
- Публикация итогового отчёта

Шаг 16:

Миссия 16

Финальный сценарий: упорядочите все ключевые этапы кейса «остановить кибератаку» от начала до конца:

1. Обнаружение аномалии
2. Изоляция угрозы
3. Расследование и сбор артефактов
4. Блокировка внешнего IP и удаление вреда
5. Восстановление и тестирование систем
6. Коммуникации и отчёты

Подсказка: Это объединение всех предыдущих миссий.

Ответ:

- Обнаружение аномалии
- Изоляция угрозы
- Расследование и сбор артефактов
- Блокировка внешнего IP и удаление вреда
- Восстановление и тестирование систем
- Коммуникации и отчёты

Урок 2 - Командная защита виртуальной компании

Шаг 01:

Миссия 1

Вы — член команды виртуальной компании «SoftSafe». Ваша первая задача — настроить базовую защиту. Какое действие вы выполните первым?

Подсказка: Без основной защиты система уязвима.

Ответ:

- **Установлю и настрою фаервол на сервере**
- Подключусь к VPN
- Открою максимальные разрешения в системах
- Запущу все сервисы без защиты

Шаг 02:

Миссия 2

Администратор сообщает, что один из сотрудников использует слабый пароль «123456». Что вы советуете сделать?

Подсказка: Пароль — первая линия защиты.

Ответ:

- **Запретить слабые пароли и обязать смену на надёжные**
- **Оставить как есть** — пусть сотрудник сам решает
- Попросить его запомнить пароль
- Сделать пароль публичным для всей команды

Шаг 03:

Миссия 3

В вашу команду присоединился внешний подрядчик. Вы должны дать ему доступ к части сети. Как обеспечить безопасный доступ?

Подсказка: Минимальный доступ — безопасный доступ.

Ответ:

- **Дать доступ только по VPN с ограничением прав**
- Дать общий административный доступ
- Открыть весь портовый доступ
- Не давать никакого доступа

Шаг 04:

Миссия 4

Сотрудник жалуется, что получает фишинговое письмо с просьбой «обновить пароль». Как вы реагируете?

Подсказка: Обучение и проверка важны.

Ответ:

- **Проверю письмо, сообщу в ИБ-команду и уведомлю команду**
- **Игнорирую** — это не моя проблема
- Нажму ссылку и введу пароль
- Открою вложения сразу

Шаг 05:

Миссия 5

Команда DevOps сообщает, что недавно добавила внешний API-сервис. Что нужно сделать прежде, чем запускать его в продакшн?

Подсказка: Без проверки API — это дыра.

Ответ:

- **Провести аудит безопасности API и тесты на уязвимости**
- Запустить сразу без проверки
- Удалить API
- Игнорировать тестирование

Шаг 06:

Миссия 6

 Сопоставьте меры защиты и их назначение в виртуальной компании.

Подсказка: Некоторые меры защищают сеть, другие — доступ или данные.

Меры:

Ответ:

- VPN доступ
- IDS / IPS
- Шифрование дисков
- Управление правами (RBAC)

Назначения:

1. Выявление попыток вторжений
2. Контроль разрешений пользователей
3. Безопасный удалённый доступ
4. Защита данных при хранении

- **VPN доступ** — Безопасный удалённый доступ
- **IDS / IPS** — Выявление попыток вторжений
- **Шифрование дисков** — Защита данных при хранении
- **Управление правами (RBAC)** — Контроль разрешений пользователей

Шаг 07:

Миссия 7

 Сопоставьте угрозу и метод защиты.

Подсказка: Некоторые защиты работают на уровне приложений, другие — на уровне систем.

Угрозы:

Ответ:

- SQL-инъекция
- Межсайтовый скриптинг (XSS)
- Брутфорс пароля
- Прослушка трафика

Защиты:

1. Проверка и экранирование вводимых данных

2. Политика CORS и фильтрация вводов
3. Ограничение попыток входа, MFA
4. Шифрование трафика (TLS / VPN)

- **SQL-инъекция** — Проверка и экранирование вводимых данных
- **Межсайтовый скриптинг (XSS)** — Политика CORS и фильтрация вводов
- **Брутфорс пароля** — Ограничение попыток входа, MFA
- **Прослушка трафика** — Шифрование трафика (TLS / VPN)

Шаг 08:

Миссия 8

 Сопоставьте логи и типы данных, которые они содержат.

Подсказка: Логи сервера, приложений, сети — разный формат.

Логи:

Ответ:

- Сетевые логи
- Системные логи ОС
- Логи приложений
- Логи доступа к API

Типы данных:

1. Пакеты, IP-адреса и порты
 2. События запуска служб, ошибки ОС
 3. Ошибки бизнес-логики, исключения
 4. Кто и когда вызывал метод API
- **Сетевые логи** — Пакеты, IP-адреса и порты
 - **Системные логи ОС** — События запуска служб, ошибки ОС
 - **Логи приложений** — Ошибки бизнес-логики, исключения
 - **Логи доступа к API** — Кто и когда вызывал метод API

Шаг 09:

Миссия 9

 Сопоставьте стадию инцидента и роль команды.

Подсказка: Команда участвует при разных этапах.

Стадии:

Ответ:

- Обнаружение
- Реагирование
- Расследование
- Восстановление

Роли:

1. Мониторинг системы и алерты
2. Изоляция и реагирование
3. Форензика, сбор доказательств
4. Откат обновлений, восстановление сервисов

- **Обнаружение** — Мониторинг системы и алерты
- **Реагирование** — Изоляция и реагирование
- **Расследование** — Форензика, сбор доказательств
- **Восстановление** — Откат обновлений, восстановление сервисов

Шаг 10:

Миссия 10

 Сопоставьте уровни защиты и зоны виртуальной сети.

Подсказка: DMZ, внутренние сети, гостевые сегменты.

Уровни защиты:

Ответ:

- DMZ
- Внутренняя сеть
- Гостевой сегмент
- Административный сегмент

Зоны:

1. Публичные сервисы (веб, API)
 2. Офисные рабочие станции сотрудников
 3. Сети подрядчиков и гостей
 4. Сервера управления ИТ и администраторов
- **DMZ** — Публичные сервисы (веб, API)
 - **Внутренняя сеть** — Офисные рабочие станции сотрудников
 - **Гостевой сегмент** — Сети подрядчиков и гостей
 - **Административный сегмент** — Сервера управления ИТ и администраторов

Шаг 11:

Миссия 11

Расположите этапы внедрения системы защиты в виртуальной компании:

1. Выбор решений (VPN, IDS и др.)
2. Настройка и конфигурация
3. Тестирование защит
4. Обучение команды
5. Запуск в продуктив

Подсказка: Сначала выбираем, затем настраиваем, тестируем, учим и запускаем.

Ответ:

- Выбор решений (VPN, IDS и др.)
- Настройка и конфигурация
- Тестирование защит
- Обучение команды
- Запуск в продуктив

Шаг 12:

Миссия 12

Расположите шаги реагирования на внутреннее нарушение безопасности:

1. Оповещение ИБ-команды
2. Изоляция затронутых сегментов
3. Сбор логов и следов
4. Устранение проблемы и патчи
5. Проверка восстановления и отчёт

Подсказка: Последовательность: уведомить, изолировать, собрать следы, исправить, проверить.

Ответ:

- Оповещение ИБ-команды
- Изоляция затронутых сегментов
- Сбор логов и следов
- Устранение проблемы и патчи
- Проверка восстановления и отчёт

Шаг 13:

Миссия 13

Расположите уровни реагирования при атаке извне:

1. Обнаружение и оповещение
2. Блокировка атакующего IP
3. Изоляция серверов
4. Анализ и форензика
5. Восстановление систем
6. Коммуникация с клиентами

Подсказка: Сначала фиксируем атаку, затем блокируем, изолируем, анализируем, восстанавливаем и информируем.

Ответ:

- Обнаружение и оповещение
- Блокировка атакующего IP
- Изоляция серверов
- Анализ и форензика
- Восстановление систем
- Коммуникация с клиентами

Шаг 14:

Миссия 14

Расположите шаги расследования безопасности API-сервиса:

1. Сбор логов API
2. Сравнение с шаблонами запросов
3. Анализ параметров запроса
4. Идентификация вредоносных вызовов
5. Блокировка атакующих путей
6. Тестирование защиты

Подсказка: Логика: собрать, проанализировать, выявить, блокировать, проверить.

Ответ:

- Сбор логов API
- Сравнение с шаблонами запросов
- Анализ параметров запроса
- Идентификация вредоносных вызовов
- Блокировка атакующих путей
- Тестирование защиты

 Шаг 15:

Миссия 15

Расположите шаги восстановления после атаки на виртуальные сервисы:

1. Откат к последней стабильной версии
2. Проверка целостности данных
3. Установка обновлений и патчей
4. Обновление ключей и паролей
5. Плавный запуск и мониторинг

Подсказка: Восстановление должно быть безопасным и поэтапным.

Ответ:

- Откат к последней стабильной версии
- Проверка целостности данных
- Установка обновлений и патчей
- Обновление ключей и паролей
- Плавный запуск и мониторинг

 Шаг 16:

Миссия 16

Расположите шаги коммуникации после инцидента для компании:

1. Сообщить команде внутри компании
2. Попросить сменить пароли
3. Информировать внешних клиентов
4. Регулярно обновлять статус расследования
5. Опубликовать итоговый отчёт

Подсказка: Важно сначала внутри, затем к пользователям, затем отчёт.

Ответ:

- Сообщить команде внутри компании
- Попросить сменить пароли
- Информировать внешних клиентов
- Регулярно обновлять статус расследования
- Опубликовать итоговый отчёт

 Шаг 17:

Миссия 17

Финальный сценарий: упорядочите ключевые этапы защиты виртуальной компании от старта до завершения инцидента:

1. Оценка рисков и план защиты
2. Развёртывание защит (VPN, фаервол, IDS)
3. Мониторинг и обнаружение угроз
4. Реагирование и локализация угрозы
5. Расследование и анализ ущерба
6. Восстановление систем и коммуникация

Подсказка: Это целостная последовательность всех миссий.

Ответ:

- Оценка рисков и план защиты
- Развёртывание защит (VPN, фаервол, IDS)
- Мониторинг и обнаружение угроз
- Реагирование и локализация угрозы
- Расследование и анализ ущерба
- Восстановление систем и коммуникация

Урок 3 - Анализ логов найди точку проникновения

Шаг 01:

Миссия 1

Вы заметили подозрительный вход в систему с нехарактерным IP-адресом. Что вы делаете в первую очередь?

Подсказка: подумайте, какой шаг минимизирует дальнейший ущерб.

Ответ:

- **Заблокировать этот IP адрес немедленно**
- **Игнорировать, возможно** — ложная тревога
- Писать в чат коллегам о наблюдении
- Перезагрузить сервер

Шаг 02:

Миссия 2

После блокировки IP вам нужно собрать первичную информацию. Какой логовой файл вы откроете первым?

Подсказка: начните с системных журналов авторизации.

Ответ:

- **/var/log/auth.log (или эквивалент)**
- /etc/passwd
- /var/log/boot.log
- /var/log/mail.log

Шаг 03:

Миссия 4

Вы заметили, что затем с этого IP попытались выполнить SSH-вход с использованием root. Какой флаг SSH вы проверяете в логах?

Подсказка: ищите успешную или неудачную авторизацию.

Ответ:

- **Failed password / Accepted password**
- Connection closed by remote host
- Port forwarding request
- X11 forwarding request

Шаг 04:

Миссия 5

✂ Сопоставление типов логов и их назначения

Понятия:

Ответ:

- auth.log / secure log
- syslog / messages
- web server access log
- application error log

Определения:

1. Журнал авторизации и аутентификации
2. Журнал общесистемных событий
3. Журнал HTTP-запросов клиентов
4. Журнал ошибок приложения

Подсказка: веб-логи фиксируют ответы клиентам, ошибки — внутреннюю логику.

- **auth.log / secure log** — Журнал авторизации и аутентификации
- **syslog / messages** — Журнал общесистемных событий
- **web server access log** — Журнал HTTP-запросов клиентов
- **application error log** — Журнал ошибок приложения

Шаг 05:

Миссия 6

✂ Сопоставление термина и роли в проникновении

Понятия:

Ответ:

- Backdoor
- Privilege escalation
- Data exfiltration
- Persistence

Определения:

1. Неавторизованный канал доступа
2. Повышение привилегий до root
3. Вывод конфиденциальных данных наружу
4. Сохранение доступа после перезагрузки

Подсказка: представьте, как атакующий удерживает контроль.

- **Backdoor** — Неавторизованный канал доступа
- **Privilege escalation** — Повышение привилегий до root
- **Data exfiltration** — Вывод конфиденциальных данных наружу
- **Persistence** — Сохранение доступа после перезагрузки

🔮 Шаг 06:

Миссия 7

✂ Сопоставление артефакта и вероятной причины в логах

Понятия:

Ответ:

- sudo:unable to resolve host
- kernel panic
- disconnect by user
- rsync: connection reset by peer

Определения:

1. Ошибка разрешения имени хоста при sudo
2. Сбой ядра, аварийная остановка системы
3. Пользователь разорвал соединение вручную
4. Сеть сбросила соединение во время передачи файлов

Подсказка: думаете об уровне: система, сеть или пользователь.

- **sudo:unable to resolve host** — Ошибка разрешения имени хоста при sudo
- **kernel panic** — Сбой ядра, аварийная остановка системы
- **disconnect by user** — Пользователь разорвал соединение вручную
- **rsync: connection reset by peer** — Сеть сбросила соединение во время передачи файлов

🔮 Шаг 07:

Миссия 8

✂ Сопоставьте событие и его значимость для расследования

Понятия:

Ответ:

- Успешный вход под root
- Неудачный пароль 100 раз
- Добавление новой учетной записи
- Запрос DNS к неизвестному домену

Определения:

1. Критическое нарушение безопасности
2. Подготовка брутфорса
3. Установление контроля атакующим
4. Потенциальный канал управления

Подсказка: представьте в каком порядке атакующий действует.

- **Успешный вход под root** — Критическое нарушение безопасности
- **Неудачный пароль 100 раз** — Подготовка брутфорса

- **Добавление новой учетной записи** — Установление контроля атакующим
- **Запрос DNS к неизвестному домену** — Потенциальный канал управления

Шаг 08:

Миссия 9

Расположите шаги реагирования на инцидент в правильном порядке:

1. Определение точки проникновения
2. Изоляция затронутых систем
3. Сбор логов и доказательств
4. Устранение уязвимости и восстановление

Подсказка: сначала содержите ущерб, потом исследуйте, затем исправляйте.

Ответ:

- Изоляция затронутых систем
- Сбор логов и доказательств
- Определение точки проникновения
- Устранение уязвимости и восстановление

Шаг 09:

Миссия 10

Расположите этапы анализа точки проникновения:

1. Выделение подозрительной сессии
2. Изучение исходных записей сессии
3. Поиск команд, использованных злоумышленником
4. Установление начального доступа (pivot)

Подсказка: логическая цепочка: обнаружил → исследовал → понял → восстановил.

Ответ:

- Выделение подозрительной сессии
- Изучение исходных записей сессии
- Поиск команд, использованных злоумышленником
- Установление начального доступа (pivot)

Шаг 10:

Миссия 11

Расположите типичные фазы атаки (Kill Chain) по порядку:

1. Reconnaissance
2. Delivery / Exploitation
3. Installation / Persistence
4. Command & Control / Actions on Objective

Подсказка: сначала разведка, потом доставка зловреда, затем удержание и управление.

Ответ:

- Reconnaissance
- Delivery / Exploitation
- Installation / Persistence

- Command & Control / Actions on Objective

Шаг 11:

Миссия 12

Расположите действия злоумышленника внутри сети:

1. Вертикальная эскалация привилегий
2. Вертикальный и латеральный переход (pivot)
3. Установка бэкдора
4. Вывод данных (exfiltration)

Подсказка: сначала укрепление, потом перемещение, потом контроль и вывод.

Ответ:

- Вертикальная эскалация привилегий
- Вертикальный и латеральный переход (pivot)
- Установка бэкдора
- Вывод данных (exfiltration)

Шаг 12:

Миссия 13

Расположите шаги привлечения внимания в журнале безопасности:

1. Множество неудачных попыток логина
2. Попытка логина под root
3. Успешный вход другого пользователя
4. Запуск подозрительной команды

Подсказка: последовательность от первичных признаков до исполнения.

Ответ:

- Множество неудачных попыток логина
- Попытка логина под root
- Успешный вход другого пользователя
- Запуск подозрительной команды

Шаг 13:

Миссия 14

Расположите уровни лога по степени важности при расследовании:

1. Authentication / Audit log
2. System / Kernel log
3. Network traffic log
4. Application log

Подсказка: сначала — авторизация, затем системные, сеть и приложения.

Ответ:

- Authentication / Audit log
- System / Kernel log
- Network traffic log
- Application log

Шаг 14:

Миссия 15

Вы анализируете web-серверные логи и находите подозрительный POST-запрос на /wp-login.php с необычным user-agent. Какой вывод наиболее вероятен?

Подсказка: необычный user-agent + попытка логина часто указывает на автоматизацию.

Ответ:

- Это может быть попытка брутфорса или автоматической атаки
- Это легитимная активность пользователя
- Это ошибка клиента
- Это тестовая проверка веб-сайта

Шаг 15:

Миссия 17

Финальный анализ: располагайте события проникновения в хронологическом порядке, основываясь на логах и действиях атакующего:

1. Начало сканирования портов и разведка
2. Успешный SSH вход с новым пользователем
3. Эскалация привилегий до root
4. Установка backdoor / persistence
5. Вывод данных (exfiltration)

Подсказка: атакующий действует поэтапно: разведка → проникновение → закрепление → эксфильтрация.

Ответ:

- Начало сканирования портов и разведка
- Успешный SSH вход с новым пользователем
- Эскалация привилегий до root
- Установка backdoor / persistence
- Вывод данных (exfiltration)

Урок 4 - Защита ИТ-инфраструктуры в реальном времени

Шаг 01:

Миссия 1

Ночью ваша команда получает оповещение: IDS зафиксировала аномальный трафик к внутреннему серверу. Какое действие вы предпринимаете первым?

Подсказка: важно быстро локализовать возможную угрозу.

Ответ:

- Отключить межсетевой экран для этого потока или заблокировать источник
- Подождать и собрать статистику трафика
- Отправить уведомление всем пользователям
- Попросить администратора сервера перезагрузить машину

Шаг 02:

Миссия 2

После блокировки источника вы видите, что сервер всё ещё пытаются атаковать через другой порт. Что вы делаете?

Подсказка: подумайте об ограничении доступа на уровне сервисов.

Ответ:

- **Закрыть все неиспользуемые порты на брандмауэре**
- Поменять IP сервера
- Повторно доверять тому же источнику
- Увеличить логирование на сервере

Шаг 03:

Миссия 3

Вы активировали ограничение и видите попытки соединения на SSH, HTTP и нестандартные порты. Как вы реагируете?

Подсказка: важно контролировать доступ по портам и протоколам.

Ответ:

- **Настроить только необходимые порты и запретить лишние протоколы**
- Открыть все порты для администраторов
- Отключить SSH
- Сменить сетевые интерфейсы

Шаг 04:

Миссия 4

Вы включаете режим повышенного логирования (verbose). Что именно вы усиливаете?

Подсказка: обратите внимание на аутентификацию и сетевые события.

Ответ:

- **Логирование событий авторизации и сетевых соединений**
- Логирование интерфейса пользователя
- Логирование SQL-запросов
- Логирование графики интерфейса

Шаг 05:

Миссия 5

♥ Сопоставьте механизм защиты с его ролью в реальном времени

Понятия:

Ответ:

- IPS (Intrusion Prevention System)
- WAF (Web Application Firewall)
- SIEM (Security Information and Event Management)
- Антивирус с эвристикой

Определения:

1. Блокирует атаки на веб-приложения по шаблонам
2. Выявляет и предотвращает сетевые атаки на лету
3. Коррелирует события и выдает оповещения в режиме реального времени
4. Обнаруживает угрозы на основе анализа поведения файлов и процессов

Подсказка: подумайте, что делает каждое средство защиты в «боевом режиме».

- **IPS (Intrusion Prevention System)** — Выявляет и предотвращает сетевые атаки на лету
- **WAF (Web Application Firewall)** — Блокирует атаки на веб-приложения по шаблонам
- **SIEM (Security Information and Event Management)** — Коррелирует события и выдает оповещения в режиме реального времени
- **Антивирус с эвристикой** — Обнаруживает угрозы на основе анализа поведения файлов и процессов

🔮 Шаг 06:

Миссия 6

♥ Сопоставьте сигнал тревоги с вероятной причиной

Понятия:

Ответ:

- Высокий процент отказов соединения
- Необычный spike трафика на необычный порт
- Множественные login failures с разных IP
- Необычная активность процессов на сервере

Определения:

1. Атака DoS или перегрузка
2. Сканирование сервисов или поиск уязвимости
3. Брутфорс или словарная атака
4. Возможный локальный компромисс или вредоносный запуск

Подсказка: проанализируйте характер события — сеть, авторизация или внутренняя активность.

- **Высокий процент отказов соединения** — Атака DoS или перегрузка
- **Необычный spike трафика на необычный порт** — Сканирование сервисов или поиск уязвимости
- **Множественные login failures с разных IP** — Брутфорс или словарная атака
- **Необычная активность процессов на сервере** — Возможный локальный компромисс или вредоносный запуск

🔮 Шаг 07:

Миссия 7

♥ Сопоставление метрики с индикатором атаки

Понятия:

Ответ:

- CPU usage внезапно до 100 %
- Всплеск DNS-запросов к неизвестному домену
- Неожиданное увеличение объёма outbound traffic
- Новый исполняемый файл с правами root

Определения:

1. DDoS-атака или нагрузка
2. Командно-контроль или callback
3. Вывод данных или утечка
4. Закрепление или установка вредоносного модуля

Подсказка: соедините внутренние признаки и последствия атаки.

- **CPU usage внезапно до 100 %** — DDoS-атака или нагрузка
- **Всплеск DNS-запросов к неизвестному домену** — Командно-контроль или callback
- **Неожиданное увеличение объёма outbound traffic** — Вывод данных или утечка
- **Новый исполняемый файл с правами root** — Закрепление или установка вредоносного модуля

🔮 Шаг 08:

Миссия 8

♥ Сопоставьте событие с соответствующим защитным слоем

Понятия:

Ответ:

- IDS сигнал тревоги
- WAF блокирует SQL-инъекцию
- Антивирус на endpoint выявляет троян
- SIEM корреляция событий

Определения:

1. Сетевой уровень обнаружения угроз
2. Уровень веб-приложения
3. Уровень конечной точки (host)
4. Уровень анализа и корреляции данных

Подсказка: подумайте, где “видит” каждое средство: сеть, приложение, хост, система.

- **IDS сигнал тревоги** — Сетевой уровень обнаружения угроз
- **WAF блокирует SQL-инъекцию** — Уровень веб-приложения
- **Антивирус на endpoint выявляет троян** — Уровень конечной точки (host)
- **SIEM корреляция событий** — Уровень анализа и корреляции данных

🔮 Шаг 09:

Миссия 9

Расположите этапы защиты в реальном времени от вторжения:

1. Обнаружение аномального поведения
2. Блокировка источника атаки
3. Анализ логов и корреляция событий
4. Устранение уязвимости и восстановление

Подсказка: сначала защитные системы срабатывают, затем действия команды.

Ответ:

- Обнаружение аномального поведения
- Блокировка источника атаки
- Анализ логов и корреляция событий
- Устранение уязвимости и восстановление

🔮 Шаг 10:

Миссия 11

Расположите фазы реагирования от момента атаки до восстановления:

1. Containment (локализация)
2. Investigation (расследование)
3. Eradication (удаление угрозы)
4. Lessons Learned (анализ после инцидента)

Подсказка: сначала сдерживаем, затем исследуем, затем чистим, затем анализируем уроки.

Ответ:

- Containment (локализация)
- Investigation (расследование)
- Eradication (удаление угрозы)
- Lessons Learned (анализ после инцидента)

Шаг 11:

Миссия 12

Расположите слои безопасности по степени близости к активу:

1. Физический контроль
2. Сетевая защита (firewall, IPS)
3. Контроль доступа и авторизация (IAM)
4. Мониторинг и корреляция (SIEM/EDR)

Подсказка: от внешнего к внутреннему, от инфраструктуры к аналитике.

Ответ:

- Физический контроль
- Сетевая защита (firewall, IPS)
- Контроль доступа и авторизация (IAM)
- Мониторинг и корреляция (SIEM/EDR)

Шаг 12:

Миссия 14

Расположите источники данных, которые аналитик использует по порядку важности:

1. Сетевые логи (IDS/Firewall)
2. Логи серверов и приложений
3. Теле метрика хостов (CPU, память, процессы)
4. События антивируса и EDR

Подсказка: сначала видны атаки снаружи, потом внутренние события и детекторы.

Ответ:

- Сетевые логи (IDS/Firewall)
- Логи серверов и приложений
- Теле метрика хостов (CPU, память, процессы)
- События антивируса и EDR

Шаг 13:

Миссия 15

Вы видите, что SIEM выдала оповещение: корреляция нескольких низкоприоритетных событий привела к подозрению на внутренний инцидент. Что вы делаете?

Подсказка: не игнорируйте даже слабые сигналы, они могут быть частью атаки.

Ответ:

- **Запустить расследование и собрать более детальные логи**
- Отключить оповещение как ложное
- Снизить порог корреляции
- Перезагрузить SIEM-сервер

Шаг 14:

Миссия 17

Финальный квест: расположите этапы защиты и реагирования в одном сценарии:

1. Событие триггерит сигнал IDS
2. SIEM коррелирует события
3. Блокировка источника атаки (firewall/IPS)
4. Расследование и сбор доказательств
5. Устранение угрозы и восстановление

Подсказка: все компоненты действуют вместе: обнаружение → корреляция → защита → расследование → восстановление.

Ответ:

- Событие триггерит сигнал IDS
- SIEM коррелирует события
- Блокировка источника атаки (firewall/IPS)
- Расследование и сбор доказательств
- Устранение угрозы и восстановление

Урок 5 - Постинцидентное расследование и отчёт

Шаг 01:

Миссия 1

Вы — инженер по безопасности, и ваша сеть зафиксировала подозрительную активность после обновления сервера. Что вы делаете в первую очередь?

Подсказка: Первое, что важно — не усугубить ситуацию.

Ответ:

- **Изолировать подозрительный сервер от сети**
- Сделать публичный отчёт о взломе
- Немедленно запустить обновление ОС
- Сбросить пароли всех пользователей

Шаг 02:

Миссия 2

Вы изолировали сервер. Теперь на нём найдены журналы с подозрительными записями неизвестных SSH-подключений. Какой следующий шаг?

Подсказка: Нужно понять, кто, когда и как подключился.

Ответ:

- Удалить журналы, чтобы скрыть следы
- **Сделать копии логов и проанализировать их**
- Перезагрузить сервер сразу
- Посмотреть только последние 10 строк файла

Шаг 03:

Миссия 3

При анализе логов вы обнаружили, что атаки начались за два дня до вашего обнаружения. Что вы делаете дальше?

Подсказка: Жизненно важно восстановить цепочку событий.

Ответ:

- **Расширить временной диапазон логов и собрать все доступные записи**
- Ограничиться только первым обнаруженным инцидентом
- Удалить логи старше двух дней
- Игнорировать старые записи

Шаг 04:

Миссия 4

Вы собрали логи с разных машин, увидели подозрительный файл, загруженный с внешнего IP. Какой следующий шаг?

Подсказка: Нужно проверить, что было загружено и откуда.

Ответ:

- **Проанализировать содержимое этого файла в безопасной среде**
- Удалить файл сразу
- Запустить его на сервере без анализа
- Игнорировать файл

Шаг 05:

Миссия 5

Файл оказался вредоносным скриптом, выполнявшим бекдор. Вы находите IP-адрес командного сервера (C2). Что вы делаете?

Подсказка: Найти происхождение C2 и заблокировать связь.

Ответ:

- **Заблокировать IP C2 на границе сети и передать информацию в CERT**
- Подключиться к C2 и провести разведку вручную
- Оставить соединение открытым, чтобы следить за атакующими
- Сообщить пользователю, что всё безопасно

Шаг 06:

Миссия 6

Вы заблокировали C2 и создали копии трафика. Что дальше?

Подсказка: Анализируйте сетевые пакеты и поведение.

Ответ:

- **Проанализировать захваченный трафик и выявить команды, отправленные ботом**
- Удалить захваченный трафик
- Игнорировать сетевые данные
- Отправить трафик обратно к атакующему

 **Шаг 07:**

Миссия 7

Анализ трафика показал, что злоумышленники использовали DNS-туннелирование. Что вы предпринимаете?

Подсказка: Нужно перекрыть канал и восстановить логи DNS.

Ответ:

- **Заблокировать подозрительные DNS-запросы и восстановить полные DNS-логи**
- Отключить DNS-сервер
- Игнорировать DNS-логи
- Установить DNS-сервер на внешний хост

 **Шаг 08:**

Миссия 8

Вы восстановили DNS-логи и видите множество запросов к экзотическим доменам. Какую информацию вы ищете?

Подсказка: Ищите шаблоны и необычные частоты.

Ответ:

- Запросы только к google.com
- **Доменные запросы с коротким TTL и редкими именами**
- Стандартные A-запросы на well-known сайты
- Только внутренняя почтовая зона

 **Шаг 09:**

Миссия 9

 Сопоставьте методы сбора артефактов с их назначением.

Методы:

Ответ:

- Снэпшот памяти
- Сбор файлов логов
- Снимки диска (forensic image)
- Захват сетевого трафика

Назначения:

1. Поймать команды, используемые в атаке
2. Сохранить текущее состояние процессной памяти
3. Получить доказательства внесённых файлов
4. Проанализировать временные метки и события доступа

 **Подсказка:**

Подумайте, какой источник содержит команды, какой — логи, какой — память, а какой — изменения файлов.

- **Снэпшот памяти** — Сохранить текущее состояние процессной памяти
- **Сбор файлов логов** — Проанализировать временные метки и события доступа
- **Снимки диска (forensic image)** — Получить доказательства внесённых файлов
- **Захват сетевого трафика** — Поймать команды, используемые в атаке

Шаг 10:

Миссия 10

 Сопоставьте типы артефактов расследования с форматами их хранения.

Типы артефактов:

Ответ:

- Логи системы
- Снэпшот памяти
- Файлы конфигурации
- Снимок диска (forensic image)

Форматы хранения:

1. RAW / E01
2. JSON / текстовый лог
3. Снимок volatile-памяти
4. INI / YAML / конфигурационные форматы

Подсказка:

Подумайте, как обычно хранятся логи, конфигурации и блочные образы.

- **Логи системы** — JSON / текстовый лог
- **Снэпшот памяти** — Снимок volatile-памяти
- **Файлы конфигурации** — INI / YAML / конфигурационные форматы
- **Снимок диска (forensic image)** — RAW / E01

Шаг 11:

Миссия 11

 Сопоставьте роли в команде расследования с ответственностью.

Роли:

Ответ:

- Инженер по безопасности
- Судебный аналитик
- Менеджер инцидентов
- Юридический консультант

Ответственности:

1. Взаимодействие с законом и регуляторами
2. Координация действий команды и коммуникация
3. Сбор технических доказательств и их анализ
4. Разработка мер по предотвращению повторения

Подсказка:

Рассмотрите: кто работает с законом, кто — с техникой, кто — с планами.

- **Инженер по безопасности** — Разработка мер по предотвращению повторения
- **Судебный аналитик** — Сбор технических доказательств и их анализ
- **Менеджер инцидентов** — Координация действий команды и коммуникация
- **Юридический консультант** — Взаимодействие с законом и регуляторами

Шаг 12:

Миссия 12

 Сопоставьте стадии постинцидентного расследования с элементами отчёта.

Стадии:

Ответ:

- Сбор данных
- Анализ инцидента
- Реакция и устранение
- Отчёт и рекомендации

Элементы отчёта:

1. Выводы и уроки
2. Список собранных артефактов и методы
3. Хронология инцидента и причины
4. Принятые меры и план улучшений

Подсказка:

Подумайте, что относится к сбору, что — к анализу, что — к действиям, что — к отчёту.

- **Сбор данных** — Список собранных артефактов и методы
- **Анализ инцидента** — Хронология инцидента и причины
- **Реакция и устранение** — Принятые меры и план улучшений
- **Отчёт и рекомендации** — Выводы и уроки

Шаг 13:

Миссия 13

Расположите шаги формирования хронологии инцидента в правильном порядке:

1. Обнаружение инцидента
2. Анализ действий злоумышленника
3. Сбор логов и артефактов
4. Корреляция событий и построение временной шкалы
5. Выводы и фиксация основных этапов

Подсказка:

Подумайте, что сначала — сбор данных, что потом — анализ, а что — оформление.

Ответ:

- Сбор логов и артефактов
- Обнаружение инцидента
- Анализ действий злоумышленника
- Корреляция событий и построение временной шкалы
- Выводы и фиксация основных этапов

Шаг 14:

Миссия 14

Расположите части отчёта от начального до завершающего:

1. Техническое описание инцидента
2. Рекомендации и план улучшений
3. Введение и контекст
4. Хронология и анализ
5. Заключение и выводы

 **Подсказка: В отчёте логично начать с контекста, потом углубляться технически, затем рекомендации.**

Ответ:

- Введение и контекст
- Техническое описание инцидента
- Хронология и анализ
- Рекомендации и план улучшений
- Заключение и выводы

Шаг 15:

Миссия 15

Расположите этапы передачи отчёта заинтересованным сторонам:

1. Обсуждение выводов с руководством
2. Подготовка краткого executive summary
3. Рассылка полного отчёта команде и смежным отделам
4. Запрос обратной связи и аудита отчёта
5. Утверждение плана исправлений и контроль внедрения

 **Подсказка: Сначала нужно заинтересовать руководство, затем дать детали, потом обсудить внедрение.**

Ответ:

- Подготовка краткого executive summary
- Обсуждение выводов с руководством
- Рассылка полного отчёта команде и смежным отделам
- Запрос обратной связи и аудита отчёта
- Утверждение плана исправлений и контроль внедрения

Шаг 16:

Миссия 16

Расположите шаги валидирования и пересмотра отчёта:

1. Проверка технической точности с аналитиками
2. Юридическая проверка и соответствие нормам
3. Обратная связь от внешних аудиторов
4. Корректировка замечаний
5. Финальное утверждение отчёта

 **Подсказка: Сначала проверка внутри, затем внешняя, затем правки и утверждение.**

Ответ:

- Проверка технической точности с аналитиками
- Юридическая проверка и соответствие нормам
- Обратная связь от внешних аудиторов
- Корректировка замечаний
- Финальное утверждение отчёта

 Шаг 17:

Миссия 17

Расположите по порядку шаги реагирования и подготовки отчёта после завершения расследования:

1. Удалить артефакты с производственной сети (если безопасно)
2. Составить план защиты от повторных атак
3. Собрать и проанализировать данные расследования
4. Подготовить и распространить отчёт заинтересованным
5. Оценить уроки и обновить процедуры безопасности

 **Подсказка: Сначала данные, затем отчёт, затем действия по защите и обновлению.**

Ответ:

- Собрать и проанализировать данные расследования
- Подготовить и распространить отчёт заинтересованным
- Оценить уроки и обновить процедуры безопасности
- Составить план защиты от повторных атак
- Удалить артефакты с производственной сети (если безопасно)

 Урок 6 - Разбор ошибок и рекомендации по развитию

 Шаг 01:

Миссия 1

Аня — младший разработчик, она случайно закоммитила пароль в репозиторий. Какое действие наиболее правильно предпринять?

Подсказка: Лишняя публичность учтётся навсегда.

Ответ:

- **Регистрировать утечку и немедленно изменить пароль и удалить секрет из истории git**
- **Оставить как есть** — никто не заметит
- Спрятать пароль в .gitignore
- Оставить файл, но положить в архив

 Шаг 02:

Миссия 2

Борис тестирует внедрение библиотеки шифрования, но обнаружил предупреждение о слабой версии. Что ему делать?

Подсказка: Безопасность не терпит устаревших компонентов.

Ответ:

- **Обновить до безопасной версии библиотеки**

- Отключить предупреждение и продолжить
- Заменить на аналогичный модуль без анализа
- Игнорировать, если тесты проходят

🔗 Шаг 03:

Миссия 3

Катя хочет защитить API-ключ, который хранится в коде. Что лучший подход?

Подсказка: Не держи секрет под рукой.

Ответ:

- **Хранить ключ в защищённом хранилище и загружать через переменные окружения**
- Оставить прямо в коде, но зашифровать вручную
- Разбить ключ на части в разных файлах
- Закодировать в base64 и оставить в репозитории

🔗 Шаг 04:

Миссия 4

Илья получает фишинговое письмо, якобы от «администратора сервера». Что он должен сделать?

Подсказка: Проверь всегда отправителя вручную.

Ответ:

- **Не кликать ссылки и отправить письмо на проверку ИТ-отделу**
- Кликнуть ссылку, чтобы проверить, что нет угрозы
- Отвечать и просить дополнительные детали
- Игнорировать только если нет вложений

🔗 Шаг 05:

Миссия 5

Саша хочет делиться своими SSH-ключами между машинами, чтобы не вводить пароль. Что безопаснее всего?

Подсказка: Ключ должен быть приватным.

Ответ:

- **Скопировать публичную часть на сервер, приватную держать локально**
- Копировать приватный ключ на все машины
- Хранить ключи в облачном файле общего доступа
- Не использовать ключи вообще, только пароли

🔗 Шаг 06:

Миссия 6

Владимир настраивает CI/CD и хочет, чтобы секреты к деплою не были в логе. Что лучше сделать?

Подсказка: Логи не должны раскрывать чувствительное.

Ответ:

- **Маскировать или не выводить секретные переменные в логах**
- Вывести их после завершения задачи

- Записать все в файл и скрыть файл
- **Ничего не делать** — никто заинтересуется

🔗 Шаг 07:

Миссия 7

Наташа работает над модулем авторизации и хочет минимизировать поверхность атаки. Какой подход ей поможет?

Подсказка: Права по минимуму.

Ответ:

- **Применить принцип наименьших привилегий**
- **Предоставлять доступ ко всему** — меньше проверки
- Использовать одна роль для всех пользователей
- Не проверять права вовсе

🔗 Шаг 08:

Миссия 8

Задача: сопоставьте распространенные ошибки безопасности с их описаниями.

Ошибки:

Ответ:

- SQL-инъекция
- Cross-Site Scripting (XSS)
- Hardcoded credentials
- Unvalidated redirects

Описания:

1. Когда злоумышленник вставляет произвольный SQL-код в запросы.
2. Когда скрипт внедряется в веб-страницу через ввод пользователя.
3. Когда учётные данные указаны прямо в коде.
4. Когда приложение перенаправляет пользователя на внешний URL без проверки.

🔗 Подсказка:

Подумайте, что означает «инъекция», «скрипт», «credential», «redirect». Всё должно совпадать по смыслу.

- **SQL-инъекция** — Когда злоумышленник вставляет произвольный SQL-код в запросы.
- **Cross-Site Scripting (XSS)** — Когда скрипт внедряется в веб-страницу через ввод пользователя.
- **Hardcoded credentials** — Когда учётные данные указаны прямо в коде.
- **Unvalidated redirects** — Когда приложение перенаправляет пользователя на внешний URL без проверки.

🔗 Шаг 09:

Миссия 9

Задача: сопоставьте угрозы безопасности с уязвимостями.

Угрозы:

Ответ:

- Сниффинг трафика

- Атака посредника (MITM)
- Эксплуатация уязвимости в десериализации
- Доступ через небезопасный API

Уязвимости:

1. Не зашифрованный HTTP-трафик.
2. Слабая проверка входных данных при десериализации.
3. Отсутствие аутентификации и авторизации в API.
4. Недостаточная защита сетевого канала.

🔗 Подсказка:

Сопоставьте угрозу и уязвимость, которые логически связаны (например, MITM и незащищённый канал).

- **Сниффинг трафика** — Не зашифрованный HTTP-трафик.
- **Атака посредника (MITM)** — Недостаточная защита сетевого канала.
- **Эксплуатация уязвимости в десериализации** — Слабая проверка входных данных при десериализации.
- **Доступ через небезопасный API** — Отсутствие аутентификации и авторизации в API.

🔗 Шаг 10:

Миссия 10

Задача: сопоставьте меры защиты с проблемами.

Проблемы:

Ответ:

- Пароль перехвачен
- Сессия угнана
- Доступ без прав
- CSRF-атака

Меры защиты:

1. Использование CSRF-токенов.
2. Таймаут сессии и проверка IP/UA.
3. Многофакторная аутентификация.
4. Проверка прав и ролей перед доступом.

🔗 **Подсказка: Одна мера подходит к каждому сценарию — подумайте, какая защита важна именно там.**

- **Пароль перехвачен** — Многофакторная аутентификация.
- **Сессия угнана** — Таймаут сессии и проверка IP/UA.
- **Доступ без прав** — Проверка прав и ролей перед доступом.
- **CSRF-атака** — Использование CSRF-токенов.

🔗 Шаг 11:

Миссия 11

Сопоставьте виды тестирования с их целью.

Виды тестирования:

Ответ:

- Пенетестация
- Статический анализ кода
- Фаззинг
- DAST (динамический анализ)

Цели:

1. Найти уязвимости через ввод случайных данных.
2. Имитировать атаки извне.
3. Анализировать код без запуска.
4. Анализировать приложение во время выполнения.

🔮 **Подсказка:** Подумайте, какой метод работает «наживую», а какой — на уровне кода.

- **Пенетестация** — Имитировать атаки извне.
- **Статический анализ кода** — Анализировать код без запуска.
- **Фаззинг** — Найти уязвимости через ввод случайных данных.
- **DAST (динамический анализ)** — Анализировать приложение во время выполнения.

🔮 **Шаг 12:**

Миссия 12

Расположите этапы расследования инцидента в правильной последовательности:

1. Сбор доказательств (логи, дампы)
2. Идентификация инцидента
3. Анализ корня и масштабов
4. Восстановление системы
5. Отчёт и рекомендации

🔮 **Подсказка:**

Сначала узнаём, что произошло, затем как, потом устраняем, а в конце — учимся на ошибках.

Ответ:

- Идентификация инцидента
- Сбор доказательств (логи, дампы)
- Анализ корня и масштабов
- Восстановление системы
- Отчёт и рекомендации

🔮 **Шаг 13:**

Миссия 13

Расположите шаги безопасной разработки от начала до развертывания:

1. Threat modeling и проектирование безопасной архитектуры
2. Кодирование с учетом безопасных практик
3. Проверка (код-ревью, тесты безопасности)
4. Интеграция и деплоймент в безопасной среде
5. Мониторинг и реагирование на инциденты

🔮 **Подсказка:**

Безопасность должна быть встроена с самого начала, не добавляться в конце.

Ответ:

- Threat modeling и проектирование безопасной архитектуры
- Кодирование с учетом безопасных практик
- Проверка (код-ревью, тесты безопасности)
- Интеграция и деплоймент в безопасной среде
- Мониторинг и реагирование на инциденты

 Шаг 14:

Миссия 14

Расположите шаги ответа на компрометацию секретов:

1. Немедленная отзывка (rotating) секретов
2. Определение источника утечки
3. Оповещение заинтересованных сторон
4. Аудит доступа и прав
5. Документирование и улучшения процесса

 Подсказка:

После утечки – сначала остановить её, затем понять причины и уведомить команду.

Ответ:

- Немедленная отзывка (rotating) секретов
- Определение источника утечки
- Оповещение заинтересованных сторон
- Аудит доступа и прав
- Документирование и улучшения процесса

 Шаг 15:

Миссия 15

Расположите стадии улучшения безопасности ПО:

1. Оценка текущего состояния (аудит, pentest)
2. Планирование улучшений
3. Внедрение изменений
4. Тестирование и проверка
5. Повторный обзор и итерации

 Подсказка:

Безопасность — это цикл, не финальная точка.

Ответ:

- Оценка текущего состояния (аудит, pentest)
- Планирование улучшений
- Внедрение изменений
- Тестирование и проверка
- Повторный обзор и итерации

 Шаг 16:

Миссия 16

Расположите уровни зрелости безопасности (от начального к продвинутому):

1. Случайная реакция на инциденты
2. Проактивное выявление и управление рисками
3. Интеграция безопасности в жизненный цикл разработки
4. Автоматизация и аналитика безопасности

 Подсказка:

Зрелость — не хаос, а постепенное усложнение процесса.

Ответ:

- Случайная реакция на инциденты
- Проактивное выявление и управление рисками
- Интеграция безопасности в жизненный цикл разработки
- Автоматизация и аналитика безопасности

 Шаг 17:

Миссия 17

Расположите шаги финальной ревизии курса безопасности перед релизом:

1. Проверка соответствия требованиям безопасности
2. Код-ревью и статический анализ
3. Проведение нагрузочного и безопасного тестирования
4. Утверждение политики доступа и секретов
5. Запуск мониторинга и алертинга перед запуском

 Подсказка:

Сначала проверяем требования, потом тестируем, затем настраиваем политики и мониторинг.

Ответ:

- Проверка соответствия требованиям безопасности
- Код-ревью и статический анализ
- Проведение нагрузочного и безопасного тестирования
- Утверждение политики доступа и секретов
- Запуск мониторинга и алертинга перед запуском

Модуль 5 - Бонусные уроки (расширение горизонтов)

Урок 1 - Red Team vs Blue Team симуляция боевых ролей

 Шаг 01:

Миссия 1

Ты играешь за Blue Team. На корпоративном сервере неожиданно вырос трафик ночью. Что твой первый шаг?

Подсказка: Начинать с самого простого — нужно понять источник подозрительного трафика.

Ответ:

- **Проверить сетевые логи и IP-адреса источников**
- Сразу перезагрузить сервер
- Написать жалобу в интернет-провайдер
- Удалить все процессы из списка задач

Шаг 02:

Миссия 2

Red Team пытается получить доступ к базе данных. Они нашли форму логина. Какой уязвимостью они могут воспользоваться?

Подсказка: Вспомни классический пример с кавычками в SQL.

Ответ:

- **SQL-инъекция**
- XSS-атака
- DDoS
- Brute Force подбор паролей

Шаг 03:

Миссия 3

Ты заметил странный процесс на рабочей станции сотрудника. Что должен сделать Blue Team аналитик?

Подсказка: Не спеши всё удалять — сначала собери данные для расследования.

Ответ:

- **Собрать артефакты и журнал событий**
- Удалить процесс и забыть
- Позвонить пользователю и спросить его мнение
- Отключить компьютер от интернета и не анализировать

Шаг 04:

Миссия 4

Red Team запускает фишинговую кампанию. Какой признак чаще всего выдаёт поддельное письмо?

Подсказка: Обрати внимание на мелкие детали: отправителя, ссылки и орфографию.

Ответ:

- **Подозрительный адрес отправителя**
- Красивое оформление письма
- Большое вложение с фото
- Письмо на русском языке

Шаг 05:

Миссия 5

На сервере появилась неизвестная учётная запись администратора. Что предпримет Blue Team?

Подсказка: Важно не просто удалить запись, а разобраться, откуда она взялась.

Ответ:

- **Провести расследование и отключить учётную запись**
- Сразу перезагрузить сервер
- Сообщить пользователю, чтобы он поменял пароль
- Ничего не делать, если всё работает

Шаг 06:

Миссия 6

Red Team тестирует приложение и находит возможность загрузить .exe файл. Какую угрозу это несет?

Подсказка: Вспомни, что загрузка исполняемых файлов может превратить сервер в троянскую лошадь.

Ответ:

- **Удаленное выполнение кода**
- Замедление работы сайта
- Снижение рейтинга в поисковиках
- Проблемы с лицензиями

Шаг 07:

Миссия 7

Blue Team замечает подозрительный трафик на порт 22. Что это может значить?

Подсказка: Подумай о протоколах администрирования.

Ответ:

- **Попытки перебора пароля по SSH**
- Просмотр видео
- Скачивание музыки
- VPN-подключение

Шаг 08:

Миссия 8

Red Team использует утилиту nmap. Для чего она нужна?

Подсказка: Это как фонарик для исследователя сети.

Ответ:

- **Сканирование портов и сервисов**
- Создание резервных копий
- Мониторинг температуры процессора
- Проверка лицензий на ПО

Шаг 09:

Миссия 9

Сопоставь роли команд с их основными задачами:

Подсказка: Red атакует, Blue защищает.

Ответ:

- **Red Team** — Имитирует атаки для проверки защиты
- **Blue Team** — Обеспечивает защиту инфраструктуры
- **Purple Team** — Синхронизирует действия атакующих и защитников
- **SOC** — Центр мониторинга и реагирования

Шаг 10:

Миссия 10

Сопоставь тип атаки с примером из практики:

Подсказка: Вспомни, чем отличается фишинг от DDoS.

Ответ:

- **Фишинг** — Письмо с поддельной ссылкой
- **DDoS** — Множество запросов к сайту одновременно
- **SQL-инъекция** — Вставка кода в запрос
- **Brute Force** — Подбор паролей

🔮 Шаг 11:

Миссия 11

Сопоставь инструменты с их назначением:

Подсказка: Одни инструменты атакуют, другие защищают.

Ответ:

- **Wireshark** — Анализ сетевого трафика
- **Metasploit** — Эксплуатация уязвимостей
- **Snort** — Система обнаружения атак
- **Burp Suite** — Тестирование веб-приложений

🔮 Шаг 12:

Миссия 12

Сопоставь угрозу и её возможный результат:

Подсказка: Каждая угроза имеет свой уникальный исход.

Ответ:

- **Ransomware** — Шифрование файлов и требование выкупа
- **Keylogger** — Кража паролей
- **Rootkit** — Соккрытие присутствия атакующего
- **Worm** — Быстрое распространение по сети

🔮 Шаг 13:

Миссия 13

Расположи шаги атаки Red Team по порядку:

Подсказка: Сначала разведка, затем атака.

Ответ:

- Разведка целей
- Сканирование
- Эксплуатация уязвимости
- Закрепление доступа

🔮 Шаг 14:

Миссия 14

Расставь шаги Blue Team при реагировании на инцидент:

Подсказка: Сначала фиксируем, потом устраняем.

Ответ:

- Обнаружение инцидента

- Изоляция системы
- Анализ и сбор артефактов
- Устранение уязвимости

Шаг 15:

Миссия 15

Расположи этапы работы SOC по порядку:

Подсказка: Всё начинается с мониторинга.

Ответ:

- Мониторинг событий
- Детектирование угрозы
- Реагирование
- Отчетность

Шаг 16:

Миссия 16

Расположи действия Red Team после успешного проникновения:

Подсказка: Сначала закрепляемся, потом движемся дальше.

Ответ:

- Закрепление доступа
- Повышение привилегий
- Перемещение по сети
- Экfiltrация данных

Урок 2 - Введение в SIEM как работает мониторинг событий

Шаг 01:

Миссия 1

Аналитик впервые открывает SIEM-панель. Что он увидит в первую очередь?

Подсказка: Это место, где собираются все события из разных источников.

Ответ:

- **Агрегированные логи и события**
- Список контактов службы поддержки
- Архив корпоративных писем
- Таблицу сотрудников и их роли

Шаг 02:

Миссия 2

Программист Петя случайно оставил уязвимость на сайте. Как SIEM может помочь Blue Team?

Подсказка: SIEM — это не защита от уязвимостей напрямую, а скорее глаза и уши команды.

Ответ:

- **Зафиксировать аномалии в логах и сообщить об атаке**
- Автоматически исправить код сайта
- Заменить разработчика на нового
- Установить новые патчи без участия администратора

Шаг 03:

Миссия 3

Аналитик видит поток логов. Какие источники чаще всего подключаются к SIEM?

Подсказка: Подумай о том, где чаще всего происходят события в ИТ-системах.

Ответ:

- **Серверы, сетевые устройства, приложения**
- Социальные сети и мессенджеры
- Музыкальные плееры пользователей
- Личные заметки сотрудников

Шаг 04:

Миссия 4

В SIEM прилетает событие: вход администратора в 3 часа ночи. Как отреагировать?

Подсказка: Ночной логин — повод насторожиться, даже если учётка админская.

Ответ:

- **Создать инцидент и проверить источник логина**
- Игнорировать, админ же знает что делает
- Удалить учётную запись администратора
- Сразу выключить сервер

Шаг 05:

Миссия 5

SIEM показал всплеск трафика на порт 3389. Что это может значить?

Подсказка: Вспомни, какой сервис использует этот порт.

Ответ:

- **Попытки подключения к RDP**
- Просмотр фильмов онлайн
- Игровая сессия в сети
- Работа с базой данных SQL

Шаг 06:

Миссия 6

SIEM генерирует много ложных срабатываний. Как Blue Team с этим справляется?

Подсказка: Важно не утонуть в алертах, а правильно фильтровать данные.

Ответ:

- **Настройка корреляции и фильтров**
- Полное отключение SIEM
- Игнорирование всех алертов
- Удаление логов вручную

Шаг 07:

Миссия 7

Разработчик Вася подключил новый веб-сервис к SIEM. Что даёт это подключение?

Подсказка: Подумай, зачем нужны дополнительные источники данных.

Ответ:

- **Возможность мониторинга событий веб-приложения**
- Автоматическое ускорение работы сайта
- Повышение скорости процессора сервера
- Автоматическую оптимизацию SQL-запросов

Шаг 08:

Миссия 8

Почему SIEM так важен для расследования инцидентов?

Подсказка: Вспомни, что делает расследование полным: хронология и контекст.

Ответ:

- **Он хранит и коррелирует события для анализа**
- Он заменяет сотрудников SOC
- Он делает серверы быстрее
- Он исправляет уязвимости в коде

Шаг 09:

Миссия 9

Сопоставь компонент SIEM с его ролью:

Подсказка: Вспомни: сбор, хранение, анализ, оповещение.

Ответ:

- **Collector** — Сбор логов
- **Storage** — Хранение событий
- **Correlation Engine** — Анализ взаимосвязей
- **Alerting System** — Генерация уведомлений

Шаг 10:

Миссия 10

Сопоставь тип события с его примером:

Подсказка: Сетевые атаки отличаются от системных входов.

Ответ:

- **Authentication Event** — Успешный вход пользователя
- **Network Alert** — Попытка сканирования портов
- **Application Log** — Ошибка базы данных
- **File Access** — Попытка открыть секретный документ

Шаг 11:

Миссия 11

Сопоставь термин с его назначением в SIEM:

Подсказка: Каждый элемент — своя роль: кто-то собирает, кто-то обрабатывает.

Ответ:

- **Parser** — Приведение логов к единому формату
- **Dashboard** — Визуализация данных

- **Correlation Rule** — Выявление подозрительных паттернов
- **Incident Ticket** — Формализация инцидента

🔮 Шаг 12:

Миссия 12

Сопоставь угрозу и ожидаемое событие в SIEM:

Подсказка: Каждая угроза оставляет свой цифровой след.

Ответ:

- **Brute Force** — Множество неудачных входов
- **Malware** — Подозрительные процессы
- **Phishing** — Аномальные переходы по ссылкам
- **Insider Threat** — Необычный доступ к данным сотрудником

🔮 Шаг 13:

Миссия 13

Сопоставь задачу аналитика SOC с действием в SIEM:

Подсказка: Рабочий день SOC строится на этих действиях.

Ответ:

- **Monitoring** — Отслеживание событий в реальном времени
- **Investigation** — Анализ логов и корреляций
- **Response** — Изоляция заражённого хоста
- **Reporting** — Подготовка отчёта по инциденту

🔮 Шаг 14:

Миссия 14

Сопоставь популярный SIEM-продукт с его особенностью:

Подсказка: Разные вендоры — разные сильные стороны.

Ответ:

- **Splunk** — Мощная визуализация и поиск
- **QRadar** — Глубокая интеграция с IBM
- **ArcSight** — Сильная корреляция событий
- **ELK Stack** — Open-source и гибкая настройка

🔮 Шаг 15:

Миссия 15

Расположи шаги обработки события в SIEM по порядку:

Подсказка: Сначала собираем, потом анализируем.

Ответ:

- Сбор данных
- Парсинг и нормализация
- Корреляция
- Алертинг

Шаг 16:

Миссия 16

Расставь этапы расследования инцидента в SIEM:

Подсказка: От первой аномалии к финальному отчёту.

Ответ:

- Обнаружение
- Корреляция событий
- Анализ угрозы
- Подготовка отчёта

Шаг 17:

Миссия 17

Расположи действия SOC после получения алерта в правильном порядке:

Подсказка: Вспомни логику: сначала проверяем, потом реагируем.

Ответ:

- Верификация алерта
- Оценка критичности
- Реакция на инцидент
- Документирование

Урок 3 - DevSecOps внедрение безопасности в разработку

Шаг 01:

Миссия 1

Молодой разработчик Костя впервые слышит про DevSecOps. Он думает: «Это, наверное, просто ещё один модный фреймворк?» Что же на самом деле означает DevSecOps?

Подсказка: DevSecOps — это не библиотека и не инструмент, а подход.

Ответ:

- **Интеграция практик безопасности на каждом этапе разработки и эксплуатации**
- Новый язык программирования для DevOps-инженеров
- Фреймворк для быстрой сборки UI
- Сервис для хранения паролей

Шаг 02:

Миссия 2

Разработчица Аня хочет быстро выкатить фичу, но команда настаивает на проверке зависимостей через SCA (Software Composition Analysis). Зачем это нужно?

Подсказка: Внешние библиотеки часто бывают источником уязвимостей.

Ответ:

- **Чтобы проверить библиотеки на известные уязвимости**
- Чтобы ускорить компиляцию
- Чтобы уменьшить размер кода
- Чтобы проверить орфографию в комментариях

🔮 Шаг 03:

Миссия 3

DevOps-инженер Паша внедряет статический анализ кода (SAST) в pipeline. Его коллега спрашивает: «А зачем это нужно, если у нас есть тестировщики?»

Подсказка: Автоматический анализ помогает найти ошибки до запуска программы.

Ответ:

- **Чтобы автоматически находить уязвимости в коде до выполнения**
- Чтобы ускорить тестировщиков
- Чтобы уменьшить количество документации
- Чтобы повысить скорость релиза

🔮 Шаг 04:

Миссия 4

Во время code review Женя заметил, что пароль к базе данных зашит прямо в коде. Как правильно поступить?

Подсказка: Секреты должны храниться безопасно, а не в кодовой базе.

Ответ:

- **Удалить пароль из кода и использовать менеджер секретов**
- Оставить как есть, ведь код закрытый
- Зашифровать пароль в комментарии
- Спрятать пароль в название переменной

🔮 Шаг 05:

Миссия 5

Команда выпускает обновление и задумывается: «А кто отвечает за безопасность — разработчики или админы?» Каков правильный подход в DevSecOps?

Подсказка: В DevSecOps ответственность распределяется.

Ответ:

- **Безопасность** — общая ответственность всей команды
- Только тестировщиков
- Только админов
- Только безопасников

🔮 Шаг 06:

Миссия 6

Лена добавила новый сервис в Kubernetes, но забыла настроить RBAC. Что это может означать для безопасности?

Подсказка: Без ролей и правил любой может получить доступ.

Ответ:

- **Пользователи могут получить лишние привилегии**
- Приложение станет быстрее
- Все данные будут зашифрованы автоматически
- Сервис будет недоступен

🔗 Шаг 07:

Миссия 7

Артур настроил CI/CD, но забыл добавить этап проверки контейнеров на уязвимости. Чем это чревато?

Подсказка: Контейнеры могут содержать уязвимые образы.

Ответ:

- **В продакшн может попасть образ с известными уязвимостями**
- Код будет компилироваться медленнее
- Нужно будет больше серверов
- CI/CD перестанет работать

🔗 Шаг 08:

Миссия 8

📖 Сопоставьте практику DevSecOps и её назначение:

Подсказка: Каждая практика имеет конкретную цель: найти уязвимости, управлять секретами или ограничить доступ.

Ответ:

- **SAST** — Поиск уязвимостей в исходном коде
- **DAST** — Тестирование приложения в работающем окружении
- **SCA** — Анализ сторонних библиотек на уязвимости
- **Secrets Management** — Безопасное хранение ключей и паролей

🔗 Шаг 09:

Миссия 9

Саша изучает CI/CD pipeline. Сопоставьте этапы с их назначением:

Подсказка: Вспомните: сборка — компиляция, тесты — проверка, деплой — выкладка.

Ответ:

- **Build** — Сборка приложения
- **Test** — Запуск автоматических проверок
- **Security Scan** — Поиск уязвимостей
- **Deploy** — Развёртывание приложения

🔗 Шаг 10:

Миссия 10

📖 Сопоставьте роли и их задачи в DevSecOps:

Подсказка: Каждая роль играет свою часть: разработка, тестирование, инфраструктура, безопасность.

Ответ:

- **Разработчик** — Пишет код и исправляет уязвимости
- **Тестировщик** — Проверяет функционал и качество
- **DevOps-инженер** — Автоматизирует инфраструктуру и CI/CD
- **Безопасник** — Анализирует угрозы и внедряет защиту

Шаг 11:

Миссия 11

 Сопоставьте уязвимость и её пример:

Подсказка: SQL-инъекция — базы данных, XSS — браузеры, CSRF — подмена действий.

Ответ:

- **SQL Injection** — Вставка зловредного запроса в SQL
- **XSS** — Встраивание вредоносного скрипта в страницу
- **CSRF** — Выполнение действий от имени пользователя
- **Hardcoded Credentials** — Пароли, зашитые в код

Шаг 12:

Миссия 12

 Сопоставьте инструмент и его основное назначение:

Подсказка: SonarQube — качество кода, Trivy — контейнеры, HashiCorp Vault — секреты, OWASP ZAP — динамическое тестирование.

Ответ:

- **SonarQube** — Статический анализ качества кода
- **Trivy** — Сканирование контейнеров
- **HashiCorp Vault** — Управление секретами
- **OWASP ZAP** — DAST тестирование

Шаг 13:

Миссия 13

Расположите шаги безопасного CI/CD pipeline в правильном порядке:

Подсказка: Сначала пишем код, затем собираем, проверяем, сканируем и деплоим.

Ответ:

- Разработка кода
- Сборка
- Тестирование
- Security Scan
- Деплой

Шаг 14:

Миссия 14

Расположите действия безопасника при обнаружении уязвимости:

Подсказка: Сначала идентифицировать, потом оценить риск, затем устранить и проверить.

Ответ:

- Идентификация уязвимости
- Оценка риска
- Исправление
- Повторная проверка

Шаг 15:

Миссия 15

Расположите принципы безопасного кодирования по логике внедрения:

Подсказка: Сначала проектирование, затем защита данных, потом логирование, потом тестирование.

Ответ:

- Безопасное проектирование
- Шифрование данных
- Логирование событий
- Тестирование безопасности

Шаг 16:

Миссия 16

Расположите этапы внедрения DevSecOps в организации:

Подсказка: Сначала обучение команды, потом выбор инструментов, затем автоматизация, и наконец контроль и улучшение.

Ответ:

- Обучение команды
- Выбор инструментов
- Автоматизация процессов
- Непрерывный контроль и улучшение

Урок 4 - Работа с honeypots ловушки для хакеров

Шаг 01:

Миссия 1

Разработчик Никита услышал про honeypot и спросил: «Это что-то вроде сладкого десерта?» Что на самом деле означает термин honeypot в кибербезопасности?

Подсказка: Honeypot — это не еда, а цифровая ловушка.

Ответ:

- **Специально созданная система-ловушка для отслеживания атак**
- Программа для ускорения интернета
- Метод шифрования файлов
- Антивирусное обновление

Шаг 02:

Миссия 2

Аня заметила, что honeypot показал аномальный трафик от неизвестного IP. Какова основная цель honeypot в такой ситуации?

Подсказка: Honeypot не защищает напрямую, а собирает информацию о злоумышленниках.

Ответ:

- **Выявление и анализ методов атаки**
- Повышение скорости работы сервера
- Автоматическая блокировка всех пользователей
- Резервное копирование данных

Шаг 03:

Миссия 3

Петя спорит с коллегами: «Honeyrot — это же полноценная система защиты, которая остановит хакеров!» Верно ли это утверждение?

Подсказка: Honeyrot не является основным щитом, он скорее приманка.

Ответ:

- Да, honeyrot полностью заменяет защиту
- **Нет, honeyrot используется для отвлечения и мониторинга**

Шаг 04:

Миссия 4

Игорь запускает honeyrot, но забывает его изолировать от основной сети. Чем это грозит?

Подсказка: Ловушка должна быть безопасной и не влиять на настоящие ресурсы.

Ответ:

- **Хакеры могут использовать honeyrot для проникновения в настоящую сеть**
- Honeyrot перестанет собирать логи
- Сервер станет работать быстрее
- Все пользователи получают уведомления

Шаг 05:

Миссия 5

Марина заметила в логах honeyrot множество попыток подбора паролей к SSH. Что это говорит о злоумышленниках?

Подсказка: Логи honeyrot часто отражают реальные техники атаки.

Ответ:

- **Они используют перебор (brute-force) для доступа**
- Они пытаются улучшить производительность сервера
- Они тестируют новые антивирусы
- Они хотят обновить систему

Шаг 06:

Миссия 6

Андрей решил поставить honeyrot с видом на веб-приложение. Зачем это может быть полезно?

Подсказка: Через такие ловушки можно изучить атаки на веб-сервисы.

Ответ:

- **Чтобы отследить SQL-инъекции и другие веб-атаки**
- Чтобы ускорить загрузку сайта
- Чтобы автоматически тестировать дизайн
- Чтобы хранить резервные копии

Шаг 07:

Миссия 7

Компания развернула несколько honeypots. Что можно сделать с собранной информацией?

Подсказка: Данные из honeyrot помогают лучше понять врага.

Ответ:

- **Использовать её для улучшения защиты инфраструктуры**
- Сразу публиковать в социальных сетях
- Удалять без анализа
- Превратить в рекламу компании

Шаг 08:

Миссия 8

 Сопоставьте тип honeypot с его особенностью:

Подсказка: Одни ловушки простые и дешёвые, другие — сложные и детализированные.

Ответ:

- **Low-interaction honeypot** — Имитация сервисов с ограниченной функциональностью
- **High-interaction honeypot** — Реалистичная система для глубокого изучения атак
- **Research honeypot** — Используется для анализа новых техник атак
- **Production honeypot** — Применяется в реальной инфраструктуре для отвлечения

Шаг 09:

Миссия 9

 Сопоставьте инструмент и его назначение в работе с honeypots:

Подсказка: Honeyd — эмуляция сервисов, Cowrie — SSH/Telnet, Dionaea — малварь, Kippo — устаревший SSH honeypot.

Ответ:

- **Honeyd** — Эмуляция различных сетевых сервисов
- **Cowrie** — Ловушка для SSH/Telnet атак
- **Dionaea** — Сбор вредоносных файлов
- **Kippo** — Старый SSH honeypot

Шаг 10:

Миссия 10

 Сопоставьте атаку и то, что может показать honeypot:

Подсказка: Brute-force — пароли, SQL Injection — запросы, Malware — файлы, DDoS — нагрузка.

Ответ:

- **Brute-force** — Попытки подбора паролей
- **SQL Injection** — Вставка вредоносных SQL-запросов
- **Malware Upload** — Загрузка подозрительных файлов
- **DDoS** — Аномальный рост трафика

Шаг 11:

Миссия 11

 Сопоставьте данные из honeypot с их применением:

Подсказка: Логи атак — для расследований, IP-адреса — для блокировок, вредоносные файлы — для анализа, поведенческие паттерны — для прогнозирования.

Ответ:

- **Логи атак** — Используются при расследовании инцидентов

- **IP-адреса злоумышленников** — Применяются для настройки блокировок
- **Захваченные вредоносные файлы** — Отправляются в песочницу на анализ
- **Поведенческие паттерны атак** — Помогают прогнозировать будущие угрозы

Шаг 12:

Миссия 12

 Сопоставьте ошибки при работе с honeypots и их последствия:

Подсказка: Неправильная изоляция — риск, отсутствие логов — потеря данных, неверная настройка — бесполезность, игнорирование анализа — упущенные уроки.

Ответ:

- **Нет изоляции от сети** — Злоумышленники могут атаковать реальную систему
- **Нет логирования** — Отсутствие информации о попытках атак
- **Неправильная настройка** — Honeypot не выполняет свою роль
- **Нет анализа данных** — Пропуск возможностей улучшить защиту

Шаг 13:

Миссия 13

Расположите шаги развёртывания honeypot в правильном порядке:

Подсказка: Сначала планируем, затем изолируем, настраиваем, запускаем и собираем данные.

Ответ:

- Планирование целей
- Изоляция системы
- Настройка honeypot
- Запуск
- Сбор и анализ данных

Шаг 14:

Миссия 14

Расположите этапы работы исследователя с данными honeypot:

Подсказка: Сначала сбор, потом фильтрация, далее анализ и наконец отчёт.

Ответ:

- Сбор логов
- Фильтрация данных
- Анализ атак
- Подготовка отчёта

Шаг 15:

Миссия 15

Расположите действия команды после выявления новой техники атаки через honeypot:

Подсказка: Вначале документирование, потом обновление защит, далее тестирование, и в конце обучение команды.

Ответ:

- Документирование техники
- Обновление защитных правил
- Тестирование изменений

- Обучение команды

Шаг 16:

Миссия 16

Расположите этапы реагирования на инцидент, выявленный honeypot:

Подсказка: Сначала обнаружение, потом сдерживание, затем устранение и, наконец, восстановление.

Ответ:

- Обнаружение
- Сдерживание
- Устранение
- Восстановление

Урок 5 - DLP-системы предотвращение утечек данных

Шаг 01:

Миссия 1

Молодой программист Лена случайно отправила служебный файл в личную почту. Как должна сработать DLP-система?

Подсказка: Вспомните, что DLP анализирует каналы передачи данных.

Ответ:

- **Заблокировать отправку письма с конфиденциальным вложением**
- Изменить содержимое файла автоматически
- Стереть почтовый ящик полностью
- Ничего не предпринимать

Шаг 02:

Миссия 2

Разработчик Кирилл копирует код на флешку, чтобы поработать дома. Что сделает DLP-система?

Подсказка: Вспомните про контроль подключаемых устройств.

Ответ:

- **Запретит копирование файла на внешний носитель**
- Сожжёт флешку лазером
- Удалит весь проект из репозитория
- Сразу отправит копию директору

Шаг 03:

Миссия 3

Сисадмин заметил подозрительный трафик: файлы уходят через мессенджер. Какую роль играет DLP?

Подсказка: Подумайте о контроле сетевых каналов.

Ответ:

- **DLP отслеживает и блокирует передачу конфиденциальных файлов в мессенджеры**

- DLP самостоятельно переписывает сообщения
- DLP блокирует доступ ко всем сайтам
- DLP удаляет приложение с устройства

Шаг 04:

Миссия 4

Инженер Антон пытается переслать чертёж по личному Gmail. Как работает DLP?

Подсказка: Вспомните про фильтрацию контента в почте.

Ответ:

- **Письмо будет остановлено системой**
- Файл превратится в картинку кота
- Gmail будет заблокирован навсегда
- Ничего не произойдет

Шаг 05:

Миссия 5

Аналитик Маша случайно прикрепила таблицу с зарплатами в общий чат команды. Что сделает DLP?

Подсказка: Таблицы с персональными данными — особая зона контроля.

Ответ:

- **Заблокирует отправку и уведомит администратора**
- Удалит у Маши аккаунт
- Поменяет данные на случайные цифры
- Сразу отправит данные конкурентам

Шаг 06:

Миссия 6

Вася подключил смартфон к рабочему ПК и скопировал файл через Bluetooth. Как реагирует DLP?

Подсказка: Контроль беспроводных каналов — часть защиты.

Ответ:

- **Заблокирует передачу по Bluetooth**
- Разрядит телефон
- Удалит драйверы
- Перезагрузит компьютер каждые 5 минут

Шаг 07:

Миссия 7

Сотрудник пытается распечатать договор с коммерческой тайной. Какую реакцию ожидаем?

Подсказка: DLP контролирует даже принтеры.

Ответ:

- **Запретить печать документа**
- Сжечь принтер
- Отправить договор в соцсети
- Поставить пароль на бумагу

Шаг 08:

Миссия 8

Артем запускает скрипт, который пытается массово выгрузить базу клиентов. Что делает DLP?

Подсказка: DLP умеет обнаруживать подозрительные массовые операции.

Ответ:

- **Заблокирует выгрузку и отправит инцидент в SOC**
- Удалит всю базу клиентов
- Позволит выполнить выгрузку полностью
- Отправит копию в мессенджер

Шаг 09:

Миссия 9

 Сопоставьте канал утечки и способ его контроля DLP:

Подсказка: Подумайте о почте, мессенджерах, печати и флешках.

Ответ:

- **Электронная почта** — Фильтрация вложений и текста писем
- **Мессенджеры** — Анализ передаваемых файлов
- **Принтер** — Блокировка печати конфиденциальных документов
- **USB-носители** — Ограничение копирования на внешние устройства

Шаг 10:

Миссия 10

Сопоставьте сотрудников и их типичные ошибки:

Подсказка: Каждый герой связан с конкретной ситуацией выше.

Ответ:

- **Лена** — Отправила файл в личную почту
- **Кирилл** — Скопировал код на флешку
- **Маша** — Поделилась таблицей с зарплатами
- **Артем** — Попытался выгрузить базу клиентов

Шаг 11:

Миссия 11

Сопоставьте возможности DLP-системы с их назначением:

Подсказка: Подумайте, что блокирует, а что мониторит.

Ответ:

- **Мониторинг** — Отслеживание действий пользователей
- **Блокировка** — Прерывание передачи запрещённых данных
- **Уведомление** — Оповещение администратора о нарушении
- **Аналитика** — Сбор статистики для отчетов

Шаг 12:

Миссия 12

Сопоставьте угрозы и меры защиты:

Подсказка: Каждая угроза имеет конкретный метод противодействия.

Ответ:

- **Отправка личных данных в чат** — Контентный анализ сообщений
- **Копирование на флешку** — Ограничение внешних устройств
- **Попытка печати документа** — Контроль печати
- **Выгрузка базы** — Обнаружение массовых операций

Шаг 13:

Миссия 13

Сопоставьте тип данных и реакцию DLP:

Подсказка: Персональные данные, финансы и секреты компании требуют разных действий.

Ответ:

- **Персональные данные** — Жёсткая блокировка и уведомление
- **Финансовая информация** — Фильтрация и мониторинг
- **Исходный код** — Контроль пересылки вне компании
- **Общая корпоративная информация** — Допускается пересылка с пометкой

Шаг 14:

Миссия 14

Расположите действия сотрудника при подозрении на утечку данных:

Подсказка: Вспомните про фиксацию, уведомление, анализ и предотвращение.

Ответ:

- Зафиксировать подозрительную активность
- Уведомить службу безопасности
- Проанализировать ситуацию
- Принять меры для предотвращения повторения

Шаг 15:

Миссия 15

Расположите этапы внедрения DLP-системы:

Подсказка: Сначала определяют данные, потом правила, затем внедрение и контроль.

Ответ:

- Определение критичных данных
- Формирование политик безопасности
- Развертывание системы
- Мониторинг и корректировка

Шаг 16:

Миссия 16

Расположите действия DLP при обнаружении запрещённого вложения:

Подсказка: Сначала анализ, затем блокировка, потом уведомление.

Ответ:

- Анализ содержимого вложения
- Блокировка отправки

- Уведомление администратора
- Формирование отчета

Урок 6 - Инцидент-репортинг и взаимодействие с CERT

Шаг 01:

Миссия 1

Разработчик Андрей заметил подозрительное письмо с вложением и думает, стоит ли его открывать. Что он должен сделать в рамках инцидент-репортинга?

Подсказка: Первое правило — не усугублять ситуацию.

Ответ:

- **Сообщить в службу безопасности и не открывать вложение**
- Сразу переслать письмо всем коллегам
- Открыть вложение для проверки
- Удалить письмо и забыть

Шаг 02:

Миссия 2

Тестировщик Игорь заметил, что сервер странно перегружен и ведёт себя аномально. Что является правильным первым шагом?

Подсказка: Действия должны быть зафиксированы.

Ответ:

- **Зафиксировать инцидент и уведомить администратора**
- Перезапустить сервер без записи информации
- Игнорировать проблему до утра
- Попробовать исправить сам, не уведомляя CERT

Шаг 03:

Миссия 3

Аналитик Маша получила подозрительное письмо от имени CERT. Что ей следует сделать?

Подсказка: Всегда проверяйте источник.

Ответ:

- **Проверить подлинность письма через официальные каналы CERT**
- Сразу кликнуть по ссылке в письме
- Удалить письмо без проверки
- Переслать письмо друзьям для совета

Шаг 04:

Миссия 4

Компания получила сообщение от CERT о критической уязвимости. Что нужно сделать в первую очередь?

Подсказка: Важно не паниковать, а действовать системно.

Ответ:

- **Оценить критичность уязвимости и начать план действий**
- Сразу отключить все серверы

- Отправить в CERT гневное письмо
- Игнорировать сообщение, так как оно общее

Шаг 05:

Миссия 5

Сотрудник нашёл флешку на парковке и подключил её к рабочему ПК. Что считается правильным действием?

Подсказка: Подумайте о цепочке инцидента.

Ответ:

- **Сообщить о событии как об инциденте и изолировать ПК**
- Скопировать файлы и передать в чат
- Стереть флешку и вернуть её владельцу
- Ничего не делать

Шаг 06:

Миссия 6

Кибербезопасник Дима обнаружил подозрительный скрипт на сервере. Какой его первый шаг?

Подсказка: Не стоит сразу удалять следы.

Ответ:

- **Собрать доказательства и уведомить CERT**
- Удалить скрипт и перезагрузить
- Игнорировать скрипт
- Разослать скрипт коллегам

Шаг 07:

Миссия 7

Компания получила фишинговую атаку на сотрудников. Что лучше всего сделать?

Подсказка: Действия должны быть коллективными.

Ответ:

- **Сообщить всем сотрудникам и в CERT**
- Удалить письма у себя и молчать
- Ответить злоумышленникам
- Поменять рабочий email и забыть

Шаг 08:

Миссия 8

DevOps Саша видит, что база данных активно выгружается на неизвестный IP. Что нужно сделать?

Подсказка: Действовать быстро, но правильно.

Ответ:

- **Отключить передачу и сообщить в CERT**
- **Игнорировать** — может, это тест
- Подождать, пока выгрузка закончится
- Отправить IP в Google

Шаг 09:

Миссия 9

 Сопоставьте роли и их задачи при инциденте:

Подсказка: CERT, сотрудники и ИБ-отдел всегда работают вместе.

Ответ:

- **CERT** — Анализ и координация расследования
- **Сотрудник** — Сообщение о подозрительной активности
- **Отдел ИБ** — Локализация и предотвращение угроз
- **Администратор** — Фиксация технических деталей инцидента

Шаг 10:

Миссия 10

Сопоставьте шаги инцидент-репортинга с их описанием:

Подсказка: Это похоже на план действий при пожаре.

Ответ:

- **Обнаружение** — Фиксация подозрительной активности
- **Сообщение** — Передача информации в ответственные службы
- **Анализ** — Определение характера атаки
- **Ответ** — Принятие мер по устранению угрозы

Шаг 11:

Миссия 11

Сопоставьте тип атаки и необходимое действие:

Подсказка: Каждое действие должно снижать последствия.

Ответ:

- **Фишинг** — Предупредить сотрудников и заблокировать домен
- **DDoS** — Включить фильтрацию трафика
- **Малварь** — Изолировать заражённое устройство
- **Инсайдерская угроза** — Ограничить доступ нарушителя

Шаг 12:

Миссия 12

Сопоставьте вид отчёта и его назначение:

Подсказка: Разные уровни отчётности для разных целей.

Ответ:

- **Технический отчёт** — Детальный анализ логов и системных событий
- **Менеджерский отчёт** — Краткие выводы для руководства
- **Отчёт для CERT** — Сведения о типе атаки и её последствиях
- **Публичный отчёт** — Информация для клиентов и СМИ

Шаг 13:

Миссия 13

Сопоставьте инструменты и их роль при расследовании:

Подсказка: Логи, IDS и SIEM нужны для разных этапов.

Ответ:

- **Логи системы** — Фиксация действий пользователей
- **IDS** — Выявление сетевых атак
- **SIEM** — Корреляция событий и аналитика
- **Форензика** — Изучение дисков и файлов

🔮 Шаг 14:

Миссия 14

Сопоставьте участников и их взаимодействие с CERT:

Подсказка: Вспомните, кто что сообщает.

Ответ:

- **Администратор** — Предоставляет логи и технические детали
- **Менеджер** — Отвечает за организационную координацию
- **CERT** — Делится аналитикой и рекомендациями
- **Сотрудники** — Сообщают о подозрительной активности

🔮 Шаг 15:

Миссия 15

Расположите этапы реагирования на инцидент:

Подсказка: Сначала нужно заметить, потом сообщить, потом действовать.

Ответ:

- Обнаружение
- Сообщение в CERT
- Анализ ситуации
- Ответные меры

🔮 Шаг 16:

Миссия 16

Расположите шаги расследования после атаки:

Подсказка: Не забудьте, что сначала собирают доказательства.

Ответ:

- Сбор доказательств
- Форензика
- Анализ причин
- Разработка мер защиты

🔮 Шаг 17:

Миссия 17

Расположите действия при взаимодействии с CERT:

Подсказка: Вспомните про уведомление, передачу данных, совместный анализ и внедрение рекомендаций.

Ответ:

- Уведомление CERT

- Передача информации
- Совместный анализ
- Внедрение рекомендаций

Урок 7 - Безопасность API и webhooks

Шаг 01:

Миссия 1

Андрей подключает сервис оплаты через API. Какой первый шаг он должен сделать, чтобы защитить ключи доступа?

Подсказка: Думай о том, где хранить секреты, а не о том, как их показывать.

Ответ:

- **Хранить ключи в переменных окружения**
- Записать ключи прямо в коде и загрузить в GitHub
- Отправить ключи коллегам по электронной почте
- Сохранить ключи в комментариях к коду

Шаг 02:

Миссия 2

Марина получила запрос на webhook от неизвестного сервиса. Что ей нужно проверить в первую очередь?

Подсказка: Всегда думай о том, кто прислал сообщение.

Ответ:

- **Проверить подпись или токен, подтверждающий источник**
- Сразу выполнить полученный код
- Открыть вложение в письме об этом webhook
- Пройгнорировать проверку и довериться содержимому

Шаг 03:

Миссия 3

Игорь заметил, что его API принимает слишком длинные запросы. Что это может означать?

Подсказка: Длинные строки могут скрывать опасность.

Ответ:

- **Попытку атаки типа DoS или SQL-инъекции**
- Просто интерес клиента к API
- Ошибку в интерфейсе пользователя
- Обычный сетевой шум

Шаг 04:

Миссия 4

Ольга разрабатывает webhook для приёма уведомлений о заказах. Какой HTTP-метод для этого наиболее безопасен?

Подсказка: Подумай о методе, который обычно используют для передачи данных.

Ответ:

- **POST**

- GET
- PUT
- DELETE

Шаг 05:

Миссия 5

Павел подключил сторонний API, но не ограничил IP-адреса. Чем это грозит?

Подсказка: Думай, кто ещё может получить доступ, если границы не заданы.

Ответ:

- **Злоумышленники смогут отправлять запросы откуда угодно**
- **Ничем** — IP не важны для безопасности
- Сервис просто будет работать быстрее
- API перестанет отвечать

Шаг 06:

Миссия 6

Саша настроил webhook, но не использует HTTPS. Чем это опасно?

Подсказка: Данные по пути могут быть перехвачены.

Ответ:

- **Данные могут быть перехвачены и изменены злоумышленником**
- Webhook не сможет работать дольше 10 секунд
- Сервис начнёт отправлять уведомления дважды
- HTTPS нужен только для красоты адреса

Шаг 07:

Миссия 7

 Сопоставь тип атаки на API с её описанием.

Подсказка: Вспомни, что DoS перегружает, XSS внедряет код, а SQL-инъекция ломает базу.

Ответ:

- **DoS-атака** — Перегрузка сервера множеством запросов
- **SQL-инъекция** — Внедрение кода в базу данных через запрос
- **XSS** — Вставка вредоносного скрипта в веб-страницу
- **MITM** — Перехват и подмена данных между клиентом и сервером

Шаг 08:

Миссия 8

 Сопоставь заголовок HTTP с его назначением.

Подсказка: Вспомни: Authorization проверяет, Content-Type описывает формат, User-Agent говорит о клиенте.

Ответ:

- **Authorization** — Передача токена для проверки доступа
- **Content-Type** — Определение формата данных запроса или ответа
- **User-Agent** — Информация о клиенте, который делает запрос
- **X-Signature** — Подпись для проверки подлинности webhook

🔧 Шаг 09:

Миссия 9

📖 Сопоставь метод защиты API с его преимуществом.

Подсказка: Rate limiting — ограничение, токены — проверка личности, логирование — расследование.

Ответ:

- **Rate limiting** — Защищает от перегрузки запросами
- **API token** — Определяет, кто имеет право доступа
- **Логирование** — Позволяет анализировать инциденты
- **IP whitelist** — Ограничивает доступ только доверенным адресам

🔧 Шаг 10:

Миссия 10

📖 Сопоставь уязвимость с примером.

Подсказка: SQL-инъекция — база, CSRF — чужие действия, XSS — скрипты.

Ответ:

- **SQL-инъекция** — `SELECT * FROM users WHERE id='1 OR 1=1'`
- **XSS** — `alert('Hacked')`
- **CSRF** — Злоумышленник заставляет жертву отправить запрос без её ведома
- **Directory Traversal** — `../../etc/passwd`

🔧 Шаг 11:

Миссия 11

📖 Сопоставь инструмент с его назначением.

Подсказка: Postman — тестирование, Burp Suite — анализ безопасности, Wireshark — трафик.

Ответ:

- **Postman** — Тестирование API-запросов
- **Burp Suite** — Поиск уязвимостей и перехват запросов
- **Wireshark** — Анализ сетевого трафика
- **NGROK** — Проброс локального сервера в интернет

🔧 Шаг 12:

Миссия 12

📖 Сопоставь формат передачи данных с его особенностью.

Подсказка: JSON — лёгкий, XML — строгий, YAML — читаемый.

Ответ:

- **JSON** — Простой и широко используемый формат
- **XML** — Поддерживает строгую структуру и валидацию
- **YAML** — Читается человеком проще, чем XML
- **Protobuf** — Быстрый двоичный формат для API

🔧 Шаг 13:

Миссия 13

Расположи шаги настройки безопасного webhook в правильном порядке.

Подсказка: Сначала настрой HTTPS, потом проверку подписи, затем обработку данных.

Ответ:

- Настроить HTTPS
- Проверять подпись запроса
- Фильтровать и валидировать входящие данные
- Логировать события

Шаг 14:

Миссия 14

Расположи шаги при обнаружении утечки API-ключа.

Подсказка: Сначала отключи ключ, потом выпусти новый, обновь систему и проанализируй.

Ответ:

- Отключить скомпрометированный ключ
- Сгенерировать новый ключ
- Обновить приложение, чтобы использовать новый ключ
- Проанализировать журналы для выявления злоупотреблений

Шаг 15:

Миссия 15

Расположи этапы защиты API от перегрузки запросами.

Подсказка: Сначала анализ, потом лимиты, потом кэш, потом мониторинг.

Ответ:

- Анализировать трафик
- Установить rate limiting
- Добавить кэширование
- Включить мониторинг нагрузки

Шаг 16:

Миссия 16

Расположи шаги безопасной публикации API.

Подсказка: Документация идёт первой, затем ограничение доступа, потом тестирование, и только потом публикация.

Ответ:

- Подготовить документацию
- Ограничить доступ по токенам
- Провести тестирование безопасности
- Опубликовать API

Урок 8 - Анализ трафика с Wireshark (вводный уровень)

Шаг 01:

Миссия 1

Андрей, начинающий программист, впервые запустил Wireshark. Какое основное назначение этого инструмента?

Подсказка: Подумай, почему безопасники и сетевики так любят этот инструмент — он позволяет «заглянуть внутрь пакетов».

Ответ:

- **Анализ сетевого трафика в реальном времени**
- Создание резервных копий диска
- Оптимизация работы процессора
- Запуск виртуальных машин

Шаг 02:

Миссия 2

Марина работает в офисе и хочет понять, какие протоколы чаще всего используют её коллеги. Какое поле в Wireshark ей нужно смотреть?

Подсказка: Оно показывает, какой «язык общения» использует пакет.

Ответ:

- **Protocol**
- Length
- Time
- Info

Шаг 03:

Миссия 3

Алекс заметил, что в Wireshark пакеты идут очень быстро. Как он может отфильтровать только HTTP-трафик?

Подсказка: В фильтре обычно указывают имя протокола.

Ответ:

- **В строке фильтра написать http**
- Включить режим Airplane Mode
- Выбрать в меню File → Save
- Сортировать по колонке Time

Шаг 04:

Миссия 4

Сергей анализирует сетевую активность на своём ноутбуке. Он увидел, что много пакетов идет на порт 443. Что это значит?

Подсказка: Этот порт связан с безопасным веб-серфингом.

Ответ:

- **Это HTTPS-трафик (шифрованное соединение)**
- Это FTP-загрузка
- Это DNS-запросы
- Это трафик ICMP (ping)

Шаг 05:

Миссия 5

Лена работает в компании и анализирует подозрительные подключения. Она заметила в Wireshark, что IP-адрес источника совпадает с адресом её принтера. Что это может значить?

Подсказка: Иногда не только компьютеры создают трафик.

Ответ:

- **Принтер тоже участвует в сетевом обмене**
- Принтер заражён вирусом
- Это ошибка Wireshark
- Это подмена IP-адреса компьютером Лены

Шаг 06:

Миссия 6

Игорь заметил, что кто-то пересылает большие файлы по сети. Какое поле в Wireshark поможет понять размер пакета?

Подсказка: Это поле напрямую связано с количеством байтов.

Ответ:

- **Length**
- Protocol
- Info
- Time

Шаг 07:

Миссия 7

Катя нашла в Wireshark пакеты с протоколом DNS. Что они означают?

Подсказка: DNS — это как телефонная книга интернета.

Ответ:

- **Запросы и ответы на преобразование доменных имен в IP-адреса**
- Шифрованный банковский трафик
- Передачу видео по сети
- Обновления Wireshark

Шаг 08:

Миссия 8

Дмитрий заметил, что фильтр «tcp.port==21» выделяет трафик. Какой протокол он отследил?

Подсказка: Этот порт традиционно используют для передачи файлов по старым методам.

Ответ:

- **FTP**
- SMTP
- SSH
- RDP

Шаг 09:

Миссия 9

👤 Задача: сопоставь протокол и его назначение.

Подсказка: Подумай, какие протоколы отвечают за почту, веб и доменные имена.

Ответ:

- **HTTP** — Передача веб-страниц без шифрования

- **HTTPS** — Передача веб-страниц с шифрованием
- **DNS** — Преобразование доменных имен в IP-адреса
- **SMTP** — Отправка электронной почты

Шаг 10:

Миссия 10

✂ Сопоставь поле Wireshark и то, что оно показывает.

Подсказка: Одно поле отвечает за протокол, другое — за размер, третье — за время.

Ответ:

- **Protocol** — Какой протокол используется
- **Length** — Размер пакета в байтах
- **Time** — Когда был получен пакет
- **Info** — Дополнительные детали о содержимом

Шаг 11:

Миссия 11

📶 Сопоставь порт и тип трафика.

Подсказка: Вспомни стандартные номера портов для HTTPS, DNS и FTP.

Ответ:

- **443** — HTTPS
- **80** — HTTP
- **53** — DNS
- **21** — FTP

Шаг 12:

Миссия 12

🖥️ Сопоставь действие пользователя с тем, какой трафик это создаёт.

Подсказка: Если заходишь на сайт — это веб-трафик, если проверяешь почту — это SMTP/IMAP.

Ответ:

- **Открыть веб-сайт** — HTTP/HTTPS
- **Отправить письмо** — SMTP
- **Запросить IP по домену** — DNS
- **Скачать файл по FTP** — FTP

Шаг 13:

Миссия 13

🔍 Сопоставь инструмент и его назначение.

Подсказка: Wireshark — не единственный инструмент анализа сетей.

Ответ:

- **Wireshark** — Анализ сетевых пакетов
- **tcpdump** — Консольный захват трафика
- **Nmap** — Сканирование портов
- **Burp Suite** — Тестирование веб-приложений

Шаг 14:

Миссия 14

 Расставь шаги для начала работы в Wireshark в правильном порядке:

Подсказка: Сначала нужно выбрать интерфейс, потом запустить захват, а уже затем анализировать.

Ответ:

- Выбрать сетевой интерфейс
- Нажать «Start capturing»
- Фильтровать и анализировать пакеты
- Сохранить результат при необходимости

Шаг 15:

Миссия 15

 Расставь уровни модели OSI от нижнего к верхнему.

Подсказка: Сначала идет физика (кабели), потом логика (протоколы), потом приложения.

Ответ:

- Физический
- Канальный
- Сетевой
- Транспортный
- Сеансовый
- Представительный
- Прикладной

Шаг 16:

Миссия 16

 Расставь шаги анализа подозрительного пакета:

Подсказка: Сначала смотришь адреса, потом порт, потом полезную нагрузку.

Ответ:

- Проверить IP-адрес источника
- Проверить порт
- Изучить протокол
- Проанализировать содержимое

Шаг 17:

Миссия 17

 Расставь действия безопасника при расследовании инцидента в правильном порядке:

Подсказка: Сначала захват, потом фильтрация, потом поиск аномалий и только потом выводы.

Ответ:

- Собрать трафик с помощью Wireshark
- Применить фильтры
- Найти подозрительные пакеты
- Составить отчет

Урок 9 - Работа с bug bounty платформами

Шаг 01:

Миссия 1

Аня только что зарегистрировалась на bug bounty платформе и хочет понять, с чего начать. Что будет правильным первым шагом?

Подсказка: Не стоит сразу искать уязвимости — лучше познакомиться с правилами.

Ответ:

- **Изучить правила программы и область охвата (scope)**
- Сразу же отправить первый найденный баг
- Скачать код сайта и начать его переписывать
- Создать десяток аккаунтов на платформе

Шаг 02:

Миссия 2

Игорь нашёл потенциальную уязвимость XSS, но сомневается, можно ли её репортить. Что ему стоит проверить в первую очередь?

Подсказка: Сначала убедись, что уязвимость входит в область охвата программы.

Ответ:

- **Является ли эта часть приложения в scope**
- Сколько лайков получит его отчёт
- Сколько платят на других платформах
- Можно ли опубликовать баг в соцсетях

Шаг 03:

Миссия 3

Саша решил написать свой первый отчёт. Что должно быть в отчёте в первую очередь?

Подсказка: Представь, что читающий не знает ничего об ошибке.

Ответ:

- **Пошаговое описание, как воспроизвести баг**
- Оценка стоимости уязвимости на рынке
- Ссылка на мем про безопасность
- Файл с кодом сайта целиком

Шаг 04:

Миссия 4

Марина обнаружила SQL-инъекцию. Что будет наилучшей практикой при её репорте?

Подсказка: Покажи, что уязвимость реальна, но не наноси ущерб системе.

Ответ:

- **Демонстрировать на примере вывода версии базы данных**
- Удалить часть таблицы для доказательства
- Опубликовать дамп базы в интернете
- Сразу требовать максимальную награду

🔮 Шаг 05:

Миссия 5

Петя заметил, что его отчёт отклонили. Какая может быть причина?

Подсказка: Иногда баг не признают уязвимостью, даже если он выглядит опасно.

Ответ:

- **Уязвимость оказалась вне области охвата**
- Он не прикрепил смайлики в отчёте
- Админ не любит его ник
- Он отправил отчёт ночью

🔮 Шаг 06:

Миссия 6

Дима хочет повысить шансы на получение награды. Что ему лучше всего сделать?

Подсказка: Чем яснее и понятнее отчёт, тем проще его проверить.

Ответ:

- **Приложить скриншоты и чёткие шаги воспроизведения**
- Написать отчёт на сленге программистов
- Просто указать: «тут баг»
- Отправить отчёт без проверки

🔮 Шаг 07:

Миссия 7

Катя прочитала про ответственность в bug bounty. Что категорически запрещено?

Подсказка: Всегда помни про закон и этику.

Ответ:

- **Эксплуатировать баг для кражи данных**
- Оповестить компанию через платформу
- Тестировать только в рамках scope
- Отправлять баги с доказательством

🔮 Шаг 08:

Миссия 8

Сопоставьте популярные bug bounty платформы с их особенностями:

Подсказка: Подумай, какие платформы чаще связаны с корпоративными программами, а какие с открытыми.

Ответ:

- **HackerOne** — Одна из крупнейших платформ, сотрудничает с мировыми корпорациями.
- **Bugcrowd** — Использует модель краудсорсинга для распределения отчётов.
- **YesWeHack** — Европейская платформа с упором на конфиденциальность.
- **OpenBugBounty** — Открытая платформа с возможностью бесплатных отчётов.

🔮 Шаг 09:

Миссия 9

Сопоставьте виды уязвимостей с их кратким описанием:

Подсказка: Вспомни OWASP Top 10 — это всегда полезный ориентир.

Ответ:

- **XSS** — Возможность внедрить вредоносный скрипт в веб-страницу.
- **SQL Injection** — Манипуляция с базой данных через пользовательский ввод.
- **CSRF** — Атака, при которой пользователь выполняет нежелательное действие.
- **IDOR** — Неправильный контроль доступа к объектам по их идентификаторам.

Шаг 10:

Миссия 10

Сопоставьте действия исследователя с их последствиями:

Подсказка: Одни действия ведут к благодарности, другие — к бану.

Ответ:

- **Ответственный репорт** — Компания благодарит и выплачивает награду.
- **Публикация бага до исправления** — Компания может лишить доступа к программе.
- **Эксплуатация уязвимости в корыстных целях** — Может привести к юридическим последствиям.
- **Чёткий отчёт со скриншотами** — Быстрая проверка и положительная репутация.

Шаг 11:

Миссия 11

Сопоставьте участников процесса bug bounty с их ролями:

Подсказка: У каждого своя задача: искать, проверять, исправлять.

Ответ:

- **Хакер-исследователь** — Ищет уязвимости и составляет отчёт.
- **Компания-заказчик** — Определяет правила и платит награду.
- **Платформа** — Посредник, обеспечивает удобство и доверие.
- **Саппорт/триажер** — Проверяет валидность отчётов.

Шаг 12:

Миссия 12

Сопоставьте действия программиста с их влиянием на репутацию в bug bounty:

Подсказка: Репутация формируется долго, но потерять её можно быстро.

Ответ:

- **Своевременные и аккуратные отчёты** — Рост доверия и повышение рейтинга.
- **Отправка мусорных багов** — Снижение репутации.
- **Нарушение правил score** — Блокировка учётной записи.
- **Помощь другим исследователям** — Уважение и позитивная репутация.

Шаг 13:

Миссия 13

Расположите шаги процесса репорта уязвимости в правильном порядке:

Подсказка: Сначала находишь баг, потом проверяешь score, затем составляешь отчёт.

Ответ:

- Найти потенциальную уязвимость

- Проверить, входит ли она в score
- Составить подробный отчёт
- Отправить через платформу

Шаг 14:

Миссия 14

Расположите действия после отправки отчёта:

Подсказка: После отправки идёт проверка, затем решение и вознаграждение.

Ответ:

- Компания проверяет отчёт
- Триажер подтверждает валидность
- Назначается награда или объясняется отказ
- Репорт закрывается

Шаг 15:

Миссия 15

Расположите шаги при обнаружении XSS для корректного репорта:

Подсказка: Сначала проверка безопасности теста, потом доказательство, затем отчёт.

Ответ:

- Проверить, что тест не повредит системе
- Подготовить минимальный PoC
- Собрать скриншоты и шаги
- Отправить отчёт

Шаг 16:

Миссия 16

Расположите этапы развития исследователя в bug bounty от новичка до профи:

Подсказка: Начинается с чтения правил, заканчивается менторством.

Ответ:

- Изучение правил и score
- Поиск и репорт простых багов
- Получение первых наград
- Регулярная охота и рост рейтинга
- Наставничество и обучение других

Урок 10 - Карьера в кибербезопасности куда двигаться дальше

Шаг 01:

Миссия 1

Оля только закончила университет и хочет понять, с чего начать карьеру в кибербезопасности. Какой первый шаг будет самым разумным?

Подсказка: Начало пути — это основа: без неё будет сложно двигаться дальше.

Ответ:

- **Получить базовые знания о сетях, ОС и безопасности**
- Сразу устраиваться пентестером

- Искать баги в банковских системах без подготовки
- Смотреть только сериалы про хакеров

🔮 Шаг 02:

Миссия 2

Игорь хочет выбрать направление в кибербезопасности. Какой из вариантов считается базовой стартовой позицией?

Подсказка: Начинать лучше с того, что позволит увидеть широкий спектр задач.

Ответ:

- **Специалист SOC (аналитик событий безопасности)**
- Руководитель отдела CISO
- Разработчик эксплойтов на заказ
- Чисто академический исследователь криптографии

🔮 Шаг 03:

Миссия 3

Маша думает, какие навыки помогут ей стать востребованным специалистом. Что из этого важнее всего на старте?

Подсказка: Техническая база нужна, но софт-скилы тоже решают.

Ответ:

- **Умение чётко объяснять сложные вещи простыми словами**
- Только знание всех CVE наизусть
- Игнорирование командной работы
- Работа исключительно в одиночку

🔮 Шаг 04:

Миссия 4

Алексей выбрал пентест. Что будет первой практической задачей?

Подсказка: Прежде чем ломать — нужно изучить поверхность атаки.

Ответ:

- **Сканирование и сбор информации о системе**
- Мгновенная эксплуатация нулевых дней
- Удаление логов администратора
- Продажа доступа на даркнет-рынке

🔮 Шаг 05:

Миссия 5

Света услышала про сертификации. С чего лучше начать?

Подсказка: Выбирай то, что подтверждает базовые знания.

Ответ:

- **CompTIA Security+**
- OSCP сразу же
- CISO Executive Program
- CISM для руководителей

🔮 Шаг 06:

Миссия 6

Денис хочет совмещать программирование и безопасность. Какое направление подойдёт?

Подсказка: Думай про код и его защиту одновременно.

Ответ:

- **Secure Code Review / DevSecOps**
- Чисто администрирование сетей
- Только написание вирусов
- Маркетинг в кибербезопасности

🔮 Шаг 07:

Миссия 7

Илья задумался о долгосрочной карьере. Что важно, чтобы расти в профессии?

Подсказка: В этой сфере знания устаревают очень быстро.

Ответ:

- **Постоянное обучение и развитие**
- Остановка на одном сертификате
- Игнорирование новых технологий
- Работа без интереса и инициативы

🔮 Шаг 08:

Миссия 8

Сопоставьте роли в кибербезопасности с их задачами:

Подсказка: У каждой роли свой фокус: защита, атака, анализ или руководство.

Ответ:

- **SOC-аналитик** — Следит за событиями и реагирует на инциденты.
- **Пентестер** — Имитирует атаки для поиска уязвимостей.
- **Blue team инженер** — Укрепляет защиту и мониторинг.
- **CISO** — Определяет стратегию безопасности компании.

🔮 Шаг 09:

Миссия 9

Сопоставьте сертификации с их особенностями:

Подсказка: Они отличаются уровнем сложности и направленностью.

Ответ:

- **OSCP** — Практическая сертификация по пентесту.
- **CISSP** — Подходит для руководителей и архитекторов.
- **Security+** — Стартовый сертификат по основам.
- **CEH** — Подтверждает знания этичного хакинга.

🔮 Шаг 10:

Миссия 10

Сопоставьте направления в кибербезопасности с их описанием:

Подсказка: Одни связаны с атакой, другие — с защитой.

Ответ:

- **Red Team** — Имитирует атаки на компанию.
- **Blue Team** — Занимается защитой инфраструктуры.
- **Purple Team** — Комбинирует атаку и защиту.
- **Incident Response** — Реагирует на инциденты безопасности.

Шаг 11:

Миссия 11

Сопоставьте популярные инструменты с их назначением:

Подсказка: Подумай, какие инструменты используют чаще всего пентестеры и аналитики.

Ответ:

- **Wireshark** — Анализ сетевого трафика.
- **Metasploit** — Фреймворк для эксплуатации уязвимостей.
- **Burp Suite** — Тестирование веб-приложений.
- **ELK Stack** — Сбор и анализ логов.

Шаг 12:

Миссия 12

Сопоставьте действия специалиста с их влиянием на карьеру:

Подсказка: Думай, что даёт рост, а что мешает.

Ответ:

- **Участие в CTF** — Прокачка практических навыков.
- **Ведение блога** — Рост личного бренда.
- **Игнорирование новых технологий** — Торможение в развитии.
- **Менторство** — Уважение и новые возможности.

Шаг 13:

Миссия 13

Расположите шаги новичка в кибербезопасности в правильном порядке:

Подсказка: Начни с базы, затем практика, потом сертификация.

Ответ:

- Изучение сетей и ОС
- Практика на лабораторных стендах
- Получение стартовой сертификации
- Поиск первой работы

Шаг 14:

Миссия 14

Расположите этапы становления специалиста Red Team:

Подсказка: Сначала нужно понять основы атак, затем отрабатывать практику.

Ответ:

- Изучение основ пентеста
- Практика с Metasploit и Burp

- Участие в CTF и лабораториях
- Работа в Red Team

Шаг 15:

Миссия 15

Расположите шаги карьеры аналитика SOC:

Подсказка: Думай о пути от простого мониторинга к расследованию инцидентов.

Ответ:

- Мониторинг событий
- Анализ подозрительной активности
- Расследование инцидентов
- Повышение до старшего аналитика

Шаг 16:

Миссия 16

Расположите этапы развития до уровня CISO:

Подсказка: От технических знаний к стратегическому управлению.

Ответ:

- Работа техническим специалистом
- Рост до руководителя команды
- Получение управленческих навыков
- Назначение CISO

Шаг 17:

Миссия 17

Расположите действия специалиста, чтобы построить международную карьеру:

Подсказка: Английский и глобальные сообщества — ключ к успеху.

Ответ:

- Изучение английского языка
- Участие в международных конференциях
- Получение глобальных сертификатов
- Работа в зарубежной компании